

***DRAFT* Gemini Enterprise for CX Security Requirements**

Draft Content

This content is currently in draft and may change before publication

Overview

This Gemini Enterprise for CX Security Guide identifies the minimum requirements that must be met for the use of Gemini Enterprise for CX. This guide helps fulfill our commitment to protecting company and customer data and ensuring compliance with legal and regulatory requirements.

Scope

This configuration guide is applicable to all usage of Gemini Enterprise for CX by Highmark Inc, its subsidiaries, and partners unless otherwise stated.

Minimum Requirements

This document presents the minimum-security requirements that must be met to use Gemini Enterprise for CX. Individual entities, services, or systems may implement security controls above and beyond those specified herein. Those additional controls may augment and enhance, but may never reduce, the level of security specified by this guide.

Definitions

This document may use terms and acronyms defined in the following sources:

- [General Cloud Glossary](#)
- [GCP Glossary](#)
- [Azure Glossary](#)
- [AWS Glossary](#)

Guidance Terms

This guidance uses the terms **SHOULD**, **SHOULD NOT**, **MAY**, **SHALL**, **MUST** and **MUST NOT** as defined [here](#).

Documentation and Exception Requirements

If unable to follow the provided guidance proper documentation and/or a formal exception is required.

The documentation and exception requirements can be found [here](#)

Security Requirements

General

ID	SG-GCP-GECX-000010.0
Requirement	Features of Gemini Enterprise for CX that are Non-GA or Pre-GA MUST NOT be used in production or with protected health information or other personal data.
Rationale	Any capability not designated GA is governed by Google's Pre-GA Offerings Terms in the Service Specific Terms. Those terms state that Pre-GA offerings are provided "as is", may be changed, suspended, or discontinued without prior notice, are not covered by any SLA, and, unless Google documentation expressly says otherwise, are not covered by the Data Location section or by any data processing terms. They also state that "Customer should not use Pre-GA Offerings to process personal data or other data subject to legal or regulatory compliance requirements." Google's HIPAA guidance says separately: "Do not use Pre-GA offerings ... in connection with PHI". A Pre-GA capability handling member conversation content therefore sits outside the contractual perimeter the BAA establishes. The exposure is created by production reliance and by regulated data, so a Pre-GA feature exercised in an isolated non-production project on synthetic data processes nothing those terms leave unprotected.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	GA status is determined only from Google's release notes and product documentation with the Pre-GA Offerings Terms disclaimer removed; console availability, marketing pages, partner training material, and press announcements are not authoritative. Where sources disagree, the more restrictive stage governs, and a product-level GA announcement does not make GA the individual features it lists. The suite spans four documentation trees, three with independent release notes (CX Agent Studio, CX Insights, and Agent Assist), so confirm GA status per component and per feature rather than for the suite. Evaluation of a Pre-GA feature is permitted only in a non-production project that holds synthetic or otherwise non-personal data, shares no tool target, data store, service agent grant, or network path with production, and on which no production process depends. Keep a register of Pre-GA features under evaluation and of those blocked, and re-verify both at every release-note review cycle.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/release-notes ; https://cloud.google.com/terms/service-terms ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/release-notes ; https://cloud.google.com/security/compliance/hipaa
Mappings	HIPAA: 164.308(a)(8) (Evaluation); NIST 800-53: SA-8 (Security and Privacy Engineering Principles), CM-3 (Configuration Change Control), CM-7 (Least Functionality), SA-4 (Acquisition Process)
Detective Policies	

ID	SG-GCP-GECX-000010.0
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000020.0
Requirement	Commerce agents MUST NOT be deployed.
Rationale	Google's own documentation states that Commerce agents are not yet released: the product page ends "Commerce agents coming soon." An unreleased product has no published security documentation, no encryption or residency configuration surface, and no IAM model to assess. If it is first released as a preview, it will fall under the Pre-GA Offerings Terms and under Google's HIPAA guidance: "Do not use Pre-GA offerings ... in connection with PHI". The umbrella covered-products entry for Gemini Enterprise for Customer Experience does not by itself establish that a component with no GA release can be used with PHI. The intended capability set compounds this: Google describes Commerce agents as executing consented actions on a customer's behalf, which is a write-capable autonomous surface reaching commerce and order systems.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	This prohibition is a specific application of this guide's baseline prohibition on Non-GA and Pre-GA features, and stands until Commerce agents reach GA, are confirmed by Google as within the BAA-covered scope of Gemini Enterprise for CX, and are assessed under a fresh capability certification. Track the product page and the CX Agent Studio release notes for the transition. Nothing in this guide anticipates the control surface Commerce agents will present.
References	https://docs.cloud.google.com/gemini-enterprise-cx/commerce-agents ; https://docs.cloud.google.com/gemini-enterprise-cx ; https://cloud.google.com/terms/service-terms ; https://cloud.google.com/security/compliance/hipaa
Mappings	HIPAA: 164.308(a)(8) (Evaluation); NIST 800-53: CM-7 (Least Functionality), SA-4 (Acquisition Process), SA-8 (Security and Privacy Engineering Principles), RA-3 (Risk Assessment)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000030.0
Requirement	The v1beta CX Agent Studio API and the v1alpha1 CX Insights API MUST NOT be called from production workloads.
Rationale	Both product APIs publish a pre-release version alongside the stable one: the CX Agent Studio REST overview lists v1 and

ID	SG-GCP-GEEX-000030.0
	v1beta, and the CX Insights REST reference lists v1alpha1 resources. Google does not state the launch stage of these versions on the reference pages. A beta or alpha version is conventionally a pre-release surface, so this guide treats both as Pre-GA as a matter of organizational policy until Google states their launch stage in writing; the policy does not assert that either version is outside the BAA, it removes production dependence on an unconfirmed answer. A client library or integration pinned to v1beta or v1alpha1 would otherwise place production conversation traffic on a surface whose support and compliance coverage are unconfirmed, and the version is a substring of an endpoint path that no console screen displays.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Audit deployed client configuration, not console settings: the version appears in the endpoint path and in generated client stubs. CX Agent Studio audit log entries record the API version in the method name, for example google.cloud.ces.v1beta.EvaluationService.RunEvaluation, so a Cloud Logging query for method names containing v1beta or v1alpha1 is the detective control. Scope that query to runtime and integration principals, because some administrative methods, such as UpdateSecuritySettings, are recorded under v1beta method names and are not production workloads. Some evaluation operations are only offered on v1beta - run those in a non-production project that holds synthetic data and shares nothing with production, rather than promoting the version. The Pre-GA treatment of v1beta and v1alpha1 is a policy position drawn from the version naming rather than from a Google statement; ask Google for the launch stage and record the answer in the certification evidence.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio ; https://docs.cloud.google.com/gemini-enterprise-cx/insights ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging ; https://cloud.google.com/terms/service-terms ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/rest ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/reference/rest
Mappings	HIPAA: 164.308(a)(8) (Evaluation); NIST 800-53: CM-7 (Least Functionality), CM-6 (Configuration Settings), SA-4 (Acquisition Process), SA-8 (Security and Privacy Engineering Principles)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000040.0
Requirement	The Google Maps tool in CX Agent Studio MUST NOT be enabled on any agent application.
Rationale	The tools overview flags the Google Maps tool as Preview while presenting it in the same tool picker as generally available tool types. A builder selecting it from that list receives no signal that the resulting agent has left the supported configuration, and the tool sends conversation-derived location context to a mapping surface outside the guide's assessed boundary.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	This is a specific application of this guide's baseline prohibition on Non-GA and Pre-GA features, restated because the console does not segregate Preview tools from GA tools in the picker. Enforce by tool-type review during agent approval rather than by expecting builders to notice the marker. At the 2026-09-24 review the only other tool type marked Preview on the overview page was the A2A Protocol tool; re-check the page at each review because the picker composition changes without a release note.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes ; https://cloud.google.com/terms/service-terms
Mappings	HIPAA: 164.308(a)(8) (Evaluation); NIST 800-53: CM-7 (Least Functionality), CM-3 (Configuration Change Control), SA-4 (Acquisition Process)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000050.0
Requirement	CX Insights capabilities documented as Preview, including fine-grained access control, conversation datasets, and multiple scorecards, MUST NOT be used as the control of record or as a production dependency.
Rationale	The CX Insights release notes place several capabilities in Preview, and one of them - fine-grained access control - is the only mechanism the product offers for scoping an analyst to a subset of conversations. Building an access model on a Pre-GA feature means the boundary protecting member conversation content is one that Google may change or withdraw without notice and does not warrant under the compliance terms.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	

ID	SG-GCP-GECX-000050.0
Notes	The practical consequence is carried by the CX Insights access requirement in this guide: because fine-grained access control cannot be the control of record, project-level CX Insights access must be compensated by a deliberately small approved group plus Data Access audit logging. Do not read this requirement as prohibiting evaluation of authorized views in a non-production project - it prohibits depending on them for a production access decision. The Preview designation of conversation datasets (release note of 2025-08-15) and multiple scorecards (release note of 2025-07-18) is established only by the CX Insights release notes; their feature pages carry no Preview banner, and no GA announcement has followed. Do not read the absence of a banner on a feature page as a change of launch stage. The appearance of authorized view set and dataset resources in the v1 REST reference likewise does not make them GA.
References	https://docs.cloud.google.com/gemini-enterprise-cx/insights/release-notes ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/best-practices-for-fine-grained-access-control ; https://cloud.google.com/terms/service-terms ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/datasets ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/qai-basics
Mappings	HIPAA: 164.308(a)(4) (Information Access Management), 164.308(a)(8) (Evaluation); NIST 800-53: AC-3 (Access Enforcement), CM-7 (Least Functionality), SA-4 (Acquisition Process), RA-3 (Risk Assessment); HITRUST CSF v11: 01.v (Information Access Restriction)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000060.0
Requirement	A capability certification review MUST be completed and approved before any Gemini Enterprise for CX component processes production member conversation data.
Rationale	Every component of this suite reads or writes unstructured member conversation, which is among the densest concentrations of protected health information the organization holds, and several of its configuration decisions cannot be reversed after first use. Certification is the gate that forces the irreversible decisions - encryption specification, residency region, project boundary, perimeter membership, retention - to be made deliberately rather than discovered after data has landed.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Sequence the certification before the first agent application, the first CX Insights location initialization, and the first

ID	SG-GCP-GECX-000060.0
	conversation ingestion. Google states that encryption key settings for a CX Insights location cannot be changed once CMEK is enabled and cannot be configured if CX Insights data already exists, and that existing CX Agent Studio resources cannot be CMEK integrated retroactively, with export and restore into a new project as the remedy. The residency region is fixed by the location specified when resources are created. Conversation TTL can be changed later and conversations can be deleted, but conversations ingested before a TTL is set remain until deleted. A certification that runs after a pilot has ingested real conversations therefore cannot remediate the encryption decisions without rebuilding the resources.
References	https://docs.cloud.google.com/gemini-enterprise-cx ; https://cloud.google.com/security/compliance/hipaa ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/cmek ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/cmek ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/region ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/ttl
Mappings	HIPAA: 164.308(a)(1)(ii)(A) (Risk Analysis), 164.308(a)(8) (Evaluation); NIST 800-53: CA-2 (Control Assessments), RA-3 (Risk Assessment), SA-8 (Security and Privacy Engineering Principles), PL-8 (Security and Privacy Architectures); NIST AI RMF (AI 100-1): GOVERN, MAP, MEASURE, MANAGE
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000070.0
Requirement	Newly released Gemini Enterprise for CX features MUST be reviewed and explicitly approved before enablement, on a review cadence no longer than monthly.
Rationale	The suite ships features continuously across three independent release-note streams, and the CX Agent Studio release notes alone record twelve feature entries between general availability on February 4, 2026 and July 1, 2026. New features become available as they ship rather than on an organization-controlled schedule, so an unreviewed release can become a production configuration change that no one authorized. Agents as tools and traffic splitting are both examples of additions that materially changed the authorization and rollout surface.
Estimated Security Value	Med
Estimated Operational Impact	Med
Audit Procedures	
Notes	Assign a named owner for each of the three release-note streams - CX Agent Studio, CX Insights, and Agent Assist - and for the suite overview page, which has no release notes of its own but is where a new component such as Commerce agents first appears. Tool types can also appear in the CX

ID	SG-GCP-GECX-000070.0
	Agent Studio tools overview without a release note (File search and Widget tools were found this way on 2026-09-23), so reconcile the tools overview at the same review. The review asks three questions per entry - does it change what data leaves the boundary, does it change what identity an action runs as, and does it change a setting this guide pins. Record the review outcome so the certification evidence stays current between annual reassessments.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/release-notes ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/release-notes
Mappings	HIPAA: 164.308(a)(8) (Evaluation); NIST 800-53: CM-3 (Configuration Change Control), CM-4 (Impact Analyses), CA-7 (Continuous Monitoring)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000080.0
Requirement	The configuration baseline for every Gemini Enterprise for CX project - guardrails, tools, deployment channels, encryption, residency, retention, and audit settings - MUST be documented and drift-checked at least quarterly.
Rationale	Almost every control in this guide is a project or agent setting that a holder of the relevant editor role can change without a deployment, a code review, or a change ticket. The ten-role IAM family means several different people can each alter one facet of the security posture independently, so the aggregate configuration is nobody's job to know unless a baseline records what it is supposed to be.
Estimated Security Value	Med
Estimated Operational Impact	Med
Audit Procedures	
Notes	Capture the baseline as configuration exported through the API rather than as console screenshots, so the comparison can be automated. The high-value drift signals are guardrail level changes, new tool registrations, a deployment channel gaining public access, and a change to security settings - all four appear in Admin Activity or Data Access audit logs and can be alerted on directly.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging
Mappings	NIST 800-53: CM-2 (Baseline Configuration), CM-3 (Configuration Change Control), CM-6 (Configuration

ID	SG-GCP-GECX-000080.0
	Settings), CA-7 (Continuous Monitoring)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000090.0
Requirement	Personnel who build, deploy, or administer Gemini Enterprise for CX agent applications SHOULD complete role-specific training covering the confused-deputy tool execution model and the irreversible configuration decisions documented in this guide.
Rationale	The two failure modes most likely to produce a material incident in this product are both invisible in the builder's workflow: a tool executes with the service agent's permissions, or with an identity configured on the tool, rather than the caller's, and several encryption and residency settings cannot be changed after first use. Neither is surfaced by the console at the moment the decision is made, so a builder who has not been told will not infer them from the interface.
Estimated Security Value	Med
Estimated Operational Impact	Low
Audit Procedures	
Notes	The training does not need to be lengthy. It needs to convey four things: tools commonly run as the CX Agent Studio service agent or another identity configured on the tool rather than as the end user, data store retrieval has no documented mechanism for applying the end user's permissions, the project boundary is the real security boundary, and CMEK and residency close at first use. The source material is the tool execution model, the data store retrieval model, the CX Insights encryption specification, the CX Agent Studio CMEK integration, and the residency region.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/cmek ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/cmek
Mappings	HIPAA: 164.308(a)(5) (Security Awareness and Training); NIST 800-53: AT-2 (Literacy Training and Awareness), AT-3 (Role-based Training), SA-8 (Security and Privacy Engineering Principles)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

Identity & Access Management

ID	SG-GCP-GECX-000100.0
Requirement	Administrative and builder access to CX Agent Studio, CX Insights, and Agent Assist MUST be federated through the organization's enterprise identity provider.
Rationale	Federation is the trust anchor that extends existing conditional access policy, multi-factor enforcement, joiner-mover-leaver lifecycle, and session control to this suite. Without it, access to a surface holding member conversation content depends on a separate identity store whose deprovisioning is not tied to the HR record, leaving orphaned accounts with standing access to conversation transcripts after a person leaves.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Federate the Google Cloud identity used to reach the console and the APIs, not just the console, either through Cloud Identity or Google Workspace single sign-on with the enterprise IdP or through Workforce Identity Federation. Confirm that the API path is covered as well, because a service account key or a personal gcloud credential bypasses federation entirely, which is why service account keys are separately prohibited for these roles.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx ; https://cloud.google.com/iam/docs/workforce-identity-federation ; https://cloud.google.com/architecture/identity/single-sign-on
Mappings	HIPAA: 164.312(d) (Person or Entity Authentication), 164.308(a)(3) (Workforce Security); NIST 800-53: IA-2 (Identification and Authentication (Organizational Users)), IA-5 (Authenticator Management), AC-17 (Remote Access); HITRUST CSF v11: 01.q (User Identification and Authentication), 01.j (User Authentication for External Connections)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	
ID	SG-GCP-GECX-000110.0
Requirement	Multi-factor authentication MUST be enforced for every human user account holding any CX Agent Studio (roles/ces.*) or CX Insights (roles/contactcenterinsights.*) role.
Rationale	A single compromised builder credential is sufficient to register a tool that reaches a backend system, to change a guardrail level, or to read conversation transcripts in bulk, because these roles operate on a surface that has no second

ID	SG-GCP-GECX-000110.0
	approval step. Credential theft through phishing or reuse is the dominant initial access vector, and MFA is the control that breaks it.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Enforce at the identity provider so the requirement covers console, gcloud, and API access uniformly. Google notes that super admins can bypass single sign-on, so enable Google two-step verification for super-admin accounts as well. Phishing-resistant factors are preferred for <code>roles/ces.admin</code>, <code>roles/ces.appEditor</code>, <code>roles/ces.securitySettingsEditor</code>, <code>roles/ces.guardrailsEditor</code>, <code>roles/ces.toolsEditor</code>, and <code>roles/ces.deploymentEditor</code>, which are the roles that can change the security posture or push to production. Service accounts and service agents that hold these roles cannot complete an interactive second factor and are outside this requirement; govern them through least-privilege grants, a prohibition on user-managed keys, and workload identity.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://cloud.google.com/architecture/identity/single-sign-on ; https://docs.cloud.google.com/iam/docs/best-practices-service-accounts
Mappings	HIPAA: 164.312(d) (Person or Entity Authentication); NIST 800-53: IA-2(1) (Multi-factor Authentication to Privileged Accounts), IA-2 (Identification and Authentication (Organizational Users)), IA-5 (Authenticator Management); HITRUST CSF v11: 01.q (User Identification and Authentication)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000120.0
Requirement	The <code>roles/ces.admin</code> role MUST be granted only to named individual administrators.
Rationale	The admin role provides full access to CX Agent Studio resources, which means it collapses the ten-role separation the product otherwise offers into a single grant covering apps, agents, tools, guardrails, evaluations, security settings, and deployments. A group grant makes the effective administrator population a function of group membership managed elsewhere, so the number of people who can silently alter the security posture is unknown to the people accountable for it.
Estimated Security Value	High
Estimated Operational Impact	Low

ID	SG-GCP-GEEX-000120.0
Audit Procedures	
Notes	Google publishes ten CX Agent Studio roles precisely so that admin does not have to be the default. Grant appEditor, agentEditor, toolsEditor, guardrailsEditor, evalsEditor, securitySettingsEditor, or deploymentEditor to match the actual job. Reserve admin for a small named set and include it in the quarterly entitlement recertification. Group grants do not satisfy this requirement. The admin role also carries every CX Insights permission - Google's product access-control page lists the CX Insights Admin role (roles/contactcenterinsights.admin) as its base role - so it grants full access to CX Insights conversations as well as CX Agent Studio resources.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/iam/docs/roles-permissions/ces
Mappings	HIPAA: 164.312(a)(1) (Access Control), 164.308(a)(4) (Information Access Management); NIST 800-53: AC-6 (Least Privilege), AC-6(1) (Authorize Access to Security Functions), AC-2 (Account Management), AC-3 (Access Enforcement); HITRUST CSF v11: 01.c (Privilege Management)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GEEX-000130.0
Requirement	Basic IAM roles - the legacy Owner, Editor, and Viewer roles and the Admin, Writer, and Reader basic roles - MUST NOT be granted on any project hosting a Gemini Enterprise for CX component.
Rationale	Basic roles predate the product's own role family and, in Google's words, "include thousands of permissions across all Google Cloud services", including ces.googleapis.com and contactcenterinsights.googleapis.com. A project Viewer therefore reads conversation content, and a project Editor registers tools and changes guardrails, without either grant appearing in any CX-specific access review. Google's own guidance is: "In production environments, do not grant basic roles unless there is no alternative."
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Audit existing bindings before enabling the APIs, because a pre-existing project Editor binding becomes a CX Agent Studio editor binding the moment the API is turned on. This is one of the reasons this guide requires a dedicated project per trust domain rather than reuse of an existing one. Google documents that only owners of the associated project can create a WhatsApp or Instagram deployment; that is not an exception to this requirement, and the channel stays

ID	SG-GCP-GECX-000130.0
	unavailable until Google documents a creation path that does not need the Owner role.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://cloud.google.com/iam/docs/roles-overview ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/whatsapp
Mappings	HIPAA: 164.312(a)(1) (Access Control); NIST 800-53: AC-6 (Least Privilege), AC-3 (Access Enforcement), AC-2 (Account Management); HITRUST CSF v11: 01.c (Privilege Management)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000140.0
Requirement	The <code>roles/ces.securitySettingsEditor</code> role MUST be held by a different set of individuals than those holding <code>roles/ces.agentEditor</code> or <code>roles/ces.toolsEditor</code> .
Rationale	The project Security Settings resource holds a single control, the endpoint control policy: the allowed origins list and its enforcement scope, which together decide which HTTP(S) endpoints tools and callbacks may call. Tool editors choose where a tool sends conversation-derived parameters, and agent editors do the same for callbacks. Where one person holds both sides, the same identity can register a tool or callback pointing at a new host and add that host to the allowed origins, opening an egress path for member data with no second party in the path. The product's role split makes this separation available at no operational cost.
Estimated Security Value	Med
Estimated Operational Impact	Low
Audit Procedures	
Notes	This is a separation-of-duties control, not a least-privilege control - it constrains combinations rather than individual grants. Implement it as a check in the access-request workflow and as a periodic query over IAM policy bindings, because IAM itself will not prevent the combination. The Security Settings resource carries no logging, redaction, or export settings; those are agent application settings changed with the <code>ces.apps.update</code> permission, which <code>roles/ces.appEditor</code> and <code>roles/ces.admin</code> hold, so this separation does not protect them. <code>roles/ces.admin</code> holds every permission on both sides and is governed by the admin role's own restrictions.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/rest/v1beta/SecuritySettings ; https://docs.cloud.google.com/iam/docs/roles-permissions/ces

ID	SG-GCP-GECX-000140.0
Mappings	HIPAA: 164.308(a)(3) (Workforce Security), 164.312(a)(1) (Access Control); NIST 800-53: AC-5 (Separation of Duties), AC-6 (Least Privilege), AC-6(1) (Authorize Access to Security Functions); HITRUST CSF v11: 01.c (Privilege Management)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000150.0
Requirement	The <code>roles/ces.deploymentEditor</code> role MUST be restricted to personnel explicitly authorized to promote changes to production.
Rationale	Deployment is the only step between an agent configuration and live member traffic. Because the product supports traffic splitting, which divides user conversations across different agent application versions within a single deployment channel, a deployment editor can also direct a share of production conversations to a different agent version without changing the agent itself.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Traffic splitting must never direct production traffic to an unreviewed agent version. Deployment create, update, and delete are <code>DATA_WRITE</code> methods, so they appear in Data Access audit logs rather than Admin Activity logs; enable Data Access audit logging for <code>ces.googleapis.com</code> and alert on those methods. Agent builders do not receive this role by default; where a builder also promotes, the grant is a named exception with a recorded approver.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/traffic-split ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging ; https://docs.cloud.google.com/iam/docs/roles-permissions/ces
Mappings	HIPAA: 164.308(a)(3) (Workforce Security); NIST 800-53: AC-5 (Separation of Duties), AC-6 (Least Privilege), CM-3 (Configuration Change Control), CM-5 (Access Restrictions for Change); HITRUST CSF v11: 01.c (Privilege Management)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000160.0
Requirement	Direct bindings of the <code>roles/ces.client</code> role MUST be limited to the service identities used by approved deployment channels and to the documented end-user principal set of an approved OAuth2 deployment channel.
Rationale	The client role provides query access to agents - its permissions are <code>ces.sessions.runSession</code> , <code>ces.sessions.bidiRunSession</code> , and <code>ces.tools.execute</code> - which is the runtime conversation path rather than an administrative one. It is the role a self-hosted token broker's service account holds, so every direct grant of it is effectively a new channel through which conversations can be initiated and tools executed. Granting it to a broad group makes the set of parties who can converse with a production agent, and therefore reach whatever its tools reach, unbounded.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Inventory direct client role bindings alongside the approved deployment channel inventory - every direct binding should map to an approved channel, and one that does not is either an undocumented integration or a leftover from testing. Google includes the client role as a base role of admin, agentEditor, toolsEditor, guardrailsEditor, and evalsEditor, so builders hold its permissions through those roles; govern them through the builder role requirements rather than this inventory. Where a web widget uses the OAuth2 option, end users sign in and their own credentials are used to access the agent application; treat that principal set as an approved channel with a documented owner rather than as an ad hoc grant. Inbound A2A callers, where the A2A Protocol is enabled, also require this role and are channels in the same sense.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/web-widget ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy ; https://docs.cloud.google.com/iam/docs/roles-permissions/ces
Mappings	HIPAA: 164.312(a)(1) (Access Control), 164.312(d) (Person or Entity Authentication); NIST 800-53: AC-3 (Access Enforcement), AC-6 (Least Privilege), IA-9 (Service Identification and Authentication), AC-2 (Account Management); HITRUST CSF v11: 01.c (Privilege Management), 01.q (User Identification and Authentication)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000170.0
Requirement	The CX Agent Studio service agent <code>service-PROJECT_NUMBER@gcp-sa-</code> <code>ces.iam.gserviceaccount.com</code> MUST be granted only the minimum IAM roles required by the approved tools in that project.
Rationale	Google documents that OpenAPI tool actions execute with the permissions granted to the CX Agent Studio service account rather than those of the end user, and names minimum IAM on that account as one of its three recommended mitigations. Every role granted to the service agent is therefore added to the effective reach of every agent in the project, including agents a different team built and agents reachable by anonymous callers.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Treat each new grant to this service agent as a change to the blast radius of every agent in the project, and require the same review as adding a tool. Where a tool needs broad access to a backend, the correct answer is usually a separate project rather than a broader grant. Google's other two stated mitigations, dedicated projects and VPC Service Controls, are each carried by their own requirement in this guide.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls
Mappings	HIPAA: 164.312(a)(1) (Access Control), 164.308(a)(4) (Information Access Management); NIST 800-53: AC-6 (Least Privilege), AC-3 (Access Enforcement), IA-9 (Service Identification and Authentication), CM-7 (Least Functionality); HITRUST CSF v11: 01.c (Privilege Management); OWASP Agentic Top 10 2026: ASI03 (Identity and Privilege Abuse)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000180.0
Requirement	Service account keys MUST NOT be created for any identity holding a Gemini Enterprise for CX role.
Rationale	A downloaded service account key is a long-lived bearer credential that bypasses federation, conditional access, and multi-factor enforcement, and it does not expire on personnel departure. Because the client role is a conversation-initiation credential and the editor roles alter what agents can reach, a leaked key for either is directly equivalent to unauthorized access to member conversation content.
Estimated Security Value	High

ID	SG-GCP-GECX-000180.0
Estimated Operational Impact	Low
Audit Procedures	
Notes	Use workload identity federation for external callers and attached service accounts for workloads inside Google Cloud. The self-hosted token broker pattern runs on Cloud Run functions with a service account that needs no key. Enforce with the organization policy constraint <code>iam.managed.disableServiceAccountKeyCreation</code> (or the legacy <code>iam.disableServiceAccountKeyCreation</code>), which disables the creation of new external service account keys.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/web-widget ; https://cloud.google.com/iam/docs/best-practices-for-managing-service-account-keys ; https://cloud.google.com/resource-manager/docs/organization-policy/restricting-service-accounts
Mappings	HIPAA: 164.312(d) (Person or Entity Authentication); NIST 800-53: IA-5 (Authenticator Management), IA-9 (Service Identification and Authentication), AC-6 (Least Privilege); HITRUST CSF v11: 01.q (User Identification and Authentication)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000190.0
Requirement	Entitlements to all <code>ces.googleapis.com</code> and <code>contactcenterinsights.googleapis.com</code> roles MUST be recertified at least quarterly by the accountable business owner.
Rationale	Access to this suite accumulates through pilots, incident response, and vendor-led enablement sessions, and none of those paths has a natural expiry. Because CX Insights project-level roles expose every conversation in the project, fine-grained scoping being Pre-GA and therefore unavailable as the control of record, an unreviewed viewer grant is standing access to the complete member conversation corpus rather than to a bounded slice of it.
Estimated Security Value	Med
Estimated Operational Impact	Med
Audit Procedures	
Notes	Recertify the CX Insights viewer and editor populations with particular care, and treat the approved CX Insights access group as the authoritative list. Recertification should confirm both that the person still needs access and that the role held is still the narrowest one that fits the job.

ID	SG-GCP-GECX-000190.0
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/best-practices-for-fine-grained-access-control
Mappings	HIPAA: 164.308(a)(3) (Workforce Security), 164.308(a)(4) (Information Access Management); NIST 800-53: AC-6(7) (Review of User Privileges), AC-2 (Account Management), AC-3 (Access Enforcement), AC-6 (Least Privilege); HITRUST CSF v11: 01.e (Review of User Access Rights)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000200.0
Requirement	Contact centre representatives receiving Agent Assist suggestions MUST authenticate through the organization's identity provider.
Rationale	Agent Assist places generated summaries, suggested replies, and knowledge excerpts in front of a human handling a live member interaction, and CX Insights subsequently evaluates that human's performance against the same conversation record. Both the disclosure of conversation content to a representative and the attribution of a quality assessment to one depend on knowing reliably which representative was present.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	The agent identifier is also the field CX Insights authorized views filter on, so a reliable representative identity is a prerequisite for any future adoption of fine-grained access control once it leaves Preview. Confirm the identifier propagated by the contact centre platform is the enterprise identity and not a platform-local seat number. The authenticated identity must also be recorded against each conversation the representative handles, since attribution is what makes both the disclosure and any later quality assessment defensible.
References	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/best-practices-for-fine-grained-access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/common-integrations ; https://cloud.google.com/iam/docs/workforce-identity-federation ; https://cloud.google.com/architecture/identity/single-sign-on
Mappings	HIPAA: 164.312(d) (Person or Entity Authentication), 164.312(b) (Audit Controls); NIST 800-53: IA-2 (Identification and Authentication (Organizational Users)), AU-3 (Content of Audit Records), AC-3 (Access Enforcement); HITRUST CSF

ID	SG-GCP-GECX-000200.0
	v11: 01.q (User Identification and Authentication), 09.aa (Audit Logging)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000210.0
Requirement	Standing administrative access to production Gemini Enterprise for CX projects SHOULD be replaced by time-bound, approved elevation.
Rationale	The administrative actions this suite requires - changing a guardrail, registering a tool, altering retention - are infrequent and individually short. Standing admin rights convert an occasional need into a permanent exposure, and because several of those actions are irreversible in effect, an attacker holding a compromised standing credential does not need to wait for an opportunity.
Estimated Security Value	Med
Estimated Operational Impact	Med
Audit Procedures	
Notes	Elevation requests should name the change being made so the audit log entry can be correlated to an approval. This pairs with administrative-action alerting: an action with no corresponding elevation record is the signal worth investigating.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control
Mappings	HIPAA: 164.308(a)(4) (Information Access Management); NIST 800-53: AC-2(11) (Usage Conditions), AC-6 (Least Privilege), AC-6(1) (Authorize Access to Security Functions), AU-6 (Audit Record Review, Analysis, and Reporting), AC-2 (Account Management); HITRUST CSF v11: 01.c (Privilege Management)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000220.0
Requirement	Access to Gemini Enterprise for CX administrative surfaces SHOULD be conditioned on managed-device posture.
Rationale	Builder and administrator sessions display member conversation content and permit configuration changes that alter what production agents can reach. An unmanaged endpoint provides no assurance of disk encryption, endpoint detection, or absence of credential-stealing malware, so a

ID	SG-GCP-GECX-000220.0
	session from one extends the trust boundary to a device the organization cannot attest.
Estimated Security Value	Med
Estimated Operational Impact	Med
Audit Procedures	
Notes	Implement at the identity provider or through Context-Aware Access rather than inside the product, which exposes no device-posture control of its own. Apply at minimum to the admin, securitySettingsEditor, deploymentEditor, and CX Insights viewer populations.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx
Mappings	HIPAA: 164.312(a)(1) (Access Control), 164.310(b) (Workstation Use); NIST 800-53: AC-17 (Remote Access), IA-3 (Device Identification and Authentication), AC-2(11) (Usage Conditions), AC-2 (Account Management); HITRUST CSF v11: 01.j (User Authentication for External Connections)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001410.0
Requirement	The <code>roles/ces.appEditor</code> role SHOULD be held by a different set of individuals than those holding <code>roles/ces.agentEditor</code> or <code>roles/ces.toolsEditor</code> in projects serving production traffic.
Rationale	Redaction, Cloud Logging, BigQuery export, audio recording, and interaction data storage are agent application settings, changed with the <code>ces.apps.update</code> permission that the App Editor role holds and the agent and tool editor roles do not. Where one person holds both sides, the same identity can change what an agent reaches and switch off the redaction or the record that would show what it did, with no second party in the path.
Estimated Security Value	Med
Estimated Operational Impact	Med
Audit Procedures	
Notes	App Editor also creates and imports applications and creates and restores application versions, so separating it moves those steps to a release or platform role; that operational cost is why this is a recommendation rather than a hard requirement. Where a team is too small to separate the roles, record the exception and rely on alerts for application setting changes, correlated with an approved change record, as the compensating control. <code>roles/ces.admin</code> holds both sides and is governed by the admin role's own restrictions.

ID	SG-GCP-GECX-001410.0
References	https://docs.cloud.google.com/iam/docs/roles-permissions/ces ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/settings
Mappings	HIPAA: 164.308(a)(3) (Workforce Security), 164.312(b) (Audit Controls); NIST 800-53: AC-5 (Separation of Duties), AC-6 (Least Privilege), AU-9 (Protection of Audit Information); HITRUST CSF v11: 01.c (Privilege Management), 09.ac (Protection of Log Information)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

Agents & Agent Management

ID	SG-GCP-GECX-000230.0
Requirement	Guardrails MUST be explicitly configured and documented on every agent application rather than left at the shipped default.
Rationale	Google states that each agent application is provided with default guardrails that the builder may modify, but the documentation does not name which safety level or which protections that default comprises. A control whose configured value is unknown cannot be attested to an assessor, cannot be drift-checked, and may change when Google revises the default for new applications. Explicit configuration converts an unknown into a baseline.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Record the four guardrail dimensions per agent: Prompt guard state and outcome, Blocklist contents and match mode, Safety level, and any Rules. This inventory is the artifact the quarterly configuration drift check compares against. Confirm the configured values by reading them back through the API rather than trusting the console form state.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/guardrail ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio
Mappings	NIST 800-53: CM-6 (Configuration Settings), CM-2 (Baseline Configuration), SI-15 (Information Output Filtering), SI-10 (Information Input Validation); OWASP LLM Top 10 2025: LLM01 (Prompt Injection)
Detective Policies	
Sentinel Modules	
CSP Level Controls	

ID	SG-GCP-GECX-000230.0
Monitoring Controls	
ID	SG-GCP-GECX-000240.0
Requirement	The Safety guardrail MUST be set to Strict on every member-facing agent application, and to Strict or Balanced on every other agent application that can reach member data.
Rationale	Google describes Relaxed as prioritizing flexible generation and low latency, which is an explicit trade of harm filtering for responsiveness. On a member-facing health or benefits conversation, the harms the filter addresses are precisely the ones with regulatory and reputational consequence, and latency is not the constraint worth optimizing against them.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Strict prioritizes deep harm filtering and is required for member-facing agents; Balanced is permitted for internal-facing agents where a documented rationale exists. Record which level each agent uses and why, because the choice is invisible in the conversation transcript and cannot be reconstructed later. The Relaxed setting is not acceptable in production on any agent that can reach member data.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/guardrail
Mappings	NIST 800-53: SI-15 (Information Output Filtering), SI-10 (Information Input Validation), CM-6 (Configuration Settings); OWASP LLM Top 10 2025: LLM09 (Misinformation); MITRE ATLAS: AML.T0054 (LLM Jailbreak)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	
ID	SG-GCP-GECX-000250.0
Requirement	The Prompt guard MUST be enabled on every agent application, with a defined outcome for a triggered guard.
Rationale	Prompt guard is the product's stated protection against prompt-based attacks such as instructing the agent to ignore its instructions. In this suite the injected instruction does not have to come from the member: tool responses, retrieved data store content, and knowledge base excerpts all enter the model context, so an attacker who can influence any of those sources reaches the same objective indirectly.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Choosing the outcome matters as much as enabling the guard. "Say exactly" is a safe terminal state. The "Handoff to

ID	SG-GCP-GECX-000250.0
	an agent" outcome transfers control to another CX Agent Studio agent, not to a person; to reach a human, hand off to an agent whose only behavior is to call the <code>end_session</code> system tool with <code>session_escalated</code> set to True. A generated response re-enters the model with the adversarial content still in context. Prompt guard is a filter and not a boundary; the architectural half of this control is treating tool output and retrieved content as untrusted input.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/guardrail ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/system
Mappings	NIST 800-53: SI-10 (Information Input Validation), SI-15 (Information Output Filtering); OWASP LLM Top 10 2025: LLM01 (Prompt Injection); MITRE ATLAS: AML.T0051.001 (LLM Prompt Injection - Indirect)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000260.0
Requirement	A Blocklist guardrail SHOULD be configured on member-facing agent applications to suppress terms the organization has designated as prohibited in a generated response.
Rationale	Safety filters address broad harm categories and will not catch organization-specific disclosures: internal system names, unreleased product terms, legally constrained phrasing around coverage determinations, or competitor references. The Blocklist is the only term-matching guardrail, and it applies to agent responses as well as user input.
Estimated Security Value	Med
Estimated Operational Impact	Med
Audit Procedures	
Notes	Apply the Blocklist to agent responses at minimum; applying it to user input as well is useful for detecting probing but will generate false positives on legitimate member language. The regex match mode is powerful and correspondingly easy to write too broadly - test against a sample of real transcripts before deployment.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/guardrail
Mappings	NIST 800-53: SI-15 (Information Output Filtering), CM-6 (Configuration Settings), SI-10 (Information Input Validation); OWASP LLM Top 10 2025: LLM02 (Sensitive Information Disclosure)
Detective Policies	
Sentinel Modules	

ID	SG-GCP-GECX-000260.0
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000270.0
Requirement	Agent instructions, prompts, application variables, and tool configurations MUST NOT contain credentials, API keys, tokens, or connection strings.
Rationale	Agent instructions and application variables are documented as data at rest inside CX Agent Studio and are readable by every holder of the viewer role, exportable through the import and export path, and reachable by the model itself at inference time. A secret placed there is therefore disclosed to a wider population than any secret store would permit and can be surfaced verbatim in a generated response through prompt injection.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Google supports Secret Manager for OpenAPI tool credentials, and MCP tools carry the same authentication options, so there is a supported path for every case where a secret is genuinely needed. Scan agent instructions and variables for high-entropy strings and known key formats as part of the pre-deployment agent security review.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/region ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/mcp
Mappings	HIPAA: 164.312(a)(1) (Access Control), 164.312(d) (Person or Entity Authentication); NIST 800-53: IA-5 (Authenticator Management), SC-28 (Protection of Information at Rest), AC-6 (Least Privilege); HITRUST CSF v11: 10.g (Key Management); OWASP LLM Top 10 2025: LLM02 (Sensitive Information Disclosure)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000280.0
Requirement	Every agent application MUST be security reviewed and approved before it is deployed to a channel carrying production traffic.
Rationale	The security posture of an agent is the union of its instructions, its guardrails, its tool set, and the reach of the project service agent, and no single console screen shows that union. Because tools execute with the platform identity, an agent that looks harmless in isolation can inherit the full

ID	SG-GCP-GECX-000280.0
	backend reach of every other tool in its project, which only a review that considers the project as a whole will catch.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	The review covers at minimum: the tool list and what each tool can reach, guardrail configuration, whether any data store grounds the agent on content narrower in audience than the agent itself, the deployment channel and whether it permits anonymous access, and whether the agent handles determination-bearing content that requires a human decision maker. Record the approval as certification evidence.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy
Mappings	HIPAA: 164.308(a)(1)(ii)(A) (Risk Analysis), 164.308(a)(8) (Evaluation); NIST 800-53: CM-3 (Configuration Change Control), CM-4 (Impact Analyses), SA-11 (Developer Testing and Evaluation), RA-3 (Risk Assessment)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000290.0
Requirement	Agent evaluations MUST be executed and reviewed against a documented test set before an agent application is promoted to production, and after any change to its instructions, tools, or guardrails.
Rationale	CX Agent Studio provides an evaluation capability with import and export of evaluation data, which makes a regression test set a supported artifact rather than an aspiration. Agent behaviour is emergent rather than specified, so a change to instructions intended to improve one interaction can silently alter refusal behaviour, tool selection, or disclosure in another, and only a held test set will detect it.
Estimated Security Value	Med
Estimated Operational Impact	Med
Audit Procedures	
Notes	The test set must include adversarial cases, not only happy paths: prompt injection attempts, requests for information the agent should refuse, and attempts to induce a tool call the caller is not entitled to. Evaluation operations may appear on the v1beta API surface, which this guide restricts to non-production projects, so run evaluations there and promote only the reviewed configuration.

ID	SG-GCP-GECX-000290.0
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio
Mappings	NIST 800-53: SA-11 (Developer Testing and Evaluation), CM-3 (Configuration Change Control), CM-4 (Impact Analyses), SI-10 (Information Input Validation); OWASP LLM Top 10 2025: LLM01 (Prompt Injection)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000300.0
Requirement	Agent applications MUST NOT be the sole authority for a coverage, eligibility, clinical, or other adverse determination communicated to a member.
Rationale	A generative agent produces a fluent answer whether or not the underlying retrieval succeeded. The data store tool's grounding score setting can suppress weakly grounded responses, but nothing in the suite reliably prevents an ungrounded or incorrect determination from being delivered. An adverse determination carries notice, appeal, and accuracy obligations under claims-procedure rules such as 29 CFR 2560.503-1, which governs ERISA-covered employee benefit plans, and those obligations attach to the organization regardless of which system produced the text.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Constrain member-facing agents to informational responses and route determination-bearing interactions to a human with the agent acting as an assistant. Where an agent surfaces a determination made elsewhere, it must present the determination reached by the system of record rather than restating it in generated language.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/guardrail ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/data-store ; https://www.ecfr.gov/current/title-29/subtitle-B/chapter-XXV/subchapter-G/part-2560/section-2560.503-1
Mappings	NIST 800-53: SA-8 (Security and Privacy Engineering Principles), PL-8 (Security and Privacy Architectures); OWASP LLM Top 10 2025: LLM09 (Misinformation); OWASP Agentic Top 10 2026: ASI09 (Human-Agent Trust Exploitation); NIST AI RMF (AI 100-1): GOVERN, MANAGE
Detective Policies	
Sentinel Modules	

ID	SG-GCP-GECX-000300.0
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000310.0
Requirement	Members interacting with a Gemini Enterprise for CX agent MUST be informed that they are interacting with an automated agent and offered a path to reach a human.
Rationale	Members are entitled to know when they are dealing with an automated agent, and some state laws restrict undisclosed bot communication online - for example, California Business and Professions Code section 17941 in commercial and electoral contexts. A member who cannot reach a person has no way to correct an agent that has misunderstood a health or benefits question. The suite supports escalation: Google documents the <code>end_session</code> system tool as used "to escalate to a human agent", and Agent Assist exists to support the human who receives the escalation, so the path is available and needs only to be configured and disclosed.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Configure the fallback behavior and the guardrail outcomes so that escalation reaches a person. The "Handoff to an agent" outcome transfers control to another CX Agent Studio agent, not a human, so route it to an agent that calls <code>end_session</code> with <code>session_escalated</code> set to True, and confirm the human receiving the handoff has the conversation context. Confirm with counsel which state disclosure laws apply to each channel. Verify the disclosure appears on every approved deployment channel, including voice, where it must be spoken rather than displayed.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/guardrail ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/system
Mappings	NIST 800-53: PT-5 (Privacy Notice), PT-5(1) (Just-in-time Notice); NIST AI RMF (AI 100-1): GOVERN, MANAGE
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000320.0
Requirement	Agent applications generated by the Start with AI capability MUST be reviewed in full, including their generated instructions and tools, before deployment.
Rationale	Start with AI generates a starter agent and its tools from supplied documentation, which means both the agent's

ID	SG-GCP-GECX-000320.0
	instructions and its tool registrations are model output rather than a human design. The generated tool set in particular determines what the agent can reach, and it is produced by inference over documentation rather than by an authorization decision.
Estimated Security Value	Med
Estimated Operational Impact	Low
Audit Procedures	
Notes	Treat the generated artifact as a draft. The standard pre-deployment agent security review applies unchanged, with additional attention to tools the generator created that no one requested. Start with AI is itself Preview: its feature page carries the Pre-GA Offerings Terms as of 2026-09-24, and the February 4, 2026 release note declares CX Agent Studio generally available and lists Start with AI among the launch's capabilities without stating that the feature is GA. Use it only in a non-production project, on documentation that contains no protected health information or other personal data, and review its output here before any of it reaches production.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/quick/generate-agent ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio
Mappings	NIST 800-53: CM-3 (Configuration Change Control), AC-6 (Least Privilege), CM-4 (Impact Analyses)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000330.0
Requirement	Where one agent is invoked as a tool of another - within one agent application or, through the A2A Protocol, across agent applications and projects - the delegation chain MUST be documented and reviewed as a single authorization surface.
Rationale	Google's release notes announced agents as tools on April 17, 2026 and declared the capability generally available on September 24, 2026. An agent-as-a-tool is another agent in the same application, invoked with its own instructions and tool set. Because those tools execute with the identities configured on them - the project service agent where Service agent ID token authentication is used - rather than the end user's, a delegation chain does not narrow authority at each hop: the invoked agent's tools reach what their identities reach, regardless of what the caller was entitled to. A chain therefore aggregates rather than attenuates reach, and reviewing either agent alone will not reveal it. The A2A Protocol extends the same chain across application and project boundaries: a remote CX Agent Studio application is reached through the calling project's service agent, and an

ID	SG-GCP-GECX-000330.0
	inbound A2A caller can write agent context directly into the invoked session.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Record the full graph of which agents invoke which, and review the union of tools reachable through the graph rather than the tool list of any single agent. A cycle or a chain crossing a trust boundary is a finding. For each A2A link also record the authentication method, the identity each side presents, what session context crosses, and which project owns each end; the A2A Protocol tool is Preview as of 2026-09-24. This is the strongest single argument for separating projects by trust domain.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/agent-as-tool ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/a2a-protocol
Mappings	HIPAA: 164.312(a)(1) (Access Control); NIST 800-53: AC-3 (Access Enforcement), AC-6 (Least Privilege), AC-4 (Information Flow Enforcement), PL-8 (Security and Privacy Architectures); HITRUST CSF v11: 01.c (Privilege Management), 01.v (Information Access Restriction); OWASP LLM Top 10 2025: LLM06 (Excessive Agency); OWASP Agentic Top 10 2026: ASI07 (Insecure Inter-Agent Communication); MITRE ATLAS: AML.T0053 (AI Agent Tool Invocation)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000340.0
Requirement	Agent versioning and changelog history SHOULD be retained for the life of the agent application.
Rationale	CX Agent Studio provides granular changelogs and rollback as a product capability. That history is the only record of what an agent was instructed to do at a given moment, which is what an incident investigation, a member complaint, or a regulatory inquiry will ask about. Conversation transcripts alone do not answer why the agent said what it said.
Estimated Security Value	Low
Estimated Operational Impact	Low
Audit Procedures	

ID	SG-GCP-GECX-000340.0
Notes	Where an investigation may need to reconstruct behavior beyond the retained changelog window, export the agent configuration on a schedule and retain the exports under the organization's records retention policy. Rollback is also the fastest containment action for a bad agent change, so exercise it at least once before relying on it in an incident. Do not prune changelog history as part of routine housekeeping.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes
Mappings	HIPAA: 164.312(b) (Audit Controls); NIST 800-53: CM-3 (Configuration Change Control), AU-11 (Audit Record Retention), SI-12 (Information Management and Retention), CP-9 (System Backup); HITRUST CSF v11: 06.c (Protection of Organizational Records)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

AI Models & Model Management

ID	SG-GCP-GECX-001260.0
Requirement	Only models on the organization's approved model allowlist MUST be selected to power a Gemini Enterprise for CX agent application.
Rationale	CX Agent Studio exposes a model picker offering several Gemini variants, and the choice determines the reasoning quality, the safety behaviour, and the latency of every member conversation the agent handles. Google states that CX Agent Studio models are performance-tuned for customer experience and may differ from the standard Vertex AI offering of the same name, so a model's behaviour here cannot be inferred from testing it elsewhere. Without an allowlist the model is whatever the builder picked from a dropdown, and it changes silently whenever Google revises the list.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Maintain the allowlist as an explicit artifact naming each approved model and the date its launch stage was checked, and reconcile it against the picker at the monthly release-note review. Voice-optimized and text-optimized models are separate entries and need separate approval, because a voice deployment reaches a different model than the text deployment of the same agent. Google can also change the model without builder action: the May 26, 2026 release note states that users who had not manually updated were automatically upgraded from Gemini 2.0 to Gemini 2.5

ID	SG-GCP-GECX-001260.0
	models. Treat such forced upgrades as allowlist changes and re-run the agent evaluations. The composite-v1 voice model, generally available since 2026-09-24, combines listener, thinking, and speaker sub-models whose minor versions Google may update automatically; approve it as one entry and re-run the voice agent evaluations at each monthly review rather than only on a visible model change.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/agent ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes
Mappings	NIST 800-53: CM-6 (Configuration Settings), CM-7 (Least Functionality), CM-2 (Baseline Configuration), SA-4 (Acquisition Process); OWASP LLM Top 10 2025: LLM03 (Supply Chain); NIST AI RMF (AI 100-1): GOVERN, MAP
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001270.0
Requirement	A model designated Preview in the CX Agent Studio model picker MUST NOT be selected for an agent application carrying production traffic.
Rationale	Google marks at least one model in the picker as Preview while presenting it alongside generally available models in the same dropdown, with no separation in the interface. A Preview model is governed by the Pre-GA Offerings Terms: no SLA, changeable or withdrawable without notice, and subject to Google's statement that Pre-GA offerings should not be used "to process personal data or other data subject to legal or regulatory compliance requirements". Google's HIPAA guidance says separately not to use Pre-GA offerings in connection with PHI. A builder selecting it is making a contractual and compliance decision through a dropdown that gives no indication one was made.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	As of 2026-09-24 the Preview entry was gemini-3-flash, with composite-v1, gemini-3.7-flash, gemini-3.5-flash, gemini-2.5-flash and gemini-3.1-flash-live shown as generally available. Verify the current designations in the picker rather than relying on that list, because the composition changes without a release note. Enforce by reviewing the selected model during the pre-deployment agent security review.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/agent ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes ;

ID	SG-GCP-GEEX-001270.0
	https://cloud.google.com/terms/service-terms ; https://cloud.google.com/security/compliance/hipaa
Mappings	HIPAA: 164.308(a)(8) (Evaluation); NIST 800-53: CM-7 (Least Functionality), CM-3 (Configuration Change Control), SA-4 (Acquisition Process), SA-8 (Security and Privacy Engineering Principles)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GEEX-001280.0
Requirement	A model override applied to an individual sub-agent MUST be documented and approved as a change to the agent application.
Rationale	Google states that a global model can be set for the agent application and overridden for specific sub-agents. An override is invisible from the application-level configuration, so an agent reviewed and approved on one model can contain a sub-agent running on another, including one that is Preview or not on the allowlist. Because sub-agents frequently handle the narrower and more sensitive parts of a conversation, the override lands precisely where it matters most.
Estimated Security Value	Med
Estimated Operational Impact	Low
Audit Procedures	
Notes	Enumerate sub-agent model assignments explicitly during review rather than reading the application-level setting alone, and record the effective model per sub-agent in the configuration baseline so the quarterly drift check can detect a change. Google states that audio agent applications do not allow overriding an agent's model except when the agent is used as a tool, so in voice applications check the model set on each agent used as a tool.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/agent ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/agent-as-tool
Mappings	NIST 800-53: CM-3 (Configuration Change Control), CM-6 (Configuration Settings), CM-2 (Baseline Configuration), CM-4 (Impact Analyses); OWASP LLM Top 10 2025: LLM03 (Supply Chain)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001290.0
Requirement	The launch stage of a selected model MUST be verified in the CX Agent Studio interface rather than inferred from that model's status in other Google Cloud products.
Rationale	Google states that all models in CX Agent Studio are considered generally available unless explicitly marked Preview in the interface, and that this launch stage is specific to CX Agent Studio and operates independently of a model's status in other Google Cloud products. A model that is generally available in Vertex AI may therefore be Preview here, and the reverse also holds. An engineer checking the model's status on its Vertex AI documentation page will reach a conclusion that does not govern this product.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	This is the reason the allowlist records where and when each launch stage was checked. Treat the CX Agent Studio picker as the only authoritative source for a model's stage within this product, and re-verify at each monthly release-note review rather than at model selection alone.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/agent ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes ; https://cloud.google.com/terms/service-terms
Mappings	HIPAA: 164.308(a)(8) (Evaluation); NIST 800-53: CM-7 (Least Functionality), SA-4 (Acquisition Process), CA-7 (Continuous Monitoring), CM-3 (Configuration Change Control)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

Tools & External Integrations

ID	SG-GCP-GECX-000350.0
Requirement	Each Gemini Enterprise for CX project MUST contain only agent applications that share a single trust domain.
Rationale	Google states that OpenAPI tool actions execute with the permissions granted to the CX Agent Studio service account rather than the end user's, and that service agent is a single identity per project. Every IAM grant made to it is therefore available to every agent application in the project whose tools authenticate as the service agent, and no in-product setting narrows those grants per application; tools configured with their own service account, OAuth, or API key credentials add their own reach on top. Combined with the Google-hosted token broker's public access path, the worst plausible configuration is an unauthenticated caller whose reach includes every grant held by the project service agent. For the

ID	SG-GCP-GEEX-000350.0
	service agent's permissions, the project boundary is the only boundary this product offers.
Estimated Security Value	High
Estimated Operational Impact	High
Audit Procedures	
Notes	This decision is made before the first agent application exists and is expensive to reverse, because moving an agent means recreating it, its tools, its deployment channels, and its data stores in a new project with a new perimeter. Google names dedicated projects as its own first recommended mitigation. Where a shared project is proposed for cost or operational reasons, the residual risk to accept is explicitly that every agent in it inherits every grant made to the project service agent. Agents serving different audiences or reaching different sensitivity tiers belong in separate projects, because the project is the scope of the service agent whose permissions every tool executes with.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls
Mappings	HIPAA: 164.312(a)(1) (Access Control), 164.308(a)(4) (Information Access Management); NIST 800-53: AC-4 (Information Flow Enforcement), AC-6 (Least Privilege), SC-7 (Boundary Protection), PL-8 (Security and Privacy Architectures); HITRUST CSF v11: 01.v (Information Access Restriction); OWASP Agentic Top 10 2026: ASI03 (Identity and Privilege Abuse); MITRE ATLAS: AML.T0053 (AI Agent Tool Invocation)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GEEX-000360.0
Requirement	An inventory of every registered tool, its type, its target system, its authentication method, and its approving owner MUST be maintained and reviewed at least quarterly.
Rationale	CX Agent Studio offers a growing catalog of tool types - eighteen in the tools overview as of 2026-09-24 - spanning arbitrary HTTP APIs, MCP servers, SaaS connectors, data stores, RAG knowledge bases, client-side functions, and code execution, and any holder of the toolsEditor role can register one without a deployment. Because a registered tool extends what agents in the project can reach - an agent reaches it once assigned, and a Python code tool can call any tool defined in its application without assignment - an unmaintained inventory means the project's effective reach is unknown to the people accountable for it.
Estimated Security Value	High

ID	SG-GCP-GE CX-000360.0
Estimated Operational Impact	Med
Audit Procedures	
Notes	The inventory is the input to the project-boundary judgement, so it must record what each tool can reach rather than only what it is called. Tool registration and modification (CreateTool, UpdateTool, and DeleteTool are DATA_WRITE methods) appear in Data Access audit logs under <code>ces.googleapis.com</code> and should be alerted on so the inventory can be reconciled against actual changes; confirm Data Access audit logging is enabled for the service, because the reconciliation depends on it. Record assignment as well as registration: which agents each tool is assigned to, and whether the application contains a Python code tool. A2A Protocol tools, added to the tools overview on 2026-09-24 as Preview, reach remote agents; record the remote agent endpoint, its owner, and its authentication method if one appears in a project, as well as any remote agent tool type found in the REST tool resource.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/rest/v1/projects.locations.apps.tools ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/a2a-protocol
Mappings	NIST 800-53: CM-8 (System Component Inventory), CM-3 (Configuration Change Control), AC-6 (Least Privilege), SA-9 (External System Services)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GE CX-000370.0
Requirement	Static credentials used by OpenAPI and MCP tools - API keys and any other secret held in the tool configuration - MUST be stored in Secret Manager and referenced rather than embedded in tool configuration, agent instructions, or custom header values.
Rationale	Google documents Secret Manager as the supported credential store for OpenAPI tools, with Secret Manager Secret Accessor granted to the CX Agent Studio service agent, and states that MCP tools carry the same authentication options. A credential held anywhere else in the product is readable by every holder of the viewer role, travels in configuration exports, and has no rotation or access-audit path of its own.
Estimated Security Value	High
Estimated Operational Impact	Low

ID	SG-GCP-GEEX-000370.0
Audit Procedures	
Notes	The Service agent ID token and Service Account authentication options are minted by the platform for each call and store no secret, so this requirement does not reach them; prefer them wherever the backend accepts a Google-issued identity. Google does not document where the OAuth option holds a client secret; confirm that before relying on it. MCP custom header values must be supplied by variables, which makes it tempting to place a static token in a variable - do not. Reference a Secret Manager secret instead. Note the perimeter interaction: Google documents that OpenAPI tools cannot reference authentication keys using secrets outside the VPC Service Controls perimeter, so the secret and the perimeter must be planned together.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/mcp ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls
Mappings	HIPAA: 164.312(a)(1) (Access Control), 164.312(d) (Person or Entity Authentication); NIST 800-53: IA-5 (Authenticator Management), SC-28 (Protection of Information at Rest), SC-12 (Cryptographic Key Establishment and Management), AC-6 (Least Privilege); HITRUST CSF v11: 10.g (Key Management)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GEEX-000380.0
Requirement	A tool MUST NOT be able to retrieve data beyond what the principal conversing with the agent is authorized to see, unless the backend authorizes every request against an identity bound to the session at authentication rather than supplied by the model.
Rationale	Because the tool executes as the project service agent and not as the caller, backend authorization is applied to the platform identity rather than to the member. A tool wired to an API that can return any member's record will return any member's record when the model is persuaded to ask for one, and no guardrail reliably prevents that because the request is a legitimate tool call.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	The backend must bind each request to a verified identifier the agent cannot choose - a session-bound identifier established at authentication, not a value the model extracts from the conversation - and return only the objects that identifier is entitled to. A backend that cannot do that is not

ID	SG-GCP-GECX-000380.0
	eligible for any agent whose audience is narrower than the backend's data, and an agent serving unauthenticated callers has no such identity, so its tools must not reach member data at all. This is the concrete form of the confused-deputy exposure that makes the project boundary the real security boundary in this product. CX Agent Studio passes no end-user identity to a tool backend on its own. For OpenAPI tools, the documented <code>x-ces-session-context</code> extension injects session context values, such as <code>\$context.session_id</code> , into a request parameter or header without the model choosing them; use it, or an equivalent server-side binding, to carry the session-bound identifier.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool
Mappings	HIPAA: 164.312(a)(1) (Access Control), 164.502(a) (Uses and Disclosures of PHI), 164.502(b) (Minimum Necessary); NIST 800-53: AC-3 (Access Enforcement), AC-4 (Information Flow Enforcement), AC-6 (Least Privilege); HITRUST CSF v11: 01.v (Information Access Restriction); OWASP API Top 10 2023: API1 (Broken Object Level Authorization); OWASP Agentic Top 10 2026: ASI02 (Tool Misuse and Exploitation); MITRE ATLAS: AML.T0053 (AI Agent Tool Invocation)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000390.0
Requirement	Data store tools and File search tools MUST NOT be grounded on content whose authorized audience is narrower than the audience able to converse with the agent.
Rationale	Neither the data store tool pages nor the REST definition of the data store tool offers any field or setting that carries the end user's identity into retrieval, whereas the connector tool in the same API explicitly supports end-user authentication. The same holds for File search tools, which retrieve from a RAG knowledge base. Absent a documented ACL-aware retrieval path, the safe reading is that any content ingested into a data store is reachable by any caller who can reach the agent, and the grounding score setting does not change who can see what.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Curate corpora to the agent's audience rather than relying on retrieval to filter: for a member-facing agent, public and member-general content only, with no internal policy documents, case notes, or provider-specific material. Connector data stores (for example Salesforce, Jira, Confluence, and BigQuery) are the type most likely to carry internal content and are within scope. Once a data store from

ID	SG-GCP-GECX-000390.0
	one region is added to a tool, only data stores from that region can be added to it. The data store tool's Filter setting lets the model add a filter parameter to a retrieval call; the console lists Never as the default while the REST reference describes the unspecified default as including it for connector data stores, and in either case the filter is model-chosen and not an access control. This reading rests on the absence of a documented permission-aware retrieval mechanism rather than on a Google statement; confirm with Google before relying on per-user retrieval.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/data-store ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/rest/v1/projects.locations.apps.tools ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/cloud-storage-data-store ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/website-data-store ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/file
Mappings	HIPAA: 164.312(a)(1) (Access Control), 164.502(b) (Minimum Necessary); NIST 800-53: AC-3 (Access Enforcement), AC-4 (Information Flow Enforcement), AC-21 (Information Sharing), AC-6 (Least Privilege); HITRUST CSF v11: 01.v (Information Access Restriction); OWASP LLM Top 10 2025: LLM02 (Sensitive Information Disclosure)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000400.0
Requirement	Content ingested into a data store or RAG knowledge base used by a member-facing agent MUST be reviewed and approved before each ingestion and ingested only from locations under the organization's control.
Rationale	Retrieved content enters the model's context and is acted upon as instruction-bearing input. Where a corpus includes externally authored material - a crawled website, a vendor document, a partner feed - an attacker who can edit that source has a durable indirect prompt injection path into every conversation the corpus grounds, without ever interacting with the agent. Ingesting only from locations the organization controls means the corpus changes only when someone the organization authorizes re-ingests it.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Externally authored material, such as a vendor document or a partner publication, is admitted only as a reviewed snapshot copied into organization-controlled storage, and each refresh

ID	SG-GCP-GECX-000400.0
	is a new ingestion that needs its own review. Website data stores are the highest-risk case because the crawl re-ingests whatever the page currently says, so restrict them to domains the organization controls - Google requires domain verification when website content is used as a source, which partly enforces this - and never point one at a third-party site. This requirement addresses the injection vector; the untrusted-input requirement addresses what the agent does with the result. File search tools, which upload files into a RAG knowledge base as a simpler alternative to data store tools, are in scope on the same terms.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/data-store ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/ ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/guardrail ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/file ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/website-data-store
Mappings	NIST 800-53: SI-10 (Information Input Validation), SR-3 (Supply Chain Controls and Processes), CM-8 (System Component Inventory); OWASP LLM Top 10 2025: LLM01 (Prompt Injection); OWASP Agentic Top 10 2026: ASI06 (Memory and Context Poisoning); MITRE ATLAS: AML.T0051.001 (LLM Prompt Injection - Indirect)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000410.0
Requirement	Tool responses, retrieved data store content, and knowledge base excerpts MUST be treated as untrusted input that cannot authorize a subsequent action the caller could not authorize directly.
Rationale	Every source that enters the model context is a channel through which an instruction can arrive, and the model does not distinguish retrieved text from a member's utterance. An agent that will call a second tool because the first tool's response told it to has delegated its authorization decision to whoever controls that backend's response body, which in a multi-hop or third-party integration is not the organization.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Enforce architecturally rather than through prompt engineering: constrain which tools an agent may call and in what sequence, and require any state-changing action to be gated on a condition established outside the model's context. The Prompt guard reduces the frequency of successful injection; it does not bound the consequence.

ID	SG-GCP-GECX-000410.0
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/guardrail ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/mcp
Mappings	HIPAA: 164.312(a)(1) (Access Control); NIST 800-53: SI-10 (Information Input Validation), AC-3 (Access Enforcement), AC-4 (Information Flow Enforcement), SI-15 (Information Output Filtering); HITRUST CSF v11: 01.v (Information Access Restriction); OWASP LLM Top 10 2025: LLM01 (Prompt Injection), LLM06 (Excessive Agency); OWASP Agentic Top 10 2026: ASI01 (Agent Goal Hijack), ASI06 (Memory and Context Poisoning); MITRE ATLAS: AML.T0051.001 (LLM Prompt Injection - Indirect), AML.T0053 (AI Agent Tool Invocation)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000420.0
Requirement	Third-party and externally hosted MCP servers MUST pass a supply chain security review before being registered as a tool.
Rationale	Google documents that MCP tools may target prebuilt servers, servers built with third-party frameworks, or servers deployed by the customer, and that they carry the same authentication options as OpenAPI tools - meaning they may execute with the project service agent's permissions (Google recommends the Service Agent ID token for Cloud Run hosted servers) or with a service account, OAuth, or API key credential configured on the tool. An MCP server also declares its own tool definitions, so a compromised or malicious server controls both the description the model reasons over and the response it acts on.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	The review covers who operates the server, how its tool definitions are versioned and change-controlled, what it logs, and whether its declared tools can change after registration. Only StreamableHttpTransport servers are supported; SSE transport servers are not, so a server offering only SSE cannot be used regardless of review outcome. An unreviewed public MCP server is never eligible for registration regardless of how convenient its tool set appears.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/mcp ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api
Mappings	HIPAA: 164.308(b)(1) (Business Associate Contracts), 164.308(a)(8) (Evaluation); NIST 800-53: SA-9 (External System Services), SR-3 (Supply Chain Controls and

ID	SG-GCP-GECX-000420.0
	Processes), SR-11 (Component Authenticity), CM-7 (Least Functionality); HITRUST CSF v11: 05.i (Identification of Risks Related to External Parties), 05.k (Addressing Security in Third Party Agreements); OWASP LLM Top 10 2025: LLM03 (Supply Chain); OWASP Agentic Top 10 2026: ASI04 (Agentic Supply Chain Vulnerabilities); MITRE ATLAS: AML.T0110 (AI Agent Tool Poisoning)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000430.0
Requirement	MCP servers used by production agent applications SHOULD be hosted within the organization's Google Cloud boundary, with invocation restricted to the CX Agent Studio service agent.
Rationale	Google's documented pattern hosts the MCP server on Cloud Run and grants the Cloud Run Invoker role to <code>service-PROJECT_NUMBER@gcp-sa-ces.iam.gserviceaccount.com</code> . That arrangement keeps the tool definitions under the organization's change control, keeps conversation-derived parameters inside the boundary, and makes the server's own logs available for investigation - none of which holds for a server operated by a third party.
Estimated Security Value	Med
Estimated Operational Impact	Med
Audit Procedures	
Notes	Restricting the Invoker role to the service agent alone also prevents the MCP server becoming an unauthenticated internal API. A VPC Service Controls perimeter narrows the network path but does not remove other IAM-authorized callers: any principal holding <code>run.routes.invoke</code> on the service or its project can still call it, so include the service's IAM policy and project-level Cloud Run grants in the review. Test the server independently with curl or Postman before registration, as Google recommends.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/mcp ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls
Mappings	HIPAA: 164.312(e)(1) (Transmission Security); NIST 800-53: SC-7 (Boundary Protection), AC-3 (Access Enforcement), SA-9 (External System Services), IA-9 (Service Identification and Authentication); HITRUST CSF v11: 09.m (Network Controls); OWASP LLM Top 10 2025: LLM03 (Supply Chain)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000440.0
Requirement	Tools that connect to Salesforce, ServiceNow, Jira, Confluence, or SharePoint - both the dedicated tool types for those systems and Integration Connector tools - MUST authenticate with the end user's own credentials or with a dedicated connection identity scoped to the minimum records the agent requires.
Rationale	These systems hold case notes, ticket bodies, and document libraries whose contents routinely include member-identifying detail written by staff for staff. The dedicated Salesforce, ServiceNow, Jira, Confluence, and SharePoint tools use the OpenAPI tool authentication options, and an Integration Connector tool passes the connection's admin authentication by default unless an end-user authentication override is configured. Unless end-user credentials are passed, the connection identity's entitlements become the agent's entitlements, and a connection created with an administrator's profile exposes the entire system through a conversational interface.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Where the connection supports it, prefer the Integration Connectors authentication override, which replaces the default admin authentication with an end-user authentication config; the Connection must have authentication override enabled or tool creation fails. Otherwise create a purpose-built integration account in each SaaS platform rather than reusing an existing service or personal account, and scope it at the source system with object, field, and record filters. Re-verify scope after any change to the source system's permission model, which is outside Google Cloud's change control and will not surface in a CX Agent Studio review.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/connector ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/salesforce ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/service-now ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/jira ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/confluence ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/sharepoint ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/rest/v1/projects.locations.apps.tools
Mappings	HIPAA: 164.312(a)(1) (Access Control), 164.502(b) (Minimum Necessary), 164.308(b)(1) (Business Associate Contracts); NIST 800-53: AC-6 (Least Privilege), AC-3 (Access Enforcement), SA-9 (External System Services), IA-9 (Service Identification and Authentication); HITRUST CSF v11: 01.c (Privilege Management), 05.k (Addressing Security in Third

ID	SG-GCP-GECX-000440.0
	Party Agreements); OWASP API Top 10 2023: API1 (Broken Object Level Authorization)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000450.0
Requirement	Python code tools MUST be reviewed as application source code before registration and before any subsequent modification.
Rationale	A Python code tool is arbitrary executable logic invoked as part of a conversation, which places it in the same risk class as application code while offering none of the surrounding pipeline controls - no branch protection, no peer review gate, no dependency scanning, no build provenance. Google documents that the code runs in a sandbox on Python 3.12 with a fixed set of importable modules, that it can read the full conversation history and session state and can modify session state, that it can call any other tool defined in the agent application, and that it can make outbound requests only to endpoints publicly available on the internet, with no private network access even where Service Directory is configured. The code therefore holds the conversation, the reach of every tool in the application, and a public egress path at the same time.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Review each Python code tool for: every outbound request through the provided HTTP client, each one data leaving the organization over the public internet; every other tool it calls, since a call from code inherits that tool's authority (for OpenAPI tools, the service agent); every write to session state, since state set in code steers later turns; and unbounded input handling. The sandbox identity, and whether its HTTP client attaches a Google credential, is undocumented; confirm with Google before using this tool type with member data, and never place a secret in the code, which is stored in the tool configuration. Google's pages disagree twice (the tool page cites the requests library while the runtime reference uses the provided client; the REST resource carries a Service Directory field although the tool page says private network access is unavailable), so verify behaviour in a non-production project. A production modification without the same review is not permitted.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/python ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/python ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/rest/v1/projects.locations.apps.tools ;

ID	SG-GCP-GECX-000450.0
	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api
Mappings	HIPAA: 164.312(e)(1) (Transmission Security); NIST 800-53: SA-11 (Developer Testing and Evaluation), SA-15 (Development Process, Standards, and Tools), CM-3 (Configuration Change Control), SI-7 (Software, Firmware, and Information Integrity), CM-7 (Least Functionality); HITRUST CSF v11: 09.s (Information Exchange Policies and Procedures); OWASP LLM Top 10 2025: LLM05 (Improper Output Handling); OWASP Agentic Top 10 2026: ASI05 (Unexpected Code Execution)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000460.0
Requirement	Client function tools MUST NOT be passed data that the end user is not already authorized to see.
Rationale	Google states that client function tools are always executed on the client side, not by the agent: the model decides when to call the function and what its arguments contain, the arguments are handed to the calling client application, and the server-side session waits until the client returns a result. On the web widget or a mobile channel that client is the end user's own device, which is untrusted and on a public deployment may belong to an unauthenticated party. Data placed in a client function call is disclosed at the moment of the call regardless of what the function does with it.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Define the parameters schema of each client function so that it can carry only fields the end user is already authorized to see, and review the function description, because the model uses it to decide when to call the function and what to pass. Treat the argument set as a disclosure to the end user in the data flow record. This requirement governs data sent to the client; results returned by the client are governed separately.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/function ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/rest/v1/projects.locations.apps.tools ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/web-widget
Mappings	HIPAA: 164.312(a)(1) (Access Control), 164.502(a) (Uses and Disclosures of PHI); NIST 800-53: AC-3 (Access Enforcement), AC-4 (Information Flow Enforcement); HITRUST CSF v11: 01.v (Information Access Restriction); OWASP LLM Top 10 2025: LLM02 (Sensitive Information Disclosure)

ID	SG-GCP-GECX-000460.0
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000470.0
Requirement	The Google Search tool SHOULD NOT be enabled on member-facing agent applications.
Rationale	Grounding a member conversation on open web results introduces content the organization neither authored nor controls into a channel members treat as authoritative, and it sends conversation-derived query terms outside the assessed boundary. For health and benefits questions the accuracy and provenance obligations sit with the organization no matter where the text originated.
Estimated Security Value	Med
Estimated Operational Impact	Low
Audit Procedures	
Notes	Where broad knowledge is genuinely needed, a curated and reviewed data store provides grounding the organization can review and version. If the Search tool is required for a specific internal-facing use case, document the query terms that can reach it and confirm they carry no member identifiers. Whether Google Search grounding is covered by the BAA was not confirmed at authoring; confirm with Google before any use that could carry member information, and treat the tool as prohibited on any agent that can reach member data if it is not covered.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/data-store
Mappings	HIPAA: 164.502(a) (Uses and Disclosures of PHI); NIST 800-53: AC-4 (Information Flow Enforcement), SC-7(10) (Prevent Exfiltration), SI-10 (Information Input Validation), SC-7 (Boundary Protection); HITRUST CSF v11: 09.s (Information Exchange Policies and Procedures); OWASP LLM Top 10 2025: LLM09 (Misinformation)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000480.0
Requirement	Where a tool's backend is reachable through Service Directory private network access, OpenAPI tools, MCP tools, and the dedicated Salesforce, ServiceNow, Jira, Confluence, and SharePoint tools MUST be configured to use the Service Directory path rather than a public endpoint.

ID	SG-GCP-GEEX-000480.0
Rationale	Google documents Service Directory private network access as the supported way for CX Agent Studio to reach OpenAPI tool targets inside a VPC network, stating that this keeps traffic within the Google Cloud network and enforces IAM and VPC Service Controls. A tool that egresses to a public endpoint instead forfeits all three properties for every conversation parameter it carries.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Configure Service Directory private network access and grant <code>servicedirectory.viewer</code> and <code>servicedirectory.pscAuthorizedService</code> to <code>service-agent-project-number@gcp-sa-ces.iam.gserviceaccount.com</code> ; where Service Directory lives in a different project, grant <code>servicedirectory.viewer</code> in both. Note that within a perimeter this stops being a preference - Google documents that tools and callbacks cannot send requests to arbitrary HTTP endpoints once VPC Service Controls is enabled without Service Directory configuration.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/salesforce ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/python
Mappings	HIPAA: 164.312(e)(1) (Transmission Security); NIST 800-53: SC-7 (Boundary Protection), SC-7(10) (Prevent Exfiltration), AC-4 (Information Flow Enforcement), SC-8 (Transmission Confidentiality and Integrity); HITRUST CSF v11: 09.m (Network Controls), 09.n (Security of Network Services)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GEEX-000490.0
Requirement	The set of tools registered in a project MUST be restricted to those the approved agent use cases require, with unused registrations removed.
Rationale	Because tool authority aggregates at the project service agent rather than attenuating per agent, every registered tool that no agent needs is pure added blast radius. Tools also accumulate during development and vendor-led enablement sessions and are rarely removed, so the gap between what is registered and what is used widens silently over time. Registration extends reach even before a tool is assigned to an agent, because a Python code tool can call any tool defined in the same application.

ID	SG-GCP-GECX-000490.0
Estimated Security Value	Med
Estimated Operational Impact	Low
Audit Procedures	
Notes	Reconcile the tool inventory against actual tool invocation observed in conversation history and audit logs on the quarterly cycle. A tool registered but never invoked in a full quarter is a candidate for removal, and its continued presence should require a stated reason.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/python
Mappings	NIST 800-53: CM-7 (Least Functionality), CM-8 (System Component Inventory), AC-6 (Least Privilege), CM-3 (Configuration Change Control); HITRUST CSF v11: 01.c (Privilege Management); OWASP LLM Top 10 2025: LLM06 (Excessive Agency); OWASP Agentic Top 10 2026: ASI02 (Tool Misuse and Exploitation)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001310.0
Requirement	Tool invocations MUST carry a correlation identifier, comprising at minimum the agent application identifier and the conversation or session identifier, that the receiving backend system records in its own logs.
Rationale	Tool calls commonly reach the backend under a shared platform or tool identity - the CX Agent Studio service agent, or a service account, OAuth client, or API key configured on the tool - so the backend's own audit log records one identity for many agents, conversations, and members. Without a correlation identifier the backend cannot attribute an action to the conversation that caused it, which means an investigation starting from a backend record - a changed claim, an unexpected lookup, an anomalous query volume - has no path back into the conversation history. The Google Cloud side of the boundary is well instrumented; the identifier is what carries that attribution across it.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	For OpenAPI tools, use the documented <code>x-ces-session-context</code> extension to inject session context such as <code>\$context.session_id</code> into a header or parameter; for MCP tools, inject session context variables into custom

ID	SG-GCP-GECX-001310.0
	headers; for Integration Connector tools, pass the identifier in a defined request field. Require the receiving system to log it as a condition of being connected. The identifier is metadata rather than content and must not carry member identifiers or conversation text. This is the control that makes the confused-deputy residual risk investigable after the fact rather than merely accepted.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/mcp ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging
Mappings	HIPAA: 164.312(b) (Audit Controls), 164.308(a)(1)(ii)(D) (Information System Activity Review); NIST 800-53: AU-3 (Content of Audit Records), AU-2 (Event Logging), IA-9 (Service Identification and Authentication), AC-3 (Access Enforcement); HITRUST CSF v11: 09.aa (Audit Logging); OWASP Agentic Top 10 2026: ASI03 (Identity and Privilege Abuse); MITRE ATLAS: AML.T0053 (AI Agent Tool Invocation)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001330.0
Requirement	Results returned by a client function tool MUST NOT be relied upon to establish the end user's identity, entitlement, or authorization for any subsequent action.
Rationale	A client function tool is executed by the calling client application, which returns the result to the agent in the tool response and the agent then continues the conversation on it. On a web or mobile channel that client is under the end user's control, so the returned value is whatever the end user's device chooses to send. An agent that treats that value as proof of who the member is, or of what they may do, lets the member assert their own authorization.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Validate each result against the response schema declared on the function and treat it as untrusted input. Establish identity and entitlement from the channel's authentication and from backend systems reached by server-side tools, never from a client function result. Google's documentation describes the flow but does not itself characterize the result as untrusted; this requirement is the organization's reading of the documented flow.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/function ; https://docs.cloud.google.com/gemini-

ID	SG-GCP-GECX-001330.0
	enterprise-cx/cx-agent-studio/reference/rest/v1/projects.locations.apps.tools
Mappings	HIPAA: 164.312(d) (Person or Entity Authentication), 164.312(a)(1) (Access Control); NIST 800-53: SI-10 (Information Input Validation), AC-3 (Access Enforcement), IA-8 (Identification and Authentication (Non-organizational Users)); HITRUST CSF v11: 01.q (User Identification and Authentication), 01.v (Information Access Restriction); OWASP API Top 10 2023: API2 (Broken Authentication); OWASP Agentic Top 10 2026: ASI03 (Identity and Privilege Abuse)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001340.0
Requirement	Data store tools that reference a search engine MUST name the specific data stores to be searched rather than leaving the data store selection empty.
Rationale	Google documents that when a data store tool targets an engine and its data store selection is empty, the search applies to all data stores associated with the engine. Any data store later attached to that engine for another purpose then becomes retrievable by every caller of the agent without any change to the agent or the tool, which silently widens the audience for that content.
Estimated Security Value	Med
Estimated Operational Impact	Low
Audit Procedures	
Notes	Review the data store selection on every engine-backed data store tool at registration and at the quarterly tool inventory review. The engine-level filter is not used when specific data stores are named, and is not an access control in either case.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/rest/v1/projects.locations.apps.tools ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/data-store
Mappings	HIPAA: 164.312(a)(1) (Access Control), 164.502(b) (Minimum Necessary); NIST 800-53: AC-3 (Access Enforcement), AC-4 (Information Flow Enforcement), CM-6 (Configuration Settings), AC-6 (Least Privilege); HITRUST CSF v11: 01.v (Information Access Restriction)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001360.0
Requirement	The RAG knowledge base behind a File search tool MUST be located in a US region where RAG Engine is designated GA.
Rationale	A File search tool uploads files into a RAG knowledge base created in a location the builder selects, and RAG knowledge bases are a RAG Engine resource billed and regionalized separately from CX Agent Studio. The residency pin configured for CX Agent Studio therefore does not govern where these files are stored, and Google's RAG Engine region table lists US regions at different launch stages - us-central1 and us-east4 as Allowlist, GA and us-east1 as Allowlist, Preview. Choosing a US region fixes where the knowledge base is created; it is not a contractual data-residency commitment, which Google states RAG Engine does not support.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Set the Location field explicitly when a local file is uploaded, because the knowledge base is created at that point. Confirm the region's launch stage in the RAG Engine region table at registration, because the table changes independently of CX Agent Studio release notes. Access to the US regions requires allowlisting by Google.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/file ; https://docs.cloud.google.com/gemini-enterprise-agent-platform/build/rag-engine/rag-overview
Mappings	HIPAA: 164.308(a)(1)(ii)(B) (Risk Management); NIST 800-53: SA-9(5) (Processing, Storage, and Service Location), CM-6 (Configuration Settings), AC-4 (Information Flow Enforcement), SA-9 (External System Services); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001370.0
Requirement	RAG knowledge bases used by File search tools MUST be protected by customer-managed encryption keys and placed inside the VPC Service Controls perimeter before any file is uploaded.
Rationale	Google states that VPC Service Controls and CMEK are supported by RAG Engine, but the CX Agent Studio CMEK integration and perimeter configuration are specific to the CX Agent Studio service and do not extend to a separate product's resources. A knowledge base created from the File search tool without its own configuration holds uploaded content under Google-managed keys and outside the perimeter.

ID	SG-GCP-GECX-001370.0
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Configure CMEK and add the RAG Engine API service to the perimeter in the project that will hold the knowledge base before the File search tool is registered, since a knowledge base is created automatically when a local file is uploaded. Include the knowledge base in the CMEK inventory and the data flow record.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/file ; https://docs.cloud.google.com/gemini-enterprise-agent-platform/build/rag-engine/rag-overview
Mappings	HIPAA: 164.312(a)(2)(iv) (Encryption and Decryption), 164.312(e)(1) (Transmission Security); NIST 800-53: SC-28 (Protection of Information at Rest), SC-12 (Cryptographic Key Establishment and Management), SC-7 (Boundary Protection), AC-4 (Information Flow Enforcement); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information), 10.g (Key Management), 09.m (Network Controls)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001380.0
Requirement	File search tools SHOULD NOT be used to ground agents on content containing protected health information.
Rationale	Google's RAG Engine overview states that data residency and Access Transparency security controls are not supported by RAG Engine. Content uploaded through a File search tool therefore sits outside two controls this deployment otherwise relies on for member data: a contractual at-rest location commitment and a record of Google personnel access.
Estimated Security Value	Med
Estimated Operational Impact	Low
Audit Procedures	
Notes	Use data store tools, or a backend reached through a server-side tool, for any retrieval corpus that must contain protected health information. Where an exception is approved, record it in the residual risk acceptance for the deployment. Re-verify the RAG Engine statement at each release-note review, because the supported-controls list can change.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/file ; https://docs.cloud.google.com/gemini-enterprise-agent-platform/build/rag-engine/rag-overview
Mappings	HIPAA: 164.502(b) (Minimum Necessary), 164.308(b)(1) (Business Associate Contracts); NIST 800-53: SA-9(5) (Processing, Storage, and Service Location), SA-9 (External

ID	SG-GCP-GEEX-001380.0
	System Services), AU-2 (Event Logging), RA-3 (Risk Assessment); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information), 09.f (Monitoring and Review of Third Party Services)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	
ID	SG-GCP-GEEX-001390.0
Requirement	Agent-to-agent (A2A) Protocol tools MUST NOT be configured on any agent application, for outbound delegation or for inbound invocation, while the capability is designated Preview.
Rationale	The CX Agent Studio tools overview and documentation navigation mark the A2A Protocol tool Preview, although its own page carries no banner, so it is governed by the Pre-GA Offerings Terms and by Google's HIPAA guidance not to use Pre-GA offerings in connection with PHI. The capability also opens a boundary this guide otherwise keeps closed: external applications and orchestrators can invoke an agent application directly while holding the Client role, which includes <code>ces.tools.execute</code> , and can send agent context metadata that the application writes directly into the current session. Outbound, the tool delegates conversation-derived tasks to remote agents in other projects, in Vertex AI Agent Engine, or at third parties authenticated with an API key or OAuth.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	This is a specific application of the baseline prohibition on Pre-GA features, restated because the tool appears in the same picker as generally available tool types. Before approving it at GA, decide each direction separately. Inbound callers need a custom role without <code>ces.tools.execute</code> and a path through the organization's API gateway, and inbound session context must be treated as untrusted input. Outbound links need a documented remote owner, authentication method, and cross-project trust decision, and the delegation chain they create is reviewed as one authorization surface. Sessions with other CX Agent Studio applications are always stateful, so context persists across the link.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/a2a-protocol ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes ; https://cloud.google.com/terms/service-terms ; https://cloud.google.com/security/compliance/hipaa
Mappings	HIPAA: 164.308(a)(8) (Evaluation), 164.312(a)(1) (Access Control); NIST 800-53: CM-7 (Least Functionality), AC-4

ID	SG-GCP-GECX-001390.0
	(Information Flow Enforcement), CA-3 (Information Exchange), SA-4 (Acquisition Process), SA-9 (External System Services); HITRUST CSF v11: 01.v (Information Access Restriction), 05.i (Identification of Risks Related to External Parties); OWASP Agentic Top 10 2026: ASI07 (Insecure Inter-Agent Communication); MITRE ATLAS: AML.T0053 (AI Agent Tool Invocation)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

Deployment & Channel Security

ID	SG-GCP-GECX-000500.0
Requirement	An inventory of every deployment channel, its authentication mode, and its approving owner MUST be maintained for each agent application.
Rationale	CX Agent Studio publishes an agent to a growing set of surfaces - as of 2026-09-24, web widget, AudioCodes, Five9, Google Cloud CCaaS, Google Telephony Platform, SecureCo, Twilio, WhatsApp and Instagram, and direct API access - and each carries a different authentication model and a different population of callers. The security posture of an agent is meaningless without knowing which of these it is exposed on, and a channel added later does not change anything visible in the agent's own configuration.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	The inventory records, per channel, whether callers are authenticated, what identity the channel's token carries, and which third party operates the transport. Reconcile it against direct grants of the Gemini Enterprise for Customer Experience Client role (<code>roles/ces.client</code>) to service accounts and other non-human principals only. Every CX Agent Studio editor role and the Admin role inherit the Client role, and end users authenticated through OAuth2 hold access to the agent themselves, so a reconciliation against all holders will not balance. A direct non-human grant with no matching channel entry is either an undocumented channel or an unused credential. Inbound A2A callers, where the A2A Protocol is enabled, are channels for this inventory. Reconcile the channel list against the deployment overview at each release-note review rather than against a fixed count.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/web-widget ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/secureco ;

ID	SG-GCP-GECX-000500.0
	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/whatsapp
Mappings	NIST 800-53: CM-8 (System Component Inventory), AC-3 (Access Enforcement), CM-3 (Configuration Change Control), PL-8 (Security and Privacy Architectures); HITRUST CSF v11: 01.j (User Authentication for External Connections), 01.v (Information Access Restriction)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000510.0
Requirement	Public access through the Google-hosted token broker MUST NOT be enabled for any agent application whose tools can reach member data.
Rationale	Google documents the Google-hosted token broker as the mechanism that allows public access to a chat widget, which means an unauthenticated caller obtains a valid token and converses with the agent. Because tools execute with the project service agent's permissions rather than the caller's, the effective reach of that anonymous conversation is every backend any tool in the project authenticates to. Anonymous access and service-agent tool execution are individually defensible and jointly a direct path from the open internet to member records.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Where a genuinely public agent is required - a benefits FAQ or a store locator - place it in its own project with its own service agent and no tool that reaches member data, so that anonymous reach is bounded by the project rather than by the agent's instructions. Google recommends deploying agent applications in a dedicated project to limit the scope of permissions available to the CX Agent Studio service account.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/web-widget ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy
Mappings	HIPAA: 164.312(a)(1) (Access Control), 164.312(d) (Person or Entity Authentication), 164.502(a) (Uses and Disclosures of PHI); NIST 800-53: AC-3 (Access Enforcement), IA-8 (Identification and Authentication (Non-organizational Users)), AC-6 (Least Privilege), SC-7 (Boundary Protection); HITRUST CSF v11: 01.j (User Authentication for External Connections), 01.v (Information Access Restriction); OWASP API Top 10 2023: API2 (Broken Authentication), API1 (Broken Object Level Authorization)

ID	SG-GCP-GECX-000510.0
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000520.0
Requirement	Where public access is approved for a bounded public-information agent, origin checks and reCAPTCHA MUST both be enabled on the widget configuration.
Rationale	Google presents these as optional additions - the documentation reads enable public access, and optionally enable origin and reCAPTCHA checks, recommended to prevent spoofing and abuse. Left at their defaults they are off, which leaves a publicly reachable generative endpoint with no origin binding and no automation control: it can be embedded on any site, driven by a script, and consumed as a free inference endpoint at the organization's expense.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Origin checks bind the widget to the organization's own pages, which is what makes an embedded agent attributable. reCAPTCHA constrains automated abuse. Neither is a substitute for the reach limitation that comes from a dedicated project with no sensitive tools, and both must be verified after any widget configuration change because they sit in the same form as the public-access toggle.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/web-widget
Mappings	NIST 800-53: SC-5 (Denial-of-service Protection), SC-23 (Session Authenticity), AC-3 (Access Enforcement), CM-6 (Configuration Settings); HITRUST CSF v11: 09.m (Network Controls); OWASP LLM Top 10 2025: LLM10 (Unbounded Consumption); OWASP API Top 10 2023: API4 (Unrestricted Resource Consumption), API6 (Unrestricted Access to Sensitive Business Flows)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000530.0
Requirement	Agent applications serving authenticated members MUST authenticate each member individually through the organization's identity provider - using the OAuth2 client path or a custom authentication API that issues a short-lived token for the member's session - and grant member identities no role that includes the <code>ces.tools.execute</code> permission.

ID	SG-GCP-GEEX-000530.0
Rationale	The widget supports an OAuth2 client that authenticates the end user and returns a token operating on that user's behalf, and a custom authentication API that returns a Google access token or signed JWT permitted to call runSession. Google notes that the identity associated with the token - end user or service account - must hold the IAM permissions to interact with the agent. A service-account broker makes every member session indistinguishable at the platform layer, so the conversation record cannot be attributed and no per-member condition can be applied at the boundary. The predefined Client role grants tools.execute in addition to runSession and bidiRunSession, so a member identity holding it could invoke the agent's tools directly, outside the conversation, with the tools' configured identity.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Where the OAuth2 path is used, grant member principals a custom role containing only <code>ces.sessions.runSession</code> (and <code>ces.sessions.bidiRunSession</code> for voice) rather than the predefined Client role. Google describes the custom option as an API that "returns a google access token or signed jwt that has the permission to call runSession in your app", which suits an organization-operated member identity provider. Authentication mode by agent type: agents serving authenticated members use per-member authentication; a self-hosted service-account token broker suits only unauthenticated or bounded public-information agents; the Google-hosted public broker is never used where tools can reach member data. End-user authentication does not make tool execution user-scoped, which remains the service agent's, so per-member data scoping must still be enforced in the backend against a session-bound identifier. Configure authorized JavaScript origins and redirect URIs to the organization's domains only.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/web-widget ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/iam/docs/roles-permissions/ces
Mappings	HIPAA: 164.312(d) (Person or Entity Authentication), 164.312(a)(1) (Access Control); NIST 800-53: IA-2 (Identification and Authentication (Organizational Users)), IA-8 (Identification and Authentication (Non-organizational Users)), AC-3 (Access Enforcement), AC-6 (Least Privilege), AU-3 (Content of Audit Records); HITRUST CSF v11: 01.q (User Identification and Authentication), 01.j (User Authentication for External Connections), 01.c (Privilege Management); OWASP API Top 10 2023: API2 (Broken Authentication)
Detective Policies	
Sentinel Modules	
CSP Level Controls	

ID	SG-GCP-GECX-000530.0
Monitoring Controls	
ID	SG-GCP-GECX-000540.0
Requirement	A self-hosted token broker SHOULD be used in preference to the Google-hosted broker for any agent application that serves unauthenticated callers or bounded public information.
Rationale	A self-hosted broker runs in the organization's own project on Cloud Run, which puts token issuance under the organization's logging, rate limiting, IP controls, and change management. The Google-hosted broker exists to enable public access and offers no organization-defined logic before a token is minted beyond its optional origin and reCAPTCHA checks.
Estimated Security Value	Med
Estimated Operational Impact	Med
Audit Procedures	
Notes	Google publishes sample code for the self-hosted broker, and its service account is granted the Customer Engagement Suite Client role. That service account should hold only that role and nothing else, and it needs no downloaded key because Cloud Run attaches the identity. Because the Client role also includes tools.execute, keep issued tokens as short-lived as the broker allows. Broker request logs are useful evidence of who initiated a conversation and when. A service-account broker is not end-user authentication: every session it issues carries the same service identity, so agents serving authenticated members authenticate each member through the organization's identity provider instead.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/web-widget ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control
Mappings	HIPAA: 164.312(d) (Person or Entity Authentication); NIST 800-53: IA-5 (Authenticator Management), AC-3 (Access Enforcement), SC-7 (Boundary Protection), AU-2 (Event Logging); HITRUST CSF v11: 01.j (User Authentication for External Connections)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	
ID	SG-GCP-GECX-000550.0
Requirement	The web widget MUST be embedded only on web origins the organization controls.
Rationale	The widget is deployed as an HTML snippet, which is copyable and will function wherever it is pasted unless an origin restriction constrains it. An agent embedded on a third-party or attacker-controlled page presents the organization's brand and voice in a context the organization cannot vouch

ID	SG-GCP-GECX-000550.0
	for, and any data the member provides transits a page the organization does not control.
Estimated Security Value	Med
Estimated Operational Impact	Low
Audit Procedures	
Notes	Enforce the origin restriction with the control that matches the widget's authentication mode: the Authorized JavaScript origins of the OAuth2 client, origin validation in a self-hosted token broker or custom authentication API, or the optional origin check of the Google-hosted broker where public access is approved. Maintain the approved origin list as configuration under change control, and review it whenever a partner or vendor site is added, since an origin approved for a marketing campaign rarely gets removed afterwards.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/web-widget ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy
Mappings	HIPAA: 164.312(a)(1) (Access Control); NIST 800-53: SC-23 (Session Authenticity), AC-3 (Access Enforcement), CM-6 (Configuration Settings), SC-7 (Boundary Protection); HITRUST CSF v11: 01.j (User Authentication for External Connections), 01.v (Information Access Restriction)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000560.0
Requirement	Non-production agent development and testing MUST be performed in a separate Google Cloud project from production, using deployment environments that carry no production traffic.
Rationale	Testing an agent means driving it with realistic input against realistic tools, and in a shared project that means the test agent inherits the production service agent's reach into production backends. Deployment environments separate versions within a project but do not separate the identity that tools execute as, so the environment feature alone does not create the boundary.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Non-production projects should carry synthetic conversation data rather than copies of member conversations. This is also where the pre-release v1beta and v1alpha1 API surfaces belong, since evaluation capabilities that are only offered there can be exercised without placing production traffic on an unsupported API version.

ID	SG-GCP-GECX-000560.0
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api
Mappings	HIPAA: 164.308(a)(4)(ii)(B) (Access Authorization), 164.502(a) (Uses and Disclosures of PHI); NIST 800-53: CM-2 (Baseline Configuration), SC-7 (Boundary Protection), AC-4 (Information Flow Enforcement), SA-11 (Developer Testing and Evaluation); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000570.0
Requirement	Traffic splitting MUST NOT direct production conversations to an agent version that has not completed security review and evaluation.
Rationale	Traffic splitting was announced in the CX Agent Studio release notes on July 1, 2026 and divides user conversations in a deployment channel across several agent application versions by percentage. Google presents it both for A/B testing and to "safely deploy updates in stages", so it acts as a release control as well as an experimentation control, and it will place real member conversations on whatever version a split names, reviewed or not. The split is configured on the deployment resource rather than in the agent definition, so reviewing the agent alone does not reveal it.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Require that every version participating in a split has passed review and evaluation, so the split decides how much traffic a version receives rather than whether an unreviewed version receives any. Split changes are UpdateDeployment calls, which Google logs as Data Access (DATA_WRITE) audit events rather than Admin Activity, so Data Access audit logging must be enabled for ces.googleapis.com before split changes can be alerted on. The traffic-splitting documentation configures splits through the v1beta API and the release note does not state a launch stage; confirm the stage before relying on the capability for production releases.

ID	SG-GCP-GECX-000570.0
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/traffic-split ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging
Mappings	NIST 800-53: CM-3 (Configuration Change Control), CM-4 (Impact Analyses), SA-11 (Developer Testing and Evaluation), AU-2 (Event Logging); HITRUST CSF v11: 10.k (Change Control Procedures), 09.aa (Audit Logging)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000580.0
Requirement	Third-party platforms that carry member conversations to or from a deployment channel - contact center providers such as AudioCodes, Five9, SecureCo, and Twilio, messaging platforms such as WhatsApp and Instagram, and any comparable intermediary - MUST have completed a third-party security assessment and, where they process ePHI, be covered by an executed business associate agreement.
Rationale	These platforms carry the full audio and text of member conversations between the member and the agent, which places them squarely in the ePHI path as business associates. Google's BAA covers Google Cloud services; it does not extend to a telephony, CCaaS, or messaging provider the organization contracts with separately, so the contractual chain has a gap unless the organization closes it directly.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Assess the recording, retention, and subprocessor posture of each provider, not only its transport encryption, because these platforms frequently retain their own copy of call audio on their own schedule. Confirm which party holds the recording of record and where it is stored, since that copy is outside every Google Cloud control applied to the agent.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy ; https://cloud.google.com/security/compliance/hipaa ; https://cloud.google.com/terms/hipaa-baa ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/secureco ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/whatsapp
Mappings	HIPAA: 164.308(b)(1) (Business Associate Contracts), 164.314(a) (Business Associate Contracts or Other

ID	SG-GCP-GEEX-000580.0
	Arrangements), 164.502(e) (Disclosures to Business Associates); NIST 800-53: SA-9 (External System Services), SR-3 (Supply Chain Controls and Processes), CA-3 (Information Exchange), RA-3 (Risk Assessment); HITRUST CSF v11: 05.i (Identification of Risks Related to External Parties), 05.k (Addressing Security in Third Party Agreements)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GEEX-000590.0
Requirement	Direct API access to deployed agent applications MUST be routed through the organization's API gateway rather than exposed to callers as a direct Google endpoint.
Rationale	The API channel is a conversational inference endpoint reachable by anything holding a token permitted to call runSession. The product's native controls at that boundary are project-scoped rather than per-caller: quotas such as RunSession LLM tokens per minute apply per project, base model, and region and are shared across all applications in the project; RunSession calls are recorded as Data Access audit events once those logs are enabled; and guardrails screen model input and output for content rather than authorizing callers. None of these distinguishes one API client from another, so fronting the channel with the gateway is what provides per-caller throttling, per-caller authorization policy, and request-level logging tied to the calling integration.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	The gateway is also the enforcement point for any per-caller authorization the backend cannot express, and its access logs are the only record of API-channel conversations that exists independently of Google's own logging. Apply the same rate limits to internal callers as to external ones - a runaway internal integration produces the same cost and the same load. Inbound A2A invocation, where the A2A Protocol is enabled, is a direct call to the same Google endpoint by a principal holding the Client role and falls under this requirement.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/api-access ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/quotas ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/guardrail ;

ID	SG-GCP-GECX-000590.0
	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/a2a-protocol
Mappings	HIPAA: 164.312(a)(1) (Access Control), 164.312(e)(1) (Transmission Security); NIST 800-53: SC-7 (Boundary Protection), AC-3 (Access Enforcement), SC-5 (Denial-of-service Protection), AU-2 (Event Logging); HITRUST CSF v11: 09.m (Network Controls); OWASP LLM Top 10 2025: LLM10 (Unbounded Consumption); OWASP API Top 10 2023: API4 (Unrestricted Resource Consumption), API2 (Broken Authentication)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000600.0
Requirement	Voice channels MUST present a recording and automated-interaction disclosure to the member before conversation content is captured.
Rationale	Where audio recording, conversation logging, or CX Insights ingestion is enabled on a voice channel, call audio or its transcript is captured and retained: CX Agent Studio routes raw audio to a customer-owned Cloud Storage bucket when audio recording is configured, and CX Insights ingests call audio and transcripts for analysis. Recording consent is governed by state law, with two-party consent jurisdictions imposing the stricter standard, so the disclosure has to be delivered before capture begins rather than alongside it.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	The disclosure must cover both recording and the automated nature of the agent, and it must be spoken on voice channels rather than assumed from a web page. Where a third-party platform plays the disclosure, confirm that it does so before audio reaches Google Cloud, not after. The legal basis is state wiretap and call-recording law rather than the HIPAA Privacy Rule; confirm the applicable jurisdictions and the disclosure wording with counsel.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/common-integrations ; https://docs.cloud.google.com/gemini-enterprise-cx/insights ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history
Mappings	NIST 800-53: PT-4 (Consent), PT-5 (Privacy Notice), PT-2 (Authority to Process Personally Identifiable Information); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)
Detective Policies	

ID	SG-GCP-GECX-000600.0
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001300.0
Requirement	Quota caps and cost alerting MUST be configured for every agent application exposed on a public or high-volume deployment channel.
Rationale	An agent application is a metered generative inference endpoint, and the web widget can be configured for anonymous public access. An attacker, a misconfigured integration, or a runaway retry loop consumes model capacity and incurs cost at a rate bounded only by the platform's own quotas, and the failure is financial and availability-affecting before it is ever a confidentiality problem. The organization's API gateway constrains the API channel but sits nowhere in the path of the web widget or the telephony connections.
Estimated Security Value	Med
Estimated Operational Impact	Med
Audit Procedures	
Notes	CX Agent Studio quotas apply per project, region, and base model and are shared across all applications in the project, so a ceiling for one channel requires placing high-exposure channels - the public widget in particular - in their own project. Alert on rate of spend rather than absolute spend so a change in pattern surfaces within hours rather than at the end of the billing period. Origin checks and reCAPTCHA reduce the frequency of automated abuse on the widget but place no ceiling on it.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/web-widget ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/quotas
Mappings	NIST 800-53: SC-5 (Denial-of-service Protection), SI-4 (System Monitoring), CM-6 (Configuration Settings), CP-2 (Contingency Plan); OWASP LLM Top 10 2025: LLM10 (Unbounded Consumption); OWASP API Top 10 2023: API4 (Unrestricted Resource Consumption)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001400.0
Requirement	WhatsApp and Instagram deployments MUST NOT be created for any Gemini Enterprise for CX agent application.

ID	SG-GCP-GECX-001400.0
Rationale	Google documents that only owners of the associated project can create a WhatsApp or Instagram deployment, so the channel cannot be enabled without the basic Owner role, which carries every permission in the project and which this guide prohibits on projects hosting the suite. The channel also routes member conversations through Meta, a messaging platform outside Google Cloud and outside Google's BAA, and the deployment page describes connecting Meta business assets without saying how Meta processes or retains the conversation content.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Lift this prohibition only when Google documents a creation path that does not need the Owner role, Meta has completed a third-party security assessment and, where member PHI would cross the channel, is covered by an executed business associate agreement, and the channel has been added to the deployment channel inventory with an approving owner. Check existing projects for WhatsApp and Instagram deployments at each review, because the option appeared in the console on 2026-09-24.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/whatsapp ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes ; https://cloud.google.com/iam/docs/roles-overview ; https://cloud.google.com/security/compliance/hipaa
Mappings	HIPAA: 164.308(b)(1) (Business Associate Contracts), 164.502(e) (Disclosures to Business Associates), 164.312(a)(1) (Access Control); NIST 800-53: CM-7 (Least Functionality), AC-6 (Least Privilege), SA-9 (External System Services), CA-3 (Information Exchange); HITRUST CSF v11: 01.c (Privilege Management), 05.k (Addressing Security in Third Party Agreements)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

Agent Assist & Human Agent Support

ID	SG-GCP-GECX-000610.0
Requirement	Customer-managed encryption keys MUST be initialized for Agent Assist before it processes any production conversation.
Rationale	Agent Assist maintains its own CMEK initialization separate from CX Agent Studio and CX Insights, so a project can be fully CMEK-covered on two components and unprotected on the third. Agent Assist holds live conversation transcripts,

ID	SG-GCP-GECX-000610.0
	generated summaries, and knowledge excerpts, which is the same class of content the other two components protect.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Immutable at first use: Google states "You cannot change encryption key settings for a location once it has been specified" and that a project already holding Agent Assist data in a location cannot have a key added for that location. Initialize through the InitializeEncryptionSpec API and grant Cloud KMS CryptoKey Encrypter/Decrypter to service-PROJECT_NUMBER@gcp-sa-ccai-cmek.iam.gserviceaccount.com. Coverage is not total: Google states "CMEK is not available for features that are disabled in Agent Assist locations and smart reply", so Smart Reply data is outside the customer-key boundary even in a fully CMEK-configured project. Record that exclusion in the data flow record and weigh it when deciding whether Smart Reply is enabled at all.
References	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/cmek ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/cmek ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/cmek
Mappings	HIPAA: 164.312(a)(2)(iv) (Encryption and Decryption); NIST 800-53: SC-28 (Protection of Information at Rest), SC-28(1) (Cryptographic Protection), SC-12 (Cryptographic Key Establishment and Management); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information), 10.g (Key Management)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000620.0
Requirement	Sensitive Data Protection redaction MUST be configured for Agent Assist conversation data using an inspect template and a deidentify template.
Rationale	Agent Assist operates on live conversation content in which members state identifiers, conditions, and payment details conversationally rather than in structured fields. Redaction configured through DLP templates is the mechanism that scrubs those values before persistence, and without it the raw utterance is what is stored, analyzed, and later exported.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Redaction fails open and is bound per conversation profile, not per project: Google states "You must specify the security settings to apply for each conversation profile" and that

ID	SG-GCP-GECX-000620.0
	without them "Agent Assist doesn't apply any redaction for that conversation profile." Security settings are configured per project and location but take effect only where attached, so verify by enumerating every conversation profile and confirming an attachment on each; a project can hold both templates and still store unredacted transcripts. The inspect template defines what counts as sensitive data and the deidentify template how it is masked or removed; tune both against real transcripts, since contact center language differs from the text DLP detectors are calibrated on. Google documents that Sensitive Data Protection templates outside the VPC Service Controls perimeter cause redaction failures for CX Agent Studio; Agent Assist behaviour is undocumented, so keep its templates in the same perimeter.
References	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/data-redaction-retention ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls
Mappings	HIPAA: 164.502(b) (Minimum Necessary), 164.312(a)(1) (Access Control); NIST 800-53: SC-7 (Boundary Protection), SC-7(10) (Prevent Exfiltration), SI-19 (De-identification), AC-4 (Information Flow Enforcement); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000630.0
Requirement	Agent Assist conversation data retention MUST be configured to the shortest period that meets a documented business need.
Rationale	Google documents that Agent Assist security settings carry a retention_window_days value and that "The default and maximum retention window is 30 days." Because the product caps retention at 30 days, the exposure is bounded in time, unlike stores that keep conversations indefinitely unless an expiry is set; the residual risk is that the default sits at the ceiling, so unless a shorter value is chosen deliberately every conversation's transcripts and suggestions are kept for the longest period the product allows.
Estimated Security Value	Med
Estimated Operational Impact	Low
Audit Procedures	
Notes	Set retention deliberately against a stated business and records-retention rationale, using retention_window_days in the project-and-location security settings. Thirty days is a ceiling rather than a starting point, so confirm that quality review, dispute resolution, and any downstream export can operate inside the chosen window. A business need longer than 30 days cannot be met by changing this setting and

ID	SG-GCP-GEEX-000630.0
	must be met by exporting to a store the organization controls, which then carries its own retention obligation.
References	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/data-redaction-retention
Mappings	HIPAA: 164.502(b) (Minimum Necessary); NIST 800-53: SI-12 (Information Management and Retention), MP-6 (Media Sanitization); HITRUST CSF v11: 06.c (Protection of Organizational Records)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GEEX-000640.0
Requirement	Generated conversation summaries MUST be reviewed by the human representative before they are committed to a system of record.
Rationale	A summarization model produces a fluent account of the conversation whether or not it captured the material facts, and it may omit a commitment made to the member or attribute a statement to the wrong party. Once a summary is written into a case, a claim note, or a service record, it becomes the organization's account of the interaction and is relied on by every downstream reader.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	The reviewing representative needs the transcript alongside the summary and a genuine ability to edit it, not merely to accept it. Writing a summary to a system of record without representative review is outside this requirement; if a business case for it arises, treat it as a documented exception approved by the record owner, with the summaries labeled as machine-generated in the record.
References	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/summarization-with-custom-sections ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist
Mappings	HIPAA: 164.312(c)(1) (Integrity); NIST 800-53: SI-10 (Information Input Validation), SI-15 (Information Output Filtering), AU-3 (Content of Audit Records); HITRUST CSF v11: 06.c (Protection of Organizational Records); OWASP LLM Top 10 2025: LLM09 (Misinformation)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000650.0
Requirement	Smart Reply, AI coach, and other generated response suggestions MUST NOT be transmitted to a member without an affirmative action by the human representative.
Rationale	Smart Reply surfaces suggested responses calculated by a custom model trained on the organization's own conversation data, and AI coach uses a large language model to suggest how the representative should respond. A suggestion that is accurate in most cases will be wrong in some. Auto-sending removes the only check in the path, and the resulting message reaches the member carrying the organization's authority with no one having read it.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Affirmative means a deliberate send action, not a timeout that sends by default and not a single click that both accepts and transmits without displaying the text. Confirm the behavior in the deployed UI module rather than in the product description, because the integration layer determines what the representative actually sees.
References	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/smart-reply ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/ai-coach-overview ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist
Mappings	HIPAA: 164.502(a) (Uses and Disclosures of PHI), 164.312(c) (1) (Integrity); NIST 800-53: SI-15 (Information Output Filtering), AC-3 (Access Enforcement), SI-10 (Information Input Validation); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information); OWASP LLM Top 10 2025: LLM06 (Excessive Agency); OWASP Agentic Top 10 2026: ASI09 (Human-Agent Trust Exploitation)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000660.0
Requirement	Knowledge bases used by Knowledge Assist and Generative Knowledge Assist MUST be scoped to content the entire representative population is authorized to see.
Rationale	Knowledge Assist surfaces excerpts from the configured knowledge base directly in the representative's workspace during a live call. Google documents metadata document filters (a SearchConfig in the knowledge search request) that narrow what generative knowledge assist retrieves, but the filter is part of the request the integration sends, and Google does not describe it as bound to the representative's identity, so it is not an authorization boundary. Any document in the corpus is therefore potentially visible to every representative

ID	SG-GCP-GECX-000660.0
	the moment a conversation makes it relevant, regardless of the access controls that governed it in its original location.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Review the corpus against the representative population rather than against the author's intent. Material scoped to clinical staff, legal, or a specific business unit does not belong in a general contact center knowledge base, and its presence there is a disclosure that no access review of the source system will detect. Content restricted to a narrower audience must be excluded from the corpus entirely; metadata filters can reduce irrelevant results but do not enforce who may see a document.
References	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/generative-knowledge-assist ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/ka-filters ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist
Mappings	HIPAA: 164.312(a)(1) (Access Control), 164.502(b) (Minimum Necessary); NIST 800-53: AC-3 (Access Enforcement), AC-21 (Information Sharing), AC-6 (Least Privilege), AC-4 (Information Flow Enforcement); HITRUST CSF v11: 01.v (Information Access Restriction)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000670.0
Requirement	Live translation output MUST NOT be relied upon as the authoritative record of a member interaction.
Rationale	Agent Assist live audio-to-audio translation, a limited-access private GA feature, translates speech between the member and the representative in real time and synthesizes the translated response for the other party. Machine translation of a conversation about benefits, coverage, or clinical detail can invert meaning in ways neither party detects, because neither participant hears both languages. If only the translated side is retained, the organization holds no record of what the member actually said and cannot reconstruct the interaction in a dispute or a grievance.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Retain the source-language audio or transcript alongside the translation and mark translated turns, so the interaction can be reconstructed in a dispute. Where the interaction determines a benefit or a clinical pathway, a qualified human interpreter remains the appropriate mechanism, and language

ID	SG-GCP-GEEX-000670.0
	access obligations are not satisfied by a machine translation feature. The overview page does not describe what is retained from a translated conversation; confirm with Google before enablement.
References	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/live-a2a-translation-overview ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist
Mappings	HIPAA: 164.312(c)(1) (Integrity); NIST 800-53: SI-10 (Information Input Validation), AU-3 (Content of Audit Records), SI-12 (Information Management and Retention); HITRUST CSF v11: 06.c (Protection of Organizational Records); OWASP LLM Top 10 2025: LLM09 (Misinformation)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GEEX-000680.0
Requirement	Agent Assist deployments MUST be pinned to a region consistent with the organization's data residency position, with per-feature residency coverage verified before enablement.
Rationale	Agent Assist maintains its own regionalization documentation separate from CX Agent Studio's two multi-regions and CX Insights' region list, which means the three components can be pinned inconsistently and produce a data path that crosses a boundary the organization believes it has closed. Agent Assist also documents several features whose processing or storage does not follow the regional pin.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Configure regionalization through the API only, since "The Agent Assist console doesn't support regionalization." Record the region, the per-feature availability table, and these documented exceptions as certification evidence before enablement. (1) Vertex AI does not support the us multi-region, so generative features pinned to us use the existing US single-region endpoints. (2) The AI/ML data location commitment applies only in US and EU locations and not to non-AI/ML data in use or in transit, so residency is an at-rest guarantee. (3) Model training does not support regionalization and may route data outside the region, affecting features trained on the organization's conversations such as Smart Reply. (4) Data stores for generative knowledge assist are supported only in global, us, and eu. (5) Grounding with Google Search does not support data residency. (6) Preview Gemini Transcribe Live remaps traffic to the Vertex AI global region, moving live audio outside any regional pin.

ID	SG-GCP-GEEX-000680.0
References	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/regionalization ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/region ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/regionalization ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/gemini-transcribe-live
Mappings	HIPAA: 164.308(a)(1)(ii)(B) (Risk Management); NIST 800-53: SA-9(5) (Processing, Storage, and Service Location), AC-4 (Information Flow Enforcement), CM-6 (Configuration Settings), SC-7 (Boundary Protection), SA-9 (External System Services); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information), 09.s (Information Exchange Policies and Procedures)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GEEX-000690.0
Requirement	Where Agent Assist data about identified human representatives - for example, AI coach suggestion usage or conversations passed to CX Insights for Quality AI scoring - is used to evaluate representative performance, that evaluation MUST be governed by the organization's employee monitoring and workforce policy before enablement.
Rationale	AI coach suggests how a representative should respond; it does not itself score the representative. Evaluation arises when Agent Assist conversations and suggestion interactions are attributed to named representatives and fed into performance processes, most directly through Quality AI, which Google describes as automating conversation scoring "to more accurately evaluate agent performance", and its agent engagement platform, which summarizes an individual agent's performance. That is continuous algorithmic evaluation of identified employees, which carries notice obligations, consultation expectations in some jurisdictions, and a fairness and contestability obligation that sits outside the security review.
Estimated Security Value	Med
Estimated Operational Impact	Med
Audit Procedures	
Notes	Confirm before enablement who can see an individual's scores, how long they are retained, whether they feed employment decisions, and what the appeal path is. This control covers the Agent Assist side of the data flow; the Quality AI scorecards and assessments built in CX Insights need the same workforce-policy approval, and one approval can satisfy both when it names both data sources. The agent engagement platform is Preview. The technical controls protecting the conversation data say nothing about the

ID	SG-GCP-GECX-000690.0
	appropriateness of the evaluation built on top of it, which is a separate approval.
References	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/ai-coach-overview ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/qai-overview ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/agent-engagement ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist
Mappings	NIST 800-53: PT-2 (Authority to Process Personally Identifiable Information), PT-5 (Privacy Notice), AC-3 (Access Enforcement), SI-12 (Information Management and Retention); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001320.0
Requirement	The Agent Assist Build your own assist capability MUST NOT be enabled while it is designated Preview.
Rationale	Google's Agent Assist regional feature table lists Build your own assist with an explicit Preview marker alongside generally available capabilities such as summarization, sentiment analysis and AI coach. The capability builds custom assistance surfaces over live member conversation, so it operates on the same content as the generally available features while carrying the Pre-GA Offerings Terms: no SLA, changeable or discontinued without notice, and no data processing terms, with Google stating that customers should not use Pre-GA Offerings to process data subject to regulatory compliance requirements.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	The Preview marker appears in the Agent Assist regional feature table alongside generally available features, and Google's HIPAA guidance says "Do not use Pre-GA offerings ... in connection with PHI, unless expressly noted otherwise in a notice or other terms of the offering." Re-check the marker at each release-note review and lift the prohibition only when the feature table or release notes show general availability.
References	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/regionalization ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist ; https://cloud.google.com/terms/service-terms ; https://cloud.google.com/security/compliance/hipaa
Mappings	HIPAA: 164.308(a)(8) (Evaluation), 164.308(b)(1) (Business Associate Contracts), 164.314(a) (Business Associate

ID	SG-GCP-GECX-001320.0
	Contracts or Other Arrangements); NIST 800-53: CM-7 (Least Functionality), CM-3 (Configuration Change Control), SA-4 (Acquisition Process); HITRUST CSF v11: 05.k (Addressing Security in Third Party Agreements)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	
ID	SG-GCP-GECX-001350.0
Requirement	Gemini Transcribe Live MUST NOT be enabled in any Agent Assist conversation profile while it is designated Preview.
Rationale	Google announced Gemini Transcribe Live for Agent Assist in Preview on 2026-09-01, under the Pre-GA Offerings Terms. It transcribes live conversation audio and, to support all Agent Assist regions, remaps that traffic to the Vertex AI supported global region, so enabling it sends member audio outside the regional pin and onto a path with no production SLA and no assurance of compliance coverage.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	The capability is enabled by setting use_gemini_asr in the speech-to-text configuration of a conversation profile. Check every conversation profile for that setting at deployment review, and alert on conversation profile changes. Reassess when the capability reaches GA, including whether the global-region remap persists.
References	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/release-notes ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/gemini-transcribe-live ; https://cloud.google.com/terms/service-terms ; https://cloud.google.com/security/compliance/hipaa
Mappings	HIPAA: 164.308(a)(8) (Evaluation), 164.308(b)(1) (Business Associate Contracts), 164.314(a) (Business Associate Contracts or Other Arrangements); NIST 800-53: CM-7 (Least Functionality), SA-9 (External System Services), SA-9(5) (Processing, Storage, and Service Location), CM-3 (Configuration Change Control), SA-4 (Acquisition Process); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

Conversation Analytics & Insights

ID	SG-GCP-GECX-000700.0
Requirement	The CX Insights encryption specification MUST be initialized with a customer-managed key for every location before any conversation is ingested into that location.
Rationale	Google states plainly that you cannot change encryption key settings for a location after that location has been enabled for CMEK, and that a project already containing CX Insights data cannot be configured for customer-managed keys retroactively. This is the single most consequential irreversible decision in the suite: getting it wrong means every conversation in that location is encrypted under Google-managed keys permanently, and the only remedy is a new project.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Initialize through the InitializeEncryptionSpec API before the first ingestion, including before any proof-of-concept upload. Create the Insights service identity first (gcloud beta services identity create --service=contactcenterinsights.googleapis.com), then grant Cloud KMS CryptoKey Encrypter/Decrypter to <code>service-PROJECT_NUMBER@gcp-sa-ccai-cmek.iam.gserviceaccount.com</code>. CX Agent Studio manages its keys through the Conversational Insights API, and conversation history logged by CX Agent Studio is stored for CX Insights, so the first logged test conversation from an agent application may count as CX Insights data for that location; initialize the specification before any agent testing with conversation logging enabled. CMEK is not available for the <code>global</code> location, which is a further reason to pin a specific region rather than accepting the default endpoint. Google warns that if the key is revoked for more than 30 days, the Insights data encrypted by that key will be lost.
References	https://docs.cloud.google.com/gemini-enterprise-cx/insights/cmek ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/regionalization ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/cmek ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history
Mappings	HIPAA: 164.312(a)(2)(iv) (Encryption and Decryption); NIST 800-53: SC-28 (Protection of Information at Rest), SC-28(1) (Cryptographic Protection), SC-12 (Cryptographic Key Establishment and Management), CM-6 (Configuration Settings); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information), 10.g (Key Management)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000710.0
Requirement	A project-level <code>conversation_ttl</code> MUST be configured in CX Insights before the first conversation is ingested.
Rationale	Google documents that a conversation not set to expire remains in CX Insights indefinitely, and that project-level TTL only applies to conversations created after the TTL is set - changing it does not retroactively change the expiration of existing conversations. Conversations ingested during a pilot before anyone set a TTL therefore persist until someone locates and deletes them explicitly.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Set the TTL as part of project initialization alongside the encryption specification, not as a later hardening step. Where both <code>expire_time</code> and <code>ttl</code> are set on a conversation, <code>expire_time</code> wins. Deletion occurs 24 hours after the expiration time and is not recoverable, so validate the value against the records-retention schedule before ingestion begins rather than after. Conversations that predate the TTL can be removed with the bulk delete method, which selects conversations by filter.
References	https://docs.cloud.google.com/gemini-enterprise-cx/insights/ttl ; https://docs.cloud.google.com/gemini-enterprise-cx/insights ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/reference/rest/v1/projects.locations.conversations/bulkDelete
Mappings	HIPAA: 164.502(b) (Minimum Necessary); NIST 800-53: SI-12 (Information Management and Retention), MP-6 (Media Sanitization), CM-6 (Configuration Settings); HITRUST CSF v11: 06.c (Protection of Organizational Records)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000720.0
Requirement	Sensitive Data Protection redaction MUST be applied on every CX Insights ingestion path before production conversations are imported - through RedactionConfig for upload and ingest paths, and in the upstream Agent Assist or CX Agent Studio configuration for runtime integrations.
Rationale	CX Insights persists complete conversation transcripts and runs machine learning analysis over them, producing sentiment scores, entities, topics, and assessments that are themselves derived from the raw content. Redaction at ingestion is the control that prevents identifiers entering that corpus in the first place, and every derived artifact inherits whatever was or was not redacted at that moment.
Estimated Security Value	High

ID	SG-GCP-GEEX-000720.0
Estimated Operational Impact	Med
Audit Procedures	
Notes	Configure RedactionConfig with a DLP inspect template and deidentify template. Google documents that these settings "are applied to conversations ingested from the UploadConversation and IngestConversations endpoints, including conversation coming from CCAI Platform" and "are not applied to conversations ingested from the CreateConversation endpoint or the Dialogflow / Agent Assist runtime integrations", where redaction is performed in Dialogflow or Agent Assist instead. Inventory every ingestion path, confirm the redaction mechanism for each, and verify with a test conversation containing synthetic identifiers that they are absent from the stored transcript before enabling production ingestion.
References	https://docs.cloud.google.com/gemini-enterprise-cx/insights/reference/rest/v1/RedactionConfig ; https://docs.cloud.google.com/gemini-enterprise-cx/insights ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/data-redaction-retention
Mappings	HIPAA: 164.502(b) (Minimum Necessary); NIST 800-53: SC-7 (Boundary Protection), SC-7(10) (Prevent Exfiltration), SI-19 (De-identification), AC-4 (Information Flow Enforcement); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GEEX-000730.0
Requirement	Project-level CX Insights access - <code>roles/contactcenterinsights.viewer</code> , <code>roles/contactcenterinsights.editor</code> , and <code>roles/contactcenterinsights.admin</code> granted directly, and the same access inherited through any CX Agent Studio role (<code>roles/ces.*</code>) - MUST be held only by a named, minimal, documented group.
Rationale	Fine-grained access control through authorized views is Pre-GA, so there is no supported way to restrict an analyst to a subset of conversations. Every holder of project-level CX Insights access therefore sees every conversation in the project, which for a contact center deployment is the complete corpus of member interactions. Google's CX Agent Studio access-control page shows that the Viewer role (<code>roles/ces.viewer</code>) has the CX Insights Viewer role (<code>roles/contactcenterinsights.viewer</code>) as a base role and is itself the base of every CX Agent Studio editor role, and that the Admin role (<code>roles/ces.admin</code>) includes the CX Insights Admin role, so every agent builder holds conversation read access unless builder access is itself restricted.

ID	SG-GCP-GECX-000730.0
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Enumerate effective access rather than direct grants: include every principal holding a roles/ces.* role in the project as well as direct CX Insights grants. Where agent builders do not need conversation access, develop agents in a project that holds no production conversations. Because the finer boundary does not exist in a supported form, the compensating controls are the size of the group and the visibility of its activity: keep the group small and named, review it quarterly, and rely on Data Access audit logging to record who read what. State the residual risk explicitly in the certification rather than implying a per-conversation boundary that the product does not provide.
References	https://docs.cloud.google.com/gemini-enterprise-cx/insights/best-practices-for-fine-grained-access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/release-notes ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/audit-logging ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/iam/docs/roles-permissions/ces
Mappings	HIPAA: 164.312(a)(1) (Access Control), 164.308(a)(4) (Information Access Management), 164.502(b) (Minimum Necessary); NIST 800-53: AC-3 (Access Enforcement), AC-6 (Least Privilege), AC-2 (Account Management), AU-2 (Event Logging); HITRUST CSF v11: 01.c (Privilege Management), 01.v (Information Access Restriction)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000740.0
Requirement	CX Insights authorized views MUST NOT be applied to conversation data containing PHI while the capability is Pre-GA, or configured with an empty filter expression in any project.
Rationale	Authorized views are Pre-GA, and Google's HIPAA guidance says "Do not use Pre-GA offerings ... in connection with PHI, unless expressly noted otherwise in a notice or other terms of the offering." Google also warns directly that empty filters or an empty string allow unrestricted access. An authorized view with an empty filter looks like a scoping control in the IAM policy and in any access review, while granting exactly the access it appears to constrain - a failure mode that is invisible precisely because the mechanism appears to be present.
Estimated Security Value	High
Estimated Operational Impact	Low

ID	SG-GCP-GECX-000740.0
Audit Procedures	
Notes	Evaluate authorized views in a project holding synthetic or non-PHI conversations until the capability is generally available. Google also warns that granting authorized view set permissions at the project level results in users having access to all authorized view sets, which defeats the mechanism a second way. Grant on the specific view or view set, never at project level, and use the <code>agent_id</code> field for representative and team scoping. Authorized views cannot import or edit conversation data, train topic models, or create scorecards, so they do not replace the project-level roles for those tasks.
References	https://docs.cloud.google.com/gemini-enterprise-cx/insights/best-practices-for-fine-grained-access-control ; https://cloud.google.com/security/compliance/hipaa
Mappings	HIPAA: 164.312(a)(1) (Access Control); NIST 800-53: AC-3 (Access Enforcement), AC-6 (Least Privilege), CM-6 (Configuration Settings), AC-4 (Information Flow Enforcement); HITRUST CSF v11: 01.v (Information Access Restriction)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000750.0
Requirement	The CX Insights global endpoint MUST NOT be used for production conversation data.
Rationale	Google documents that CX Insights uses the legacy location ID <code>us-central1</code> for the global endpoint and that CMEK is not available for the <code>global</code> location. Using it therefore forfeits customer-managed encryption entirely while presenting no visible indication that it has done so, because the hostname carries no region and the default client configuration reaches it.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Both the endpoint host and the resource location path must be changed together - Google states you need to change both the host of the URL and the resource location to use the regional instance. Google does not document what happens when only one is changed; treat a mismatch as a misconfiguration. In Python clients this means setting the <code>ClientOptions api_endpoint</code> and updating the parent parameter; verify both in code review rather than in configuration documentation.
References	https://docs.cloud.google.com/gemini-enterprise-cx/insights/regionalization ;

ID	SG-GCP-GECX-000750.0
	https://docs.cloud.google.com/gemini-enterprise-cx/insights/cmek
Mappings	HIPAA: 164.312(a)(2)(iv) (Encryption and Decryption); NIST 800-53: SA-9(5) (Processing, Storage, and Service Location), SC-28 (Protection of Information at Rest), CM-6 (Configuration Settings), AC-4 (Information Flow Enforcement), SA-9 (External System Services); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000760.0
Requirement	Cloud Storage buckets holding conversation audio for CX Insights MUST be encrypted with customer-managed keys, located in the approved region, and placed inside the service perimeter.
Rationale	Call audio is the richest single artifact in this suite: it carries the member's voice, everything they said before any redaction was applied, and background context that no transcript captures. It lands in a customer-owned Cloud Storage bucket whose security posture is entirely the organization's responsibility and is governed by none of the CX Insights settings.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Where VPC Service Controls protects CX Agent Studio, Google documents that audio recordings cannot be written to Cloud Storage buckets outside the perimeter, so perimeter membership is a functional requirement for that path as well as a hardening one. Set a Cloud KMS key as the bucket default key so objects written by the service are encrypted with it; Google documents that "By default, objects in a bucket use the bucket default key." Apply a lifecycle policy consistent with the conversation TTL, since the bucket has no relationship to the CX Insights expiry and will otherwise retain audio after the analyzed conversation is gone.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/common-integrations ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/cmek ; https://cloud.google.com/storage/docs/encryption/customer-managed-keys
Mappings	HIPAA: 164.312(a)(2)(iv) (Encryption and Decryption); NIST 800-53: SC-28 (Protection of Information at Rest), SC-28(1) (Cryptographic Protection), SC-7 (Boundary Protection), SI-12

ID	SG-GCP-GECX-000760.0
	(Information Management and Retention); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information), 06.c (Protection of Organizational Records)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	
ID	SG-GCP-GECX-000770.0
Requirement	Cloud Speech-to-Text MUST be configured with customer-managed encryption keys where it transcribes conversation audio for CX Insights or Agent Assist.
Rationale	Google states directly that features involving external data transfer need separate CMEK configuration in the corresponding services, naming Cloud Speech-to-Text for audio transcription. Speech-to-Text is a distinct service with its own encryption configuration, so a fully CMEK-covered CX Insights deployment still passes every second of member audio through a transcription service under Google-managed keys unless it is configured separately.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	This is one of the most easily missed gaps in the suite because the transcription step is invisible in the CX Insights console - it appears as a transcript that simply exists. Include Speech-to-Text in the CMEK inventory and in the perimeter, and verify coverage by inspecting the service configuration rather than inferring it from the CX Insights encryption specification. Agent Assist conversation profiles can select the Gemini Transcribe Live model, which Google describes as using "the Gemini model for Speech-to-Text API"; record in the CMEK inventory which transcription model each conversation profile uses.
References	https://docs.cloud.google.com/gemini-enterprise-cx/insights/cmek ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/common-integrations ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/gemini-transcribe-live
Mappings	HIPAA: 164.312(a)(2)(iv) (Encryption and Decryption); NIST 800-53: SC-28 (Protection of Information at Rest), SC-28(1) (Cryptographic Protection), SC-12 (Cryptographic Key Establishment and Management), AC-4 (Information Flow Enforcement); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information), 10.g (Key Management)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000780.0
Requirement	BigQuery datasets receiving the CX Insights conversation export MUST be encrypted with customer-managed keys, located in the approved region, and placed inside the service perimeter.
Rationale	Google states that BigQuery needs its own CMEK configuration for conversation exports. The export is a full copy of analyzed conversation content in a general-purpose analytics store governed by BigQuery IAM rather than by CX Insights roles, which means the carefully limited CX Insights access group has no bearing on who can query the exported copy.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Reconcile the BigQuery dataset's IAM against the approved CX Insights access group - a broader BigQuery grant silently widens access to the same conversation content. Google does not document whether deleting a conversation in CX Insights removes its exported row; assume it does not, and apply a table expiration or partition expiration consistent with the conversation TTL.
References	https://docs.cloud.google.com/gemini-enterprise-cx/insights/cmek ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls ; https://docs.cloud.google.com/gemini-enterprise-cx/insights ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/export
Mappings	HIPAA: 164.312(a)(1) (Access Control), 164.312(a)(2)(iv) (Encryption and Decryption); NIST 800-53: SC-28 (Protection of Information at Rest), AC-3 (Access Enforcement), SC-7 (Boundary Protection), SI-12 (Information Management and Retention); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information), 01.v (Information Access Restriction)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000790.0
Requirement	CX Insights Pub/Sub notifications for triggers whose message data is a Conversation resource - create-conversation and update-conversation, including when all events are selected - MUST NOT be routed to a topic whose subscribers are not approved to receive member conversation content.
Rationale	Google documents that for the create-conversation and update-conversation triggers the Pub/Sub message data is the Conversation itself, while the other triggers carry an operation name. The notification payload is not configurable, so the only controls are which triggers are enabled and who can subscribe, and subscribers are governed by Pub/Sub IAM

ID	SG-GCP-GECX-000790.0
	rather than by any CX Insights control. A topic carrying conversation resources becomes an uncontrolled distribution channel for member conversation content into systems that were never assessed.
Estimated Security Value	Med
Estimated Operational Impact	Low
Audit Procedures	
Notes	Prefer triggers that carry only an operation name, and have subscribers call back through the CX Insights API, where CX Insights IAM applies, to obtain content. Where a conversation trigger is required, restrict topic and subscription IAM to approved service identities and keep the topic in the approved region and perimeter. Review topic and subscription IAM alongside the CX Insights access review, since a subscription created for an integration project typically outlives it.
References	https://docs.cloud.google.com/gemini-enterprise-cx/insights ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/common-integrations ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/pub-sub
Mappings	HIPAA: 164.312(a)(1) (Access Control), 164.502(a) (Uses and Disclosures of PHI); NIST 800-53: AC-4 (Information Flow Enforcement), AC-3 (Access Enforcement), CA-3 (Information Exchange), SC-7(10) (Prevent Exfiltration), SC-7 (Boundary Protection); HITRUST CSF v11: 09.s (Information Exchange Policies and Procedures)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000800.0
Requirement	The CX Insights Google Sheets integration MUST NOT be used in any project that holds member conversation data.
Rationale	The Sheets integration is Pre-GA, and Google's HIPAA guidance says "Do not use Pre-GA offerings ... in connection with PHI, unless expressly noted otherwise in a notice or other terms of the offering." It moves CX Insights data into a spreadsheet shared with the CX Insights service account and governed by Google Workspace sharing rather than by Google Cloud IAM, and Google's Cloud HIPAA guidance states that HIPAA compliance for Google Workspace is covered separately. A single link change converts a controlled dataset into a broadly shared one, and the copy is beyond the reach of any retention setting, TTL, or deletion request in CX Insights.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	

ID	SG-GCP-GECX-000800.0
Notes	Where analysts need tabular access, direct them to the CMEK-protected BigQuery export inside the perimeter, which retains IAM control and expiration. Aggregate reporting that must reach a spreadsheet is produced from BigQuery through a separate, reviewed process rather than through this integration.
References	https://docs.cloud.google.com/gemini-enterprise-cx/insights ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/google-sheets-integration ; https://cloud.google.com/security/compliance/hipaa
Mappings	HIPAA: 164.312(a)(1) (Access Control), 164.502(a) (Uses and Disclosures of PHI); NIST 800-53: AC-21 (Information Sharing), AC-3 (Access Enforcement), SC-7 (Boundary Protection), SC-7(10) (Prevent Exfiltration), SI-12 (Information Management and Retention); HITRUST CSF v11: 09.s (Information Exchange Policies and Procedures)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000810.0
Requirement	Topic models, scorecards, summarization generators, and other artifacts trained or derived from conversation content MUST be treated as carrying the sensitivity of the source conversations.
Rationale	CX Insights generates a layer of derived artifacts from the conversation corpus - inferred topics, assessment results, trained topic models. These are routinely treated as aggregate analytics and shared more freely than transcripts, but they are computed from member conversation and can retain identifying detail, particularly for rare topics where a category may correspond to a single member.
Estimated Security Value	Med
Estimated Operational Impact	Med
Audit Procedures	
Notes	Apply the same access group, retention, and residency treatment to derived artifacts as to the conversations. Pay particular attention to sparse categories: a topic matching a small number of conversations is effectively a pointer to those members. Aggregation alone does not make an artifact de-identified under HIPAA 164.514(a); treat derived artifacts as protected health information unless that standard has actually been met. Note that authorized views cannot be used to train topic models or create scorecards, so these artifacts are produced with project-level access to the full corpus.
References	https://docs.cloud.google.com/gemini-enterprise-cx/insights ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/best-practices-for-fine-grained-access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/release-notes

ID	SG-GCP-GECX-000810.0
Mappings	HIPAA: 164.502(b) (Minimum Necessary), 164.514(a) (De-identification of PHI); NIST 800-53: AC-3 (Access Enforcement), SI-12 (Information Management and Retention), AC-21 (Information Sharing), SC-28 (Protection of Information at Rest); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000820.0
Requirement	Where Quality AI assessments evaluate identified human representatives, their use MUST be approved under the organization's workforce monitoring policy before enablement.
Rationale	Quality AI produces scorecards and assessments of representative performance from conversation content, which is algorithmic evaluation of identified employees at a scale manual review never reached. That carries notice, retention, and contestability obligations distinct from the security controls protecting the conversation data itself, and assessment results are personnel data with their own access constraints.
Estimated Security Value	Med
Estimated Operational Impact	Med
Audit Procedures	
Notes	Determine before enablement who can see individual scores, how long assessments are retained, whether they inform employment decisions, and how a representative contests one. This control covers Quality AI scorecards, assessments, and the agent engagement platform in CX Insights; the Agent Assist data that feeds them needs the same workforce-policy approval, and one approval can satisfy both when it names both data sources. The agent engagement platform is Preview, and multiple scorecards remains a Preview capability, so any design depending on either rests on a Pre-GA feature.
References	https://docs.cloud.google.com/gemini-enterprise-cx/insights ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/release-notes ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/best-practices-for-fine-grained-access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/agent-engagement
Mappings	NIST 800-53: PT-2 (Authority to Process Personally Identifiable Information), PT-5 (Privacy Notice), AC-3 (Access Enforcement), SI-12 (Information Management and Retention); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)
Detective Policies	

ID	SG-GCP-GECX-000820.0
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000830.0
Requirement	Conversations ingested into CX Insights during pilot or proof-of-concept activity MUST be deleted before the production deployment is certified, unless they were ingested under the full production control set.
Rationale	Pilot conversations are ingested before the controls are finished, which is the point of a pilot. If the encryption specification was not initialized, they are permanently under Google-managed keys; if no TTL was set they persist indefinitely, because the project-level TTL is not retroactive; and if redaction was not configured they hold unredacted member content that every subsequent analysis inherits.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Enumerate and delete pilot conversations explicitly - for example with the bulk delete method and a filter that selects the pilot period - rather than assuming a later TTL will collect them; Google is explicit that changing the TTL does not retroactively change the expiration of existing conversations. Where the encryption specification was not set correctly at pilot time, deleting the conversations does not fix the location, and a new project is the remedy.
References	https://docs.cloud.google.com/gemini-enterprise-cx/insights/ttl ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/cmek ; https://docs.cloud.google.com/gemini-enterprise-cx/insights ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/reference/rest/v1/projects.locations.conversations/bulkDelete
Mappings	HIPAA: 164.502(b) (Minimum Necessary); NIST 800-53: MP-6 (Media Sanitization), SI-12 (Information Management and Retention), CM-3 (Configuration Change Control), SC-28 (Protection of Information at Rest); HITRUST CSF v11: 09.p (Disposal of Media)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

Data Protection & Privacy

ID	SG-GCP-GECX-000840.0
Requirement	CX Agent Studio MUST be CMEK-integrated at project creation, before any agent application or conversation data exists in the project.
Rationale	Google states that existing resources in non-CMEK integrated projects cannot be CMEK integrated retroactively, and recommends that resources be exported and restored in a new project for CMEK. A project that begins without CMEK therefore holds agent instructions, tool configurations, application variables, and conversation history under Google-managed keys until the deployment is exported and restored into a new CMEK-integrated project, which is a migration rather than a setting change.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Treat CMEK integration as a project provisioning step in the same class as enabling the API, not as a hardening task. Google notes that one key should be used per project location, and that CX Agent Studio key management (create, enable, and revoke) is handled by using the Conversational Insights API. For CX Insights, create the Insights service identity, grant service-PROJECT_NUMBER@gcp-sa-ccai-cmek.iam.gserviceaccount.com the Cloud KMS CryptoKey Encrypter/Decrypter role, and call InitializeEncryptionSpec for the location; Google warns that a customer-managed key cannot be configured for a project that already has CX Insights data. Because conversation history is surfaced through CX Insights, assume that a logged test conversation may create Insights data, and complete this step first. Verify with GetEncryptionSpec before the first agent application is created. Google also warns that if a key is revoked for more than 30 days, the Insights data encrypted by that key will be lost.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/cmek ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/cmek
Mappings	HIPAA: 164.312(a)(2)(iv) (Encryption and Decryption), 164.312(e)(2)(ii) (Encryption); NIST 800-53: SC-28 (Protection of Information at Rest), SC-28(1) (Cryptographic Protection), SC-12 (Cryptographic Key Establishment and Management), CM-6 (Configuration Settings); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information), 10.g (Key Management)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000850.0
Requirement	Cloud KMS keys protecting Gemini Enterprise for CX data MUST be monitored for availability, with key destruction and disablement gated on multi-party authorization.
Rationale	Google warns that if a key is revoked for more than 30 days, the CX Insights data encrypted by that key will be lost. This converts an ordinary key management error - a mistaken disable, an over-eager cleanup of an apparently unused key, an expired rotation schedule - into permanent destruction of the member conversation corpus on a 30-day fuse, with no recovery path once it burns.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Alert on key state changes and on decryption failures against these keys, and treat any such alert as an availability incident with a hard 30-day clock rather than a configuration ticket. Protect key destruction with organization policy and a separate approval, and confirm the KMS key's own IAM excludes the people who administer the CX projects.
References	https://docs.cloud.google.com/gemini-enterprise-cx/insights/cmek ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/cmek
Mappings	HIPAA: 164.312(a)(2)(iv) (Encryption and Decryption), 164.308(a)(7) (Contingency Plan); NIST 800-53: SC-12 (Cryptographic Key Establishment and Management), SC-12(1) (Availability), CM-5 (Access Restrictions for Change), AC-5 (Separation of Duties), SI-4 (System Monitoring); HITRUST CSF v11: 10.g (Key Management), 09.ab (Monitoring System Use)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000860.0
Requirement	Cloud KMS key versions protecting Gemini Enterprise for CX data MUST NOT be disabled or destroyed while any data encrypted under them is still retained.
Rationale	Google states for CX Agent Studio that key rotation is supported but data re-encryption is not: re-encrypting previously encrypted data with a new key version is not supported. Rotation therefore protects only newly written data, and previously written conversation content stays bound to the older key version for as long as it is retained. A rotation standard that retires old key versions on a schedule makes that data unreadable, which is the same permanent loss that follows revoking the key itself.
Estimated Security Value	High
Estimated Operational Impact	Low

ID	SG-GCP-GECX-000860.0
Audit Procedures	
Notes	Retain every key version for as long as any data encrypted under it is retained, which means key version lifetime is governed by the conversation retention schedule rather than by the rotation period. Document this explicitly, because it contradicts the default assumption behind most rotation standards.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/cmek
Mappings	HIPAA: 164.312(a)(2)(iv) (Encryption and Decryption); NIST 800-53: SC-12 (Cryptographic Key Establishment and Management), SC-28 (Protection of Information at Rest), SI-12 (Information Management and Retention); HITRUST CSF v11: 10.g (Key Management)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000870.0
Requirement	CX Agent Studio agent data MUST be located in the us multi-region.
Rationale	CX Agent Studio offers exactly two multi-regions, us and eu , and the region governs where callback code, tool code and configurations, agent instructions and prompts, application variables, and conversation history are stored at rest. Member conversation content for a US population belongs in the US multi-region both to satisfy the organization's residency position and to keep the data path within a single legal jurisdiction.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	A region must be supplied on every API request through the location path or resource parameter, so an omitted or defaulted region in client code is a residency defect that no console setting reveals. Verify the region in deployed client configuration rather than in design documentation. Two adjacent services need separate attention: Google states that OpenAPI tools support only global Secret Manager (regional secrets are unsupported), so the storage location of tool credentials is governed by each secret's own replication policy rather than by the agent region and must be confirmed separately; and the BigQuery export dataset must exist in the same location as the agent.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/region ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/settings

ID	SG-GCP-GEEX-000870.0
Mappings	HIPAA: 164.308(a)(1)(ii)(B) (Risk Management); NIST 800-53: SA-9(5) (Processing, Storage, and Service Location), CM-6 (Configuration Settings), SA-9 (External System Services); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GEEX-000880.0
Requirement	Cloud Logging MUST be configured with a US region for log storage independently of the Gemini Enterprise for CX residency setting.
Rationale	Google's residency documentation for CX Agent Studio directs the reader to the Cloud Logging documentation to control where logs are stored, which means logging sits outside the product's residency guarantee. Because Cloud Logging is documented as one of the customer-owned storage paths for conversation data, service logs routed there may contain member conversation content, and an unpinned logging configuration can store that content outside the residency boundary the rest of the deployment maintains.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Set the default storage location for new _Default and _Required log buckets in the Cloud Logging default resource settings at organization or folder level, so new projects inherit it, and confirm the location of existing buckets. Confirm that any log sink forwarding to a SIEM does not itself relocate the data. This is a separate configuration in a separate product, so it is easily missed in a residency review that only examines the CX components.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/region ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history ; https://cloud.google.com/logging/docs/regionalized-logs ; https://cloud.google.com/logging/docs/default-settings
Mappings	HIPAA: 164.308(a)(1)(ii)(B) (Risk Management); NIST 800-53: SA-9(5) (Processing, Storage, and Service Location), CM-6 (Configuration Settings), SA-9 (External System Services); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000890.0
Requirement	Conversation history retention in CX Agent Studio MUST be configured to a documented period no longer than the business need requires.
Rationale	Google documents retention as configurable with a default of one year and a maximum of two. Left at the default, the deployment accumulates a year of complete member conversation history because nobody made a decision, and the volume of that corpus is the primary determinant of the impact of any future compromise of the analytics surface.
Estimated Security Value	Med
Estimated Operational Impact	Low
Audit Procedures	
Notes	Set the value against the records-retention schedule and the operational need for dispute resolution, and record the rationale. Google states that the Log your customer conversations setting applies to both CX Agent Studio and CX Insights; separately, CX Insights documents per-conversation TTL and states that a conversation not set to expire remains in CX Insights indefinitely, so confirm with Google which mechanism governs conversations that reach CX Insights from CX Agent Studio. The Cloud Storage audio, the BigQuery export, and Cloud Logging each expire on their own schedules and must be aligned deliberately. Leaving the setting at its one-year default is not a decision.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/ttl
Mappings	HIPAA: 164.502(b) (Minimum Necessary); NIST 800-53: SI-12 (Information Management and Retention), MP-6 (Media Sanitization), CM-6 (Configuration Settings); HITRUST CSF v11: 06.c (Protection of Organizational Records)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000900.0
Requirement	The state of the Log your customer conversations setting (labeled Interaction data in agent application settings) MUST be an explicit, documented decision for every agent application.
Rationale	This single toggle governs whether long-term conversational data exists at all: Google states that disabling it disables all types of long-term conversational data except BigQuery data, and that with logging disabled conversational data does not exist in any Google-owned persistent storage to be accessed. It is simultaneously the strongest available data minimization control and a control that disables the monitoring dashboards and the CX Insights corpus that operations depends on.
Estimated Security Value	High

ID	SG-GCP-GECX-000900.0
Estimated Operational Impact	Low
Audit Procedures	
Notes	Because the trade is real, make it deliberately rather than by default. Note the exception in Google's own wording - BigQuery data is not disabled by the toggle - so a deployment that turns logging off while an export remains configured has not stopped conversation content being persisted. Google's settings page labels the same control Interaction data ("Store interaction data for deeper insights and your reference"), while the conversation history page calls it Log your customer conversations. Record the decision and the exception check as certification evidence.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/settings
Mappings	HIPAA: 164.502(b) (Minimum Necessary); NIST 800-53: SI-12 (Information Management and Retention), CM-6 (Configuration Settings), AC-4 (Information Flow Enforcement); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000910.0
Requirement	Written confirmation from Google that the Service Specific Terms training restriction covers every Gemini Enterprise for CX component and data path in use MUST be obtained and retained as certification evidence.
Rationale	Google's Service Specific Terms contain a contractual training restriction in section 18: "Google will not use Customer Data to train or fine-tune any AI/ML models without Customer's prior permission or instruction." The conversation history documentation separately states that customer content shared through the Improve agent performance by sharing conversation data toggle is never used to train Google's production machine learning models. Neither text names the individual components of this suite or its data paths, including audio through Speech-to-Text and analytics in CX Insights, and member conversation content used for training would be a use of PHI outside the purposes the organization has authorized.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Section 18 sits under the AI/ML Services part of the Service Specific Terms; ask Google to confirm, through the contracting relationship, that each component in use and

ID	SG-GCP-GECX-000910.0
	each data path falls within it, rather than relying on a documentation sentence that Google can revise without notice. Google's HIPAA guidance also states that a customer using Cloud Speech-to-Text under a BAA should not opt into the data logging program; confirm that it is not enabled. Retain the response as evidence, and re-confirm at contract renewal and whenever a new component is enabled.
References	https://cloud.google.com/terms/service-terms ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history ; https://cloud.google.com/terms/hipaa-baa ; https://cloud.google.com/security/compliance/hipaa
Mappings	HIPAA: 164.502(a) (Uses and Disclosures of PHI), 164.308(b) (1) (Business Associate Contracts), 164.504(e) (Business Associate Contracts); NIST 800-53: SA-9 (External System Services), PT-2 (Authority to Process Personally Identifiable Information), CA-3 (Information Exchange); HITRUST CSF v11: 05.k (Addressing Security in Third Party Agreements), 06.d (Data Protection and Privacy of Covered Information)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000920.0
Requirement	Sensitive Data Protection templates used by any Gemini Enterprise for CX component MUST be located inside the same VPC Service Controls perimeter as the component that references them.
Rationale	Google states that Sensitive Data Protection redaction templates outside the perimeter cause failures in redacting conversation contents. Google does not document whether ingestion stops or continues when redaction fails; if it continues, unredacted member content reaches the conversation corpus and the misconfiguration surfaces later as a data problem rather than as an error at the time.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Verify template location as part of perimeter change review, and monitor for redaction failures as an operational signal rather than assuming success. Because a template can be moved or a perimeter redrawn independently of the CX configuration, re-verify after any change to either. Redacted transcripts are not de-identified under HIPAA and remain PHI.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/common-integrations
Mappings	HIPAA: 164.502(b) (Minimum Necessary); NIST 800-53: SC-7 (Boundary Protection), SC-7(10) (Prevent Exfiltration), SI-19

ID	SG-GCP-GECX-000920.0
	(De-identification), CM-6 (Configuration Settings); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	
ID	SG-GCP-GECX-000930.0
Requirement	Member identifiers and other sensitive values MUST NOT be written into application variables, agent instructions, or tool configuration as static values.
Rationale	Google's HIPAA guidance states that when creating or updating Conversational Agents agents, customers should avoid including PHI or security credentials anywhere in the agent definition. Application variables and agent instructions are documented as agent data at rest, readable by every holder of the Gemini Enterprise for CX Viewer role and carried in configuration exports. A member identifier placed there persists beyond the conversation that produced it, sits outside the conversation retention and TTL settings, and is not subject to the redaction applied to conversation content.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Pass values that vary by member at runtime through the session rather than the configuration; Google documents session context variables that can be injected into OpenAPI tool requests. Include a scan for identifier-shaped values in the pre-deployment agent review, alongside the credential scan.
References	https://cloud.google.com/security/compliance/hipaa ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/region ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api
Mappings	HIPAA: 164.502(b) (Minimum Necessary), 164.312(a)(1) (Access Control); NIST 800-53: SI-12 (Information Management and Retention), AC-3 (Access Enforcement), SC-28 (Protection of Information at Rest); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information), 01.v (Information Access Restriction)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000940.0
Requirement	A documented procedure MUST exist to locate and delete all copies of an individual member's conversation data across every store in the deployment.
Rationale	Conversation content is written to at least five documented places: the Google-managed store used by CX Agent Studio and CX Insights, CX Insights conversations, Cloud Storage audio, Cloud Logging, and the BigQuery export, plus any downstream subscriber the organization configures. Each has its own deletion mechanism and its own retention clock, and deleting a conversation in one does not remove it from the others. A deletion obligation - from the organization's records-retention schedule, from applicable state law, or from the business associate agreement's return-or-destroy clause on termination - that the organization cannot execute completely is a compliance failure regardless of intent.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Build the procedure against the store inventory rather than against the console, and test it end to end with a synthetic conversation, verifying absence in every store afterwards. CX Agent Studio provides DeleteConversation and BatchDeleteConversations operations, and CX Insights conversations can be deleted manually; the BigQuery export and Cloud Storage audio require their own steps. HIPAA does not create an individual right to deletion; record which obligation each deletion satisfies.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/ttl ; https://docs.cloud.google.com/gemini-enterprise-cx/insights ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging ; https://cloud.google.com/terms/hipaa-baa
Mappings	HIPAA: 164.310(d)(2)(i) (Disposal), 164.502(b) (Minimum Necessary); NIST 800-53: SI-12 (Information Management and Retention), MP-6 (Media Sanitization), CM-8 (System Component Inventory); HITRUST CSF v11: 09.p (Disposal of Media), 06.c (Protection of Organizational Records)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	
ID	SG-GCP-GECX-000950.0
Requirement	The short-lived caches the product maintains MUST be documented in the data flow record supporting certification.
Rationale	Google documents a session memcache holding active session management data and metadata with a 30-minute TTL, and a Text-to-Speech Memstore cache with a one-hour TTL. These are minor exposures individually, but an

ID	SG-GCP-GECX-000950.0
	incomplete data flow diagram is a finding in its own right, and an assessor who discovers an undocumented store asks what else was omitted.
Estimated Security Value	Med
Estimated Operational Impact	Low
Audit Procedures	
Notes	Record them as transient stores with their stated TTLs rather than attempting to control them - the product exposes no configuration for either. Their presence is also the reason a deletion request cannot be confirmed complete within the first hour of a conversation ending.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history
Mappings	HIPAA: 164.316(b)(1) (Documentation); NIST 800-53: PL-8 (Security and Privacy Architectures), CM-8 (System Component Inventory), SI-12 (Information Management and Retention); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000960.0
Requirement	Google personnel access to Gemini Enterprise for CX conversation data SHOULD be gated by Access Approval and recorded through Access Transparency.
Rationale	Google documents that support and engineering personnel may have controlled, just-in-time access to Google-managed operational data for critical debugging and system maintenance. For a corpus of member conversation content this is provider access to ePHI permitted under the business associate relationship. Google lists Access Approval approval requests as generally available for Customer Experience Agent Studio, Customer Experience Insights, and Gemini Enterprise for Customer Experience, which lets the organization decide on that access before it occurs, and lists Access Transparency as generally available for the same services, which provides the record.
Estimated Security Value	Med
Estimated Operational Impact	Med
Audit Procedures	
Notes	Confirm with Google the entitlement required for Access Approval and Access Transparency, and route the logs to the same destination as the audit logs. Confirm per service which components of this suite are covered rather than assuming the whole deployment is, since coverage is enumerated per service and changes over time.

ID	SG-GCP-GECX-000960.0
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history ; https://cloud.google.com/assured-workloads/access-approval/docs/supported-services ; https://cloud.google.com/assured-workloads/access-transparency/docs/supported-services ; https://cloud.google.com/security/compliance/hipaa
Mappings	HIPAA: 164.312(b) (Audit Controls), 164.308(a)(1)(ii)(D) (Information System Activity Review), 164.308(b)(1) (Business Associate Contracts); NIST 800-53: AU-2 (Event Logging), AU-6 (Audit Record Review, Analysis, and Reporting), SA-9 (External System Services), SI-4 (System Monitoring); HITRUST CSF v11: 09.f (Monitoring and Review of Third Party Services), 09.ab (Monitoring System Use)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

Network & Perimeter Security

ID	SG-GCP-GECX-000970.0
Requirement	A VPC Service Controls perimeter MUST be configured with <code>ces.googleapis.com</code> , <code>contactcenterinsights.googleapis.com</code> , and, where Agent Assist is used, <code>dialogflow.googleapis.com</code> in the restricted services list.
Rationale	<code>ces.googleapis.com</code> carries agent configuration, tool invocation, and live conversation; <code>contactcenterinsights.googleapis.com</code> carries the analyzed conversation corpus; and Agent Assist is served through <code>dialogflow.googleapis.com</code> . Any of these left unrestricted remains reachable with stolen credentials from any network, which for the Insights service means the complete member conversation corpus.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Google names <code>ces.googleapis.com</code> and <code>contactcenterinsights.googleapis.com</code> in its perimeter guidance for CX Agent Studio, and its VPC Service Controls supported-products list gives <code>dialogflow.googleapis.com</code> as the service name for Agent Assist. The CX Agent Studio perimeter page documents failures when Cloud Storage buckets, BigQuery datasets, Sensitive Data Protection redaction templates, Secret Manager secrets, and data stores sit outside the perimeter, so restrict <code>storage.googleapis.com</code> , <code>bigquery.googleapis.com</code> , <code>dlp.googleapis.com</code> , <code>secretmanager.googleapis.com</code> , and <code>discoveryengine.googleapis.com</code> in the same perimeter. The CX Insights entry also directs adding the Agent

ID	SG-GCP-GECX-000970.0
	Platform API (aiplatform.googleapis.com) when integrating multiple CCAI products. Restrict Cloud KMS and Speech-to-Text where they are used as a design choice; Google does not name them as breakage points.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls ; https://cloud.google.com/vpc-service-controls/docs/supported-products
Mappings	HIPAA: 164.312(e)(1) (Transmission Security), 164.312(a)(1) (Access Control); NIST 800-53: SC-7 (Boundary Protection), SC-7(10) (Prevent Exfiltration), AC-4 (Information Flow Enforcement), CM-6 (Configuration Settings); HITRUST CSF v11: 09.m (Network Controls), 09.n (Security of Network Services)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000980.0
Requirement	The service perimeter MUST be established and enforced before agent applications, data stores, deployment channels, and CX Insights locations are created.
Rationale	Google documents seven distinct operations that fail once a perimeter is enforced around existing resources: tools and callbacks reaching arbitrary HTTP endpoints, Cloud Storage audio writes, BigQuery export, Sensitive Data Protection redaction templates, OpenAPI tool secrets, data store tool execution, and cross-perimeter agent references and import or export. Enforcing a perimeter after the fact therefore produces a wave of simultaneous production failures at exactly the moment there is pressure to write exceptions rather than relocate resources.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Google documentation does not itself state a sequencing requirement - this control is derived from the enumerated breakages rather than quoted from Google. Sequence as: define the perimeter, add restricted services, configure ingress and egress rules, validate in dry-run, enforce, then create resources. Record an owner and a removal condition for any exception written during cutover.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls
Mappings	HIPAA: 164.312(e)(1) (Transmission Security); NIST 800-53: SC-7 (Boundary Protection), CM-3 (Configuration Change Control), PL-8 (Security and Privacy Architectures), CM-4 (Impact Analyses); HITRUST CSF v11: 09.m (Network Controls)
Detective Policies	

ID	SG-GCP-GECX-000980.0
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-000990.0
Requirement	The service perimeter MUST be validated in dry-run mode and its findings resolved before enforcement.
Rationale	Dry-run mode reports what enforcement would block without blocking it, which is the only safe way to discover which of the seven documented breakage paths a given deployment actually depends on. Skipping it means discovering the same information as a production outage, and outage-driven remediation reliably produces broad exceptions instead of relocated resources.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Run the dry-run across a full operational cycle rather than a single test conversation, because several breakage paths - BigQuery export, Cloud Storage audio writes, and agent application import and export - occur only when those features are exercised. Google documents that in dry run mode requests that violate the perimeter policy are not denied, only logged, with metadata.dryRun set to True in the audit log. Resolve each finding by moving the resource inside the perimeter, not by exempting the service.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls ; https://cloud.google.com/vpc-service-controls/docs/dry-run-mode
Mappings	HIPAA: 164.312(e)(1) (Transmission Security); NIST 800-53: SC-7 (Boundary Protection), CM-3 (Configuration Change Control), CA-2 (Control Assessments), CM-4 (Impact Analyses); HITRUST CSF v11: 09.m (Network Controls)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001000.0
Requirement	Tools and callbacks MUST NOT be able to call HTTP(S) endpoints outside the approved list, enforced through the CX Agent Studio allowed origins endpoint control policy with its enforcement scope set to ALWAYS.
Rationale	A tool or callback URL is an outbound channel for conversation-derived parameters. Google documents that allowed origins applies to all types of tools and callbacks which can make external requests, that when VPC Service Controls is not enabled (the default) all endpoints are allowed, and that the ALWAYS enforcement scope applies regardless

ID	SG-GCP-GECX-001000.0
	of VPC-SC status. Without that policy, any holder of the Tools Editor role (for tools) or the Agent Editor role (for callbacks) can point the deployment at any host on the internet.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Set EndpointControlPolicy.enforcementScope to ALWAYS; an unspecified scope is treated as VPCSC_ONLY. Allowed origins are exact-match URLs including the scheme and optional port, with no wildcards, and an origin without a port allows all ports. The setting applies at project and location level and requires the <code>ces.securitySettings.update</code> permission, held by <code>roles/ces.securitySettingsEditor</code> and <code>roles/ces.admin</code> , which Google intends for security or project administrators separate from those who edit agent data. Reconcile the list against the tool inventory quarterly. For targets inside the organization's VPC, configure Service Directory private network access.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/settings ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/rest/v1beta/SecuritySettings ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/iam/docs/roles-permissions/ces
Mappings	HIPAA: 164.312(e)(1) (Transmission Security), 164.502(a) (Uses and Disclosures of PHI); NIST 800-53: SC-7 (Boundary Protection), SC-7(10) (Prevent Exfiltration), AC-4 (Information Flow Enforcement), CA-3 (Information Exchange); HITRUST CSF v11: 09.m (Network Controls), 09.s (Information Exchange Policies and Procedures)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001010.0
Requirement	Service Directory private network access MUST be configured for OpenAPI tool targets hosted inside the organization's VPC network.
Rationale	Google documents Service Directory integration as the supported path that keeps traffic within the Google Cloud network and enforces IAM and VPC Service Controls for OpenAPI tool targets. It lets a tool reach an internal system without exposing that system publicly and without breaking under perimeter enforcement; Google also lists Integration Connectors as an optional perimeter dependency for connector-based tools.

ID	SG-GCP-GECX-001010.0
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Grant <code>servicedirectory.viewer</code> and <code>servicedirectory.pscAuthorizedService</code> to <code>service-agent-project-number@gcp-sa-ces.iam.gserviceaccount.com</code> , and where Service Directory resides in a different project grant <code>servicedirectory.viewer</code> in both projects. Configure this before perimeter enforcement so tool connectivity is already on the supported path.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls
Mappings	HIPAA: 164.312(e)(1) (Transmission Security); NIST 800-53: SC-7 (Boundary Protection), AC-4 (Information Flow Enforcement), SC-8 (Transmission Confidentiality and Integrity), CA-9 (Internal System Connections); HITRUST CSF v11: 09.m (Network Controls), 09.n (Security of Network Services)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001020.0
Requirement	Cloud Storage buckets, BigQuery datasets, Secret Manager secrets, Sensitive Data Protection templates, and data stores referenced by Gemini Enterprise for CX MUST reside inside the same service perimeter as the components that reference them.
Rationale	Google enumerates each of these as a specific failure: audio recordings cannot be written to buckets outside the perimeter, conversation data cannot be written to external BigQuery datasets, OpenAPI tools cannot reference secrets outside the perimeter, external redaction templates cause redaction failures, and data store tools specifying a data store outside the perimeter fail to execute. A resource outside the perimeter is therefore both a security gap and a functional break.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Enumerate every referenced resource before enforcement, because these references are created by different roles at different times and no single console view lists them together. The redaction template case is the most dangerous of the five, since it degrades data protection rather than producing an obvious failure.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls

ID	SG-GCP-GECX-001020.0
Mappings	HIPAA: 164.312(e)(1) (Transmission Security), 164.312(a)(1) (Access Control); NIST 800-53: SC-7 (Boundary Protection), AC-4 (Information Flow Enforcement), CM-6 (Configuration Settings), SC-7(10) (Prevent Exfiltration); HITRUST CSF v11: 09.m (Network Controls)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001030.0
Requirement	Every ingress rule, egress rule, and allowed origin for the Gemini Enterprise for CX perimeter MUST name specific identities, sources, services, or URLs - never ANY_IDENTITY, an access level or service name of "*" - and carry a documented owner and a review at least annually.
Rationale	A VPC Service Controls perimeter denies cross-boundary requests unless an ingress or egress rule allows them, so the perimeter's effective strength is set by those rules and by the CX Agent Studio allowed origins list. Google documents that ANY_IDENTITY allows requests from all identities, including unauthenticated requests, and that an access level of "*" allows access from any network origin. Broad rules accumulate under delivery pressure, most often during the enforcement cutover, and an unreviewed rule set converts the perimeter into documentation rather than a control.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Record for each rule or origin what it permits, who requested it, and what would have to change for it to be removed. Rules added during a cutover deserve particular scrutiny because they were written to end an outage rather than to express an authorization decision.
References	https://cloud.google.com/vpc-service-controls/docs/ingress-egress-rules ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/settings ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls
Mappings	HIPAA: 164.312(e)(1) (Transmission Security); NIST 800-53: SC-7 (Boundary Protection), SC-7(5) (Deny by Default - Allow by Exception), AC-4 (Information Flow Enforcement), CM-3 (Configuration Change Control); HITRUST CSF v11: 09.m (Network Controls)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001040.0
Requirement	Flow-based agents MUST NOT reference agent resources located outside the service perimeter.
Rationale	Google documents that flow-based agents specifying an agent resource outside the perimeter fail when called. Beyond the functional break, a cross-perimeter agent reference delegates conversation handling across a security boundary. Google does not document the identity under which a referenced agent in another project executes; if it runs with its own project's service agent permissions, the reference extends reach into a project the calling perimeter does not govern.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Keep the full agent delegation graph inside a single perimeter and review it whenever a new agent reference is added. A reference that crosses perimeters should be treated as a design finding rather than a configuration option.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool
Mappings	HIPAA: 164.312(a)(1) (Access Control), 164.312(e)(1) (Transmission Security); NIST 800-53: SC-7 (Boundary Protection), AC-4 (Information Flow Enforcement), AC-3 (Access Enforcement), CA-3 (Information Exchange); HITRUST CSF v11: 09.m (Network Controls)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001050.0
Requirement	Import and export operations for agent configuration MUST target Cloud Storage buckets inside the service perimeter.
Rationale	Google documents that import and export operations targeting external Cloud Storage buckets fail under perimeter enforcement. Export carries the complete agent configuration - instructions, tool definitions, and application variables - so an export to a bucket outside the perimeter is a full disclosure of the deployment's logic and its integration topology.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Restrict export destinations to a small set of perimeter-internal buckets under change control. Google's audit logging reference lists ExportApp under ADMIN_READ, a Data Access audit log type that is typically disabled by default, and ImportApp under ADMIN_WRITE, which is recorded in Admin

ID	SG-GCP-GEEX-001050.0
	Activity logs; enable the ADMIN_READ sub-type for <code>ces.googleapis.com</code> or exports will not be logged. Google also documents that requests involving Cloud Storage access use the caller's permissions, so the exporting principal needs access to the destination bucket as well.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging ; https://cloud.google.com/logging/docs/audit/configure-data-access ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control
Mappings	HIPAA: 164.312(a)(1) (Access Control); NIST 800-53: SC-7 (Boundary Protection), AC-4 (Information Flow Enforcement), AU-2 (Event Logging), CM-3 (Configuration Change Control); HITRUST CSF v11: 09.m (Network Controls)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GEEX-001060.0
Requirement	Changes to the service perimeter protecting Gemini Enterprise for CX MUST be change controlled and alerted on.
Rationale	The perimeter is the compensating control for several exposures this product cannot address internally, including the service-agent tool execution model and the absence of supported per-conversation scoping in the analytics surface. Because a single policy edit can remove a service from the restricted list without any visible effect on the application, perimeter changes are both high impact and low friction.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Alert on Access Context Manager service perimeter changes - for example <code>CreateServicePerimeter</code> , <code>UpdateServicePerimeter</code> , <code>DeleteServicePerimeter</code> , <code>ReplaceServicePerimeters</code> , and <code>CommitServicePerimeters</code> under <code>protoPayload.serviceName="accesscontextmanager.googleapis.com"</code> - and route them to the security operations queue rather than to the platform team that made them. Reconcile the restricted service list against the documented baseline on a quarterly configuration review.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls ; https://cloud.google.com/access-context-manager/docs/audit-logging
Mappings	HIPAA: 164.312(e)(1) (Transmission Security), 164.312(b) (Audit Controls); NIST 800-53: CM-3 (Configuration Change Control), SC-7 (Boundary Protection), AU-6 (Audit Record Review, Analysis, and Reporting), SI-4 (System Monitoring);

ID	SG-GCP-GECX-001060.0
	HITRUST CSF v11: 09.m (Network Controls), 09.ab (Monitoring System Use)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

Monitoring & Analytics

ID	SG-GCP-GECX-001070.0
Requirement	Data Access audit logs for <code>ces.googleapis.com</code> MUST be explicitly enabled for all three sub-types: ADMIN_READ, DATA_READ, and DATA_WRITE.
Rationale	Google documents that Admin Activity audit logs are enabled by default while Data Access logs require explicit enablement. For CX Agent Studio the Data Access tier is the one that records agent and tool operations and conversation deletion - the reads and writes touching member conversation content. Without it, the audit trail covers who created an application but not who used it or what it reached.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Enable at organization level so new projects inherit the configuration rather than depending on a project-creation checklist. Google lists ExportApp and GetSecuritySettings under ADMIN_READ, and CreateTool, UpdateTool, DeleteConversation, BatchDeleteConversations, and RunSession under DATA_WRITE, so enabling DATA_READ alone misses both exports and changes. Verify with a filter on <code>protoPayload.serviceName="ces.googleapis.com"</code> after enablement, and note that long-running operations produce two entries, one at start and one at completion.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging ; https://cloud.google.com/logging/docs/audit/configure-data-access
Mappings	HIPAA: 164.312(b) (Audit Controls), 164.308(a)(1)(ii)(D) (Information System Activity Review); NIST 800-53: AU-2 (Event Logging), AU-12 (Audit Record Generation), AU-3 (Content of Audit Records), CM-6 (Configuration Settings); HITRUST CSF v11: 09.aa (Audit Logging)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001080.0
Requirement	Data Access audit logs for <code>contactcenterinsights.googleapis.com</code> MUST be explicitly enabled for all three sub-types: ADMIN_READ, DATA_READ, and DATA_WRITE.
Rationale	CX Insights holds the complete analysed conversation corpus and, because fine-grained access control is Pre-GA, every approved user can read all of it. The Data Access log is therefore the only record of which analyst read which member's conversation, which makes it the primary compensating control for the absence of a supported per-conversation access boundary.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Google lists reads such as GetConversation, ListConversations, and ExportInsightsData under DATA_READ, and nearly every mutation - including CreateAnalysis, CreateAnalysisRule, BulkDeleteConversations, and UpdateSettings - under DATA_WRITE; only SetIamPolicy is ADMIN_WRITE. Without DATA_WRITE, almost no change to CX Insights is recorded. Verify with a filter on <code>protoPayload.serviceName="contactcenterinsights.googleapis.com"</code> . Given the breadth of standing access, retention and reviewability of these logs matter more here than anywhere else in the deployment.
References	https://docs.cloud.google.com/gemini-enterprise-cx/insights/audit-logging ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/best-practices-for-fine-grained-access-control ; https://cloud.google.com/logging/docs/audit/configure-data-access
Mappings	HIPAA: 164.312(b) (Audit Controls), 164.308(a)(1)(ii)(D) (Information System Activity Review), 164.312(a)(1) (Access Control); NIST 800-53: AU-2 (Event Logging), AU-12 (Audit Record Generation), AU-6 (Audit Record Review, Analysis, and Reporting), AC-3 (Access Enforcement); HITRUST CSF v11: 09.aa (Audit Logging)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001090.0
Requirement	Audit logs from every Gemini Enterprise for CX project MUST be exported to the organization's security information and event management platform.
Rationale	Cloud Logging retention is bounded and project-scoped, and detection of misuse across a multi-project deployment requires correlation that a per-project log view cannot provide.

ID	SG-GCP-GECX-001090.0
	Exporting is also what places the records outside the control of the same administrators whose actions they record.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Export Admin Activity, Data Access, and any Access Transparency logs through an aggregated sink at organization or folder level with includeChildren set, so a newly created project is covered without action. Confirm that the sink destination does not relocate the data outside the residency boundary maintained elsewhere in the deployment.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/audit-logging ; https://cloud.google.com/logging/docs/export/aggregated_sinks ; https://cloud.google.com/logging/docs/routing/overview
Mappings	HIPAA: 164.312(b) (Audit Controls), 164.308(a)(1)(ii)(D) (Information System Activity Review); NIST 800-53: AU-6 (Audit Record Review, Analysis, and Reporting), AU-9 (Protection of Audit Information), SI-4 (System Monitoring), AU-4 (Audit Log Storage Capacity); HITRUST CSF v11: 09.aa (Audit Logging), 09.ab (Monitoring System Use), 09.ac (Protection of Log Information)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001100.0
Requirement	Audit log retention MUST meet or exceed the organization's retention requirement for records of access to protected health information.
Rationale	Data Access logs for these services are the evidence of who read member conversation content, and their value in an investigation or a breach determination is a direct function of how far back they reach. Google documents that Data Access audit logs are stored in the _Default bucket unless routed elsewhere, and that the _Default bucket's default retention period is 30 days.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	The organization treats these audit logs as records of activity required by HIPAA 164.316(b)(1), and therefore applies the six-year period in 164.316(b)(2)(i), which requires that documentation to be retained for six years from creation or the date it was last in effect, whichever is later. The regulation does not name audit logs specifically; six years is the organization's interpretation and a conservative floor. Set retention on the log bucket (1 to 3650 days) or on the export

ID	SG-GCP-GECX-001100.0
	destination rather than relying on defaults, and lock the bucket so the retention policy cannot be reduced; Google warns that locking a log bucket is irreversible. Retention on the exported copy is what matters if the project itself is compromised or deleted.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/audit-logging ; https://cloud.google.com/logging/docs/audit/configure-data-access ; https://cloud.google.com/logging/quotas ; https://cloud.google.com/logging/docs/buckets ; https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.316
Mappings	HIPAA: 164.312(b) (Audit Controls), 164.316(b)(1) (Documentation), 164.316(b)(2)(i) (Time Limit); NIST 800-53: AU-11 (Audit Record Retention), AU-4 (Audit Log Storage Capacity), AU-9 (Protection of Audit Information), SI-12 (Information Management and Retention); HITRUST CSF v11: 09.aa (Audit Logging), 09.ac (Protection of Log Information)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001110.0
Requirement	Exported audit logs MUST be protected against modification and deletion by the administrators of the Gemini Enterprise for CX projects.
Rationale	The administrators of these projects are the population whose actions the logs record. Where the same identities can edit sinks, alter retention, or delete log buckets, the audit trail attests only to activity that the administrator chose to leave in place, which is not an audit trail.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Route the export to a project under separate administrative control with its own IAM, and restrict log bucket and sink modification to the logging or security function. Lock the destination log bucket so its retention policy cannot be reduced and the bucket cannot be deleted until its entries have met the retention period. Alert on changes to sink configuration and log retention as security events.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/audit-logging ; https://cloud.google.com/logging/docs/routing/overview ; https://cloud.google.com/logging/docs/buckets
Mappings	HIPAA: 164.312(b) (Audit Controls), 164.312(c)(1) (Integrity); NIST 800-53: AU-9 (Protection of Audit Information), AU-9(4)

ID	SG-GCP-GEEX-001110.0
	(Access by Subset of Privileged Users), AC-5 (Separation of Duties), AC-6 (Least Privilege); HITRUST CSF v11: 09.ac (Protection of Log Information)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	
ID	SG-GCP-GEEX-001120.0
Requirement	Alerts MUST be configured for changes to CX Agent Studio security settings and to agent application logging, redaction, and export settings.
Rationale	The project-level security settings hold the endpoint control policy - the allowed origins list that governs which HTTP(S) endpoints tools and callbacks can call - so a single change there widens the egress boundary of every agent application in the project and location. Redaction, Cloud Logging, BigQuery export, audio recording, and interaction data storage are agent application settings, managed by the App Editor role. Neither change produces a deployment, and neither is visible to someone reading an individual agent's configuration.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Alert on <code>google.cloud.ces.v1beta.AgentService.UpdateSecuritySettings</code> and on <code>AgentService.UpdateApp</code> (v1 and v1beta), both recorded in Admin Activity logs under <code>ces.googleapis.com</code> , and route them to the security operations queue. Correlate each alert with an approved change record and investigate any change without one.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/settings ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/rest/v1beta/SecuritySettings ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control
Mappings	HIPAA: 164.312(b) (Audit Controls), 164.308(a)(1)(ii)(D) (Information System Activity Review); NIST 800-53: SI-4 (System Monitoring), AU-6 (Audit Record Review, Analysis, and Reporting), CM-3 (Configuration Change Control), IR-4 (Incident Handling); HITRUST CSF v11: 09.ab (Monitoring System Use), 09.ad (Administrator and Operator Logs)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001130.0
Requirement	Alerts MUST be configured for conversation deletion and bulk deletion operations in CX Agent Studio and CX Insights.
Rationale	Conversation deletion is both a legitimate privacy operation and the natural final step of an attacker or an insider covering their activity. CX Insights supports bulk operations over conversations, which makes large-scale destruction a single API call, and expiry-based deletion is documented as not recoverable.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Alert on DeleteConversation and the bulk delete operations in both services, and distinguish deletions performed through the documented privacy procedure from ad hoc ones. A deletion volume anomaly is worth investigating even where each individual deletion appears authorized.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/audit-logging ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/ttl
Mappings	HIPAA: 164.312(b) (Audit Controls), 164.312(c)(1) (Integrity), 164.308(a)(6) (Security Incident Procedures); NIST 800-53: SI-4 (System Monitoring), AU-6 (Audit Record Review, Analysis, and Reporting), IR-4 (Incident Handling), AU-2 (Event Logging); HITRUST CSF v11: 09.ab (Monitoring System Use)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001140.0
Requirement	Alerts MUST be configured for tool registration and modification in CX Agent Studio and for changes to the tools assigned to agents.
Rationale	Tools execute with the CX Agent Studio service account's permissions rather than the end user's. A new tool becomes reachable once it is added to an agent, and a modified tool changes the reach of every agent already using it, so tool changes alter the deployment's effective authorization boundary without a deployment step or an approval gate in the product.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Alert on CreateTool, UpdateTool, CreateToolset, and UpdateToolset (DATA_WRITE, recorded in Data Access logs under <code>ces.googleapis.com</code>), and on UpdateAgent, through which the Agent Editor role adds tools to agents. Reconcile

ID	SG-GCP-GECX-001140.0
	against the tool inventory. A registration with no corresponding inventory entry is either an undocumented integration or a compromise, and both warrant the same first question.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control
Mappings	NIST 800-53: SI-4 (System Monitoring), CM-3 (Configuration Change Control), CM-8 (System Component Inventory), AU-6 (Audit Record Review, Analysis, and Reporting); HITRUST CSF v11: 09.ab (Monitoring System Use)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001150.0
Requirement	Alerts MUST be configured for anomalous read volume against CX Insights conversation data.
Rationale	Because every approved CX Insights user can read every conversation, the difference between legitimate analysis and bulk extraction is volume and pattern rather than authorization. No preventive control distinguishes them, so detection is the available control and it depends entirely on the Data Access log being both enabled and monitored.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Baseline normal analyst read volume before setting thresholds, and alert on deviation rather than on an absolute count, since legitimate quality review is itself high volume. Pair with the quarterly entitlement review so that an unexpected reader is noticed as well as an unexpected volume.
References	https://docs.cloud.google.com/gemini-enterprise-cx/insights/audit-logging ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/best-practices-for-fine-grained-access-control
Mappings	HIPAA: 164.308(a)(1)(ii)(D) (Information System Activity Review), 164.312(b) (Audit Controls); NIST 800-53: SI-4 (System Monitoring), AU-6 (Audit Record Review, Analysis, and Reporting), IR-4 (Incident Handling), AC-6 (Least Privilege); HITRUST CSF v11: 09.ab (Monitoring System Use)
Detective Policies	
Sentinel Modules	
CSP Level Controls	

ID	SG-GCP-GECX-001150.0
Monitoring Controls	
ID	SG-GCP-GECX-001160.0
Requirement	Operational monitoring MUST NOT depend solely on the product's built-in conversation dashboards where conversation logging is disabled or can be disabled.
Rationale	Google notes that disabling the conversation logging toggle affects the monitoring dashboards, which couples the data minimization decision to the observability capability. A monitoring practice that assumes those dashboards will be populated becomes silently blind if the toggle is turned off for a privacy reason on a different team's initiative.
Estimated Security Value	Med
Estimated Operational Impact	Low
Audit Procedures	
Notes	Base operational and security monitoring on Cloud Audit Logs and platform metrics, and treat the product dashboards as a convenience layer. Google does not state whether these sources are affected by the toggle, so confirm after any change to the logging setting that they are still populated. Record the dependency so the observability consequence is visible to whoever considers changing the logging setting.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging
Mappings	NIST 800-53: SI-4 (System Monitoring), AU-2 (Event Logging), CM-6 (Configuration Settings), CA-7 (Continuous Monitoring); HITRUST CSF v11: 09.ab (Monitoring System Use)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	
ID	SG-GCP-GECX-001170.0
Requirement	An incident response procedure covering Gemini Enterprise for CX MUST be documented, including containment steps for a compromised agent application or tool.
Rationale	The containment actions in this product are specific and not obvious under pressure: restoring a previous agent application version, revoking the Gemini Enterprise for CX Client role from the principal a channel uses, removing a tool registration, deleting a deployment, locking the agent application against further changes, tightening the allowed origins list, and tightening the perimeter. A generic cloud incident procedure will not name any of them, and a live agent continues serving members throughout the delay.
Estimated Security Value	High

ID	SG-GCP-GEEX-001170.0
Estimated Operational Impact	Med
Audit Procedures	
Notes	Document who can execute each containment action and confirm they can reach it outside business hours. Exercise the agent version restore at least once before relying on it. Where an incident involves member conversation content, the breach determination path and the notification clock apply as they would to any other ePHI disclosure; under the BAA, Google notifies the organization of breaches it discovers (164.410), and the organization's own duties under 164.404 and 164.408 follow from discovery.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/settings ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging
Mappings	HIPAA: 164.308(a)(6) (Security Incident Procedures), 164.404 (Notification to Individuals), 164.408 (Notification to the Secretary); NIST 800-53: IR-4 (Incident Handling), IR-6 (Incident Reporting), CM-2 (Baseline Configuration), CM-2(3) (Retention of Previous Configurations), CM-3 (Configuration Change Control); HITRUST CSF v11: 11.a (Reporting Information Security Events), 11.c (Responsibilities and Procedures)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

Compliance & Certification

ID	SG-GCP-GEEX-001180.0
Requirement	A business associate agreement covering Google Cloud MUST be executed and its scope confirmed to include every Gemini Enterprise for CX component in use before production member conversation data is processed.
Rationale	Every component of this suite processes protected health information in its most unstructured and least controllable form. Google's BAA covers the infrastructure and the services named in the covered products list, and coverage attaches per product rather than per platform, so an executed BAA is a necessary but not sufficient condition and its scope must be checked against the specific components deployed.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	

ID	SG-GCP-GECX-001180.0
Notes	Confirm coverage before enablement rather than at annual review, since the components are enabled independently and by different teams. Retain the confirmation as certification evidence with the date it was checked, because the covered products list is revised as products are added.
References	https://cloud.google.com/terms/hipaa-baa ; https://cloud.google.com/security/compliance/hipaa
Mappings	HIPAA: 164.308(b)(1) (Business Associate Contracts), 164.314(a) (Business Associate Contracts or Other Arrangements), 164.502(e) (Disclosures to Business Associates); NIST 800-53: SA-9 (External System Services), SA-4 (Acquisition Process), CA-3 (Information Exchange); HITRUST CSF v11: 05.k (Addressing Security in Third Party Agreements)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001190.0
Requirement	Gemini Enterprise for CX components MUST NOT process protected health information unless Google's HIPAA covered products list names the component or Google confirms in writing that the component falls within a listed product.
Rationale	Google's covered products list is a flat list that names, verbatim, Gemini Enterprise for Customer Experience (GECX), Customer Experience Agent Studio, CX Insights, Contact Center AI Agent Assist, Contact Center AI Platform, and Conversational Agents. Because the suite name is itself an entry, the absence of a feature's own name is not conclusive either way: a generally available component may be covered through the suite entry, while a component with no GA release, such as Commerce agents, is not shown to be covered by it. Coverage therefore has to be demonstrated per component, by its own entry or by Google's written confirmation, and processing ePHI through a component that has neither is a disclosure outside the BAA.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	Record, per component, the list entry or the written confirmation that establishes coverage and the date it was checked, and re-check before enablement and at each annual reassessment. As of 2026-09-24, Commerce agents does not appear in the list under its own name.
References	https://cloud.google.com/security/compliance/hipaa ; https://cloud.google.com/terms/hipaa-baa
Mappings	HIPAA: 164.308(b)(1) (Business Associate Contracts), 164.502(e) (Disclosures to Business Associates), 164.502(a) (Uses and Disclosures of PHI); NIST 800-53: SA-9 (External

ID	SG-GCP-GEEX-001190.0
	System Services), CM-7 (Least Functionality), SA-4 (Acquisition Process), RA-3 (Risk Assessment); HITRUST CSF v11: 05.k (Addressing Security in Third Party Agreements)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	
ID	SG-GCP-GEEX-001200.0
Requirement	Every Google API in the path of member conversation data, including the Dialogflow API (<code>dialogflow.googleapis.com</code>) used by Agent Assist and Conversational Agents, MUST be confirmed by Google in writing as within a product on Google's HIPAA covered products list before it processes protected health information.
Rationale	Google's HIPAA covered products list names Conversational Agents, Contact Center AI Agent Assist, Customer Experience Agent Studio, and CX Insights but does not use the name Dialogflow. The VPC Service Controls documentation gives <code>dialogflow.googleapis.com</code> as the service name for Agent Assist, CX Insights requires Dialogflow runtime integration to ingest conversations from Dialogflow and Agent Assist, and Google's SOC 2 scope lists Conversational Agents as formerly Dialogflow. Product names, API names, and list entries therefore do not line up one to one, and a deployment can route PHI through an API whose coverage has been assumed rather than confirmed.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	Inventory each API in the data path by service name, map it to a covered product name, and obtain Google's written confirmation for any mapping that is not self-evident, starting with <code>dialogflow.googleapis.com</code> . Audit the CX Insights ingestion configuration for Dialogflow runtime integration and for legacy Dialogflow ES agents; Google's Dialogflow documentation lists Dialogflow ES separately from Conversational Agents, so do not assume ES is covered without confirmation.
References	https://cloud.google.com/security/compliance/hipaa ; https://cloud.google.com/vpc-service-controls/docs/supported-products ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/common-integrations ; https://cloud.google.com/security/compliance/soc-2 ; https://docs.cloud.google.com/dialogflow/cx/docs

ID	SG-GCP-GECX-001200.0
Mappings	HIPAA: 164.308(b)(1) (Business Associate Contracts), 164.502(e) (Disclosures to Business Associates); NIST 800-53: SA-9 (External System Services), CM-8 (System Component Inventory), CM-7 (Least Functionality), RA-3 (Risk Assessment); HITRUST CSF v11: 05.k (Addressing Security in Third Party Agreements)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001210.0
Requirement	Compliance attestations relied upon for Gemini Enterprise for CX MUST be retrieved, reviewed, and their exclusions tracked at least annually.
Rationale	An attestation is a point-in-time statement with a defined scope, and the useful information is usually in what it excludes rather than what it covers. For a suite whose components are certified individually and whose supporting services - Speech-to-Text, Cloud Storage, BigQuery, Cloud KMS, Pub/Sub - carry their own scope, the compliance picture is a composition rather than a single document.
Estimated Security Value	Med
Estimated Operational Impact	Low
Audit Procedures	
Notes	Track the exclusions as a register rather than filing the reports. Google states that customers can request its SOC 2 reports through Compliance Reports Manager. Product names differ across attestations: at the time of authoring, Google's SOC 2 scope lists CX Agent Studio and CX Insights by name, while its HITRUST CSF scope list uses Conversational AI and Conversational Insights and does not name CX Agent Studio, so confirm with Google which entries cover each component. An exclusion that overlaps a control this guide depends on is a finding to escalate, not a footnote, and it will not announce itself between annual reviews.
References	https://cloud.google.com/security/compliance/soc-2 ; https://cloud.google.com/security/compliance/hitrust ; https://cloud.google.com/security/compliance/hipaa ; https://cloud.google.com/terms/service-terms
Mappings	HIPAA: 164.308(a)(8) (Evaluation), 164.308(b)(1) (Business Associate Contracts); NIST 800-53: CA-2 (Control Assessments), SA-9 (External System Services), CA-7 (Continuous Monitoring), RA-3 (Risk Assessment); HITRUST CSF v11: 09.f (Monitoring and Review of Third Party Services)
Detective Policies	
Sentinel Modules	
CSP Level Controls	

ID	SG-GCP-GECX-001210.0
Monitoring Controls	
ID	SG-GCP-GECX-001220.0
Requirement	The complete data flow for member conversation content across all Gemini Enterprise for CX components and supporting services MUST be documented and maintained as certification evidence.
Rationale	Conversation content is written to at least six stores across two product APIs and five supporting Google Cloud services, each with independent encryption, residency, retention, and access configuration. Without a maintained data flow record, no one can answer where a given member's conversation exists, and every deletion, residency, and breach-scope question becomes an investigation.
Estimated Security Value	High
Estimated Operational Impact	Med
Audit Procedures	
Notes	The record must name each store, the service that owns it, its encryption configuration, its region, its retention clock, and who can read it. Refresh it whenever a component, ingestion source, export, or subscriber is added, since each of those creates a new copy rather than a new view. Include transient stores the product exposes no configuration for, such as the session memcache and the Text-to-Speech cache, and every path by which content leaves the suite - exports, ingestion, tool calls, remote agents reached through the A2A Protocol, and third-party channel platforms.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/common-integrations ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/cmek
Mappings	HIPAA: 164.308(a)(1)(ii)(A) (Risk Analysis), 164.316(b)(1) (Documentation); NIST 800-53: PL-8 (Security and Privacy Architectures), CM-8 (System Component Inventory), RA-3 (Risk Assessment), SI-12 (Information Management and Retention); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	
ID	SG-GCP-GECX-001230.0
Requirement	The residual risks this product cannot mitigate MUST be documented and formally accepted before production certification.
Rationale	Three exposures in this suite have no configuration remedy: tools execute with the project service agent's permissions

ID	SG-GCP-GEEX-001230.0
	rather than the caller's, data store retrieval is not documented as permission-aware, and per-conversation scoping in the analytics surface is available only as a Pre-GA feature. Each is compensated in this guide rather than closed, and a certification that does not name them implies a boundary that does not exist.
Estimated Security Value	High
Estimated Operational Impact	Low
Audit Procedures	
Notes	State each residual risk with the compensating control that bounds it and the accepting authority. This is the record a later reviewer needs in order to distinguish a control that was considered and bounded from one that was overlooked.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/data-store ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/best-practices-for-fine-grained-access-control
Mappings	HIPAA: 164.308(a)(1)(ii)(A) (Risk Analysis), 164.308(a)(1)(ii)(B) (Risk Management), 164.316(b)(1) (Documentation); NIST 800-53: RA-3 (Risk Assessment), CA-2 (Control Assessments), PL-8 (Security and Privacy Architectures), SA-8 (Security and Privacy Engineering Principles); HITRUST CSF v11: 01.v (Information Access Restriction); NIST AI RMF (AI 100-1): GOVERN, MAP, MEASURE, MANAGE
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GEEX-001240.0
Requirement	Gemini Enterprise for CX agent applications MUST be registered in the organization's AI system inventory with a named accountable owner.
Rationale	A member-facing generative agent making statements about coverage and benefits is a consequential AI system under every governance framework the organization is likely to be measured against, and this suite makes creating one a low-friction action available to any holder of an editor role. An inventory is what makes the population of deployed agents knowable to the people accountable for them.
Estimated Security Value	Med
Estimated Operational Impact	Low
Audit Procedures	
Notes	Register the agent, its purpose, its audience, its tool reach, and its accountable owner, and reconcile the inventory against the deployed agents on the quarterly cycle. The reconciliation is the control - an unregistered production agent is the finding it exists to surface. NIST AI 100-1 calls for

ID	SG-GCP-GECX-001240.0
	mechanisms to inventory AI systems, resourced according to organizational risk priorities (GOVERN 1.6).
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy ; https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf
Mappings	NIST 800-53: CM-8 (System Component Inventory), PM-5 (System Inventory), PL-8 (Security and Privacy Architectures), RA-3 (Risk Assessment); NIST AI RMF (AI 100-1): GOVERN, MAP, MEASURE, MANAGE
Detective Policies	
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

ID	SG-GCP-GECX-001250.0
Requirement	The security posture of this deployment MUST be reassessed whenever a Gemini Enterprise for CX component transitions a capability from Preview to general availability.
Rationale	Several controls in this guide exist because a capability is Pre-GA, most consequentially the compensating access model that stands in for CX Insights fine-grained access control. When such a capability reaches GA the compensating control becomes unnecessary overhead and the stronger native control becomes available, so a guide that is never revisited keeps the organization on the weaker posture indefinitely.
Estimated Security Value	Med
Estimated Operational Impact	Low
Audit Procedures	
Notes	Review the CX Agent Studio, CX Insights, and Agent Assist release notes at least monthly to detect Preview-to-GA transitions. On a transition, revisit any prohibition on the capability, the compensating control that stood in for it, and the residual risk that was accepted because of it - all three change together. Increment the Revision column on each affected row rather than renumbering.
References	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/release-notes ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/release-notes
Mappings	HIPAA: 164.308(a)(8) (Evaluation); NIST 800-53: CA-7 (Continuous Monitoring), CM-3 (Configuration Change Control), RA-3 (Risk Assessment), CA-2 (Control Assessments); NIST AI RMF (AI 100-1): GOVERN, MAP, MEASURE, MANAGE
Detective Policies	

ID	SG-GCP-GECX-001250.0
Sentinel Modules	
CSP Level Controls	
Monitoring Controls	

Appendices

Appendix A - List of Requirements

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
SG-GCP-GECX-000010	Features of Gemini Enterprise for CX that are Non-GA or Pre-GA MUST NOT be used in production or with protected health information or other personal data.	Any capability not designated GA is governed by Google's Pre-GA Offerings Terms in the Service Specific Terms. Those terms state that Pre-GA offerings are provided "as is", may be changed, suspended, or discontinued without prior notice, are not covered by any SLA, and, unless Google documentation expressly says otherwise, are not covered by the Data Location section or by any data	High	Low		GA status is determined only from Google's release notes and product documentation with the Pre-GA Offerings Terms disclaimer removed; console availability, marketing pages, partner training material, and press announcements are not authoritative. Where sources disagree, the more restrictive stage governs, and a product-level GA announcement does not make GA the individual features it lists. The	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/release-notes ; https://cloud.google.com/terms/service-terms ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/release-notes ; https://cloud.google.com/security/compliance/hipaa	HIPAA: 164.308(a)(8) (Evaluation); NIST 800-53: SA-8 (Security and Privacy Engineering Principles), CM-3 (Configuration Change Control), CM-7 (Least Functionality), SA-4 (Acquisition Process)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		processing terms. They also state that "Customer should not use Pre-GA Offerings to process personal data or other data subject to legal or regulatory compliance requirements." Google's HIPAA guidance says separately: "Do not use Pre-GA offerings ... in connection with PHI". A Pre-GA capability handling member conversation content therefore sits outside the contractual perimeter the BAA establishes. The exposure is created by production reliance and by regulated data, so a Pre-GA feature exercised in an isolated non-production				suite spans four documentat ion trees, three with independent release notes (CX Agent Studio, CX Insights, and Agent Assist), so confirm GA status per component and per feature rather than for the suite. Evaluation of a Pre-GA feature is permitted only in a non-production project that holds synthetic or otherwise non-personal data, shares no tool target, data store, service agent grant, or network path with production, and on which no production process depends. Keep a register of Pre-GA features under evaluation and of those		

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		project on synthetic data processes nothing those terms leave unprotected.				blocked, and re-verify both at every release-note review cycle.		
SG-GCP-GECX-000020	Commerce agents MUST NOT be deployed.	Google's own documentation states that Commerce agents are not yet released: the product page ends "Commerce agents coming soon." An unreleased product has no published security documentation, no encryption or residency configuration surface, and no IAM model to assess. If it is first released as a preview, it will fall under the Pre-GA Offerings Terms and under Google's HIPAA guidance: "Do not use Pre-GA offerings ... in connection	High	Low		This prohibition is a specific application of this guide's baseline prohibition on Non-GA and Pre-GA features, and stands until Commerce agents reach GA, are confirmed by Google as within the BAA-covered scope of Gemini Enterprise for CX, and are assessed under a fresh capability certification. Track the product page and the CX Agent Studio release notes for the transition. Nothing in this guide anticipates the control	https://docs.cloud.google.com/gemini-enterprise-cx/commerce-agents ; https://docs.cloud.google.com/gemini-enterprise-cx ; https://cloud.google.com/terms/service-terms ; https://cloud.google.com/security/compliance/hipaa	HIPAA: 164.308(a)(8) (Evaluation); NIST 800-53: CM-7 (Least Functionality), SA-4 (Acquisition Process), SA-8 (Security and Privacy Engineering Principles), RA-3 (Risk Assessment)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		with PHI". The umbrella covered-products entry for Gemini Enterprise for Customer Experience does not by itself establish that a component with no GA release can be used with PHI. The intended capability set compounds this: Google describes Commerce agents as executing consented actions on a customer's behalf, which is a write-capable autonomous surface reaching commerce and order systems.				surface Commerce agents will present.		
SG-GCP-GEEX-000030	The v1beta CX Agent Studio API and the v1alpha1 CX Insights API MUST NOT be called from	Both product APIs publish a pre-release version alongside the stable one: the CX Agent Studio	High	Low		Audit deployed client configuration, not console settings: the version appears in the endpoint	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio	HIPAA: 164.308(a)(8) (Evaluation); NIST 800-53: CM-7 (Least Functionality), CM-6 (Configurati

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	production workloads.	REST overview lists v1 and v1beta, and the CX Insights REST reference lists v1alpha1 resources. Google does not state the launch stage of these versions on the reference pages. A beta or alpha version is conventionally a pre-release surface, so this guide treats both as Pre-GA as a matter of organizational policy until Google states their launch stage in writing; the policy does not assert that either version is outside the BAA, it removes production dependence on an unconfirmed answer. A client library or integration pinned to				path and in generated client stubs. CX Agent Studio audit log entries record the API version in the method name, for example google.cloud.ces.v1beta.EvaluationService.RunEvaluation, so a Cloud Logging query for method names containing v1beta or v1alpha1 is the detective control. Scope that query to runtime and integration principals, because some administrative methods, such as UpdateSecuritySettings, are recorded under v1beta method names and are not production workloads. Some evaluation operations	ini-enterprise-cx/insights; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging ; https://cloud.google.com/terms/service-terms ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/reference/rest	on Settings), SA-4 (Acquisition Process), SA-8 (Security and Privacy Engineering Principles)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		v1beta or v1alpha1 would otherwise place production conversation traffic on a surface whose support and compliance coverage are unconfirmed, and the version is a substring of an endpoint path that no console screen displays.				are only offered on v1beta - run those in a non-production project that holds synthetic data and shares nothing with production, rather than promoting the version. The Pre-GA treatment of v1beta and v1alpha1 is a policy position drawn from the version naming rather than from a Google statement; ask Google for the launch stage and record the answer in the certification evidence.		
SG-GCP-GECX-000040	The Google Maps tool in CX Agent Studio MUST NOT be enabled on any agent application.	The tools overview flags the Google Maps tool as Preview while presenting it in the same tool picker as generally available tool types. A builder	High	Low		This is a specific application of this guide's baseline prohibition on Non-GA and Pre-GA features, restated because the console does not	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-	HIPAA: 164.308(a)(8) (Evaluation); NIST 800-53: CM-7 (Least Functionality), CM-3 (Configuration Change Control), SA-4

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		selecting it from that list receives no signal that the resulting agent has left the supported configuration, and the tool sends conversation-derived location context to a mapping surface outside the guide's assessed boundary.				segregate Preview tools from GA tools in the picker. Enforce by tool-type review during agent approval rather than by expecting builders to notice the marker. At the 2026-09-24 review the only other tool type marked Preview on the overview page was the A2A Protocol tool; re-check the page at each review because the picker composition changes without a release note.	studio/resources/release-notes; https://cloud.google.com/terms/service-terms	(Acquisition Process)
SG-GCP-GECX-000050	CX Insights capabilities documented as Preview, including fine-grained access control, conversation datasets, and multiple scorecards,	The CX Insights release notes place several capabilities in Preview, and one of them - fine-grained access control - is the only mechanism the product	High	Low		The practical consequence is carried by the CX Insights access requirement in this guide: because fine-grained access	https://docs.cloud.google.com/gemini-enterprise-cx/insights/release-notes ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/best-	HIPAA: 164.308(a)(4) (Information Access Management), 164.308(a)(8) (Evaluation); NIST 800-53: AC-3 (Access Enforcement)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	MUST NOT be used as the control of record or as a production dependency.	offers for scoping an analyst to a subset of conversations. Building an access model on a Pre-GA feature means the boundary protecting member conversation content is one that Google may change or withdraw without notice and does not warrant under the compliance terms.				control cannot be the control of record, project-level CX Insights access must be compensated by a deliberately small approved group plus Data Access audit logging. Do not read this requirement as prohibiting evaluation of authorized views in a non-production project - it prohibits depending on them for a production access decision. The Preview designation of conversation datasets (release note of 2025-08-15) and multiple scorecards (release note of 2025-07-18) is established only by the CX Insights	practices-for-fine-grained-access-control; https://cloud.google.com/terms/service-terms ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/datasets ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/qai-basics	nt), CM-7 (Least Functionality), SA-4 (Acquisition Process), RA-3 (Risk Assessment); HITRUST CSF v11: 01.v (Information Access Restriction)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
						release notes; their feature pages carry no Preview banner, and no GA announcement has followed. Do not read the absence of a banner on a feature page as a change of launch stage. The appearance of authorized view set and dataset resources in the v1 REST reference likewise does not make them GA.		
SG-GCP-GECX-000060	A capability certification review MUST be completed and approved before any Gemini Enterprise for CX component processes production member conversation data.	Every component of this suite reads or writes unstructured member conversation, which is among the densest concentrations of protected health information the organization holds, and several of its configuration decisions	High	Med		Sequence the certification before the first agent application, the first CX Insights location initialization, and the first conversation ingestion. Google states that encryption key settings for a CX Insights location cannot be	https://docs.cloud.google.com/gemini-enterprise-cx ; https://cloud.google.com/security/compliance/hipaa ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/cmek ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/cmek	HIPAA: 164.308(a)(1)(ii)(A) (Risk Analysis), 164.308(a)(8) (Evaluation); NIST 800-53: CA-2 (Control Assessments), RA-3 (Risk Assessment), SA-8 (Security and Privacy Engineering Principles), PL-8

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		cannot be reversed after first use. Certification is the gate that forces the irreversible decisions - encryption specification, residency region, project boundary, perimeter membership, retention - to be made deliberately rather than discovered after data has landed.				changed once CMEK is enabled and cannot be configured if CX Insights data already exists, and that existing CX Agent Studio resources cannot be CMEK integrated retroactively, with export and restore into a new project as the remedy. The residency region is fixed by the location specified when resources are created. Conversation TTL can be changed later and conversations can be deleted, but conversations ingested before a TTL is set remain until deleted. A certification that runs after a pilot has ingested real conversatio	ini-enterprise-cx/insights/cmek; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/region ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/tl	(Security and Privacy Architectures); NIST AI RMF (AI 100-1): GOVERN, MAP, MEASURE, MANAGE

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
						ns therefore cannot remediate the encryption decisions without rebuilding the resources.		
SG-GCP-GECX-000070	Newly released Gemini Enterprise for CX features MUST be reviewed and explicitly approved before enablement , on a review cadence no longer than monthly.	The suite ships features continuously across three independent release-note streams, and the CX Agent Studio release notes alone record twelve feature entries between general availability on February 4, 2026 and July 1, 2026. New features become available as they ship rather than on an organization-controlled schedule, so an unreviewed release can become a production configuration change that no one authorized.	Med	Med		Assign a named owner for each of the three release-note streams - CX Agent Studio, CX Insights, and Agent Assist - and for the suite overview page, which has no release notes of its own but is where a new component such as Commerce agents first appears. Tool types can also appear in the CX Agent Studio tools overview without a release note (File search and Widget tools were found this way on 2026-09-23), so reconcile	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/release-notes ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/release-notes	HIPAA: 164.308(a)(8) (Evaluation); NIST 800-53: CM-3 (Configuration Change Control), CM-4 (Impact Analyses), CA-7 (Continuous Monitoring)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		Agents as tools and traffic splitting are both examples of additions that materially changed the authorization and rollout surface.				the tools overview at the same review. The review asks three questions per entry - does it change what data leaves the boundary, does it change what identity an action runs as, and does it change a setting this guide pins. Record the review outcome so the certification evidence stays current between annual reassessments.		
SG-GCP-GECX-000080	The configuration baseline for every Gemini Enterprise for CX project - guardrails, tools, deployment channels, encryption, residency, retention, and audit settings - MUST be documented and drift-checked at	Almost every control in this guide is a project or agent setting that a holder of the relevant editor role can change without a deployment, a code review, or a change ticket. The ten-role IAM family means several	Med	Med		Capture the baseline as configuration exported through the API rather than as console screenshots, so the comparison can be automated. The high-value drift signals are guardrail level changes, new tool registration	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control	NIST 800-53: CM-2 (Baseline Configuration), CM-3 (Configuration Change Control), CM-6 (Configuration Settings), CA-7 (Continuous Monitoring)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	least quarterly.	different people can each alter one facet of the security posture independently, so the aggregate configuration is nobody's job to know unless a baseline records what it is supposed to be.				s, a deployment channel gaining public access, and a change to security settings - all four appear in Admin Activity or Data Access audit logs and can be alerted on directly.	enterprise-cx/cx-agent-studio/audit-logging	
SG-GCP-GEEX-000090	Personnel who build, deploy, or administer Gemini Enterprise for CX agent applications SHOULD complete role-specific training covering the confused-deputy tool execution model and the irreversible configuration decisions documented in this guide.	The two failure modes most likely to produce a material incident in this product are both invisible in the builder's workflow: a tool executes with the service agent's permissions, or with an identity configured on the tool, rather than the caller's, and several encryption and residency settings cannot be changed after first use. Neither is surfaced by	Med	Low		The training does not need to be lengthy. It needs to convey four things: tools commonly run as the CX Agent Studio service agent or another identity configured on the tool rather than as the end user, data store retrieval has no documented mechanism for applying the end user's permissions, the project boundary is the real	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/cmek	HIPAA: 164.308(a)(5) (Security Awareness and Training); NIST 800-53: AT-2 (Literacy Training and Awareness), AT-3 (Role-based Training), SA-8 (Security and Privacy Engineering Principles)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		the console at the moment the decision is made, so a builder who has not been told will not infer them from the interface.				security boundary, and CMEK and residency close at first use. The source material is the tool execution model, the data store retrieval model, the CX Insights encryption specification, the CX Agent Studio CMEK integration, and the residency region.		
SG-GCP-GEEX-000100	Administrative and builder access to CX Agent Studio, CX Insights, and Agent Assist MUST be federated through the organization's enterprise identity provider.	Federation is the trust anchor that extends existing conditional access policy, multi-factor enforcement, joiner-mover-leaver lifecycle, and session control to this suite. Without it, access to a surface holding member conversation content depends on a separate identity store whose	High	Med		Federate the Google Cloud identity used to reach the console and the APIs, not just the console, either through Cloud Identity or Google Workspace single sign-on with the enterprise IdP or through Workforce Identity Federation. Confirm that the API path is covered as well,	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx ; https://cloud.google.com/iam/docs/workforce-identity-federation ; https://cloud.google.com/architecture/identity/single-sign-on	HIPAA: 164.312(d) (Person or Entity Authentication), 164.308(a) (3) (Workforce Security); NIST 800-53: IA-2 (Identification and Authentication (Organizational Users)), IA-5 (Authenticator Management), AC-17 (Remote Access); HITRUST CSF v11: 01.q (User Identification)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		deprovisioning is not tied to the HR record, leaving orphaned accounts with standing access to conversation transcripts after a person leaves.				because a service account key or a personal gcloud credential bypasses federation entirely, which is why service account keys are separately prohibited for these roles.		n and Authentication), 01.j (User Authentication for External Connections)
SG-GCP-GEEX-000110	Multi-factor authentication MUST be enforced for every human user account holding any CX Agent Studio (roles/ce s.*) or CX Insights (roles/contactcenterinsights.*) role.	A single compromised builder credential is sufficient to register a tool that reaches a backend system, to change a guardrail level, or to read conversation transcripts in bulk, because these roles operate on a surface that has no second approval step. Credential theft through phishing or reuse is the dominant initial access vector, and MFA is the control that breaks it.	High	Low		Enforce at the identity provider so the requirement covers console, gcloud, and API access uniformly. Google notes that super admins can bypass single sign-on, so enable Google two-step verification for super-admin accounts as well. Phishing-resistant factors are preferred for roles/ce s.admin, roles/ce s.appEditor, roles/ce s.securitySettings	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://cloud.google.com/architecture/identity/single-sign-on ; https://docs.cloud.google.com/iam/docs/best-practices-service-accounts	HIPAA: 164.312(d) (Person or Entity Authentication); NIST 800-53: IA-2(1) (Multi-factor Authentication to Privileged Accounts), IA-2 (Identification and Authentication (Organizational Users)), IA-5 (Authentication Management); HITRUST CSF v11: 01.q (User Identification and Authentication)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
						Editor, roles/ces.guardrailsEditor, roles/ces.toolsEditor, and roles/ces.deploymentsEditor, which are the roles that can change the security posture or push to production. Service accounts and service agents that hold these roles cannot complete an interactive second factor and are outside this requirement; govern them through least-privilege grants, a prohibition on user-managed keys, and workload identity.		
SG-GCP-GECX-000120	The roles/ces.admin role MUST be granted only to named individual administrators.	The admin role provides full access to CX Agent Studio resources, which means it	High	Low		Google publishes ten CX Agent Studio roles precisely so that admin does not have to	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs	HIPAA: 164.312(a)(1) (Access Control), 164.308(a)(4) (Information Access Management); NIST

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		collapses the ten-role separation the product otherwise offers into a single grant covering apps, agents, tools, guardrails, evaluations, security settings, and deployments. A group grant makes the effective administrator or population a function of group membership managed elsewhere, so the number of people who can silently alter the security posture is unknown to the people accountable for it.				be the default. Grant appEditor, agentEditor, toolsEditor, guardrailsEditor, evalsEditor, securitySettingsEditor, or deploymentEditor to match the actual job. Reserve admin for a small named set and include it in the quarterly entitlement recertification. Group grants do not satisfy this requirement. The admin role also carries every CX Insights permission - Google's product access-control page lists the CX Insights Admin role (roles/contactcenterinsights.admin) as its base role - so it grants full access to CX Insights conversations as well as CX	.cloud.google.com/iam/docs/roles-permissions/ces	800-53: AC-6 (Least Privilege), AC-6(1) (Authorize Access to Security Functions), AC-2 (Account Management), AC-3 (Access Enforcement); HITRUST CSF v11: 01.c (Privilege Management)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
						Agent Studio resources.		
SG-GCP-GECX-000130	Basic IAM roles - the legacy Owner, Editor, and Viewer roles and the Admin, Writer, and Reader basic roles - MUST NOT be granted on any project hosting a Gemini Enterprise for CX component.	Basic roles predate the product's own role family and, in Google's words, "include thousands of permissions across all Google Cloud services", including ces.google.com/enterprise-leap and contactcenterinsights.google.com . A project Viewer therefore reads conversation content, and a project Editor registers tools and changes guardrails, without either grant appearing in any CX-specific access review. Google's own guidance is: "In production environments, do not grant basic roles unless	High	Low		Audit existing bindings before enabling the APIs, because a pre-existing project Editor binding becomes a CX Agent Studio editor binding the moment the API is turned on. This is one of the reasons this guide requires a dedicated project per trust domain rather than reuse of an existing one. Google documents that only owners of the associated project can create a WhatsApp or Instagram deployment; that is not an exception to this requirement, and the channel stays unavailable	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://cloud.google.com/iam/docs/roles-overview ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/whatsapp	HIPAA: 164.312(a)(1) (Access Control); NIST 800-53: AC-6 (Least Privilege), AC-3 (Access Enforcement), AC-2 (Account Management); HITRUST CSF v11: 01.c (Privilege Management)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		there is no alternative."				until Google documents a creation path that does not need the Owner role.		
SG-GCP-GECX-000140	The <code>roles/cloudsecuritysettings.editor</code> role MUST be held by a different set of individuals than those holding <code>roles/cloudsecuritysettings.agenteditor</code> or <code>roles/cloudsecuritysettings.toolseditor</code> .	The project Security Settings resource holds a single control, the endpoint control policy: the allowed origins list and its enforcement scope, which together decide which HTTP(S) endpoints tools and callbacks may call. Tool editors choose where a tool sends conversation-derived parameters, and agent editors do the same for callbacks. Where one person holds both sides, the same identity can register a tool or callback pointing at a new host and add	Med	Low		This is a separation-of-duties control, not a least-privilege control - it constrains combinations rather than individual grants. Implement it as a check in the access-request workflow and as a periodic query over IAM policy bindings, because IAM itself will not prevent the combination. The Security Settings resource carries no logging, redaction, or export settings; those are agent application settings changed with the <code>ces.apps.update</code> permission, which	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/rest/v1beta/SecuritySettings ; https://docs.cloud.google.com/iam/docs/roles-permissions/ces	HIPAA: 164.308(a)(3) (Workforce Security), 164.312(a)(1) (Access Control); NIST 800-53: AC-5 (Separation of Duties), AC-6 (Least Privilege), AC-6(1) (Authorize Access to Security Functions); HITRUST CSF v11: 01.c (Privilege Management)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		that host to the allowed origins, opening an egress path for member data with no second party in the path. The product's role split makes this separation available at no operational cost.				roles/ces.appEditor and roles/ces.admin hold, so this separation does not protect them. roles/ces.admin holds every permission on both sides and is governed by the admin role's own restrictions.		
SG-GCP-GECX-000150	The roles/ces.deploymentsEditor role MUST be restricted to personnel explicitly authorized to promote changes to production.	Deployment is the only step between an agent configuration and live member traffic. Because the product supports traffic splitting, which divides user conversations across different agent application versions within a single deployment channel, a deployment editor can also direct a share of production conversations to a	High	Low		Traffic splitting must never direct production traffic to an unreviewed agent version. Deployment create, update, and delete are DATA_WRITE methods, so they appear in Data Access audit logs rather than Admin Activity logs; enable Data Access audit logging for ces.googleapis.com and alert	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deployment/traffic-split ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging ; https://docs.cloud.google.com/iam/docs/roles-permissions/ces	HIPAA: 164.308(a)(3) (Workforce Security); NIST 800-53: AC-5 (Separation of Duties), AC-6 (Least Privilege), CM-3 (Configuration Change Control), CM-5 (Access Restrictions for Change); HITRUST CSF v11: 01.c (Privilege Management)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		different agent version without changing the agent itself.				on those methods. Agent builders do not receive this role by default; where a builder also promotes, the grant is a named exception with a recorded approver.		
SG-GCP-GECX-000160	Direct bindings of the <code>roles/cloud.googleapis.com/clientRole</code> MUST be limited to the service identities used by approved deployment channels and to the documented end-user principal set of an approved OAuth2 deployment channel.	The client role provides query access to agents - its permissions are <code>ces.sessions.runSession</code> , <code>ces.sessions.bidirectionalRunSession</code> , and <code>ces.tools.execute</code> - which is the runtime conversation path rather than an administrative one. It is the role a self-hosted token broker's service account holds, so every direct grant of it is effectively a new channel through which conversatio	High	Low		Inventory direct client role bindings alongside the approved deployment channel inventory - every direct binding should map to an approved channel, and one that does not is either an undocumented integration or a leftover from testing. Google includes the client role as a base role of admin, <code>agentEditor</code> , <code>toolsEditor</code> , <code>guardrailsEditor</code> , and <code>evalsEditor</code> , so builders	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/web-widget ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy ; https://docs.cloud.google.com/iam/docs/roles-permissions/ces	HIPAA: 164.312(a)(1) (Access Control), 164.312(d) (Person or Entity Authentication); NIST 800-53: AC-3 (Access Enforcement), AC-6 (Least Privilege), IA-9 (Service Identification and Authentication), AC-2 (Account Management); HITRUST CSF v11: 01.c (Privilege Management), 01.q (User Identification and Authentication)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		ns can be initiated and tools executed. Granting it to a broad group makes the set of parties who can converse with a production agent, and therefore reach whatever its tools reach, unbounded .				hold its permissions through those roles; govern them through the builder role requirements rather than this inventory. Where a web widget uses the OAuth2 option, end users sign in and their own credentials are used to access the agent application; treat that principal set as an approved channel with a documented owner rather than as an ad hoc grant. Inbound A2A callers, where the A2A Protocol is enabled, also require this role and are channels in the same sense.		
SG-GCP-GECX-000170	The CX Agent Studio service agent <code>service-PROJECT_N</code>	Google documents that OpenAPI tool actions execute with the	High	Med		Treat each new grant to this service agent as a change to the blast	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-	HIPAA: 164.312(a)(1) (Access Control), 164.308(a)(4) (Informatio

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	UMBER@gcp-sa-ces.iam.gserviceaccount.com MUST be granted only the minimum IAM roles required by the approved tools in that project.	permissions granted to the CX Agent Studio service account rather than those of the end user, and names minimum IAM on that account as one of its three recommended mitigations. Every role granted to the service agent is therefore added to the effective reach of every agent in the project, including agents a different team built and agents reachable by anonymous callers.				radius of every agent in the project, and require the same review as adding a tool. Where a tool needs broad access to a backend, the correct answer is usually a separate project rather than a broader grant. Google's other two stated mitigations, dedicated projects and VPC Service Controls, are each carried by their own requirement in this guide.	studio/tool/open-api; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls	n Access Management); NIST 800-53: AC-6 (Least Privilege), AC-3 (Access Enforcement), IA-9 (Service Identification and Authentication), CM-7 (Least Functionality); HITRUST CSF v11: 01.c (Privilege Management); OWASP Agentic Top 10 2026: ASI03 (Identity and Privilege Abuse)
SG-GCP-GECX-000180	Service account keys MUST NOT be created for any identity holding a Gemini Enterprise for CX role.	A downloaded service account key is a long-lived bearer credential that bypasses federation, conditional access, and multi-factor enforcement	High	Low		Use workload identity federation for external callers and attached service accounts for workloads inside Google Cloud. The self-hosted token	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls	HIPAA: 164.312(d) (Person or Entity Authentication); NIST 800-53: IA-5 (Authenticator Management), IA-9 (Service Identification and Authentication)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		nt, and it does not expire on personnel departure. Because the client role is a conversation-initiation credential and the editor roles alter what agents can reach, a leaked key for either is directly equivalent to unauthorized access to member conversation content.				broker pattern runs on Cloud Run functions with a service account that needs no key. Enforce with the organization policy constraint <code>iam.managed.disableServiceAccountKeyCreation</code> (or the legacy <code>iam.disableServiceAccountKeyCreation</code>), which disables the creation of new external service account keys.	studio/deploy/web-widget; https://cloud.google.com/iam/docs/best-practices-for-managing-service-account-keys ; https://cloud.google.com/resource-manager/docs/organization-policy/restricting-service-accounts	on), AC-6 (Least Privilege); HITRUST CSF v11: 01.q (User Identification and Authentication)
SG-GCP-GECX-000190	Entitlements to all <code>ces.googleapis.com</code> and <code>contactcenterinsights.googleapis.com</code> roles MUST be recertified at least quarterly by the accountable business owner.	Access to this suite accumulates through pilots, incident response, and vendor-led enablement sessions, and none of those paths has a natural expiry. Because CX Insights project-level roles expose every	Med	Med		Recertify the CX Insights viewer and editor populations with particular care, and treat the approved CX Insights access group as the authoritative list. Recertification should confirm both that the person	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/best-practices-for-fine-grained-access-control	HIPAA: 164.308(a)(3) (Workforce Security), 164.308(a)(4) (Information Access Management); NIST 800-53: AC-6(7) (Review of User Privileges), AC-2 (Account Management), AC-3 (Access Enforcement)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		conversation in the project, fine-grained scoping being Pre-GA and therefore unavailable as the control of record, an unreviewed viewer grant is standing access to the complete member conversation corpus rather than to a bounded slice of it.				still needs access and that the role held is still the narrowest one that fits the job.		nt), AC-6 (Least Privilege); HITRUST CSF v11: 01.e (Review of User Access Rights)
SG-GCP-GECX-000200	Contact centre representatives receiving Agent Assist suggestions MUST authenticate through the organization's identity provider.	Agent Assist places generated summaries, suggested replies, and knowledge excerpts in front of a human handling a live member interaction, and CX Insights subsequently evaluates that human's performance against the same conversation record. Both the disclosure	High	Med		The agent identifier is also the field CX Insights authorized views filter on, so a reliable representative identity is a prerequisite for any future adoption of fine-grained access control once it leaves Preview. Confirm the identifier propagated by the contact centre	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/best-practices-for-fine-grained-access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/common-integrations ; https://cloud	HIPAA: 164.312(d) (Person or Entity Authentication), 164.312(b) (Audit Controls); NIST 800-53: IA-2 (Identification and Authentication (Organizational Users)), AU-3 (Content of Audit Records), AC-3 (Access Enforcement); HITRUST CSF v11: 01.q (User

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		of conversation content to a representative and the attribution of a quality assessment to one depend on knowing reliably which representative was present.				platform is the enterprise identity and not a platform-local seat number. The authenticated identity must also be recorded against each conversation the representative handles, since attribution is what makes both the disclosure and any later quality assessment defensible.	d.google.com/iam/docs/workforce-identity-federation; https://cloud.google.com/architecture/identity/single-sign-on	Identification and Authentication), 09.aa (Audit Logging)
SG-GCP-GECX-000210	Standing administrative access to production Gemini Enterprise for CX projects SHOULD be replaced by time-bound, approved elevation.	The administrative actions this suite requires - changing a guardrail, registering a tool, altering retention - are infrequent and individually short. Standing admin rights convert an occasional need into a permanent exposure,	Med	Med		Elevation requests should name the change being made so the audit log entry can be correlated to an approval. This pairs with administrative-action alerting: an action with no corresponding elevation record is the signal	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control	HIPAA: 164.308(a)(4) (Information Access Management); NIST 800-53: AC-2(11) (Usage Conditions), AC-6 (Least Privilege), AC-6(1) (Authorize Access to Security Functions), AU-6 (Audit Record Review, Analysis, and

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		and because several of those actions are irreversible in effect, an attacker holding a compromised standing credential does not need to wait for an opportunity.				worth investigating.		Reporting), AC-2 (Account Management); HITRUST CSF v11: 01.c (Privilege Management)
SG-GCP-GECX-000220	Access to Gemini Enterprise for CX administrative surfaces SHOULD be conditioned on managed-device posture.	Builder and administrator sessions display member conversation content and permit configuration changes that alter what production agents can reach. An unmanaged endpoint provides no assurance of disk encryption, endpoint detection, or absence of credential-stealing malware, so a session from one extends the trust boundary to a device the organization cannot attest.	Med	Med		Implement at the identity provider or through Context-Aware Access rather than inside the product, which exposes no device-posture control of its own. Apply at minimum to the admin, securitySettingsEditor, deploymentEditor, and CX Insights viewer populations.	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx	HIPAA: 164.312(a)(1) (Access Control), 164.310(b) (Workstation Use); NIST 800-53: AC-17 (Remote Access), IA-3 (Device Identification and Authentication), AC-2(11) (Usage Conditions), AC-2 (Account Management); HITRUST CSF v11: 01.j (User Authentication for External Connections)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
SG-GCP-GEEX-001410	The <code>roles/ces.appEditor</code> role SHOULD be held by a different set of individuals than those holding <code>roles/ces.agentEditor</code> or <code>roles/ces.toolsEditor</code> in projects serving production traffic.	Redaction, Cloud Logging, BigQuery export, audio recording, and interaction data storage are agent application settings, changed with the <code>ces.apps.update</code> permission that the App Editor role holds and the agent and tool editor roles do not. Where one person holds both sides, the same identity can change what an agent reaches and switch off the redaction or the record that would show what it did, with no second party in the path.	Med	Med		App Editor also creates and imports applications and creates and restores application versions, so separating it moves those steps to a release or platform role; that operational cost is why this is a recommendation rather than a hard requirement. Where a team is too small to separate the roles, record the exception and rely on alerts for application setting changes, correlated with an approved change record, as the compensating control. <code>roles/ces.admin</code> holds both sides and is governed by the admin role's own restrictions.	https://docs.cloud.google.com/iam/docs/roles-permissions/ces ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/settings	HIPAA: 164.308(a)(3) (Workforce Security), 164.312(b) (Audit Controls); NIST 800-53: AC-5 (Separation of Duties), AC-6 (Least Privilege), AU-9 (Protection of Audit Information); HITRUST CSF v11: 01.c (Privilege Management), 09.ac (Protection of Log Information)
SG-GCP-GEEX-	Guardrails MUST be	Google states that	High	Low		Record the four	https://docs.cloud.google.com/	NIST 800-53: CM-6

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
000230	explicitly configured and documented on every agent application rather than left at the shipped default.	each agent application is provided with default guardrails that the builder may modify, but the documentation does not name which safety level or which protections that default comprises. A control whose configured value is unknown cannot be attested to an assessor, cannot be drift-checked, and may change when Google revises the default for new applications. Explicit configuration converts an unknown into a baseline.				guardrail dimensions per agent: Prompt guard state and outcome, Blocklist contents and match mode, Safety level, and any Rules. This inventory is the artifact the quarterly configuration drift check compares against. Confirm the configured values by reading them back through the API rather than trusting the console form state.	le.com/gemini-enterprise-cx/cx-agent-studio/guardrail; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio	(Configuration Settings), CM-2 (Baseline Configuration), SI-15 (Information Output Filtering), SI-10 (Information Input Validation); OWASP LLM Top 10 2025: LLM01 (Prompt Injection)
SG-GCP-GECX-000240	The Safety guardrail MUST be set to Strict on every member-facing agent application, and to Strict or	Google describes Relaxed as prioritizing flexible generation and low latency, which is an explicit trade of	High	Low		Strict prioritizes deep harm filtering and is required for member-facing agents; Balanced is permitted	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/guardrail	NIST 800-53: SI-15 (Information Output Filtering), SI-10 (Information Input Validation), CM-6 (Configuration

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	Balanced on every other agent application that can reach member data.	harm filtering for responsiveness. On a member-facing health or benefits conversation, the harms the filter addresses are precisely the ones with regulatory and reputational consequence, and latency is not the constraint worth optimizing against them.				for internal-facing agents where a documented rationale exists. Record which level each agent uses and why, because the choice is invisible in the conversation transcript and cannot be reconstructed later. The Relaxed setting is not acceptable in production on any agent that can reach member data.		on Settings); OWASP LLM Top 10 2025: LLM09 (Misinformation); MITRE ATLAS: AML.T0054 (LLM Jailbreak)
SG-GCP-GECX-000250	The Prompt guard MUST be enabled on every agent application, with a defined outcome for a triggered guard.	Prompt guard is the product's stated protection against prompt-based attacks such as instructing the agent to ignore its instructions. In this suite the injected instruction does not have to come from the	High	Low		Choosing the outcome matters as much as enabling the guard. "Say exactly" is a safe terminal state. The "Handoff to an agent" outcome transfers control to another CX Agent Studio agent, not to a	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/guardrail ; https://docs.cloud.google.com/gemini-enterprise-	NIST 800-53: SI-10 (Information Input Validation), SI-15 (Information Output Filtering); OWASP LLM Top 10 2025: LLM01 (Prompt Injection); MITRE ATLAS: AML.T0051.001 (LLM Prompt Injection - Indirect)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		member: tool responses, retrieved data store content, and knowledge base excerpts all enter the model context, so an attacker who can influence any of those sources reaches the same objective indirectly.				person; to reach a human, hand off to an agent whose only behavior is to call the <code>end_session</code> system tool with <code>session_escalated</code> set to <code>True</code> . A generated response re-enters the model with the adversarial content still in context. Prompt guard is a filter and not a boundary; the architectural half of this control is treating tool output and retrieved content as untrusted input.	cx/cx-agent-studio/tool/system	
SG-GCP-GECX-000260	A Blocklist guardrail SHOULD be configured on member-facing agent applications to suppress terms the organization has designated as	Safety filters address broad harm categories and will not catch organization-specific disclosures: internal system names, unreleased product terms, legally	Med	Med		Apply the Blocklist to agent responses at minimum; applying it to user input as well is useful for detecting probing but will generate false positives	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/guardrail	NIST 800-53: SI-15 (Information Output Filtering), CM-6 (Configuration Settings), SI-10 (Information Input Validation); OWASP LLM Top 10 2025: LLM02

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	prohibited in a generated response.	constrained phrasing around coverage determinations, or competitor references. The Blocklist is the only term-matching guardrail, and it applies to agent responses as well as user input.				on legitimate member language. The regex match mode is powerful and correspondingly easy to write too broadly - test against a sample of real transcripts before deployment.		(Sensitive Information Disclosure)
SG-GCP-GEEX-000270	Agent instructions, prompts, application variables, and tool configurations MUST NOT contain credentials, API keys, tokens, or connection strings.	Agent instructions and application variables are documented as data at rest inside CX Agent Studio and are readable by every holder of the viewer role, exportable through the import and export path, and reachable by the model itself at inference time. A secret placed there is therefore disclosed to a wider population than any secret store	High	Low		Google supports Secret Manager for OpenAPI tool credentials, and MCP tools carry the same authentication options, so there is a supported path for every case where a secret is genuinely needed. Scan agent instructions and variables for high-entropy strings and known key formats as part of the pre-deployment agent	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/region; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/mcp	HIPAA: 164.312(a)(1) (Access Control), 164.312(d) (Person or Entity Authentication); NIST 800-53: IA-5 (Authenticator Management), SC-28 (Protection of Information at Rest), AC-6 (Least Privilege); HITRUST CSF v11: 10.g (Key Management); OWASP LLM Top 10 2025: LLM02 (Sensitive Information Disclosure)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		would permit and can be surfaced verbatim in a generated response through prompt injection.				security review.		
SG-GCP-GECX-000280	Every agent application MUST be security reviewed and approved before it is deployed to a channel carrying production traffic.	The security posture of an agent is the union of its instructions, its guardrails, its tool set, and the reach of the project service agent, and no single console screen shows that union. Because tools execute with the platform identity, an agent that looks harmless in isolation can inherit the full backend reach of every other tool in its project, which only a review that considers the project as a whole will catch.	High	Med		The review covers at minimum: the tool list and what each tool can reach, guardrail configuration, whether any data store grounds the agent on content narrower in audience than the agent itself, the deployment channel and whether it permits anonymous access, and whether the agent handles determination-bearing content that requires a human decision maker. Record the approval as certification evidence.	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy	HIPAA: 164.308(a)(1)(ii)(A) (Risk Analysis), 164.308(a)(8) (Evaluation); NIST 800-53: CM-3 (Configuration Change Control), CM-4 (Impact Analyses), SA-11 (Developer Testing and Evaluation), RA-3 (Risk Assessment)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
SG-GCP-GEEX-000290	Agent evaluations MUST be executed and reviewed against a documented test set before an agent application is promoted to production, and after any change to its instructions, tools, or guardrails.	CX Agent Studio provides an evaluation capability with import and export of evaluation data, which makes a regression test set a supported artifact rather than an aspiration. Agent behaviour is emergent rather than specified, so a change to instructions intended to improve one interaction can silently alter refusal behaviour, tool selection, or disclosure in another, and only a held test set will detect it.	Med	Med		The test set must include adversarial cases, not only happy paths: prompt injection attempts, requests for information the agent should refuse, and attempts to induce a tool call the caller is not entitled to. Evaluation operations may appear on the v1beta API surface, which this guide restricts to non-production projects, so run evaluations there and promote only the reviewed configuration.	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio	NIST 800-53: SA-11 (Developer Testing and Evaluation), CM-3 (Configuration Change Control), CM-4 (Impact Analyses), SI-10 (Information Input Validation); OWASP LLM Top 10 2025: LLM01 (Prompt Injection)
SG-GCP-GEEX-000300	Agent applications MUST NOT be the sole authority for a coverage, eligibility, clinical, or other adverse determination	A generative agent produces a fluent answer whether or not the underlying retrieval succeeded. The data store tool's grounding	High	Med		Constrain member-facing agents to informational responses and route determination-bearing interactions to a human with the agent	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio	NIST 800-53: SA-8 (Security and Privacy Engineering Principles), PL-8 (Security and Privacy Architectures); OWASP LLM Top 10

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	communicated to a member.	score setting can suppress weakly grounded responses, but nothing in the suite reliably prevents an ungrounded or incorrect determination from being delivered. An adverse determination carries notice, appeal, and accuracy obligations under claims-procedure rules such as 29 CFR 2560.503-1, which governs ERISA-covered employee benefit plans, and those obligations attach to the organization regardless of which system produced the text.				acting as an assistant. Where an agent surfaces a determination made elsewhere, it must present the determination reached by the system of record rather than restating it in generated language.	agent-studio/guardrail; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/data-store ; https://www.ecfr.gov/current/title-29/subtitle-B/chapter-XXV/subchapter-G/part-2560/section-2560.503-1	2025: LLM09 (Misinformation); OWASP Agentic Top 10 2026: ASI09 (Human-Agent Trust Exploitation); NIST AI RMF (AI 100-1): GOVERN, MANAGE
SG-GCP-GECX-000310	Members interacting with a Gemini Enterprise for CX agent MUST be	Members are entitled to know when they are dealing with an automated agent, and	High	Low		Configure the fallback behavior and the guardrail outcomes so that escalation	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/guar	NIST 800-53: PT-5 (Privacy Notice), PT-5(1) (Just-in-time Notice);

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	informed that they are interacting with an automated agent and offered a path to reach a human.	some state laws restrict undisclosed bot communication online - for example, California Business and Professions Code section 17941 in commercial and electoral contexts. A member who cannot reach a person has no way to correct an agent that has misunderstood a health or benefits question. The suite supports escalation: Google documents the end_session system tool as used "to escalate to a human agent", and Agent Assist exists to support the human who receives the escalation, so the path is available and needs				reaches a person. The "Handoff to an agent" outcome transfers control to another CX Agent Studio agent, not a human, so route it to an agent that calls end_session with session_escalated set to True, and confirm the human receiving the handoff has the conversation context. Confirm with counsel which state disclosure laws apply to each channel. Verify the disclosure appears on every approved deployment channel, including voice, where it must be spoken rather than displayed.	drail; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/system	NIST AI RMF (AI 100-1): GOVERN, MANAGE

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		only to be configured and disclosed.						
SG-GCP-GECX-000320	Agent applications generated by the Start with AI capability MUST be reviewed in full, including their generated instructions and tools, before deployment.	Start with AI generates a starter agent and its tools from supplied documentation, which means both the agent's instructions and its tool registrations are model output rather than a human design. The generated tool set in particular determines what the agent can reach, and it is produced by inference over documentation rather than by an authorization decision.	Med	Low		Treat the generated artifact as a draft. The standard pre-deployment agent security review applies unchanged, with additional attention to tools the generator created that no one requested. Start with AI is itself Preview: its feature page carries the Pre-GA Offerings Terms as of 2026-09-24, and the February 4, 2026 release note declares CX Agent Studio generally available and lists Start with AI among the launch's capabilities without stating that the feature is GA. Use it only in a non-	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/quick/generate-agent ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio	NIST 800-53: CM-3 (Configuration Control), AC-6 (Least Privilege), CM-4 (Impact Analyses)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
						production project, on documentation that contains no protected health information or other personal data, and review its output here before any of it reaches production.		
SG-GCP-GECX-000330	Where one agent is invoked as a tool of another - within one agent application or, through the A2A Protocol, across agent applications and projects - the delegation chain MUST be documented and reviewed as a single authorization surface.	Google's release notes announced agents as tools on April 17, 2026 and declared the capability generally available on September 24, 2026. An agent-as-a-tool is another agent in the same application, invoked with its own instructions and tool set. Because those tools execute with the identities configured on them - the project service agent where Service	High	Med		Record the full graph of which agents invoke which, and review the union of tools reachable through the graph rather than the tool list of any single agent. A cycle or a chain crossing a trust boundary is a finding. For each A2A link also record the authentication method, the identity each side presents, what session context crosses, and which project owns each	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/agent-as-tool ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/agent-as-tool	HIPAA: 164.312(a)(1) (Access Control); NIST 800-53: AC-3 (Access Enforcement), AC-6 (Least Privilege), AC-4 (Information Flow Enforcement), PL-8 (Security and Privacy Architectures); HITRUST CSF v11: 01.c (Privilege Management), 01.v (Information Access Restriction); OWASP LLM Top 10 2025: LLM06 (Excessive Agency); OWASP Agentic Top 10 2026: ASI07

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		agent ID token authentication is used - rather than the end user's, a delegation chain does not narrow authority at each hop: the invoked agent's tools reach what their identities reach, regardless of what the caller was entitled to. A chain therefore aggregates rather than attenuates reach, and reviewing either agent alone will not reveal it. The A2A Protocol extends the same chain across application and project boundaries: a remote CX Agent Studio application is reached through the calling project's service agent, and an inbound A2A caller can write agent context directly into				end; the A2A Protocol tool is Preview as of 2026-09-24. This is the strongest single argument for separating projects by trust domain.	le.com/gemini-enterprise-cx/cx-agent-studio/tool/a2a-protocol	(Insecure Inter-Agent Communication); MITRE ATLAS: AML.T0053 (AI Agent Tool Invocation)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		the invoked session.						
SG-GCP-GECX-000340	Agent versioning and changelog history SHOULD be retained for the life of the agent application.	CX Agent Studio provides granular changelogs and rollback as a product capability. That history is the only record of what an agent was instructed to do at a given moment, which is what an incident investigation, a member complaint, or a regulatory inquiry will ask about. Conversation transcripts alone do not answer why the agent said what it said.	Low	Low		Where an investigation may need to reconstruct behavior beyond the retained changelog window, export the agent configuration on a schedule and retain the exports under the organization's records retention policy. Rollback is also the fastest containment action for a bad agent change, so exercise it at least once before relying on it in an incident. Do not prune changelog history as part of routine housekeeping.	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes	HIPAA: 164.312(b) (Audit Controls); NIST 800-53: CM-3 (Configuration Control), AU-11 (Audit Record Retention), SI-12 (Information Management and Retention), CP-9 (System Backup); HITRUST CSF v11: 06.c (Protection of Organizational Records)
SG-GCP-GECX-001260	Only models on the organization's approved model allowlist	CX Agent Studio exposes a model picker offering several Gemini	High	Low		Maintain the allowlist as an explicit artifact naming each approved	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/agen	NIST 800-53: CM-6 (Configuration Settings), CM-7 (Least Functionality)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	MUST be selected to power a Gemini Enterprise for CX agent application.	variants, and the choice determines the reasoning quality, the safety behaviour, and the latency of every member conversation the agent handles. Google states that CX Agent Studio models are performance-tuned for customer experience and may differ from the standard Vertex AI offering of the same name, so a model's behaviour here cannot be inferred from testing it elsewhere. Without an allowlist the model is whatever the builder picked from a dropdown, and it changes silently whenever Google revises the list.				model and the date its launch stage was checked, and reconcile it against the picker at the monthly release-note review. Voice-optimized and text-optimized models are separate entries and need separate approval, because a voice deployment reaches a different model than the text deployment of the same agent. Google can also change the model without builder action: the May 26, 2026 release note states that users who had not manually updated were automatically upgraded from Gemini 2.0 to Gemini 2.5 models. Treat such	t; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes	y), CM-2 (Baseline Configuration), SA-4 (Acquisition Process); OWASP LLM Top 10 2025: LLM03 (Supply Chain); NIST AI RMF (AI 100-1): GOVERN, MAP

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
						forced upgrades as allowlist changes and re-run the agent evaluations . The composite-v1 voice model, generally available since 2026-09-24, combines listener, thinking, and speaker sub-models whose minor versions Google may update automatically; approve it as one entry and re-run the voice agent evaluations at each monthly review rather than only on a visible model change.		
SG-GCP-GECX-001270	A model designated Preview in the CX Agent Studio model picker MUST NOT be selected for an agent application carrying	Google marks at least one model in the picker as Preview while presenting it alongside generally available models in the same dropdown, with no	High	Low		As of 2026-09-24 the Preview entry was gemini-3-flash, with composite-v1, gemini-3.7-flash, gemini-3.5-flash, gemini-2.5-flash and gemini-3.1-flash-live	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/agent ; https://docs.cloud.google.com/gemini-enterprise-cx/	HIPAA: 164.308(a)(8) (Evaluation); NIST 800-53: CM-7 (Least Functionality), CM-3 (Configuration Change Control), SA-4 (Acquisition

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	production traffic.	separation in the interface. A Preview model is governed by the Pre-GA Offerings Terms: no SLA, changeable or withdrawable without notice, and subject to Google's statement that Pre-GA offerings should not be used "to process personal data or other data subject to legal or regulatory compliance requirements". Google's HIPAA guidance says separately not to use Pre-GA offerings in connection with PHI. A builder selecting it is making a contractual and compliance decision through a dropdown that gives no indication				shown as generally available. Verify the current designations in the picker rather than relying on that list, because the composition changes without a release note. Enforce by reviewing the selected model during the pre-deployment agent security review.	agent-studio/resources/release-notes; https://cloud.google.com/terms/service-terms ; https://cloud.google.com/security/compliance/hipaa	Process), SA-8 (Security and Privacy Engineering Principles)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		one was made.						
SG-GCP-GECX-001280	A model override applied to an individual sub-agent MUST be documented and approved as a change to the agent application.	Google states that a global model can be set for the agent application and overridden for specific sub-agents. An override is invisible from the application-level configuration, so an agent reviewed and approved on one model can contain a sub-agent running on another, including one that is Preview or not on the allowlist. Because sub-agents frequently handle the narrower and more sensitive parts of a conversation, the override lands precisely where it matters most.	Med	Low		Enumerate sub-agent model assignments explicitly during review rather than reading the application-level setting alone, and record the effective model per sub-agent in the configuration baseline so the quarterly drift check can detect a change. Google states that audio agent applications do not allow overriding an agent's model except when the agent is used as a tool, so in voice applications check the model set on each agent used as a tool.	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/agent-t;https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/agent-as-tool	NIST 800-53: CM-3 (Configuration Control), CM-6 (Configuration Settings), CM-2 (Baseline Configuration), CM-4 (Impact Analyses); OWASP LLM Top 10 2025: LLM03 (Supply Chain)
SG-GCP-GECX-001290	The launch stage of a selected model	Google states that all models in CX	High	Low		This is the reason the allowlist records	https://docs.cloud.google.com/gemini-	HIPAA: 164.308(a)(8) (Evaluation)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	MUST be verified in the CX Agent Studio interface rather than inferred from that model's status in other Google Cloud products.	Agent Studio are considered generally available unless explicitly marked Preview in the interface, and that this launch stage is specific to CX Agent Studio and operates independently of a model's status in other Google Cloud products. A model that is generally available in Vertex AI may therefore be Preview here, and the reverse also holds. An engineer checking the model's status on its Vertex AI documentation page will reach a conclusion that does not govern this product.				where and when each launch stage was checked. Treat the CX Agent Studio picker as the only authoritative source for a model's stage within this product, and re-verify at each monthly release-note review rather than at model selection alone.	enterprise-cx/cx-agent-studio/agent; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes ; https://cloud.google.com/terms/service-terms	); NIST 800-53: CM-7 (Least Functionality), SA-4 (Acquisition Process), CA-7 (Continuous Monitoring), CM-3 (Configuration Change Control)
SG-GCP-GECX-000350	Each Gemini Enterprise for CX project	Google states that OpenAPI tool actions execute	High	High		This decision is made before the first agent	https://docs.cloud.google.com/gemini-enterprise-	HIPAA: 164.312(a)(1) (Access Control), 164.308(a)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	MUST contain only agent applications that share a single trust domain.	with the permissions granted to the CX Agent Studio service account rather than the end user's, and that service agent is a single identity per project. Every IAM grant made to it is therefore available to every agent application in the project whose tools authenticate as the service agent, and no in-product setting narrows those grants per application; tools configured with their own service account, OAuth, or API key credentials add their own reach on top. Combined with the Google-hosted token broker's public				application exists and is expensive to reverse, because moving an agent means recreating it, its tools, its deployment channels, and its data stores in a new project with a new perimeter. Google names dedicated projects as its own first recommended mitigation. Where a shared project is proposed for cost or operational reasons, the residual risk to accept is explicitly that every agent in it inherits every grant made to the project service agent. Agents serving different audiences or reaching different sensitivity tiers belong in separate projects, because	cx/cx-agent-studio/tool/open-api; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls	(4) (Information Access Management); NIST 800-53: AC-4 (Information Flow Enforcement), AC-6 (Least Privilege), SC-7 (Boundary Protection), PL-8 (Security and Privacy Architectures); HITRUST CSF v11: 01.v (Information Access Restriction); OWASP Agentic Top 10 2026: ASI03 (Identity and Privilege Abuse); MITRE ATLAS: AML.T0053 (AI Agent Tool Invocation)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		access path, the worst plausible configuration is an unauthenticated caller whose reach includes every grant held by the project service agent. For the service agent's permissions, the project boundary is the only boundary this product offers.				the project is the scope of the service agent whose permissions every tool executes with.		
SG-GCP-GEEX-000360	An inventory of every registered tool, its type, its target system, its authentication method, and its approving owner MUST be maintained and reviewed at least quarterly.	CX Agent Studio offers a growing catalog of tool types - eighteen in the tools overview as of 2026-09-24 - spanning arbitrary HTTP APIs, MCP servers, SaaS connectors, data stores, RAG knowledge bases, client-side functions, and code execution, and any holder of the toolsEditor	High	Med		The inventory is the input to the project-boundary judgement, so it must record what each tool can reach rather than only what it is called. Tool registration and modification (CreateTool, UpdateTool, and DeleteTool are DATA_WRITE methods) appear in Data Access	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging	NIST 800-53: CM-8 (System Component Inventory), CM-3 (Configuration Change Control), AC-6 (Least Privilege), SA-9 (External System Services)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		role can register one without a deployment . Because a registered tool extends what agents in the project can reach - an agent reaches it once assigned, and a Python code tool can call any tool defined in its application without assignment - an unmaintained inventory means the project's effective reach is unknown to the people accountable for it.				audit logs under <code>ces.googleapis.com</code> and should be alerted on so the inventory can be reconciled against actual changes; confirm Data Access audit logging is enabled for the service, because the reconciliation depends on it. Record assignment as well as registration: which agents each tool is assigned to, and whether the application contains a Python code tool. A2A Protocol tools, added to the tools overview on 2026-09-24 as Preview, reach remote agents; record the remote agent endpoint, its owner,	enterprise-cx/cx-agent-studio/reference/rest/v1/projects.locations.apps.tools; https://docs.google.com/geminienterprise-cx/cx-agent-studio/tool/a2a-protocol	

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
						and its authentication method if one appears in a project, as well as any remote agent tool type found in the REST tool resource.		
SG-GCP-GECX-000370	Static credentials used by OpenAPI and MCP tools - API keys and any other secret held in the tool configuration - MUST be stored in Secret Manager and referenced rather than embedded in tool configuration, agent instructions, or custom header values.	Google documents Secret Manager as the supported credential store for OpenAPI tools, with Secret Manager Secret Accessor granted to the CX Agent Studio service agent, and states that MCP tools carry the same authentication options. A credential held anywhere else in the product is readable by every holder of the viewer role, travels in configuration exports, and has no rotation or access-	High	Low		The Service agent ID token and Service Account authentication options are minted by the platform for each call and store no secret, so this requirement does not reach them; prefer them wherever the backend accepts a Google-issued identity. Google does not document where the OAuth option holds a client secret; confirm that before relying on it. MCP custom header values	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls	HIPAA: 164.312(a)(1) (Access Control), 164.312(d) (Person or Entity Authentication); NIST 800-53: IA-5 (Authenticator Management), SC-28 (Protection of Information at Rest), SC-12 (Cryptographic Key Establishment and Management), AC-6 (Least Privilege); HITRUST CSF v11: 10.g (Key Management)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		audit path of its own.				must be supplied by variables, which makes it tempting to place a static token in a variable - do not. Reference a Secret Manager secret instead. Note the perimeter interaction: Google documents that OpenAPI tools cannot reference authentication keys using secrets outside the VPC Service Controls perimeter, so the secret and the perimeter must be planned together.		
SG-GCP-GECX-000380	A tool MUST NOT be able to retrieve data beyond what the principal conversing with the agent is authorized to see, unless the	Because the tool executes as the project service agent and not as the caller, backend authorization is applied to the platform	High	Med		The backend must bind each request to a verified identifier the agent cannot choose - a session-bound identifier established	https://docs.cloud.google.com/gemini-enterprise-	HIPAA: 164.312(a)(1) (Access Control), 164.502(a) (Uses and Disclosures of PHI), 164.502(b) (Minimum Necessary); NIST 800-53: AC-3 (Access

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	backend authorizes every request against an identity bound to the session at authentication rather than supplied by the model.	identity rather than to the member. A tool wired to an API that can return any member's record will return any member's record when the model is persuaded to ask for one, and no guardrail reliably prevents that because the request is a legitimate tool call.				at authentication, not a value the model extracts from the conversation - and return only the objects that identifier is entitled to. A backend that cannot do that is not eligible for any agent whose audience is narrower than the backend's data, and an agent serving unauthenticated callers has no such identity, so its tools must not reach member data at all. This is the concrete form of the confused-deputy exposure that makes the project boundary the real security boundary in this product. CX Agent Studio passes no end-user identity to a	cx/cx-agent-studio/tool	Enforcement), AC-4 (Information Flow Enforcement), AC-6 (Least Privilege); HITRUST CSF v11: 01.v (Information Access Restriction); OWASP API Top 10 2023: API1 (Broken Object Level Authorization); OWASP Agentic Top 10 2026: ASI02 (Tool Misuse and Exploitation); MITRE ATLAS: AML.T0053 (AI Agent Tool Invocation)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
						tool backend on its own. For OpenAPI tools, the documented x-cs-session-context extension injects session context values, such as \$context.session_id, into a request parameter or header without the model choosing them; use it, or an equivalent server-side binding, to carry the session-bound identifier.		
SG-GCP-GECX-000390	Data store tools and File search tools MUST NOT be grounded on content whose authorized audience is narrower than the audience able to converse with the agent.	Neither the data store tool pages nor the REST definition of the data store tool offers any field or setting that carries the end user's identity into retrieval, whereas the connector tool in the same API explicitly supports end-user	High	Med		Curate corpora to the agent's audience rather than relying on retrieval to filter: for a member-facing agent, public and member-general content only, with no internal policy documents, case notes, or provider-specific material.	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/data-store ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool	HIPAA: 164.312(a)(1) (Access Control), 164.502(b) (Minimum Necessary); NIST 800-53: AC-3 (Access Enforcement), AC-4 (Information Flow Enforcement), AC-21 (Information Sharing), AC-6 (Least Privilege); HITRUST CSF v11:

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		authentication. The same holds for File search tools, which retrieve from a RAG knowledge base. Absent a documented ACL-aware retrieval path, the safe reading is that any content ingested into a data store is reachable by any caller who can reach the agent, and the grounding score setting does not change who can see what.				Connector data stores (for example Salesforce, Jira, Confluence, and BigQuery) are the type most likely to carry internal content and are within scope. Once a data store from one region is added to a tool, only data stores from that region can be added to it. The data store tool's Filter setting lets the model add a filter parameter to a retrieval call; the console lists Never as the default while the REST reference describes the unspecified default as including it for connector data stores, and in either case the filter is model-chosen and	agent-studio/reference/rest/v1/projects.locations.apps.tools; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/cloud-storage-data-store; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/website-data-store; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/file	01.v (Information Access Restriction); OWASP LLM Top 10 2025: LLM02 (Sensitive Information Disclosure)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
						not an access control. This reading rests on the absence of a documented permission-aware retrieval mechanism rather than on a Google statement; confirm with Google before relying on per-user retrieval.		
SG-GCP- GECX- 000400	Content ingested into a data store or RAG knowledge base used by a member-facing agent MUST be reviewed and approved before each ingestion and ingested only from locations under the organization's control.	Retrieved content enters the model's context and is acted upon as instruction-bearing input. Where a corpus includes externally authored material - a crawled website, a vendor document, a partner feed - an attacker who can edit that source has a durable indirect prompt injection path into	High	Med		Externally authored material, such as a vendor document or a partner publication, is admitted only as a reviewed snapshot copied into organization-controlled storage, and each refresh is a new ingestion that needs its own review. Website data stores are the highest-risk case because the crawl re-ingests	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/data-store ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool ; https://docs.cloud.google.com/gemini-enterprise-	NIST 800-53: SI-10 (Information Input Validation), SR-3 (Supply Chain Controls and Processes), CM-8 (System Component Inventory); OWASP LLM Top 10 2025: LLM01 (Prompt Injection); OWASP Agentic Top 10 2026: ASI06 (Memory and Context Poisoning); MITRE ATLAS:

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		every conversation in the corpus grounds, without ever interacting with the agent. Ingesting only from locations the organization controls means the corpus changes only when someone the organization authorizes re-ingests it.				whatever the page currently says, so restrict them to domains the organization controls - Google requires domain verification when website content is used as a source, which partly enforces this - and never point one at a third-party site. This requirement addresses the injection vector; the untrusted-input requirement addresses what the agent does with the result. File search tools, which upload files into a RAG knowledge base as a simpler alternative to data store tools, are in scope on the same terms.	cx/cx-agent-studio/tool/file; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/website-data-store	AML.T0051.001 (LLM Prompt Injection - Indirect)
SG-GCP-GEEX-	Tool responses,	Every source that	High	Med		Enforce architecture	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/website-data-store	HIPAA: 164.312(a)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
000410	retrieved data store content, and knowledge base excerpts MUST be treated as untrusted input that cannot authorize a subsequent action the caller could not authorize directly.	enters the model context is a channel through which an instruction can arrive, and the model does not distinguish retrieved text from a member's utterance. An agent that will call a second tool because the first tool's response told it to has delegated its authorization decision to whoever controls that backend's response body, which in a multi-hop or third-party integration is not the organization.				lly rather than through prompt engineering : constrain which tools an agent may call and in what sequence, and require any state-changing action to be gated on a condition established outside the model's context. The Prompt guard reduces the frequency of successful injection; it does not bound the consequence.	le.com/gemini-enterprise-cx/cx-agent-studio/tool; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/guardrail; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/mcp	(1) (Access Control); NIST 800-53: SI-10 (Information Input Validation), AC-3 (Access Enforcement), AC-4 (Information Flow Enforcement), SI-15 (Information Output Filtering); HITRUST CSF v11: 01.v (Information Access Restriction) ; OWASP LLM Top 10 2025: LLM01 (Prompt Injection), LLM06 (Excessive Agency); OWASP Agentic Top 10 2026: ASI01 (Agent Goal Hijack), ASI06 (Memory and Context Poisoning); MITRE ATLAS: AML.T0051.001 (LLM Prompt Injection - Indirect), AML.T0053 (AI Agent Tool Invocation)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
SG-GCP-GEEX-000420	Third-party and externally hosted MCP servers MUST pass a supply chain security review before being registered as a tool.	Google documents that MCP tools may target prebuilt servers, servers built with third-party frameworks, or servers deployed by the customer, and that they carry the same authentication options as OpenAPI tools - meaning they may execute with the project service agent's permissions (Google recommends the Service Agent ID token for Cloud Run hosted servers) or with a service account, OAuth, or API key credential configured on the tool. An MCP server also declares its own tool definitions, so a compromised or	High	Med		The review covers who operates the server, how its tool definitions are versioned and change-controlled, what it logs, and whether its declared tools can change after registration. Only Streamable HttpTransport servers are supported; SSE transport servers are not, so a server offering only SSE cannot be used regardless of review outcome. An unreviewed public MCP server is never eligible for registration regardless of how convenient its tool set appears.	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/mcp; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api	HIPAA: 164.308(b)(1) (Business Associate Contracts), 164.308(a)(8) (Evaluation); NIST 800-53: SA-9 (External System Services), SR-3 (Supply Chain Controls and Processes), SR-11 (Component Authenticity), CM-7 (Least Functionality); HITRUST CSF v11: 05.i (Identification of Risks Related to External Parties), 05.k (Addressing Security in Third Party Agreements); OWASP LLM Top 10 2025: LLM03 (Supply Chain); OWASP Agentic Top 10 2026: ASI04 (Agentic Supply Chain)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		malicious server controls both the description the model reasons over and the response it acts on.						Vulnerabilities); MITRE ATLAS: AML.T0110 (AI Agent Tool Poisoning)
SG-GCP-GECX-000430	MCP servers used by production agent applications SHOULD be hosted within the organization's Google Cloud boundary, with invocation restricted to the CX Agent Studio service agent.	Google's documented pattern hosts the MCP server on Cloud Run and grants the Cloud Run Invoker role to <code>service-PROJECT_NUMBER@gcp-sa-ces.iam.gserviceaccount.com</code> . That arrangement keeps the tool definitions under the organization's change control, keeps conversation-derived parameters inside the boundary, and makes the server's own logs available for investigation - none of which holds for a server operated	Med	Med		Restricting the Invoker role to the service agent alone also prevents the MCP server becoming an unauthenticated internal API. A VPC Service Controls perimeter narrows the network path but does not remove other IAM-authorized callers: any principal holding <code>run.routes.invoke</code> on the service or its project can still call it, so include the service's IAM policy and project-level Cloud Run grants in the review. Test the server	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/mcp ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls	HIPAA: 164.312(e)(1) (Transmission Security); NIST 800-53: SC-7 (Boundary Protection), AC-3 (Access Enforcement), SA-9 (External System Services), IA-9 (Service Identification and Authentication); HITRUST CSF v11: 09.m (Network Controls); OWASP LLM Top 10 2025: LLM03 (Supply Chain)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		by a third party.				independently with curl or Postman before registration, as Google recommends.		
SG-GCP-GECX-000440	Tools that connect to Salesforce, ServiceNow, Jira, Confluence, or SharePoint - both the dedicated tool types for those systems and Integration Connector tools - MUST authenticate with the end user's own credentials or with a dedicated connection identity scoped to the minimum records the agent requires.	These systems hold case notes, ticket bodies, and document libraries whose contents routinely include member-identifying detail written by staff for staff. The dedicated Salesforce, ServiceNow, Jira, Confluence, and SharePoint tools use the OpenAPI tool authentication options, and an Integration Connector tool passes the connection's admin authentication by default unless an end-user authentication override is configured. Unless	High	Med		Where the connection supports it, prefer the Integration Connectors authentication override, which replaces the default admin authentication with an end-user authentication config; the Connection must have authentication override enabled or tool creation fails. Otherwise create a purpose-built integration account in each SaaS platform rather than reusing an existing service or personal account, and scope it at the source system with object, field, and record	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/connector; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/salesforce; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/service-now; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/service-	HIPAA: 164.312(a)(1) (Access Control), 164.502(b) (Minimum Necessary), 164.308(b)(1) (Business Associate Contracts); NIST 800-53: AC-6 (Least Privilege), AC-3 (Access Enforcement), SA-9 (External System Services), IA-9 (Service Identification and Authentication); HITRUST CSF v11: 01.c (Privilege Management), 05.k (Addressing Security in Third Party Agreements); OWASP API Top 10 2023: API1 (Broken Object Level

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		end-user credentials are passed, the connection identity's entitlements become the agent's entitlements, and a connection created with an administrator's profile exposes the entire system through a conversational interface.				filters. Re-verify scope after any change to the source system's permission model, which is outside Google Cloud's change control and will not surface in a CX Agent Studio review.	ini-enterprise-cx/cx-agent-studio/tool/jira; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/confluence ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/sharepoint ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/rest/v1/projects.locations.apps.tools	Authorization)
SG-GCP-GECX-000450	Python code tools MUST be reviewed as application source code before registration and before any subsequent modification.	A Python code tool is arbitrary executable logic invoked as part of a conversation, which places it in the same risk class as application code while offering none of the surrounding pipeline controls -	High	Med		Review each Python code tool for: every outbound request through the provided HTTP client, each one data leaving the organization over the public internet; every other tool it calls, since a call	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/python ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/python ; https://docs	HIPAA: 164.312(e)(1) (Transmission Security); NIST 800-53: SA-11 (Developer Testing and Evaluation), SA-15 (Development Process, Standards, and Tools), CM-3 (Configuration Change

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		no branch protection, no peer review gate, no dependency scanning, no build provenance. Google documents that the code runs in a sandbox on Python 3.12 with a fixed set of importable modules, that it can read the full conversation history and session state and can modify session state, that it can call any other tool defined in the agent application, and that it can make outbound requests only to endpoints publicly available on the internet, with no private network access even where Service Directory is configured. The code therefore holds the conversatio				from code inherits that tool's authority (for OpenAPI tools, the service agent); every write to session state, since state set in code steers later turns; and unbounded input handling. The sandbox identity, and whether its HTTP client attaches a Google credential, is undocumented; confirm with Google before using this tool type with member data, and never place a secret in the code, which is stored in the tool configuration. Google's pages disagree twice (the tool page cites the requests library while the runtime reference	.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/rest/v1/projects.locations.apps.tools; https://docs.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api	Control), SI-7 (Software, Firmware, and Information Integrity), CM-7 (Least Functionality); HITRUST CSF v11: 09.s (Information Exchange Policies and Procedures); OWASP LLM Top 10 2025: LLM05 (Improper Output Handling); OWASP Agentic Top 10 2026: ASI05 (Unexpected Code Execution)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		n, the reach of every tool in the application, and a public egress path at the same time.				uses the provided client; the REST resource carries a Service Directory field although the tool page says private network access is unavailable), so verify behaviour in a non-production project. A production modification without the same review is not permitted.		
SG-GCP-GECX-000460	Client function tools MUST NOT be passed data that the end user is not already authorized to see.	Google states that client function tools are always executed on the client side, not by the agent: the model decides when to call the function and what its arguments contain, the arguments are handed to the calling client application, and the server-side	High	Low		Define the parameters schema of each client function so that it can carry only fields the end user is already authorized to see, and review the function description, because the model uses it to decide when to call the function and what to pass. Treat the argument set as a disclosure	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/function ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-	HIPAA: 164.312(a)(1) (Access Control), 164.502(a) (Uses and Disclosures of PHI); NIST 800-53: AC-3 (Access Enforcement), AC-4 (Information Flow Enforcement); HITRUST CSF v11: 01.v (Information Access Restriction); OWASP LLM Top 10 2025: LLM02 (Sensitive

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		session waits until the client returns a result. On the web widget or a mobile channel that client is the end user's own device, which is untrusted and on a public deployment may belong to an unauthenticated party. Data placed in a client function call is disclosed at the moment of the call regardless of what the function does with it.				to the end user in the data flow record. This requirement governs data sent to the client; results returned by the client are governed separately.	studio/deploy/web-widget	Information Disclosure)
SG-GCP-GECX-000470	The Google Search tool SHOULD NOT be enabled on member-facing agent applications.	Grounding a member conversation on open web results introduces content the organization neither authored nor controls into a channel members treat as authoritative, and it sends conversation-derived	Med	Low		Where broad knowledge is genuinely needed, a curated and reviewed data store provides grounding the organization can review and version. If the Search tool is required for	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/data-store	HIPAA: 164.502(a) (Uses and Disclosures of PHI); NIST 800-53: AC-4 (Information Flow Enforcement), SC-7(10) (Prevent Exfiltration), SI-10 (Information Input Validation), SC-7 (Boundary

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		query terms outside the assessed boundary. For health and benefits questions the accuracy and provenance obligations sit with the organization no matter where the text originated.				a specific internal-facing use case, document the query terms that can reach it and confirm they carry no member identifiers. Whether Google Search grounding is covered by the BAA was not confirmed at authoring; confirm with Google before any use that could carry member information, and treat the tool as prohibited on any agent that can reach member data if it is not covered.		Protection); HITRUST CSF v11: 09.s (Information Exchange Policies and Procedures); OWASP LLM Top 10 2025: LLM09 (Misinformation)
SG-GCP-GECX-000480	Where a tool's backend is reachable through Service Directory private network access, OpenAPI tools, MCP tools, and the dedicated Salesforce,	Google documents Service Directory private network access as the supported way for CX Agent Studio to reach OpenAPI tool targets inside a	High	Med		Configure Service Directory private network access and grant servicedirectory.viewer and servicedirectory.pscAuthorizedService to	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-	HIPAA: 164.312(e)(1) (Transmission Security); NIST 800-53: SC-7 (Boundary Protection), SC-7(10) (Prevent Exfiltration), AC-4 (Information Flow

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	ServiceNow, Jira, Confluence, and SharePoint tools MUST be configured to use the Service Directory path rather than a public endpoint.	VPC network, stating that this keeps traffic within the Google Cloud network and enforces IAM and VPC Service Controls. A tool that egresses to a public endpoint instead forfeits all three properties for every conversation parameter it carries.				service-agent-project-number@gcp-sa-ces.iam.google.com; where Service Directory lives in a different project, grant servicedirectory.viewer in both. Note that within a perimeter this stops being a preference - Google documents that tools and callbacks cannot send requests to arbitrary HTTP endpoints once VPC Service Controls is enabled without Service Directory configuration.	agent-studio/tool/open-api; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/salesforce; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/python	Enforcement), SC-8 (Transmission Confidentiality and Integrity); HITRUST CSF v11: 09.m (Network Controls), 09.n (Security of Network Services)
SG-GCP-GECX-000490	The set of tools registered in a project MUST be restricted to those the approved agent use cases require, with	Because tool authority aggregates at the project service agent rather than attenuating per agent, every	Med	Low		Reconcile the tool inventory against actual tool invocation observed in conversation history and audit logs on the quarterly	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool; https://docs.cloud.google.com/gemini-	NIST 800-53: CM-7 (Least Functionality), CM-8 (System Component Inventory), AC-6 (Least Privilege), CM-3

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	unused registrations removed.	registered tool that no agent needs is pure added blast radius. Tools also accumulate during development and vendor-led enablement sessions and are rarely removed, so the gap between what is registered and what is used widens silently over time. Registration extends reach even before a tool is assigned to an agent, because a Python code tool can call any tool defined in the same application.				cycle. A tool registered but never invoked in a full quarter is a candidate for removal, and its continued presence should require a stated reason.	enterprise-cx/cx-agent-studio/access-control; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/python	(Configuration on Change Control); HITRUST CSF v11: 01.c (Privilege Management); OWASP LLM Top 10 2025: LLM06 (Excessive Agency); OWASP Agentic Top 10 2026: ASI02 (Tool Misuse and Exploitation)
SG-GCP-GECX-001310	Tool invocations MUST carry a correlation identifier, comprising at minimum the agent application identifier and the conversation or	Tool calls commonly reach the backend under a shared platform or tool identity - the CX Agent Studio service agent, or a service	High	Med		For OpenAPI tools, use the documented <code>x-cs-session-context</code> extension to inject session context such as <code>\$context</code>	https://docs.cloud.google.com/gemini-enterprise-	HIPAA: 164.312(b) (Audit Controls), 164.308(a)(1)(ii)(D) (Information System Activity Review); NIST 800-53: AU-3 (Content of Audit

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	session identifier, that the receiving backend system records in its own logs.	account, OAuth client, or API key configured on the tool - so the backend's own audit log records one identity for many agents, conversations, and members. Without a correlation identifier the backend cannot attribute an action to the conversation that caused it, which means an investigation starting from a backend record - a changed claim, an unexpected lookup, an anomalous query volume - has no path back into the conversation history. The Google Cloud side of the boundary is well instrumented; the identifier is what carries that				.session_id into a header or parameter; for MCP tools, inject session context variables into custom headers; for Integration Connector tools, pass the identifier in a defined request field. Require the receiving system to log it as a condition of being connected. The identifier is metadata rather than content and must not carry member identifiers or conversation text. This is the control that makes the confused-deputy residual risk investigable after the fact rather than merely accepted.	cx/cx-agent-studio/tool/mcp; https://docs.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging	Records), AU-2 (Event Logging), IA-9 (Service Identification and Authentication), AC-3 (Access Enforcement); HITRUST CSF v11: 09.aa (Audit Logging); OWASP Agentic Top 10 2026: ASI03 (Identity and Privilege Abuse); MITRE ATLAS: AML.T0053 (AI Agent Tool Invocation)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		attribution across it.						
SG-GCP-GECX-001330	Results returned by a client function tool MUST NOT be relied upon to establish the end user's identity, entitlement, or authorization for any subsequent action.	A client function tool is executed by the calling client application, which returns the result to the agent in the tool response and the agent then continues the conversation on it. On a web or mobile channel that client is under the end user's control, so the returned value is whatever the end user's device chooses to send. An agent that treats that value as proof of who the member is, or of what they may do, lets the member assert their own authorization.	High	Low		Validate each result against the response schema declared on the function and treat it as untrusted input. Establish identity and entitlement from the channel's authentication and from backend systems reached by server-side tools, never from a client function result. Google's documentation describes the flow but does not itself characterize the result as untrusted; this requirement is the organization's reading of the documented flow.	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/function;https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/rest/v1/projects.locations.apis.tools	HIPAA: 164.312(d) (Person or Entity Authentication), 164.312(a) (1) (Access Control); NIST 800-53: SI-10 (Information Input Validation), AC-3 (Access Enforcement), IA-8 (Identification and Authentication (Non-organizational Users)); HITRUST CSF v11: 01.q (User Identification and Authentication), 01.v (Information Access Restriction); OWASP API Top 10 2023: API2 (Broken Authentication); OWASP Agentic Top 10 2026: ASI03 (Identity and Privilege Abuse)
SG-GCP-GECX-001340	Data store tools that reference a	Google documents that when a	Med	Low		Review the data store selection	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/function;https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/rest/v1/projects.locations.apis.tools	HIPAA: 164.312(a) (1) (Access

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	search engine MUST name the specific data stores to be searched rather than leaving the data store selection empty.	data store tool targets an engine and its data store selection is empty, the search applies to all data stores associated with the engine. Any data store later attached to that engine for another purpose then becomes retrievable by every caller of the agent without any change to the agent or the tool, which silently widens the audience for that content.				on every engine-backed data store tool at registration and at the quarterly tool inventory review. The engine-level filter is not used when specific data stores are named, and is not an access control in either case.	ini-enterprise-cx/cx-agent-studio/reference/rest/v1/projects.locations.apps.tools; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/data-store	Control), 164.502(b) (Minimum Necessary); NIST 800-53: AC-3 (Access Enforcement), AC-4 (Information Flow Enforcement), CM-6 (Configuration Settings), AC-6 (Least Privilege); HITRUST CSF v11: 01.v (Information Access Restriction)
SG-GCP-GECX-001360	The RAG knowledge base behind a File search tool MUST be located in a US region where RAG Engine is designated GA.	A File search tool uploads files into a RAG knowledge base created in a location the builder selects, and RAG knowledge bases are a RAG Engine resource billed and regionalized	High	Low		Set the Location field explicitly when a local file is uploaded, because the knowledge base is created at that point. Confirm the region's launch stage in the RAG Engine region table	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/file ; https://docs.cloud.google.com/gemini-enterprise-agent-platform/build/rag-engine/rag-overview	HIPAA: 164.308(a)(1)(ii)(B) (Risk Management); NIST 800-53: SA-9(5) (Processing, Storage, and Service Location), CM-6 (Configuration Settings), AC-4 (Information Flow

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		separately from CX Agent Studio. The residency pin configured for CX Agent Studio therefore does not govern where these files are stored, and Google's RAG Engine region table lists US regions at different launch stages - us-central1 and us-east4 as Allowlist, GA and us-east1 as Allowlist, Preview. Choosing a US region fixes where the knowledge base is created; it is not a contractual data-residency commitment, which Google states RAG Engine does not support.				at registration, because the table changes independently of CX Agent Studio release notes. Access to the US regions requires allowlisting by Google.		Enforcement), SA-9 (External System Services); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)
SG-GCP-GEEX-001370	RAG knowledge bases used by File	Google states that VPC Service	High	Med		Configure CMEK and add the RAG	https://docs.cloud.google.com/gemini-	HIPAA: 164.312(a)(2)(iv) (Encryption

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	search tools MUST be protected by customer-managed encryption keys and placed inside the VPC Service Controls perimeter before any file is uploaded.	Controls and CMEK are supported by RAG Engine, but the CX Agent Studio CMEK integration and perimeter configuration are specific to the CX Agent Studio service and do not extend to a separate product's resources. A knowledge base created from the File search tool without its own configuration holds uploaded content under Google-managed keys and outside the perimeter.				Engine API service to the perimeter in the project that will hold the knowledge base before the File search tool is registered, since a knowledge base is created automatically when a local file is uploaded. Include the knowledge base in the CMEK inventory and the data flow record.	enterprise-cx/cx-agent-studio/tool/file; https://docs.cloud.google.com/gemini-enterprise-agent-platform/build/rag-engine/rag-overview	and Decryption), 164.312(e)(1) (Transmission Security); NIST 800-53: SC-28 (Protection of Information at Rest), SC-12 (Cryptographic Key Establishment and Management), SC-7 (Boundary Protection), AC-4 (Information Flow Enforcement); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information), 10.g (Key Management), 09.m (Network Controls)
SG-GCP-GEEX-001380	File search tools SHOULD NOT be used to ground agents on content containing protected health information.	Google's RAG Engine overview states that data residency and Access Transparency security controls are not supported	Med	Low		Use data store tools, or a backend reached through a server-side tool, for any retrieval corpus that must contain protected	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/file ;	

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		by RAG Engine. Content uploaded through a File search tool therefore sits outside two controls this deployment otherwise relies on for member data: a contractual at-rest location commitment and a record of Google personnel access.				health information. Where an exception is approved, record it in the residual risk acceptance for the deployment . Re-verify the RAG Engine statement at each release-note review, because the supported-controls list can change.	enterprise-agent-platform/build/rag-engine/rag-overview	g, Storage, and Service Location), SA-9 (External System Services), AU-2 (Event Logging), RA-3 (Risk Assessment); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information), 09.f (Monitoring and Review of Third Party Services)
SG-GCP-GEEX-001390	Agent-to-agent (A2A) Protocol tools MUST NOT be configured on any agent application, for outbound delegation or for inbound invocation, while the capability is designated Preview.	The CX Agent Studio tools overview and documentation navigation mark the A2A Protocol tool Preview, although its own page carries no banner, so it is governed by the Pre-GA Offerings Terms and by Google's HIPAA guidance not to use Pre-GA offerings in	High	Low		This is a specific application of the baseline prohibition on Pre-GA features, restated because the tool appears in the same picker as generally available tool types. Before approving it at GA, decide each direction separately. Inbound callers need a custom role without	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/a2a-protocol ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes ; https://cloud.google.com/healthcare-api/docs/concepts/basics	HIPAA: 164.308(a)(8) (Evaluation), 164.312(a)(1) (Access Control); NIST 800-53: CM-7 (Least Functionality), AC-4 (Information Flow Enforcement), CA-3 (Information Exchange), SA-4 (Acquisition Process), SA-9 (External System Services); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information), 09.f (Monitoring and Review of Third Party Services)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		connection with PHI. The capability also opens a boundary this guide otherwise keeps closed: external applications and orchestrators can invoke an agent application directly while holding the Client role, which includes <code>ces.tools.execute</code>, and can send agent context metadata that the application writes directly into the current session. Outbound, the tool delegates conversation-derived tasks to remote agents in other projects, in Vertex AI Agent Engine, or at third parties authenticated with an API key or OAuth.				<code>ces.tools.execute</code> and a path through the organization's API gateway, and inbound session context must be treated as untrusted input. Outbound links need a documented remote owner, authentication method, and cross-project trust decision, and the delegation chain they create is reviewed as one authorization surface. Sessions with other CX Agent Studio applications are always stateful, so context persists across the link.	d.google.com/terms/service-terms; https://cloud.google.com/security/compliance/hipaa	01.v (Information Access Restriction), 05.i (Identification of Risks Related to External Parties); OWASP Agent Top 10 2026: ASI07 (Insecure Inter-Agent Communication); MITRE ATLAS: AML.T0053 (AI Agent Tool Invocation)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
SG-GCP-GEEX-000500	An inventory of every deployment channel, its authentication mode, and its approving owner MUST be maintained for each agent application.	CX Agent Studio publishes an agent to a growing set of surfaces - as of 2026-09-24, web widget, AudioCodes, Five9, Google Cloud CCaaS, Google Telephony Platform, SecureCo, Twilio, WhatsApp and Instagram, and direct API access - and each carries a different authentication model and a different population of callers. The security posture of an agent is meaningless without knowing which of these it is exposed on, and a channel added later does not change anything visible in the agent's own configuration.	High	Low		The inventory records, per channel, whether callers are authenticated, what identity the channel's token carries, and which third party operates the transport. Reconcile it against direct grants of the Gemini Enterprise for Customer Experience Client role (roles/cxs.client) to service accounts and other non-human principals only. Every CX Agent Studio editor role and the Admin role inherit the Client role, and end users authenticated through OAuth2 hold access to the agent themselves, so a reconciliation against all holders	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/web-widget; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/secureco; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/whatsapp	NIST 800-53: CM-8 (System Component Inventory), AC-3 (Access Enforcement), CM-3 (Configuration Control), PL-8 (Security and Privacy Architectures); HITRUST CSF v11: 01.j (User Authentication for External Connections), 01.v (Information Access Restriction)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
						will not balance. A direct non-human grant with no matching channel entry is either an undocumented channel or an unused credential. Inbound A2A callers, where the A2A Protocol is enabled, are channels for this inventory. Reconcile the channel list against the deployment overview at each release-note review rather than against a fixed count.		
SG-GCP-GECX-000510	Public access through the Google-hosted token broker MUST NOT be enabled for any agent application whose tools can reach member data.	Google documents the Google-hosted token broker as the mechanism that allows public access to a chat widget, which means an unauthenticated caller obtains a	High	Med		Where a genuinely public agent is required - a benefits FAQ or a store locator - place it in its own project with its own service agent and no tool that reaches member	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/web-widget ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/	HIPAA: 164.312(a)(1) (Access Control), 164.312(d) (Person or Entity Authentication), 164.502(a) (Uses and Disclosures of PHI); NIST 800-53: AC-3 (Access Enforcement), IA-8

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		valid token and converses with the agent. Because tools execute with the project service agent's permissions rather than the caller's, the effective reach of that anonymous conversation is every backend any tool in the project authenticates to. Anonymous access and service-agent tool execution are individually defensible and jointly a direct path from the open internet to member records.				data, so that anonymous reach is bounded by the project rather than by the agent's instructions. Google recommends deploying agent applications in a dedicated project to limit the scope of permissions available to the CX Agent Studio service account.	open-api; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy	(Identification and Authentication (Non-organizational Users)), AC-6 (Least Privilege), SC-7 (Boundary Protection); HITRUST CSF v11: 01.j (User Authentication for External Connections), 01.v (Information Access Restriction); OWASP API Top 10 2023: API2 (Broken Authentication), API1 (Broken Object Level Authorization)
SG-GCP-GECX-000520	Where public access is approved for a bounded public-information agent, origin checks and reCAPTCHA A MUST	Google presents these as optional additions - the documentation reads enable public access, and optionally	High	Low		Origin checks bind the widget to the organization's own pages, which is what makes an embedded agent	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/web-widget	NIST 800-53: SC-5 (Denial-of-service Protection), SC-23 (Session Authenticity), AC-3 (Access Enforcement), CM-6 (Configurati

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	both be enabled on the widget configuration.	enable origin and reCAPTCHA checks, recommended to prevent spoofing and abuse. Left at their defaults they are off, which leaves a publicly reachable generative endpoint with no origin binding and no automation control: it can be embedded on any site, driven by a script, and consumed as a free inference endpoint at the organization's expense.				attributable. reCAPTCHA A constrains automated abuse. Neither is a substitute for the reach limitation that comes from a dedicated project with no sensitive tools, and both must be verified after any widget configuration change because they sit in the same form as the public-access toggle.		on Settings); HITRUST CSF v11: 09.m (Network Controls); OWASP LLM Top 10 2025: LLM10 (Unbounded Consumption); OWASP API Top 10 2023: API4 (Unrestricted Resource Consumption), API6 (Unrestricted Access to Sensitive Business Flows)
SG-GCP-GECX-000530	Agent applications serving authenticated members MUST authenticate each member individually through the organization's identity provider - using the OAuth2 client path or a custom	The widget supports an OAuth2 client that authenticates the end user and returns a token operating on that user's behalf, and a custom authentication API that returns a Google access	High	Med		Where the OAuth2 path is used, grant member principals a custom role containing only <code>ces.sessions.runSession</code> (and <code>ces.sessions.bidiRunSession</code> for voice) rather than the	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/web-widget ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api ;	HIPAA: 164.312(d) (Person or Entity Authentication), 164.312(a)(1) (Access Control); NIST 800-53: IA-2 (Identification and Authentication (Organizational Users)), IA-8

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	authentication API that issues a short-lived token for the member's session - and grant member identities no role that includes the <code>ces.tools.execute</code> permission.	token or signed JWT permitted to call <code>runSession</code> . Google notes that the identity associated with the token - end user or service account - must hold the IAM permissions to interact with the agent. A service-account broker makes every member session indistinguishable at the platform layer, so the conversation record cannot be attributed and no per-member condition can be applied at the boundary. The predefined Client role grants <code>tools.execute</code> in addition to <code>runSession</code> and <code>bidirunSession</code> , so a member identity				predefined Client role. Google describes the custom option as an API that "returns a google access token or signed jwt that has the permission to call <code>runSession</code> in your app", which suits an organization-operated member identity provider. Authentication mode by agent type: agents serving authenticated members use per-member authentication; a self-hosted service-account token broker suits only unauthenticated or bounded public-information agents; the Google-hosted public broker is never used where tools can reach member data. End-	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ; https://docs.cloud.google.com/iam/docs/roles-permission/ces	(Identification and Authentication (Non-organizational Users)), AC-3 (Access Enforcement), AC-6 (Least Privilege), AU-3 (Content of Audit Records); HITRUST CSF v11: 01.q (User Identification and Authentication), 01.j (User Authentication for External Connections), 01.c (Privilege Management); OWASP API Top 10 2023: API2 (Broken Authentication)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		holding it could invoke the agent's tools directly, outside the conversation, with the tools' configured identity.				user authentication does not make tool execution user-scoped, which remains the service agent's, so per-member data scoping must still be enforced in the backend against a session-bound identifier. Configure authorized JavaScript origins and redirect URIs to the organization's domains only.		
SG-GCP-GECX-000540	A self-hosted token broker SHOULD be used in preference to the Google-hosted broker for any agent application that serves unauthenticated callers or bounded public information.	A self-hosted broker runs in the organization's own project on Cloud Run, which puts token issuance under the organization's logging, rate limiting, IP controls, and change management. The Google-hosted	Med	Med		Google publishes sample code for the self-hosted broker, and its service account is granted the Customer Engagement Suite Client role. That service account should hold only that role and nothing else, and it	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/web-widget ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control	HIPAA: 164.312(d) (Person or Entity Authentication); NIST 800-53: IA-5 (Authenticator Management), AC-3 (Access Enforcement), SC-7 (Boundary Protection), AU-2 (Event Logging); HITRUST CSF v11:

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		broker exists to enable public access and offers no organization-defined logic before a token is minted beyond its optional origin and reCAPTCHA checks.				needs no downloaded key because Cloud Run attaches the identity. Because the Client role also includes tools.execute, keep issued tokens as short-lived as the broker allows. Broker request logs are useful evidence of who initiated a conversation and when. A service-account broker is not end-user authentication: every session it issues carries the same service identity, so agents serving authenticated members authenticate each member through the organization's identity provider instead.		01.j (User Authentication for External Connections)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
SG-GCP-GEEX-000550	The web widget MUST be embedded only on web origins the organization controls.	The widget is deployed as an HTML snippet, which is copyable and will function wherever it is pasted unless an origin restriction constrains it. An agent embedded on a third-party or attacker-controlled page presents the organization's brand and voice in a context the organization cannot vouch for, and any data the member provides transits a page the organization does not control.	Med	Low		Enforce the origin restriction with the control that matches the widget's authentication mode: the Authorized JavaScript origins of the OAuth2 client, origin validation in a self-hosted token broker or custom authentication API, or the optional origin check of the Google-hosted broker where public access is approved. Maintain the approved origin list as configuration under change control, and review it whenever a partner or vendor site is added, since an origin approved for a marketing campaign rarely gets	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/web-widget ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy	HIPAA: 164.312(a)(1) (Access Control); NIST 800-53: SC-23 (Session Authenticity), AC-3 (Access Enforcement), CM-6 (Configuration Settings), SC-7 (Boundary Protection); HITRUST CSF v11: 01.j (User Authentication for External Connections), 01.v (Information Access Restriction)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
						removed afterwards.		
SG-GCP-GECX-000560	Non-production agent development and testing MUST be performed in a separate Google Cloud project from production, using deployment environments that carry no production traffic.	Testing an agent means driving it with realistic input against realistic tools, and in a shared project that means the test agent inherits the production service agent's reach into production backends. Deployment environments separate versions within a project but do not separate the identity that tools execute as, so the environment feature alone does not create the boundary.	High	Med		Non-production projects should carry synthetic conversation data rather than copies of member conversations. This is also where the pre-release v1beta and v1alpha1 API surfaces belong, since evaluation capabilities that are only offered there can be exercised without placing production traffic on an unsupported API version.	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/accelerate-control ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api	HIPAA: 164.308(a)(4)(ii)(B) (Access Authorization), 164.502(a) (Uses and Disclosures of PHI); NIST 800-53: CM-2 (Baseline Configuration), SC-7 (Boundary Protection), AC-4 (Information Flow Enforcement), SA-11 (Developer Testing and Evaluation); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)
SG-GCP-GECX-000570	Traffic splitting MUST NOT direct production conversations to an agent version that has not completed security	Traffic splitting was announced in the CX Agent Studio release notes on July 1, 2026 and divides user	High	Low		Require that every version participating in a split has passed review and evaluation, so the split decides how much traffic a version	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api	NIST 800-53: CM-3 (Configuration Change Control), CM-4 (Impact Analyses), SA-11 (Developer Testing and Evaluation), AU-2

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	review and evaluation.	conversations in a deployment channel across several agent application versions by percentage. Google presents it both for A/B testing and to "safely deploy updates in stages", so it acts as a release control as well as an experimentation control, and it will place real member conversations on whatever version a split names, reviewed or not. The split is configured on the deployment resource rather than in the agent definition, so reviewing the agent alone does not reveal it.				receives rather than whether an unreviewed version receives any. Split changes are UpdateDeployment calls, which Google logs as Data Access (DATA_WRITE) audit events rather than Admin Activity, so Data Access audit logging must be enabled for ces.googleapis.com before split changes can be alerted on. The traffic-splitting documentation configures splits through the v1beta API and the release note does not state a launch stage; confirm the stage before relying on the capability for production releases.	enterprise-cx/cx-agent-studio/resources/release-notes; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/traffic-split ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging	(Event Logging); HITRUST CSF v11: 10.k (Change Control Procedures), 09.aa (Audit Logging)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
SG-GCP-GECX-000580	Third-party platforms that carry member conversations to or from a deployment channel - contact center providers such as AudioCodes, Five9, SecureCo, and Twilio, messaging platforms such as WhatsApp and Instagram, and any comparable intermediary - MUST have completed a third-party security assessment and, where they process ePHI, be covered by an executed business associate agreement.	These platforms carry the full audio and text of member conversations between the member and the agent, which places them squarely in the ePHI path as business associates. Google's BAA covers Google Cloud services; it does not extend to a telephony, CCaaS, or messaging provider the organization contracts with separately, so the contractual chain has a gap unless the organization closes it directly.	High	Med		Assess the recording, retention, and subprocess or posture of each provider, not only its transport encryption, because these platforms frequently retain their own copy of call audio on their own schedule. Confirm which party holds the recording of record and where it is stored, since that copy is outside every Google Cloud control applied to the agent.	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy; https://cloud.google.com/security/compliance/hipaa; https://cloud.google.com/terms/hipaa-baa; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/secureco; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/whatsapp	HIPAA: 164.308(b)(1) (Business Associate Contracts), 164.314(a) (Business Associate Contracts or Other Arrangements), 164.502(e) (Disclosures to Business Associates); NIST 800-53: SA-9 (External System Services), SR-3 (Supply Chain Controls and Processes), CA-3 (Information Exchange), RA-3 (Risk Assessment); HITRUST CSF v11: 05.i (Identification of Risks Related to External Parties), 05.k (Addressing Security in Third Party Agreements)
SG-GCP-GECX-000590	Direct API access to deployed agent	The API channel is a conversatio	High	Med		The gateway is also the enforceme	https://docs.cloud.google.com/gemini-	HIPAA: 164.312(a)(1) (Access Control),

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	application MUST be routed through the organization's API gateway rather than exposed to callers as a direct Google endpoint.	nal inference endpoint reachable by anything holding a token permitted to call runSession . The product's native controls at that boundary are project-scoped rather than per-caller: quotas such as RunSession LLM tokens per minute apply per project, base model, and region and are shared across all applications in the project; RunSession calls are recorded as Data Access audit events once those logs are enabled; and guardrails screen model input and output for content rather than authorizing callers. None of these				nt point for any per-caller authorization the backend cannot express, and its access logs are the only record of API-channel conversations that exists independently of Google's own logging. Apply the same rate limits to internal callers as to external ones - a runaway internal integration produces the same cost and the same load. Inbound A2A invocation, where the A2A Protocol is enabled, is a direct call to the same Google endpoint by a principal holding the Client role and falls under this requirement.	enterprise-cx/cx-agent-studio/deploy; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/api-access ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/quotas ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/guardrail ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/guardrail	164.312(e)(1) (Transmission Security); NIST 800-53: SC-7 (Boundary Protection), AC-3 (Access Enforcement), SC-5 (Denial-of-service Protection), AU-2 (Event Logging); HITRUST CSF v11: 09.m (Network Controls); OWASP LLM Top 10 2025: LLM10 (Unbounded Consumption); OWASP API Top 10 2023: API4 (Unrestricted Resource Consumption), API2 (Broken Authentication)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		distinguishes one API client from another, so fronting the channel with the gateway is what provides per-caller throttling, per-caller authorization policy, and request-level logging tied to the calling integration.					agent-studio/tool/a2a-protocol	
SG-GCP-GEEX-000600	Voice channels MUST present a recording and automated-interaction disclosure to the member before conversation content is captured.	Where audio recording, conversation logging, or CX Insights ingestion is enabled on a voice channel, call audio or its transcript is captured and retained: CX Agent Studio routes raw audio to a customer-owned Cloud Storage bucket when audio recording is configured, and CX Insights ingests call audio and transcripts	High	Low		The disclosure must cover both recording and the automated nature of the agent, and it must be spoken on voice channels rather than assumed from a web page. Where a third-party platform plays the disclosure, confirm that it does so before audio reaches Google Cloud, not after. The legal basis is state wiretap and call-	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy; https://docs.cloud.google.com/gemini-enterprise-cx/insights/common-integrations; https://docs.cloud.google.com/gemini-enterprise-cx/insights; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history	NIST 800-53: PT-4 (Consent), PT-5 (Privacy Notice), PT-2 (Authority to Process Personally Identifiable Information); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		for analysis. Recording consent is governed by state law, with two-party consent jurisdictions imposing the stricter standard, so the disclosure has to be delivered before capture begins rather than alongside it.				recording law rather than the HIPAA Privacy Rule; confirm the applicable jurisdictions and the disclosure wording with counsel.		
SG-GCP-GEEX-001300	Quota caps and cost alerting MUST be configured for every agent application exposed on a public or high-volume deployment channel.	An agent application is a metered generative inference endpoint, and the web widget can be configured for anonymous public access. An attacker, a misconfigured integration, or a runaway retry loop consumes model capacity and incurs cost at a rate bounded only by the platform's own quotas, and	Med	Med		CX Agent Studio quotas apply per project, region, and base model and are shared across all applications in the project, so a ceiling for one channel requires placing high-exposure channels - the public widget in particular - in their own project. Alert on rate of spend rather than absolute spend so a change in	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/web-widget ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/	NIST 800-53: SC-5 (Denial-of-service Protection), SI-4 (System Monitoring), CM-6 (Configuration Settings), CP-2 (Contingency Plan); OWASP LLM Top 10 2025: LLM10 (Unbounded Consumption); OWASP API Top 10 2023: API4 (Unrestricted Resource Consumption)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		the failure is financial and availability-affecting before it is ever a confidentiality problem. The organization's API gateway constrains the API channel but sits nowhere in the path of the web widget or the telephony connections.				pattern surfaces within hours rather than at the end of the billing period. Origin checks and reCAPTCHA reduce the frequency of automated abuse on the widget but place no ceiling on it.	agent-studio/resources/quotas	
SG-GCP-GEEX-001400	WhatsApp and Instagram deployments MUST NOT be created for any Gemini Enterprise for CX agent application.	Google documents that only owners of the associated project can create a WhatsApp or Instagram deployment, so the channel cannot be enabled without the basic Owner role, which carries every permission in the project and which this guide prohibits on projects hosting the suite. The	High	Low		Lift this prohibition only when Google documents a creation path that does not need the Owner role, Meta has completed a third-party security assessment and, where member PHI would cross the channel, is covered by an executed business associate agreement, and the channel has been	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/whatsapp ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes ; https://cloud.google.co	HIPAA: 164.308(b)(1) (Business Associate Contracts), 164.502(e) (Disclosures to Business Associates), 164.312(a)(1) (Access Control); NIST 800-53: CM-7 (Least Functionality), AC-6 (Least Privilege), SA-9 (External System Services), CA-3 (Information Exchange); HITRUST

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		channel also routes member conversations through Meta, a messaging platform outside Google Cloud and outside Google's BAA, and the deployment page describes connecting Meta business assets without saying how Meta processes or retains the conversation content.				added to the deployment channel inventory with an approving owner. Check existing projects for WhatsApp and Instagram deployments at each review, because the option appeared in the console on 2026-09-24.	m/iam/docs/roles-overview; https://cloud.google.com/security/compliance/hipaa	CSF v11: 01.c (Privilege Management), 05.k (Addressing Security in Third Party Agreements)
SG-GCP-GEEX-000610	Customer-managed encryption keys MUST be initialized for Agent Assist before it processes any production conversation.	Agent Assist maintains its own CMEK initialization separate from CX Agent Studio and CX Insights, so a project can be fully CMEK-covered on two components and unprotected on the third. Agent Assist holds live conversation	High	Med		Immutable at first use: Google states "You cannot change encryption key settings for a location once it has been specified" and that a project already holding Agent Assist data in a location cannot have a key added for that location.	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/cmek ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/cmek ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/cmek	HIPAA: 164.312(a)(2)(iv) (Encryption and Decryption); NIST 800-53: SC-28 (Protection of Information at Rest), SC-28(1) (Cryptographic Protection), SC-12 (Cryptographic Key Establishment and Management); HITRUST CSF v11: 06.d (Data

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		transcripts, generated summaries, and knowledge excerpts, which is the same class of content the other two components protect.				Initialize through the InitializeEncryptionSpec API and grant Cloud KMS CryptoKey Encrypter/Decrypter to service-PROJECT_NUMBER@gcp-sa-ccai-cmek.iam.gserviceaccount.com. Coverage is not total: Google states "CMEK is not available for features that are disabled in Agent Assist locations and smart reply", so Smart Reply data is outside the customer-key boundary even in a fully CMEK-configured project. Record that exclusion in the data flow record and weigh it when deciding whether Smart Reply is enabled at all.		Protection and Privacy of Covered Information), 10.g (Key Management)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
SG-GCP-GECX-000620	Sensitive Data Protection redaction MUST be configured for Agent Assist conversation data using an inspect template and a deidentify template.	Agent Assist operates on live conversation content in which members state identifiers, conditions, and payment details conversationally rather than in structured fields. Redaction configured through DLP templates is the mechanism that scrubs those values before persistence, and without it the raw utterance is what is stored, analyzed, and later exported.	High	Med		Redaction fails open and is bound per conversation profile, not per project: Google states "You must specify the security settings to apply for each conversation profile" and that without them "Agent Assist doesn't apply any redaction for that conversation profile." Security settings are configured per project and location but take effect only where attached, so verify by enumerating every conversation profile and confirming an attachment on each; a project can hold both templates and still store unredacted transcripts. The inspect	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/data-redaction-retention; https://docs.cloud.google.com/gemini-enterprise-cx/agent-studio/vpc-service-controls	HIPAA: 164.502(b) (Minimum Necessary), 164.312(a) (1) (Access Control); NIST 800-53: SC-7 (Boundary Protection), SC-7(10) (Prevent Exfiltration), SI-19 (De-identification), AC-4 (Information Flow Enforcement); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
						template defines what counts as sensitive data and the deidentify template how it is masked or removed; tune both against real transcripts, since contact center language differs from the text DLP detectors are calibrated on. Google documents that Sensitive Data Protection templates outside the VPC Service Controls perimeter cause redaction failures for CX Agent Studio; Agent Assist behaviour is undocumented, so keep its templates in the same perimeter.		
SG-GCP-GECX-000630	Agent Assist conversation data	Google documents that Agent Assist	Med	Low		Set retention deliberately against a	https://docs.cloud.google.com/gemini-	HIPAA: 164.502(b) (Minimum Necessary)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	retention MUST be configured to the shortest period that meets a documented business need.	security settings carry a retention_window_days value and that "The default and maximum retention window is 30 days." Because the product caps retention at 30 days, the exposure is bounded in time, unlike stores that keep conversations indefinitely unless an expiry is set; the residual risk is that the default sits at the ceiling, so unless a shorter value is chosen deliberately every conversation's transcripts and suggestions are kept for the longest period the product allows.				stated business and records-retention rationale, using retention_window_days in the project-and-location security settings. Thirty days is a ceiling rather than a starting point, so confirm that quality review, dispute resolution, and any downstream export can operate inside the chosen window. A business need longer than 30 days cannot be met by changing this setting and must be met by exporting to a store the organization controls, which then carries its own retention obligation.	enterprise-cx/agent-assist/data-redaction-retention	; NIST 800-53: SI-12 (Information Management and Retention), MP-6 (Media Sanitization); HITRUST CSF v11: 06.c (Protection of Organizational Records)
SG-GCP-GECX-000640	Generated conversation summaries	A summarization model produces a	High	Med		The reviewing representative needs	https://docs.cloud.google.com/gemini-	HIPAA: 164.312(c)(1) (Integrity);

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	MUST be reviewed by the human representative before they are committed to a system of record.	fluent account of the conversation whether or not it captured the material facts, and it may omit a commitment made to the member or attribute a statement to the wrong party. Once a summary is written into a case, a claim note, or a service record, it becomes the organization's account of the interaction and is relied on by every downstream reader.				the transcript alongside the summary and a genuine ability to edit it, not merely to accept it. Writing a summary to a system of record without representative review is outside this requirement; if a business case for it arises, treat it as a documented exception approved by the record owner, with the summaries labeled as machine-generated in the record.	enterprise-cx/agent-assist/summarization-with-custom-sections; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist	NIST 800-53: SI-10 (Information Input Validation), SI-15 (Information Output Filtering), AU-3 (Content of Audit Records); HITRUST CSF v11: 06.c (Protection of Organizational Records); OWASP LLM Top 10 2025: LLM09 (Misinformation)
SG-GCP-GECX-000650	Smart Reply, AI coach, and other generated response suggestions MUST NOT be transmitted to a member without an affirmative action by the human	Smart Reply surfaces suggested responses calculated by a custom model trained on the organization's own conversation data, and AI coach uses a	High	Low		Affirmative means a deliberate send action, not a timeout that sends by default and not a single click that both accepts and transmits without displaying the text.	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/smart-reply ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/ai-coach-overview ;	HIPAA: 164.502(a) (Uses and Disclosures of PHI), 164.312(c) (1) (Integrity); NIST 800-53: SI-15 (Information Output Filtering), AC-3 (Access Enforcement), SI-10

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	representative.	large language model to suggest how the representative should respond. A suggestion that is accurate in most cases will be wrong in some. Auto-sending removes the only check in the path, and the resulting message reaches the member carrying the organization's authority with no one having read it.				Confirm the behavior in the deployed UI module rather than in the product description, because the integration layer determines what the representative actually sees.	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist	(Information Input Validation); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information); OWASP LLM Top 10 2025: LLM06 (Excessive Agency); OWASP Agentic Top 10 2026: ASI09 (Human-Agent Trust Exploitation)
SG-GCP-GECX-000660	Knowledge bases used by Knowledge Assist and Generative Knowledge Assist MUST be scoped to content the entire representative population is authorized to see.	Knowledge Assist surfaces excerpts from the configured knowledge base directly in the representative's workspace during a live call. Google documents metadata document filters (a SearchConfig in the knowledge	High	Med		Review the corpus against the representative population rather than against the author's intent. Material scoped to clinical staff, legal, or a specific business unit does not belong in a general contact center knowledge	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/generative-knowledge-assist ; https://docs.cloud.google.com/gemini-enterprise-	HIPAA: 164.312(a)(1) (Access Control), 164.502(b) (Minimum Necessary); NIST 800-53: AC-3 (Access Enforcement), AC-21 (Information Sharing), AC-6 (Least Privilege), AC-4 (Information Flow Enforcement); HITRUST

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		search request) that narrow what generative knowledge assist retrieves, but the filter is part of the request the integration sends, and Google does not describe it as bound to the representative's identity, so it is not an authorization boundary. Any document in the corpus is therefore potentially visible to every representative the moment a conversation makes it relevant, regardless of the access controls that governed it in its original location.				base, and its presence there is a disclosure that no access review of the source system will detect. Content restricted to a narrower audience must be excluded from the corpus entirely; metadata filters can reduce irrelevant results but do not enforce who may see a document.	cx/agent-assist	CSF v11: 01.v (Information Access Restriction)
SG-GCP-GECX-000670	Live translation output MUST NOT be relied upon as the authoritative record of	Agent Assist live audio-to-audio translation, a limited-access private GA	High	Med		Retain the source-language audio or transcript alongside the translation	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/live-a2a-	HIPAA: 164.312(c)(1) (Integrity); NIST 800-53: SI-10 (Information Input)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	a member interaction.	feature, translates speech between the member and the representative in real time and synthesizes the translated response for the other party. Machine translation of a conversation about benefits, coverage, or clinical detail can invert meaning in ways neither party detects, because neither participant hears both languages. If only the translated side is retained, the organization holds no record of what the member actually said and cannot reconstruct the interaction in a dispute or a grievance.				and mark translated turns, so the interaction can be reconstructed in a dispute. Where the interaction determines a benefit or a clinical pathway, a qualified human interpreter remains the appropriate mechanism, and language access obligations are not satisfied by a machine translation feature. The overview page does not describe what is retained from a translated conversation; confirm with Google before enablement.	translation-overview; https://docs.google.com/gemini-enterprise-cx/agent-assist	Validation), AU-3 (Content of Audit Records), SI-12 (Information Management and Retention); HITRUST CSF v11: 06.c (Protection of Organizational Records); OWASP LLM Top 10 2025: LLM09 (Misinformation)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
SG-GCP-GEEX-000680	Agent Assist deployments MUST be pinned to a region consistent with the organization's data residency position, with per-feature residency coverage verified before enablement.	Agent Assist maintains its own regionalization documentation separate from CX Agent Studio's two multi-regions and CX Insights' region list, which means the three components can be pinned inconsistently and produce a data path that crosses a boundary the organization believes it has closed. Agent Assist also documents several features whose processing or storage does not follow the regional pin.	High	Med		Configure regionalization through the API only, since "The Agent Assist console doesn't support regionalization." Record the region, the per-feature availability table, and these documented exceptions as certification evidence before enablement. (1) Vertex AI does not support the us multi-region, so generative features pinned to us use the existing US single-region endpoints. (2) The AI/ML data location commitment applies only in US and EU locations and not to non-AI/ML data in use or in transit, so residency is an at-rest guarantee. (3) Model	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/regionalization ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/region ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/regionalization ; https://docs.cloud.google.com/gemini-transcribe-live	HIPAA: 164.308(a)(1)(ii)(B) (Risk Management); NIST 800-53: SA-9(5) (Processing, Storage, and Service Location), AC-4 (Information Flow Enforcement), CM-6 (Configuration Settings), SC-7 (Boundary Protection), SA-9 (External System Services); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information), 09.s (Information Exchange Policies and Procedures)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
						training does not support regionalization and may route data outside the region, affecting features trained on the organization's conversations such as Smart Reply. (4) Data stores for generative knowledge assist are supported only in global, us, and eu. (5) Grounding with Google Search does not support data residency. (6) Preview Gemini Transcribe Live remaps traffic to the Vertex AI global region, moving live audio outside any regional pin.		
SG-GCP-GECX-000690	Where Agent Assist data about identified human	AI coach suggests how a representative should respond; it	Med	Med		Confirm before enablement who can see an individual's	https://docs.cloud.google.com/gemini-enterprise-cx/agent-	NIST 800-53: PT-2 (Authority to Process Personally Identifiable

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	representatives - for example, AI coach suggestion usage or conversations passed to CX Insights for Quality AI scoring - is used to evaluate representative performance, that evaluation MUST be governed by the organization's employee monitoring and workforce policy before enablement.	does not itself score the representative. Evaluation arises when Agent Assist conversations and suggestion interactions are attributed to named representatives and fed into performance processes, most directly through Quality AI, which Google describes as automating conversation scoring "to more accurately evaluate agent performance", and its agent engagement platform, which summarizes an individual agent's performance. That is continuous algorithmic evaluation of identified employees, which carries notice				scores, how long they are retained, whether they feed employment decisions, and what the appeal path is. This control covers the Agent Assist side of the data flow; the Quality AI scorecards and assessments built in CX Insights need the same workforce-policy approval, and one approval can satisfy both when it names both data sources. The agent engagement platform is Preview. The technical controls protecting the conversation data say nothing about the appropriateness of the evaluation built on top of it, which is a separate approval.	assist/ai-coach-overview; https://docs.cloud.google.com/gemini-enterprise-cx/insights/qai-overview ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist	Information), PT-5 (Privacy Notice), AC-3 (Access Enforcement), SI-12 (Information Management and Retention); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		obligations, consultation expectations in some jurisdictions, and a fairness and contestability obligation that sits outside the security review.						
SG-GCP-GECX-001320	The Agent Assist Build your own assist capability MUST NOT be enabled while it is designated Preview.	Google's Agent Assist regional feature table lists Build your own assist with an explicit Preview marker alongside generally available capabilities such as summarization, sentiment analysis and AI coach. The capability builds custom assistance surfaces over live member conversation, so it operates on the same content as the generally available features	High	Low		The Preview marker appears in the Agent Assist regional feature table alongside generally available features, and Google's HIPAA guidance says "Do not use Pre-GA offerings ... in connection with PHI, unless expressly noted otherwise in a notice or other terms of the offering." Re-check the marker at each release-note review and lift the prohibition	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/regionalization; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist; https://cloud.google.com/terms/service-terms; https://cloud.google.com/security/compliance/hipaa	HIPAA: 164.308(a)(8) (Evaluation), 164.308(b)(1) (Business Associate Contracts), 164.314(a) (Business Associate Contracts or Other Arrangements); NIST 800-53: CM-7 (Least Functionality), CM-3 (Configuration Change Control), SA-4 (Acquisition Process); HITRUST CSF v11: 05.k (Addressing Security in Third Party Agreements)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		while carrying the Pre-GA Offerings Terms: no SLA, changeable or discontinued without notice, and no data processing terms, with Google stating that customers should not use Pre-GA Offerings to process data subject to regulatory compliance requirements.				only when the feature table or release notes show general availability.		
SG-GCP-GECX-001350	Gemini Transcribe Live MUST NOT be enabled in any Agent Assist conversation profile while it is designated Preview.	Google announced Gemini Transcribe Live for Agent Assist in Preview on 2026-09-01, under the Pre-GA Offerings Terms. It transcribes live conversation audio and, to support all Agent Assist regions, remaps that traffic to the Vertex AI supported global region, so	High	Low		The capability is enabled by setting use_gemini_asr in the speech-to-text configuration of a conversation profile. Check every conversation profile for that setting at deployment review, and alert on conversation profile changes. Reassess when the capability reaches GA,	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/release-notes ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/gemini-transcribe-live ; https://cloud.google.com/terms/service-terms ; https://cloud.google.com/security/compliance/hipaa	HIPAA: 164.308(a)(8) (Evaluation), 164.308(b)(1) (Business Associate Contracts), 164.314(a) (Business Associate Contracts or Other Arrangements); NIST 800-53: CM-7 (Least Functionality), SA-9 (External System Services), SA-9(5) (Processing, Storage, and

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		enabling it sends member audio outside the regional pin and onto a path with no production SLA and no assurance of compliance coverage.				including whether the global-region remap persists.		Service Location), CM-3 (Configuration Change Control), SA-4 (Acquisition Process); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)
SG-GCP-GECX-000700	The CX Insights encryption specification MUST be initialized with a customer-managed key for every location before any conversation is ingested into that location.	Google states plainly that you cannot change encryption key settings for a location after that location has been enabled for CMEK, and that a project already containing CX Insights data cannot be configured for customer-managed keys retroactively. This is the single most consequential irreversible decision in the suite: getting it wrong means every	High	Med		Initialize through the InitializeEncryptionSpec API before the first ingestion, including before any proof-of-concept upload. Create the Insights service identity first (gcloud beta services identity create --service=contactcenterinsights.googleapis.com), then grant Cloud KMS CryptoKey Encrypter/Decrypter to <code>service-PROJECT_NUMBER@gcp-sa-ccai-cmek.iam.gservicea</code>	https://docs.cloud.google.com/gemini-enterprise-cx/insights/cmek ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/regionalization ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/cmek ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history	HIPAA: 164.312(a)(2)(iv) (Encryption and Decryption); NIST 800-53: SC-28 (Protection of Information at Rest), SC-28(1) (Cryptographic Protection), SC-12 (Cryptographic Key Establishment and Management), CM-6 (Configuration Settings); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information), 10.g (Key Management)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		conversation in that location is encrypted under Google-managed keys permanently, and the only remedy is a new project.				ccount.com. CX Agent Studio manages its keys through the Conversational Insights API, and conversation history logged by CX Agent Studio is stored for CX Insights, so the first logged test conversation from an agent application may count as CX Insights data for that location; initialize the specification before any agent testing with conversation logging enabled. CMEK is not available for the global location, which is a further reason to pin a specific region rather than accepting the default endpoint. Google warns that		

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
						if the key is revoked for more than 30 days, the Insights data encrypted by that key will be lost.		
SG-GCP-GECX-000710	A project-level <code>conversation_ttl</code> MUST be configured in CX Insights before the first conversation is ingested.	Google documents that a conversation not set to expire remains in CX Insights indefinitely, and that project-level TTL only applies to conversations created after the TTL is set - changing it does not retroactively change the expiration of existing conversations. Conversations ingested during a pilot before anyone set a TTL therefore persist until someone locates and deletes them explicitly.	High	Low		Set the TTL as part of project initialization alongside the encryption specification, not as a later hardening step. Where both <code>expire_time</code> and <code>ttl</code> are set on a conversation, <code>expire_time</code> wins. Deletion occurs 24 hours after the expiration time and is not recoverable, so validate the value against the records-retention schedule before ingestion begins rather than after. Conversations that predate the TTL can be removed with the	https://docs.cloud.google.com/gemini-enterprise-cx/insights/ttl ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/reference/rest/v1/projects.locations.conversations/bulkDelete	HIPAA: 164.502(b) (Minimum Necessary); NIST 800-53: SI-12 (Information Management and Retention), MP-6 (Media Sanitization), CM-6 (Configuration Settings); HITRUST CSF v11: 06.c (Protection of Organizational Records)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
						bulk delete method, which selects conversations by filter.		
SG-GCP-GECX-000720	Sensitive Data Protection redaction MUST be applied on every CX Insights ingestion path before production conversations are imported - through RedactionC onfig for upload and ingest paths, and in the upstream Agent Assist or CX Agent Studio configuration for runtime integrations .	CX Insights persists complete conversation transcripts and runs machine learning analysis over them, producing sentiment scores, entities, topics, and assessments that are themselves derived from the raw content. Redaction at ingestion is the control that prevents identifiers entering that corpus in the first place, and every derived artifact inherits whatever was or was not redacted at that moment.	High	Med		Configure RedactionC onfig with a DLP inspect template and deidentify template. Google documents that these settings "are applied to conversations ingested from the UploadCon versation and IngestConv ersations endpoints, including conversatio n coming from CCAI Platform" and "are not applied to conversatio ns ingested from the CreateCon versation endpoint or the Dialogflow / Agent Assist runtime integrations ", where redaction is performed in Dialogflow or Agent	https://docs.cloud.google.com/gemini-enterprise-cx/insights/reference/rest/v1/RedactionConfig ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/data-redaction-retention	HIPAA: 164.502(b) (Minimum Necessary) ; NIST 800-53: SC-7 (Boundary Protection), SC-7(10) (Prevent Exfiltration) , SI-19 (De-identification), AC-4 (Information Flow Enforcement); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
						Assist instead. Inventory every ingestion path, confirm the redaction mechanism for each, and verify with a test conversation containing synthetic identifiers that they are absent from the stored transcript before enabling production ingestion.		
SG-GCP- GECX- 000730	Project-level CX Insights access - roles/contactcenterinsights.viewer, roles/contactcenterinsights.editor, and roles/contactcenterinsights.admin granted directly, and the same access inherited through any CX Agent Studio role (roles/ces.*) - MUST be	Fine-grained access control through authorized views is Pre-GA, so there is no supported way to restrict an analyst to a subset of conversations. Every holder of project-level CX Insights access therefore sees every conversation in the project, which for a contact center deployment	High	Med		Enumerate effective access rather than direct grants: include every principal holding a roles/ces.* role in the project as well as direct CX Insights grants. Where agent builders do not need conversation access, develop agents in a project that holds no production conversations.	https://docs.cloud.google.com/gemini-enterprise-cx/insights/best-practices-for-fine-grained-access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/release-notes ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/audit-logging ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/audit-logging	HIPAA: 164.312(a)(1) (Access Control), 164.308(a)(4) (Information Access Management), 164.502(b) (Minimum Necessary); NIST 800-53: AC-3 (Access Enforcement), AC-6 (Least Privilege), AC-2 (Account Management), AU-2 (Event Logging); HITRUST CSF v11: 01.c (Privilege

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	held only by a named, minimal, documented group.	is the complete corpus of member interactions. Google's CX Agent Studio access-control page shows that the Viewer role (roles/ces.viewer) has the CX Insights Viewer role (roles/contactcenterinsights.viewer) as a base role and is itself the base of every CX Agent Studio editor role, and that the Admin role (roles/ces.admin) includes the CX Insights Admin role, so every agent builder holds conversation read access unless builder access is itself restricted.				Because the finer boundary does not exist in a supported form, the compensating controls are the size of the group and the visibility of its activity: keep the group small and named, review it quarterly, and rely on Data Access audit logging to record who read what. State the residual risk explicitly in the certification rather than implying a conversation boundary that the product does not provide.	le.com/gemini-enterprise-cx/cx-agent-studio/access-control; https://docs.cloud.google.com/iam/docs/roles-permissions/ces	Management), 01.v (Information Access Restriction)
SG-GCP-GEEX-000740	CX Insights authorized views MUST NOT	Authorized views are Pre-GA, and	High	Low		Evaluate authorized views in a project	https://docs.cloud.google.com/gemini-	HIPAA: 164.312(a)(1) (Access Control);

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	be applied to conversation data containing PHI while the capability is Pre-GA, or configured with an empty filter expression in any project.	Google's HIPAA guidance says "Do not use Pre-GA offerings ... in connection with PHI, unless expressly noted otherwise in a notice or other terms of the offering." Google also warns directly that empty filters or an empty string allow unrestricted access. An authorized view with an empty filter looks like a scoping control in the IAM policy and in any access review, while granting exactly the access it appears to constrain - a failure mode that is invisible precisely because the mechanism appears to be present.				holding synthetic or non-PHI conversations until the capability is generally available. Google also warns that granting authorized view set permissions at the project level results in users having access to all authorized view sets, which defeats the mechanism a second way. Grant on the specific view or view set, never at project level, and use the <code>agent_id</code> field for representative and team scoping. Authorized views cannot import or edit conversation data, train topic models, or create scorecards, so they do not replace	enterprise-cx/insights/best-practices-for-fine-grained-access-control; https://cloud.google.com/security/compliance/hipaa	NIST 800-53: AC-3 (Access Enforcement), AC-6 (Least Privilege), CM-6 (Configuration Settings), AC-4 (Information Flow Enforcement); HITRUST CSF v11: 01.v (Information Access Restriction)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
						the project-level roles for those tasks.		
SG-GCP-GEEX-000750	The CX Insights global endpoint MUST NOT be used for production conversation data.	Google documents that CX Insights uses the legacy location ID us-central1 for the global endpoint and that CMEK is not available for the global location. Using it therefore forfeits customer-managed encryption entirely while presenting no visible indication that it has done so, because the hostname carries no region and the default client configuration reaches it.	High	Low		Both the endpoint host and the resource location path must be changed together - Google states you need to change both the host of the URL and the resource location to use the regional instance. Google does not document what happens when only one is changed; treat a mismatch as a misconfiguration. In Python clients this means setting the ClientOptions api_endpoint and updating the parent parameter; verify both in code review rather than in configuration	https://docs.cloud.google.com/gemini-enterprise-cx/insights/regionalization; https://docs.cloud.google.com/gemini-enterprise-cx/insights/cmek	HIPAA: 164.312(a)(2)(iv) (Encryption and Decryption); NIST 800-53: SA-9(5) (Processing, Storage, and Service Location), SC-28 (Protection of Information at Rest), CM-6 (Configuration Settings), AC-4 (Information Flow Enforcement), SA-9 (External System Services); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
						n documentat ion.		
SG-GCP- GECX- 000760	Cloud Storage buckets holding conversation audio for CX Insights MUST be encrypted with customer-managed keys, located in the approved region, and placed inside the service perimeter.	Call audio is the richest single artifact in this suite: it carries the member's voice, everything they said before any redaction was applied, and background context that no transcript captures. It lands in a customer-owned Cloud Storage bucket whose security posture is entirely the organization's responsibility and is governed by none of the CX Insights settings.	High	Med		Where VPC Service Controls protects CX Agent Studio, Google documents that audio recordings cannot be written to Cloud Storage buckets outside the perimeter, so perimeter membership is a functional requirement for that path as well as a hardening one. Set a Cloud KMS key as the bucket default key so objects written by the service are encrypted with it; Google documents that "By default, objects in a bucket use the bucket default key." Apply a lifecycle policy consistent with the conversatio	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls; https://docs.cloud.google.com/gemini-enterprise-cx/insights/common-integrations; https://docs.cloud.google.com/gemini-enterprise-cx/insights/cmek; https://cloud.google.com/storage/docs/encryption/customer-managed-keys	HIPAA: 164.312(a)(2)(iv) (Encryption and Decryption); NIST 800-53: SC-28 (Protection of Information at Rest), SC-28(1) (Cryptographic Protection), SC-7 (Boundary Protection), SI-12 (Information Management and Retention); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information), 06.c (Protection of Organizational Records)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
						n TTL, since the bucket has no relationship to the CX Insights expiry and will otherwise retain audio after the analyzed conversation is gone.		
SG-GCP-GECX-000770	Cloud Speech-to-Text MUST be configured with customer-managed encryption keys where it transcribes conversation audio for CX Insights or Agent Assist.	Google states directly that features involving external data transfer need separate CMEK configuration in the corresponding services, naming Cloud Speech-to-Text for audio transcription. Speech-to-Text is a distinct service with its own encryption configuration, so a fully CMEK-covered CX Insights deployment still passes every second of member audio through a transcriptio	High	Med		This is one of the most easily missed gaps in the suite because the transcription step is invisible in the CX Insights console - it appears as a transcript that simply exists. Include Speech-to-Text in the CMEK inventory and in the perimeter, and verify coverage by inspecting the service configuration rather than inferring it from the CX Insights encryption specification. Agent Assist conversatio	https://docs.cloud.google.com/gemini-enterprise-cx/insights/cmek; https://docs.cloud.google.com/gemini-enterprise-cx/insights/common-integrations; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/gemini-transcribe-live	HIPAA: 164.312(a)(2)(iv) (Encryption and Decryption); NIST 800-53: SC-28 (Protection of Information at Rest), SC-28(1) (Cryptographic Protection), SC-12 (Cryptographic Key Establishment and Management), AC-4 (Information Flow Enforcement); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information), 10.g (Key Management)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		n service under Google-managed keys unless it is configured separately.				n profiles can select the Gemini Transcribe Live model, which Google describes as using "the Gemini model for Speech-to-Text API"; record in the CMEK inventory which transcription model each conversation profile uses.		
SG-GCP-GEEX-000780	BigQuery datasets receiving the CX Insights conversation export MUST be encrypted with customer-managed keys, located in the approved region, and placed inside the service perimeter.	Google states that BigQuery needs its own CMEK configuration for conversation exports. The export is a full copy of analyzed conversation content in a general-purpose analytics store governed by BigQuery IAM rather than by CX Insights roles, which means the carefully limited CX Insights access group has	High	Med		Reconcile the BigQuery dataset's IAM against the approved CX Insights access group - a broader BigQuery grant silently widens access to the same conversation content. Google does not document whether deleting a conversation in CX Insights removes its exported row; assume it does not, and apply a	https://docs.cloud.google.com/gemini-enterprise-cx/insights/cmek ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls ; https://docs.cloud.google.com/gemini-enterprise-cx/insights ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/export	HIPAA: 164.312(a)(1) (Access Control), 164.312(a)(2)(iv) (Encryption and Decryption); NIST 800-53: SC-28 (Protection of Information at Rest), AC-3 (Access Enforcement), SC-7 (Boundary Protection), SI-12 (Information Management and Retention); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		no bearing on who can query the exported copy.				table expiration or partition expiration consistent with the conversation TTL.		Information), 01.v (Information Access Restriction)
SG-GCP-GEEX-000790	CX Insights Pub/Sub notifications for triggers whose message data is a Conversation resource - create-conversation and update-conversation, including when all events are selected - MUST NOT be routed to a topic whose subscribers are not approved to receive member conversation content.	Google documents that for the create-conversation and update-conversation triggers the Pub/Sub message data is the Conversation itself, while the other triggers carry an operation name. The notification payload is not configurable, so the only controls are which triggers are enabled and who can subscribe, and subscribers are governed by Pub/Sub IAM rather than by any CX Insights control. A topic carrying conversation resources becomes	Med	Low		Prefer triggers that carry only an operation name, and have subscribers call back through the CX Insights API, where CX Insights IAM applies, to obtain content. Where a conversation trigger is required, restrict topic and subscription IAM to approved service identities and keep the topic in the approved region and perimeter. Review topic and subscription IAM alongside the CX Insights access review, since a subscription created for an integration	https://docs.cloud.google.com/gemini-enterprise-cx/insights ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/common-integrations ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/pub-sub	HIPAA: 164.312(a)(1) (Access Control), 164.502(a) (Uses and Disclosures of PHI); NIST 800-53: AC-4 (Information Flow Enforcement), AC-3 (Access Enforcement), CA-3 (Information Exchange), SC-7(10) (Prevent Exfiltration), SC-7 (Boundary Protection); HITRUST CSF v11: 09.s (Information Exchange Policies and Procedures)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		an uncontrolled distribution channel for member conversation content into systems that were never assessed.				project typically outlives it.		
SG-GCP-GECX-000800	The CX Insights Google Sheets integration MUST NOT be used in any project that holds member conversation data.	The Sheets integration is Pre-GA, and Google's HIPAA guidance says "Do not use Pre-GA offerings ... in connection with PHI, unless expressly noted otherwise in a notice or other terms of the offering." It moves CX Insights data into a spreadsheet shared with the CX Insights service account and governed by Google Workspace sharing rather than by Google Cloud IAM, and Google's Cloud	High	Low		Where analysts need tabular access, direct them to the CMEK-protected BigQuery export inside the perimeter, which retains IAM control and expiration. Aggregate reporting that must reach a spreadsheet is produced from BigQuery through a separate, reviewed process rather than through this integration.	https://docs.cloud.google.com/gemini-enterprise-cx/insights ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/google-sheets-integration ; https://cloud.google.com/security/compliance/hipaa	HIPAA: 164.312(a)(1) (Access Control), 164.502(a) (Uses and Disclosures of PHI); NIST 800-53: AC-21 (Information Sharing), AC-3 (Access Enforcement), SC-7 (Boundary Protection), SC-7(10) (Prevent Exfiltration), SI-12 (Information Management and Retention); HITRUST CSF v11: 09.s (Information Exchange Policies and Procedures)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		HIPAA guidance states that HIPAA compliance for Google Workspace is covered separately. A single link change converts a controlled dataset into a broadly shared one, and the copy is beyond the reach of any retention setting, TTL, or deletion request in CX Insights.						
SG-GCP-GEEX-000810	Topic models, scorecards, summarization generators, and other artifacts trained or derived from conversation content MUST be treated as carrying the sensitivity of the source conversations.	CX Insights generates a layer of derived artifacts from the conversation corpus - inferred topics, assessment results, trained topic models. These are routinely treated as aggregate analytics and shared more freely than transcripts, but they are computed from	Med	Med		Apply the same access group, retention, and residency treatment to derived artifacts as to the conversations. Pay particular attention to sparse categories: a topic matching a small number of conversations is effectively a pointer to those members. Aggregation	https://docs.cloud.google.com/gemini-enterprise-cx/insights ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/best-practices-for-fine-grained-access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/release-notes	HIPAA: 164.502(b) (Minimum Necessary), 164.514(a) (De-identification of PHI); NIST 800-53: AC-3 (Access Enforcement), SI-12 (Information Management and Retention), AC-21 (Information Sharing), SC-28 (Protection of Information at Rest); HITRUST

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		member conversation and can retain identifying detail, particularly for rare topics where a category may correspond to a single member.				n alone does not make an artifact de-identified under HIPAA 164.514(a); treat derived artifacts as protected health information unless that standard has actually been met. Note that authorized views cannot be used to train topic models or create scorecards, so these artifacts are produced with project-level access to the full corpus.		CSF v11: 06.d (Data Protection and Privacy of Covered Information)
SG-GCP-GECX-000820	Where Quality AI assessments evaluate identified human representatives, their use MUST be approved under the organization's workforce monitoring policy before	Quality AI produces scorecards and assessments of representative performance from conversation content, which is algorithmic evaluation of identified employees at a scale manual	Med	Med		Determine before enablement who can see individual scores, how long assessments are retained, whether they inform employment decisions, and how a representative contests	https://docs.cloud.google.com/gemini-enterprise-cx/insights ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/release-notes ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/release-notes	NIST 800-53: PT-2 (Authority to Process Personally Identifiable Information), PT-5 (Privacy Notice), AC-3 (Access Enforcement), SI-12 (Information Management and Retention);

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	enablement .	review never reached. That carries notice, retention, and contestability obligations distinct from the security controls protecting the conversation data itself, and assessment results are personnel data with their own access constraints.				one. This control covers Quality AI scorecards, assessments, and the agent engagement platform in CX Insights; the Agent Assist data that feeds them needs the same workforce-policy approval, and one approval can satisfy both when it names both data sources. The agent engagement platform is Preview, and multiple scorecards remains a Preview capability, so any design depending on either rests on a Pre-GA feature.	cx/insights/best-practices-for-fine-grained-access-control; https://docs.google.com/gemini-enterprise-cx/insights/agent-engagement	HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)
SG-GCP-GECX-000830	Conversations ingested into CX Insights during pilot or proof-of-concept activity MUST be deleted before the	Pilot conversations are ingested before the controls are finished, which is the point of a pilot. If the encryption specificatio	High	Med		Enumerate and delete pilot conversations explicitly - for example with the bulk delete method and a filter that selects	https://docs.google.com/gemini-enterprise-cx/insights/tl ; https://docs.google.com/gemini-enterprise-	HIPAA: 164.502(b) (Minimum Necessary) ; NIST 800-53: MP-6 (Media Sanitization), SI-12 (Information Manageme

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	production deployment is certified, unless they were ingested under the full production control set.	n was not initialized, they are permanently under Google-managed keys; if no TTL was set they persist indefinitely, because the project-level TTL is not retroactive; and if redaction was not configured they hold unredacted member content that every subsequent analysis inherits.				the pilot period - rather than assuming a later TTL will collect them; Google is explicit that changing the TTL does not retroactively change the expiration of existing conversations. Where the encryption specification was not set correctly at pilot time, deleting the conversations does not fix the location, and a new project is the remedy.	cx/insights/cmek; https://docs.cloud.google.com/gemini-enterprise-cx/insights ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/reference/rest/v1/projects.locations/conversations/bulkDelete	nt and Retention), CM-3 (Configuration Change Control), SC-28 (Protection of Information at Rest); HITRUST CSF v11: 09.p (Disposal of Media)
SG-GCP-GECX-000840	CX Agent Studio MUST be CMEK-integrated at project creation, before any agent application or conversation data exists in the project.	Google states that existing resources in non-CMEK integrated projects cannot be CMEK integrated retroactively, and recommends that resources be exported and restored in a new project for	High	Med		Treat CMEK integration as a project provisioning step in the same class as enabling the API, not as a hardening task. Google notes that one key should be used per project location, and that CX Agent	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/cmek ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/cmek	HIPAA: 164.312(a)(2)(iv) (Encryption and Decryption), 164.312(e)(2)(ii) (Encryption); NIST 800-53: SC-28 (Protection of Information at Rest), SC-28(1) (Cryptographic Protection), SC-12

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		CMEK. A project that begins without CMEK therefore holds agent instructions, tool configurations, application variables, and conversation history under Google-managed keys until the deployment is exported and restored into a new CMEK-integrated project, which is a migration rather than a setting change.				Studio key management (create, enable, and revoke) is handled by using the Conversational Insights API. For CX Insights, create the Insights service identity, grant service-PROJECT_NUMBER@gcp-sa-ccai-cmek.iam.gserviceaccount.com the Cloud KMS CryptoKey Encrypter/Decrypter role, and call InitializeEncryptionSpec for the location; Google warns that a customer-managed key cannot be configured for a project that already has CX Insights data. Because conversation history is surfaced through CX Insights, assume		(Cryptographic Key Establishment and Management), CM-6 (Configuration Settings); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information), 10.g (Key Management)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
						that a logged test conversation may create Insights data, and complete this step first. Verify with GetEncryptionSpec before the first agent application is created. Google also warns that if a key is revoked for more than 30 days, the Insights data encrypted by that key will be lost.		
SG-GCP- GECX- 000850	Cloud KMS keys protecting Gemini Enterprise for CX data MUST be monitored for availability, with key destruction and disablement gated on multi-party authorization.	Google warns that if a key is revoked for more than 30 days, the CX Insights data encrypted by that key will be lost. This converts an ordinary key management error - a mistaken disable, an over-eager cleanup of an apparently unused key, an expired	High	Med		Alert on key state changes and on decryption failures against these keys, and treat any such alert as an availability incident with a hard 30-day clock rather than a configuration ticket. Protect key destruction with organization policy and a separate approval,	https://docs.cloud.google.com/gemini-enterprise-cx/insights/cmek ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/cmek	HIPAA: 164.312(a)(2)(iv) (Encryption and Decryption), 164.308(a)(7) (Contingency Plan); NIST 800-53: SC-12 (Cryptographic Key Establishment and Management), SC-12(1) (Availability), CM-5 (Access Restrictions for Change), AC-5

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		rotation schedule - into permanent destruction of the member conversation corpus on a 30-day fuse, with no recovery path once it burns.				and confirm the KMS key's own IAM excludes the people who administer the CX projects.		(Separation of Duties), SI-4 (System Monitoring); HITRUST CSF v11: 10.g (Key Management), 09.ab (Monitoring System Use)
SG-GCP-GECX-000860	Cloud KMS key versions protecting Gemini Enterprise for CX data MUST NOT be disabled or destroyed while any data encrypted under them is still retained.	Google states for CX Agent Studio that key rotation is supported but data re-encryption is not: re-encrypting previously encrypted data with a new key version is not supported. Rotation therefore protects only newly written data, and previously written conversation content stays bound to the older key version for as long as it is retained. A rotation standard that retires old key versions on a schedule makes that	High	Low		Retain every key version for as long as any data encrypted under it is retained, which means key version lifetime is governed by the conversation retention schedule rather than by the rotation period. Document this explicitly, because it contradicts the default assumption behind most rotation standards.	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/cmek	HIPAA: 164.312(a)(2)(iv) (Encryption and Decryption); NIST 800-53: SC-12 (Cryptographic Key Establishment and Management), SC-28 (Protection of Information at Rest), SI-12 (Information Management and Retention); HITRUST CSF v11: 10.g (Key Management)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		data unreadable , which is the same permanent loss that follows revoking the key itself.						
SG-GCP-GECX-000870	CX Agent Studio agent data MUST be located in the us multi-region.	CX Agent Studio offers exactly two multi-regions, us and eu , and the region governs where callback code, tool code and configurations, agent instructions and prompts, application variables, and conversation history are stored at rest. Member conversation content for a US population belongs in the US multi-region both to satisfy the organization's residency position and to keep the data path within a single legal jurisdiction.	High	Low		A region must be supplied on every API request through the location path or resource parameter, so an omitted or defaulted region in client code is a residency defect that no console setting reveals. Verify the region in deployed client configuration rather than in design documentation. Two adjacent services need separate attention: Google states that OpenAPI tools support only global Secret Manager (regional secrets are	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/region ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/settings	HIPAA: 164.308(a)(1)(ii)(B) (Risk Management); NIST 800-53: SA-9(5) (Processing, Storage, and Service Location), CM-6 (Configuration Settings), SA-9 (External System Services); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
						unsupported), so the storage location of tool credentials is governed by each secret's own replication policy rather than by the agent region and must be confirmed separately; and the BigQuery export dataset must exist in the same location as the agent.		
SG-GCP-GEEX-000880	Cloud Logging MUST be configured with a US region for log storage independently of the Gemini Enterprise for CX residency setting.	Google's residency documentation for CX Agent Studio directs the reader to the Cloud Logging documentation to control where logs are stored, which means logging sits outside the product's residency guarantee. Because Cloud Logging is documented as one of the customer-	High	Low		Set the default storage location for new _Default and _Required log buckets in the Cloud Logging default resource settings at organization or folder level, so new projects inherit it, and confirm the location of existing buckets. Confirm that any log sink forwarding	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/region; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history; https://cloud.google.com/logging/docs/region-logs; https://cloud.google.com/logging/d	HIPAA: 164.308(a)(1)(ii)(B) (Risk Management); NIST 800-53: SA-9(5) (Processing, Storage, and Service Location), CM-6 (Configuration Settings), SA-9 (External System Services); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		owned storage paths for conversation data, service logs routed there may contain member conversation content, and an unpinned logging configuration can store that content outside the residency boundary the rest of the deployment maintains.				to a SIEM does not itself relocate the data. This is a separate configuration in a separate product, so it is easily missed in a residency review that only examines the CX components.	ocs/default-settings	
SG-GCP-GEEX-000890	Conversation history retention in CX Agent Studio MUST be configured to a documented period no longer than the business need requires.	Google documents retention as configurable with a default of one year and a maximum of two. Left at the default, the deployment accumulates a year of complete member conversation history because nobody made a decision, and the volume of that corpus is the primary determinant of the impact of	Med	Low		Set the value against the records-retention schedule and the operational need for dispute resolution, and record the rationale. Google states that the Log your customer conversations setting applies to both CX Agent Studio and CX Insights; separately, CX Insights documents per-	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/tl	HIPAA: 164.502(b) (Minimum Necessary); NIST 800-53: SI-12 (Information Management and Retention), MP-6 (Media Sanitization), CM-6 (Configuration Settings); HITRUST CSF v11: 06.c (Protection of Organizational Records)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		any future compromise of the analytics surface.				conversation TTL and states that a conversation not set to expire remains in CX Insights indefinitely, so confirm with Google which mechanism governs conversations that reach CX Insights from CX Agent Studio. The Cloud Storage audio, the BigQuery export, and Cloud Logging each expire on their own schedules and must be aligned deliberately. Leaving the setting at its one-year default is not a decision.		
SG-GCP-GECX-000900	The state of the Log your customer conversations setting (labeled Interaction data in agent application settings) MUST be	This single toggle governs whether long-term conversational data exists at all: Google states that disabling it disables all types of	High	Low		Because the trade is real, make it deliberately rather than by default. Note the exception in Google's own wording - BigQuery	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history	HIPAA: 164.502(b) (Minimum Necessary); NIST 800-53: SI-12 (Information Management and Retention), CM-6 (Configurati

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	an explicit, documented decision for every agent application.	long-term conversational data except BigQuery data, and that with logging disabled conversational data does not exist in any Google-owned persistent storage to be accessed. It is simultaneously the strongest available data minimization control and a control that disables the monitoring dashboards and the CX Insights corpus that operations depends on.				data is not disabled by the toggle - so a deployment that turns logging off while an export remains configured has not stopped conversational content being persisted. Google's settings page labels the same control Interaction data ("Store interaction data for deeper insights and your reference"), while the conversational history page calls it Log your customer conversations. Record the decision and the exception check as certification evidence.	ini-enterprise-cx/cx-agent-studio/settings	on Settings), AC-4 (Information Flow Enforcement); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)
SG-GCP-GEEX-000910	Written confirmation from Google that the Service Specific Terms training restriction covers	Google's Service Specific Terms contain a contractual training restriction in section 18: "Google	High	Low		Section 18 sits under the AI/ML Services part of the Service Specific Terms; ask Google to confirm,	https://cloud.google.com/terms/service-terms; https://docs.cloud.google.com/gemini-enterprise-cx-	HIPAA: 164.502(a) (Uses and Disclosures of PHI), 164.308(b) (1) (Business Associate Contracts),

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	every Gemini Enterprise for CX component and data path in use MUST be obtained and retained as certification evidence.	will not use Customer Data to train or fine-tune any AI/ML models without Customer's prior permission or instruction." The conversation history documentation separately states that customer content shared through the Improve agent performance by sharing conversation data toggle is never used to train Google's production machine learning models. Neither text names the individual components of this suite or its data paths, including audio through Speech-to-Text and analytics in CX Insights, and member conversatio				through the contracting relationship, that each component in use and each data path falls within it, rather than relying on a documentation sentence that Google can revise without notice. Google's HIPAA guidance also states that a customer using Cloud Speech-to-Text under a BAA should not opt into the data logging program; confirm that it is not enabled. Retain the response as evidence, and re-confirm at contract renewal and whenever a new component is enabled.	agent-studio/conversation-history; https://cloud.google.com/terms/hipaa-baa ; https://cloud.google.com/security/compliance/hipaa	164.504(e) (Business Associate Contracts); NIST 800-53: SA-9 (External System Services), PT-2 (Authority to Process Personally Identifiable Information), CA-3 (Information Exchange); HITRUST CSF v11: 05.k (Addressing Security in Third Party Agreements), 06.d (Data Protection and Privacy of Covered Information)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		n content used for training would be a use of PHI outside the purposes the organization has authorized.						
SG-GCP-GECX-000920	Sensitive Data Protection templates used by any Gemini Enterprise for CX component MUST be located inside the same VPC Service Controls perimeter as the component that references them.	Google states that Sensitive Data Protection redaction templates outside the perimeter cause failures in redacting conversation contents. Google does not document whether ingestion stops or continues when redaction fails; if it continues, unredacted member content reaches the conversation corpus and the misconfiguration surfaces later as a data problem rather than as an error at the time.	High	Low		Verify template location as part of perimeter change review, and monitor for redaction failures as an operational signal rather than assuming success. Because a template can be moved or a perimeter redrawn independently of the CX configuration, re-verify after any change to either. Redacted transcripts are not de-identified under HIPAA and remain PHI.	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/common-integrations	HIPAA: 164.502(b) (Minimum Necessary); NIST 800-53: SC-7 (Boundary Protection), SC-7(10) (Prevent Exfiltration), SI-19 (De-identification), CM-6 (Configuration Settings); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)
SG-GCP-GECX-000930	Member identifiers and other	Google's HIPAA guidance	High	Low		Pass values that vary by	https://cloud.google.com/security/	HIPAA: 164.502(b) (Minimum

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	sensitive values MUST NOT be written into application variables, agent instructions, or tool configuration as static values.	states that when creating or updating Conversational Agents agents, customers should avoid including PHI or security credentials anywhere in the agent definition. Application variables and agent instructions are documented as agent data at rest, readable by every holder of the Gemini Enterprise for CX Viewer role and carried in configuration exports. A member identifier placed there persists beyond the conversation that produced it, sits outside the conversation retention and TTL settings, and is not subject to the redaction applied to				member at runtime through the session rather than the configuration; Google documents session context variables that can be injected into OpenAPI tool requests. Include a scan for identifier-shaped values in the pre-deployment agent review, alongside the credential scan.	compliance/hipaa; https://docs.cloud.google.com/gemini-enterprise-cx/agent-studio/reference/region ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-studio/access-control ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-studio/tool/open-api	Necessary), 164.312(a)(1) (Access Control); NIST 800-53: SI-12 (Information Management and Retention), AC-3 (Access Enforcement), SC-28 (Protection of Information at Rest); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information), 01.v (Information Access Restriction)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		conversation content.						
SG-GCP-GEEX-000940	A documented procedure MUST exist to locate and delete all copies of an individual member's conversation data across every store in the deployment.	Conversation content is written to at least five documented places: the Google-managed store used by CX Agent Studio and CX Insights, CX Insights conversations, Cloud Storage audio, Cloud Logging, and the BigQuery export, plus any downstream subscriber the organization configures. Each has its own deletion mechanism and its own retention clock, and deleting a conversation in one does not remove it from the others. A deletion obligation - from the organization's records-retention schedule, from	High	Med		Build the procedure against the store inventory rather than against the console, and test it end to end with a synthetic conversation, verifying absence in every store afterwards. CX Agent Studio provides DeleteConversation and BatchDeleteConversations operations, and CX Insights conversations can be deleted manually; the BigQuery export and Cloud Storage audio require their own steps. HIPAA does not create an individual right to deletion; record which obligation each deletion satisfies.	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history; https://docs.cloud.google.com/gemini-enterprise-cx/insights/ttl; https://docs.cloud.google.com/gemini-enterprise-cx/insights; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging; https://cloud.google.com/terms/hipaa-baa	HIPAA: 164.310(d)(2)(i) (Disposal), 164.502(b) (Minimum Necessary); NIST 800-53: SI-12 (Information Management and Retention), MP-6 (Media Sanitization), CM-8 (System Component Inventory); HITRUST CSF v11: 09.p (Disposal of Media), 06.c (Protection of Organizational Records)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		applicable state law, or from the business associate agreement's return-or-destroy clause on termination - that the organization cannot execute completely is a compliance failure regardless of intent.						
SG-GCP-GEEX-000950	The short-lived caches the product maintains MUST be documented in the data flow record supporting certification .	Google documents a session memcache holding active session management data and metadata with a 30-minute TTL, and a Text-to-Speech Memstore cache with a one-hour TTL. These are minor exposures individually, but an incomplete data flow diagram is a finding in its own right, and an assessor who discovers an undocumented store	Med	Low		Record them as transient stores with their stated TTLs rather than attempting to control them - the product exposes no configuration for either. Their presence is also the reason a deletion request cannot be confirmed complete within the first hour of a conversation ending.	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history	HIPAA: 164.316(b)(1) (Documentation); NIST 800-53: PL-8 (Security and Privacy Architectures), CM-8 (System Component Inventory), SI-12 (Information Management and Retention); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		asks what else was omitted.						
SG-GCP- GECX- 000960	Google personnel access to Gemini Enterprise for CX conversation data SHOULD be gated by Access Approval and recorded through Access Transparency.	Google documents that support and engineering personnel may have controlled, just-in-time access to Google-managed operational data for critical debugging and system maintenance. For a corpus of member conversation content this is provider access to ePHI permitted under the business associate relationship. Google lists Access Approval approval requests as generally available for Customer Experience Agent Studio, Customer Experience Insights, and Gemini Enterprise for Customer Experience	Med	Med		Confirm with Google the entitlement required for Access Approval and Access Transparency, and route the logs to the same destination as the audit logs. Confirm per service which components of this suite are covered rather than assuming the whole deployment is, since coverage is enumerated per service and changes over time.	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history ; https://cloud.google.com/assured-workloads/access-approval/docs/supported-services ; https://cloud.google.com/security/compliance/hipaa	HIPAA: 164.312(b) (Audit Controls), 164.308(a) (1)(ii)(D) (Information System Activity Review), 164.308(b) (1) (Business Associate Contracts); NIST 800-53: AU-2 (Event Logging), AU-6 (Audit Record Review, Analysis, and Reporting), SA-9 (External System Services), SI-4 (System Monitoring); HITRUST CSF v11: 09.f (Monitoring and Review of Third Party Services), 09.ab (Monitoring System Use)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		, which lets the organization decide on that access before it occurs, and lists Access Transparency as generally available for the same services, which provides the record.						
SG-GCP-GEEX-000970	A VPC Service Controls perimeter MUST be configured with <code>ces.googleapis.com</code> , <code>contactcenterinsights.googleapis.com</code> , and, where Agent Assist is used, <code>dialogflow.googleapis.com</code> in the restricted services list.	<code>ces.googleapis.com</code> carries agent configuration, tool invocation, and live conversation; <code>contactcenterinsights.googleapis.com</code> carries the analyzed conversation corpus; and Agent Assist is served through <code>dialogflow.googleapis.com</code> . Any of these left unrestricted remains reachable with stolen credentials from any network, which for the Insights service	High	Med		Google names <code>ces.googleapis.com</code> and <code>contactcenterinsights.googleapis.com</code> in its perimeter guidance for CX Agent Studio, and its VPC Service Controls supported-products list gives <code>dialogflow.googleapis.com</code> as the service name for Agent Assist. The CX Agent Studio perimeter page documents failures when Cloud Storage	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls ; https://cloud.google.com/vpc-service-controls/docs/supported-products	HIPAA: 164.312(e)(1) (Transmission Security), 164.312(a)(1) (Access Control); NIST 800-53: SC-7 (Boundary Protection), SC-7(10) (Prevent Exfiltration), AC-4 (Information Flow Enforcement), CM-6 (Configuration Settings); HITRUST CSF v11: 09.m (Network Controls), 09.n (Security of Network Services)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		means the complete member conversation corpus.				buckets, BigQuery datasets, Sensitive Data Protection redaction templates, Secret Manager secrets, and data stores sit outside the perimeter, so restrict storage. googleapis.com, bigquery.googleapis.com, dl.googleapis.com, secretmanager.googleapis.com, and discoverengine.googleapis.com in the same perimeter. The CX Insights entry also directs adding the Agent Platform API (aiplatform.googleapis.com) when integrating multiple CCAI products. Restrict Cloud KMS and Speech-to-Text where		

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
						they are used as a design choice; Google does not name them as breakage points.		
SG-GCP-GECX-000980	The service perimeter MUST be established and enforced before agent applications, data stores, deployment channels, and CX Insights locations are created.	Google documents seven distinct operations that fail once a perimeter is enforced around existing resources: tools and callbacks reaching arbitrary HTTP endpoints, Cloud Storage audio writes, BigQuery export, Sensitive Data Protection redaction templates, OpenAPI tool secrets, data store tool execution, and cross-perimeter agent references and import or export. Enforcing a perimeter after the fact therefore	High	Med		Google documentation does not itself state a sequencing requirement - this control is derived from the enumerated breakages rather than quoted from Google. Sequence as: define the perimeter, add restricted services, configure ingress and egress rules, validate in dry-run, enforce, then create resources. Record an owner and a removal condition for any exception written during cutover.	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls	HIPAA: 164.312(e)(1) (Transmission Security); NIST 800-53: SC-7 (Boundary Protection), CM-3 (Configuration Change Control), PL-8 (Security and Privacy Architectures), CM-4 (Impact Analyses); HITRUST CSF v11: 09.m (Network Controls)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		produces a wave of simultaneous production failures at exactly the moment there is pressure to write exceptions rather than relocate resources.						
SG-GCP-GECX-000990	The service perimeter MUST be validated in dry-run mode and its findings resolved before enforcement.	Dry-run mode reports what enforcement would block without blocking it, which is the only safe way to discover which of the seven documented breakage paths a given deployment actually depends on. Skipping it means discovering the same information as a production outage, and outage-driven remediation reliably produces broad exceptions instead of	High	Low		Run the dry-run across a full operational cycle rather than a single test conversation, because several breakage paths - BigQuery export, Cloud Storage audio writes, and agent application import and export - occur only when those features are exercised. Google documents that in dry run mode requests that violate the perimeter policy are not denied, only logged, with	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls ; https://cloud.google.com/vpc-service-controls/docs/dry-run-mode	HIPAA: 164.312(e)(1) (Transmission Security); NIST 800-53: SC-7 (Boundary Protection), CM-3 (Configuration Change Control), CA-2 (Control Assessments), CM-4 (Impact Analyses); HITRUST CSF v11: 09.m (Network Controls)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		relocated resources.				metadata.dryRun set to True in the audit log. Resolve each finding by moving the resource inside the perimeter, not by exempting the service.		
SG-GCP-GECX-001000	Tools and callbacks MUST NOT be able to call HTTP(S) endpoints outside the approved list, enforced through the CX Agent Studio allowed origins endpoint control policy with its enforcement scope set to ALWAYS.	A tool or callback URL is an outbound channel for conversation-derived parameters. Google documents that allowed origins applies to all types of tools and callbacks which can make external requests, that when VPC Service Controls is not enabled (the default) all endpoints are allowed, and that the ALWAYS enforcement scope applies regardless of VPC-SC status. Without	High	Med		Set EndpointControlPolicy.enforcementScope to ALWAYS; an unspecified scope is treated as VPCSC_ONLY. Allowed origins are exact-match URLs including the scheme and optional port, with no wildcards, and an origin without a port allows all ports. The setting applies at project and location level and requires the <code>ces.securitySettings.update</code> permission,	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/settings ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/rest/v1beta/SecuritySettings ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api	HIPAA: 164.312(e)(1) (Transmission Security), 164.502(a) (Uses and Disclosures of PHI); NIST 800-53: SC-7 (Boundary Protection), SC-7(10) (Prevent Exfiltration), AC-4 (Information Flow Enforcement), CA-3 (Information Exchange); HITRUST CSF v11: 09.m (Network Controls), 09.s (Information Exchange Policies and Procedures)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		that policy, any holder of the Tools Editor role (for tools) or the Agent Editor role (for callbacks) can point the deployment at any host on the internet.				held by roles/ces.securitySettingsEditor and roles/ces.admin, which Google intends for security or project administrators separate from those who edit agent data. Reconcile the list against the tool inventory quarterly. For targets inside the organization's VPC, configure Service Directory private network access.	le.com/gemini-enterprise-cx/cx-agent-studio/access-control; https://docs.cloud.google.com/iam/docs/roles-permissions/ces	
SG-GCP-GECX-001010	Service Directory private network access MUST be configured for OpenAPI tool targets hosted inside the organization's VPC network.	Google documents Service Directory integration as the supported path that keeps traffic within the Google Cloud network and enforces IAM and VPC Service Controls for OpenAPI	High	Med		Grant servicedirectory.viewer and servicedirectory.pscAuthorizedService to service-agent-project-number@gcp-sa-ces.iam.gserviceaccount.com, and where Service	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls	HIPAA: 164.312(e)(1) (Transmission Security); NIST 800-53: SC-7 (Boundary Protection), AC-4 (Information Flow Enforcement), SC-8 (Transmission Confidentiality and Integrity), CA-9

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		tool targets. It lets a tool reach an internal system without exposing that system publicly and without breaking under perimeter enforcement; Google also lists Integration Connectors as an optional perimeter dependency for connector-based tools.				Directory resides in a different project grant servicedirectory. viewer in both projects. Configure this before perimeter enforcement so tool connectivity is already on the supported path.		(Internal System Connections); HITRUST CSF v11: 09.m (Network Controls), 09.n (Security of Network Services)
SG-GCP-GEEX-001020	Cloud Storage buckets, BigQuery datasets, Secret Manager secrets, Sensitive Data Protection templates, and data stores referenced by Gemini Enterprise for CX MUST reside inside the same service perimeter as the components that reference them.	Google enumerates each of these as a specific failure: audio recordings cannot be written to buckets outside the perimeter, conversation data cannot be written to external BigQuery datasets, OpenAPI tools cannot reference secrets outside the perimeter, external redaction templates	High	Med		Enumerate every referenced resource before enforcement, because these references are created by different roles at different times and no single console view lists them together. The redaction template case is the most dangerous of the five, since it degrades data protection	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls	HIPAA: 164.312(e)(1) (Transmission Security), 164.312(a)(1) (Access Control); NIST 800-53: SC-7 (Boundary Protection), AC-4 (Information Flow Enforcement), CM-6 (Configuration Settings), SC-7(10) (Prevent Exfiltration); HITRUST CSF v11: 09.m (Network Controls)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		cause redaction failures, and data store tools specifying a data store outside the perimeter fail to execute. A resource outside the perimeter is therefore both a security gap and a functional break.				rather than producing an obvious failure.		
SG-GCP-GEEX-001030	Every ingress rule, egress rule, and allowed origin for the Gemini Enterprise for CX perimeter MUST name specific identities, sources, services, or URLs - never ANY_IDENTITY, an access level or service name of "*" - and carry a documented owner and a review at least annually.	A VPC Service Controls perimeter denies cross-boundary requests unless an ingress or egress rule allows them, so the perimeter's effective strength is set by those rules and by the CX Agent Studio allowed origins list. Google documents that ANY_IDENTITY allows requests from all identities, including unauthenticated	High	Med		Record for each rule or origin what it permits, who requested it, and what would have to change for it to be removed. Rules added during a cutover deserve particular scrutiny because they were written to end an outage rather than to express an authorization decision.	https://cloud.google.com/vpc-service-controls/docs/ingress-egress-rules ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/settings ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls	HIPAA: 164.312(e)(1) (Transmission Security); NIST 800-53: SC-7 (Boundary Protection), SC-7(5) (Deny by Default - Allow by Exception), AC-4 (Information Flow Enforcement), CM-3 (Configuration Change Control); HITRUST CSF v11: 09.m (Network Controls)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		requests, and that an access level of "*" allows access from any network origin. Broad rules accumulate under delivery pressure, most often during the enforcement cutover, and an unreviewed rule set converts the perimeter into documentation rather than a control.						
SG-GCP-GECX-001040	Flow-based agents MUST NOT reference agent resources located outside the service perimeter.	Google documents that flow-based agents specifying an agent resource outside the perimeter fail when called. Beyond the functional break, a cross-perimeter agent reference delegates conversation handling across a security boundary. Google does not	High	Low		Keep the full agent delegation graph inside a single perimeter and review it whenever a new agent reference is added. A reference that crosses perimeters should be treated as a design finding rather than a configuration option.	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool	HIPAA: 164.312(a)(1) (Access Control), 164.312(e)(1) (Transmission Security); NIST 800-53: SC-7 (Boundary Protection), AC-4 (Information Flow Enforcement), AC-3 (Access Enforcement), CA-3 (Information Exchange); HITRUST CSF v11: 09.m

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		document the identity under which a referenced agent in another project executes; if it runs with its own project's service agent permissions, the reference extends reach into a project the calling perimeter does not govern.						(Network Controls)
SG-GCP-GEEX-001050	Import and export operations for agent configuration MUST target Cloud Storage buckets inside the service perimeter.	Google documents that import and export operations targeting external Cloud Storage buckets fail under perimeter enforcement. Export carries the complete agent configuration - instructions, tool definitions, and application variables - so an export to a bucket outside the perimeter is a full disclosure	High	Low		Restrict export destinations to a small set of perimeter-internal buckets under change control. Google's audit logging reference lists ExportApp under ADMIN_READ, a Data Access audit log type that is typically disabled by default, and ImportApp under ADMIN_WRITE, which is recorded in	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging ; https://cloud.google.com/logging/docs/audit/configure-data-access ; https://docs.cloud.google.com/gemini-enterprise-cx-	HIPAA: 164.312(a)(1) (Access Control); NIST 800-53: SC-7 (Boundary Protection), AC-4 (Information Flow Enforcement), AU-2 (Event Logging), CM-3 (Configuration Change Control); HITRUST CSF v11: 09.m (Network Controls)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		of the deployment's logic and its integration topology.				Admin Activity logs; enable the ADMIN_RE AD sub-type for ces.googleapis.com or exports will not be logged. Google also documents that requests involving Cloud Storage access use the caller's permissions, so the exporting principal needs access to the destination bucket as well.	agent-studio/access-control	
SG-GCP-GECX-001060	Changes to the service perimeter protecting Gemini Enterprise for CX MUST be change controlled and alerted on.	The perimeter is the compensating control for several exposures this product cannot address internally, including the service-agent tool execution model and the absence of supported per-conversation scoping in the	High	Low		Alert on Access Context Manager service perimeter changes - for example CreateServicePerimeter, UpdateServicePerimeter, DeleteServicePerimeter, ReplaceServicePerimeters, and CommitServicePerimeters under	https://docs.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls ; https://cloud.google.com/access-context-manager/docs/audit-logging	HIPAA: 164.312(e)(1) (Transmission Security), 164.312(b) (Audit Controls); NIST 800-53: CM-3 (Configuration Change Control), SC-7 (Boundary Protection), AU-6 (Audit Record Review, Analysis, and Reporting),

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		analytics surface. Because a single policy edit can remove a service from the restricted list without any visible effect on the application, perimeter changes are both high impact and low friction.				protoPayload.serviceName="accesscontextmanager.googleapis.com" - and route them to the security operations queue rather than to the platform team that made them. Reconcile the restricted service list against the documented baseline on a quarterly configuration review.		SI-4 (System Monitoring); HITRUST CSF v11: 09.m (Network Controls), 09.ab (Monitoring System Use)
SG-GCP-GECX-001070	Data Access audit logs for <code>ces.googleapis.com</code> MUST be explicitly enabled for all three sub-types: ADMIN_READ, DATA_READ, and DATA_WRITE.	Google documents that Admin Activity audit logs are enabled by default while Data Access logs require explicit enablement. For CX Agent Studio the Data Access tier is the one that records agent and tool operations and conversatio	High	Low		Enable at organization level so new projects inherit the configuration rather than depending on a project-creation checklist. Google lists ExportApp and GetSecurity Settings under ADMIN_READ, and CreateTool, UpdateTool, DeleteConv	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging ; https://cloud.google.com/logging/docs/audit/configure-data-access	HIPAA: 164.312(b) (Audit Controls), 164.308(a)(1)(ii)(D) (Information System Activity Review); NIST 800-53: AU-2 (Event Logging), AU-12 (Audit Record Generation), AU-3 (Content of Audit Records), CM-6 (Configuration Settings);

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		n deletion - the reads and writes touching member conversation content. Without it, the audit trail covers who created an application but not who used it or what it reached.				ersation, BatchDeleteConversations, and RunSession under DATA_WRITE, so enabling DATA_READ alone misses both exports and changes. Verify with a filter on <code>protoPayload.serviceName="ces.googleapis.com"</code> after enablement, and note that long-running operations produce two entries, one at start and one at completion.		HITRUST CSF v11: 09.aa (Audit Logging)
SG-GCP- GECX- 001080	Data Access audit logs for <code>contactcenterinsights.googleapis.com</code> MUST be explicitly enabled for all three sub-types: ADMIN_READ, DATA_READ, and DATA_WRITE.	CX Insights holds the complete analysed conversation corpus and, because fine-grained access control is Pre-GA, every approved user can read all of it. The Data Access log is therefore the only record of which	High	Low		Google lists reads such as GetConversation, ListConversations, and ExportInsightsData under DATA_READ, and nearly every mutation - including CreateAnalysis, CreateAnalysisRule, BulkDeleteConversations	https://docs.cloud.google.com/gemini-enterprise-cx/insights/audit-logging ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/best-practices-for-fine-grained-access-control ; https://cloud.google.com/logging/d	HIPAA: 164.312(b) (Audit Controls), 164.308(a)(1)(ii)(D) (Information System Activity Review), 164.312(a)(1) (Access Control); NIST 800-53: AU-2 (Event Logging), AU-12 (Audit Record Generation), AU-6 (Audit

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		analyst read which member's conversation, which makes it the primary compensating control for the absence of a supported per-conversation access boundary.				ons, and UpdateSettings - under DATA_WRITE; only SetlamPolicy is ADMIN_WRITE. Without DATA_WRITE, almost no change to CX Insights is recorded. Verify with a filter on <code>protoPayload.serviceName="contactcenterinsights.googleapis.com"</code> . Given the breadth of standing access, retention and reviewability of these logs matter more here than anywhere else in the deployment.	ocs/audit/configure-data-access	Record Review, Analysis, and Reporting), AC-3 (Access Enforcement); HITRUST CSF v11: 09.aa (Audit Logging)
SG-GCP-GECX-001090	Audit logs from every Gemini Enterprise for CX project MUST be exported to the organization's security information and event management platform.	Cloud Logging retention is bounded and project-scoped, and detection of misuse across a multi-project deployment requires correlation	High	Med		Export Admin Activity, Data Access, and any Access Transparency logs through an aggregated sink at organization or folder level with includeChil	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/audit-	HIPAA: 164.312(b) (Audit Controls), 164.308(a)(1)(ii)(D) (Information System Activity Review); NIST 800-53: AU-6 (Audit Record Review, Analysis,

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		that a per-project log view cannot provide. Exporting is also what places the records outside the control of the same administrators whose actions they record.				dren set, so a newly created project is covered without action. Confirm that the sink destination does not relocate the data outside the residency boundary maintained elsewhere in the deployment .	logging; https://cloud.google.com/logging/docs/export/aggregated_sinks ; https://cloud.google.com/logging/docs/routing/overview	and Reporting), AU-9 (Protection of Audit Information), SI-4 (System Monitoring), AU-4 (Audit Log Storage Capacity); HITRUST CSF v11: 09.aa (Audit Logging), 09.ab (Monitoring System Use), 09.ac (Protection of Log Information)
SG-GCP-GEEX-001100	Audit log retention MUST meet or exceed the organization's retention requirement for records of access to protected health information.	Data Access logs for these services are the evidence of who read member conversation content, and their value in an investigation or a breach determination is a direct function of how far back they reach. Google documents that Data Access audit logs are stored in the	High	Low		The organization treats these audit logs as records of activity required by HIPAA 164.316(b)(1), and therefore applies the six-year period in 164.316(b)(2)(i), which requires that documentation to be retained for six years from creation or the date it was last in effect, whichever is later. The	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/audit-logging ; https://cloud.google.com/logging/docs/audit/configure-data-access ; https://cloud.google.com/logging/quotas ; https://cloud.google.com	HIPAA: 164.312(b) (Audit Controls), 164.316(b)(1) (Documentation), 164.316(b)(2)(i) (Time Limit); NIST 800-53: AU-11 (Audit Record Retention), AU-4 (Audit Log Storage Capacity), AU-9 (Protection of Audit Information), SI-12 (Information Management and Retention);

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		_Default bucket unless routed elsewhere, and that the _Default bucket's default retention period is 30 days.				regulation does not name audit logs specifically; six years is the organization's interpretation and a conservative floor. Set retention on the log bucket (1 to 3650 days) or on the export destination rather than relying on defaults, and lock the bucket so the retention policy cannot be reduced; Google warns that locking a log bucket is irreversible. Retention on the exported copy is what matters if the project itself is compromised or deleted.	m/logging/docs/buckets; https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.316	HITRUST CSF v11: 09.aa (Audit Logging), 09.ac (Protection of Log Information)
SG-GCP-GECX-001110	Exported audit logs MUST be protected against modification and deletion by the	The administrators of these projects are the population whose actions the logs record.	High	Med		Route the export to a project under separate administrative control with its own IAM, and	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging ;	HIPAA: 164.312(b) (Audit Controls), 164.312(c) (1) (Integrity); NIST 800-53: AU-9

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	administrators of the Gemini Enterprise for CX projects.	Where the same identities can edit sinks, alter retention, or delete log buckets, the audit trail attests only to activity that the administrator chose to leave in place, which is not an audit trail.				restrict log bucket and sink modification to the logging or security function. Lock the destination log bucket so its retention policy cannot be reduced and the bucket cannot be deleted until its entries have met the retention period. Alert on changes to sink configuration and log retention as security events.	https://docs.cloud.google.com/gemini-enterprise-cx/insights/audit-logging; https://cloud.google.com/logging/docs/routing/overview; https://cloud.google.com/logging/docs/buckets	(Protection of Audit Information), AU-9(4) (Access by Subset of Privileged Users), AC-5 (Separation of Duties), AC-6 (Least Privilege); HITRUST CSF v11: 09.ac (Protection of Log Information)
SG-GCP-GECX-001120	Alerts MUST be configured for changes to CX Agent Studio security settings and to agent application logging, redaction, and export settings.	The project-level security settings hold the endpoint control policy - the allowed origins list that governs which HTTP(S) endpoints tools and callbacks can call - so a single change there	High	Low		Alert on google.cloud.ces.v1beta.AgentService.UpdateSecuritySettings and on AgentService.UpdateApp (v1 and v1beta), both recorded in Admin Activity logs under ces.googleapis.com, and	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging; https://docs.cloud.google.com/gemini-	HIPAA: 164.312(b) (Audit Controls), 164.308(a)(1)(ii)(D) (Information System Activity Review); NIST 800-53: SI-4 (System Monitoring), AU-6 (Audit Record Review, Analysis, and Reporting), CM-3

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		widens the egress boundary of every agent application in the project and location. Redaction, Cloud Logging, BigQuery export, audio recording, and interaction data storage are agent application settings, managed by the App Editor role. Neither change produces a deployment, and neither is visible to someone reading an individual agent's configuration.				route them to the security operations queue. Correlate each alert with an approved change record and investigate any change without one.	enterprise-cx/cx-agent-studio/reference/rest/v1beta/SecuritySettings; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control	(Configuration Change Control), IR-4 (Incident Handling); HITRUST CSF v11: 09.ab (Monitoring System Use), 09.ad (Administrator and Operator Logs)
SG-GCP-GECX-001130	Alerts MUST be configured for conversation deletion and bulk deletion operations in CX Agent Studio and CX Insights.	Conversation deletion is both a legitimate privacy operation and the natural final step of an attacker or an insider covering their activity. CX Insights supports bulk	High	Low		Alert on DeleteConversation and the bulk delete operations in both services, and distinguish deletions performed through the documented privacy procedure from ad	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/audit-logging ;	HIPAA: 164.312(b) (Audit Controls), 164.312(c) (1) (Integrity), 164.308(a) (6) (Security Incident Procedures); NIST 800-53: SI-4 (System Monitoring), AU-6

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		operations over conversations, which makes large-scale destruction a single API call, and expiry-based deletion is documented as not recoverable.				hoc ones. A deletion volume anomaly is worth investigating even where each individual deletion appears authorized.	https://docs.cloud.google.com/gemini-enterprise-cx/insights/tl	(Audit Record Review, Analysis, and Reporting), IR-4 (Incident Handling), AU-2 (Event Logging); HITRUST CSF v11: 09.ab (Monitoring System Use)
SG-GCP-GEEX-001140	Alerts MUST be configured for tool registration and modification in CX Agent Studio and for changes to the tools assigned to agents.	Tools execute with the CX Agent Studio service account's permissions rather than the end user's. A new tool becomes reachable once it is added to an agent, and a modified tool changes the reach of every agent already using it, so tool changes alter the deployment's effective authorization boundary without a deployment step or an approval	High	Low		Alert on CreateTool, UpdateTool, CreateTool set, and UpdateTool set (DATA_WRITE, recorded in Data Access logs under ces.googleapis.com), and on UpdateAgent, through which the Agent Editor role adds tools to agents. Reconcile against the tool inventory. A registration with no corresponding inventory entry is either an undocumented integration	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control	NIST 800-53: SI-4 (System Monitoring), CM-3 (Configuration Change Control), CM-8 (System Component Inventory), AU-6 (Audit Record Review, Analysis, and Reporting); HITRUST CSF v11: 09.ab (Monitoring System Use)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		gate in the product.				or a compromise, and both warrant the same first question.		
SG-GCP-GECX-001150	Alerts MUST be configured for anomalous read volume against CX Insights conversation data.	Because every approved CX Insights user can read every conversation, the difference between legitimate analysis and bulk extraction is volume and pattern rather than authorization. No preventive control distinguishes them, so detection is the available control and it depends entirely on the Data Access log being both enabled and monitored.	High	Med		Baseline normal analyst read volume before setting thresholds, and alert on deviation rather than on an absolute count, since legitimate quality review is itself high volume. Pair with the quarterly entitlement review so that an unexpected reader is noticed as well as an unexpected volume.	https://docs.cloud.google.com/gemini-enterprise-cx/insights/audit-logging ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/best-practices-for-fine-grained-access-control	HIPAA: 164.308(a)(1)(ii)(D) (Information System Activity Review), 164.312(b) (Audit Controls); NIST 800-53: SI-4 (System Monitoring), AU-6 (Audit Record Review, Analysis, and Reporting), IR-4 (Incident Handling), AC-6 (Least Privilege); HITRUST CSF v11: 09.ab (Monitoring System Use)
SG-GCP-GECX-001160	Operational monitoring MUST NOT depend solely on the product's built-in conversation dashboards where conversation logging is	Google notes that disabling the conversation logging toggle affects the monitoring dashboards, which couples the data minimization	Med	Low		Base operational and security monitoring on Cloud Audit Logs and platform metrics, and treat the product dashboards as a	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history ; https://docs.cloud.google.com/gemini-	NIST 800-53: SI-4 (System Monitoring), AU-2 (Event Logging), CM-6 (Configuration Settings), CA-7 (Continuous

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	disabled or can be disabled.	n decision to the observability capability. A monitoring practice that assumes those dashboards will be populated becomes silently blind if the toggle is turned off for a privacy reason on a different team's initiative.				convenience layer. Google does not state whether these sources are affected by the toggle, so confirm after any change to the logging setting that they are still populated. Record the dependency so the observability consequence is visible to whoever considers changing the logging setting.	enterprise-cx/cx-agent-studio/audit-logging	Monitoring); HITRUST CSF v11: 09.ab (Monitoring System Use)
SG-GCP-GECX-001170	An incident response procedure covering Gemini Enterprise for CX MUST be documented, including containment steps for a compromised agent application or tool.	The containment actions in this product are specific and not obvious under pressure: restoring a previous agent application version, revoking the Gemini Enterprise for CX Client role from the principal a channel uses, removing a tool registration,	High	Med		Document who can execute each containment action and confirm they can reach it outside business hours. Exercise the agent version restore at least once before relying on it. Where an incident involves member conversation content, the breach	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control ;	HIPAA: 164.308(a)(6) (Security Incident Procedures), 164.404 (Notification to Individuals), 164.408 (Notification to the Secretary); NIST 800-53: IR-4 (Incident Handling), IR-6 (Incident Reporting), CM-2 (Baseline Configuration), CM-2(3)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		deleting a deployment , locking the agent application against further changes, tightening the allowed origins list, and tightening the perimeter. A generic cloud incident procedure will not name any of them, and a live agent continues serving members throughout the delay.				determination path and the notification clock apply as they would to any other ePHI disclosure; under the BAA, Google notifies the organization of breaches it discovers (164.410), and the organization's own duties under 164.404 and 164.408 follow from discovery.	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/settings ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging	(Retention of Previous Configurations), CM-3 (Configuration Change Control); HITRUST CSF v11: 11.a (Reporting Information Security Events), 11.c (Responsibilities and Procedures)
SG-GCP-GEEX-001180	A business associate agreement covering Google Cloud MUST be executed and its scope confirmed to include every Gemini Enterprise for CX component in use before production member conversation data is processed.	Every component of this suite processes protected health information in its most unstructured and least controllable form. Google's BAA covers the infrastructure and the services named in the covered products list, and coverage attaches per product rather than per	High	Low		Confirm coverage before enablement rather than at annual review, since the components are enabled independently and by different teams. Retain the confirmation as certification evidence with the date it was checked, because the covered products list is	https://cloud.google.com/terms/hipaa-baa ; https://cloud.google.com/security/compliance/hipaa	HIPAA: 164.308(b)(1) (Business Associate Contracts), 164.314(a) (Business Associate Contracts or Other Arrangements), 164.502(e) (Disclosures to Business Associates) ; NIST 800-53: SA-9 (External System Services), SA-4 (Acquisition Process), CA-3

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		platform, so an executed BAA is a necessary but not sufficient condition and its scope must be checked against the specific components deployed.				revised as products are added.		(Information Exchange); HITRUST CSF v11: 05.k (Addressing Security in Third Party Agreements)
SG-GCP-GECX-001190	Gemini Enterprise for CX components MUST NOT process protected health information unless Google's HIPAA covered products list names the component or Google confirms in writing that the component falls within a listed product.	Google's covered products list is a flat list that names, verbatim, Gemini Enterprise for Customer Experience (GECX), Customer Experience Agent Studio, CX Insights, Contact Center AI Agent Assist, Contact Center AI Platform, and Conversational Agents. Because the suite name is itself an entry, the absence of a feature's own name is not conclusive either way: a generally	High	Low		Record, per component, the list entry or the written confirmation that establishes coverage and the date it was checked, and re-check before enablement and at each annual reassessment. As of 2026-09-24, Commerce agents does not appear in the list under its own name.	https://cloud.google.com/security/compliance/hipaa ; https://cloud.google.com/terms/hipaa-baa	HIPAA: 164.308(b)(1) (Business Associate Contracts), 164.502(e) (Disclosures to Business Associates), 164.502(a) (Uses and Disclosures of PHI); NIST 800-53: SA-9 (External System Services), CM-7 (Least Functionality), SA-4 (Acquisition Process), RA-3 (Risk Assessment); HITRUST CSF v11: 05.k (Addressing Security in Third Party Agreements)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		available component may be covered through the suite entry, while a component with no GA release, such as Commerce agents, is not shown to be covered by it. Coverage therefore has to be demonstrated per component, by its own entry or by Google's written confirmation, and processing ePHI through a component that has neither is a disclosure outside the BAA.						
SG-GCP-GECX-001200	Every Google API in the path of member conversation data, including the Dialogflow API (dialogflow.googleapis.com) used by Agent Assist and Conversational	Google's HIPAA covered products list names Conversational Agents, Contact Center AI Agent Assist, Customer Experience Agent Studio, and CX Insights but does	High	Med		Inventory each API in the data path by service name, map it to a covered product name, and obtain Google's written confirmation for any mapping that is not self-	https://cloud.google.com/security/compliance/hipaa ; https://cloud.google.com/vpc-service-controls/docs/supported-products ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/	HIPAA: 164.308(b)(1) (Business Associate Contracts), 164.502(e) (Disclosures to Business Associates); NIST 800-53: SA-9 (External System Services), CM-8 (System

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	Agents, MUST be confirmed by Google in writing as within a product on Google's HIPAA covered products list before it processes protected health information.	not use the name Dialogflow. The VPC Service Controls documentation gives <code>dialogflow.googleapis.com</code> as the service name for Agent Assist, CX Insights requires Dialogflow runtime integration to ingest conversations from Dialogflow and Agent Assist, and Google's SOC 2 scope lists Conversational Agents as formerly Dialogflow. Product names, API names, and list entries therefore do not line up one to one, and a deployment can route PHI through an API whose coverage has been assumed rather than confirmed.				evident, starting with <code>dialogflow.googleapis.com</code> . Audit the CX Insights ingestion configuration for Dialogflow runtime integration and for legacy Dialogflow ES agents; Google's Dialogflow documentation lists Dialogflow ES separately from Conversational Agents, so do not assume ES is covered without confirmation.	common-integrations ; https://cloud.google.com/security/compliance/soc-2 ; https://docs.cloud.google.com/dialogflow/cx/docs	Component Inventory), CM-7 (Least Functionality), RA-3 (Risk Assessment); HITRUST CSF v11: 05.k (Addressing Security in Third Party Agreements)
SG-GCP-GEEX-001210	Compliance attestations relied upon	An attestation is a point-in-time	Med	Low		Track the exclusions as a register	https://cloud.google.com/security/compliance	HIPAA: 164.308(a)(8) (Evaluation

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	for Gemini Enterprise for CX MUST be retrieved, reviewed, and their exclusions tracked at least annually.	statement with a defined scope, and the useful information is usually in what it excludes rather than what it covers. For a suite whose components are certified individually and whose supporting services - Speech-to-Text, Cloud Storage, BigQuery, Cloud KMS, Pub/Sub - carry their own scope, the compliance picture is a composition rather than a single document.				rather than filing the reports. Google states that customers can request its SOC 2 reports through Compliance Reports Manager. Product names differ across attestations : at the time of authoring, Google's SOC 2 scope lists CX Agent Studio and CX Insights by name, while its HITRUST CSF scope list uses Conversational AI and Conversational Insights and does not name CX Agent Studio, so confirm with Google which entries cover each component. An exclusion that overlaps a control this guide depends on is a finding to escalate,	/soc-2; https://cloud.google.com/security/compliance/hitrust ; https://cloud.google.com/security/compliance/hipaa ; https://cloud.google.com/terms/service-terms	), 164.308(b)(1) (Business Associate Contracts); NIST 800-53: CA-2 (Control Assessments), SA-9 (External System Services), CA-7 (Continuous Monitoring), RA-3 (Risk Assessment); HITRUST CSF v11: 09.f (Monitoring and Review of Third Party Services)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
						not a footnote, and it will not announce itself between annual reviews.		
SG-GCP-GECX-001220	The complete data flow for member conversation content across all Gemini Enterprise for CX components and supporting services MUST be documented and maintained as certification evidence.	Conversation content is written to at least six stores across two product APIs and five supporting Google Cloud services, each with independent encryption, residency, retention, and access configuration. Without a maintained data flow record, no one can answer where a given member's conversation exists, and every deletion, residency, and breach-scope question becomes an investigation.	High	Med		The record must name each store, the service that owns it, its encryption configuration, its region, its retention clock, and who can read it. Refresh it whenever a component, ingestion source, export, or subscriber is added, since each of those creates a new copy rather than a new view. Include transient stores the product exposes no configuration for, such as the session memcache and the Text-to-Speech cache, and every path by which content leaves the suite -	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/common-integrations ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/cmek	HIPAA: 164.308(a)(1)(ii)(A) (Risk Analysis), 164.316(b)(1) (Documentation); NIST 800-53: PL-8 (Security and Privacy Architectures), CM-8 (System Component Inventory), RA-3 (Risk Assessment), SI-12 (Information Management and Retention); HITRUST CSF v11: 06.d (Data Protection and Privacy of Covered Information)

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
						exports, ingestion, tool calls, remote agents reached through the A2A Protocol, and third-party channel platforms.		
SG-GCP-GECX-001230	The residual risks this product cannot mitigate MUST be documented and formally accepted before production certification.	Three exposures in this suite have no configuration remedy: tools execute with the project service agent's permissions rather than the caller's, data store retrieval is not documented as permission-aware, and per-conversation scoping in the analytics surface is available only as a Pre-GA feature. Each is compensated in this guide rather than closed, and a certification that does not name	High	Low		State each residual risk with the compensating control that bounds it and the accepting authority. This is the record a later reviewer needs in order to distinguish a control that was considered and bounded from one that was overlooked.	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api ; https://docs.cloud.google.com/gemini-enterprise-cx/insights/best-practices-for-fine-grained-access-control	HIPAA: 164.308(a)(1)(ii)(A) (Risk Analysis), 164.308(a)(1)(ii)(B) (Risk Management), 164.316(b)(1) (Documentation); NIST 800-53: RA-3 (Risk Assessment), CA-2 (Control Assessments), PL-8 (Security and Privacy Architectures), SA-8 (Security and Privacy Engineering Principles); HITRUST CSF v11: 01.v (Information Access Restriction); NIST AI RMF (AI 100-1): GOVERN, MAP,

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
		them implies a boundary that does not exist.						MEASURE, MANAGE
SG-GCP-GECX-001240	Gemini Enterprise for CX agent applications MUST be registered in the organization's AI system inventory with a named accountable owner.	A member-facing generative agent making statements about coverage and benefits is a consequential AI system under every governance framework the organization is likely to be measured against, and this suite makes creating one a low-friction action available to any holder of an editor role. An inventory is what makes the population of deployed agents knowable to the people accountable for them.	Med	Low		Register the agent, its purpose, its audience, its tool reach, and its accountable owner, and reconcile the inventory against the deployed agents on the quarterly cycle. The reconciliation is the control - an unregistered production agent is the finding it exists to surface. NIST AI 100-1 calls for mechanisms to inventory AI systems, resourced according to organizational risk priorities (GOVERN 1.6).	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/ ; https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/ ; https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf	NIST 800-53: CM-8 (System Component Inventory), PM-5 (System Inventory), PL-8 (Security and Privacy Architectures), RA-3 (Risk Assessment); NIST AI RMF (AI 100-1): GOVERN, MAP, MEASURE, MANAGE
SG-GCP-GECX-001250	The security posture of this	Several controls in this guide exist	Med	Low		Review the CX Agent Studio, CX Insights,	https://docs.cloud.google.com/gemini-	HIPAA: 164.308(a)(8) (Evaluation

ID	Requirement	Rationale	Estimated Security Value	Estimated Cost	Audit Procedure	Notes	References	Mappings
	deployment MUST be reassessed whenever a Gemini Enterprise for CX component transitions a capability from Preview to general availability.	because a capability is Pre-GA, most consequentially the compensating access model that stands in for CX Insights fine-grained access control. When such a capability reaches GA the compensating control becomes unnecessary overhead and the stronger native control becomes available, so a guide that is never revisited keeps the organization on the weaker posture indefinitely.				and Agent Assist release notes at least monthly to detect Preview-to-GA transitions. On a transition, revisit any prohibition on the capability, the compensating control that stood in for it, and the residual risk that was accepted because of it - all three change together. Increment the Revision column on each affected row rather than renumbering.	enterprise-cx/cx-agent-studio/resources/release-notes; https://docs.cloud.google.com/gemini-enterprise-cx/insights/release-notes ; https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/release-notes	); NIST 800-53: CA-7 (Continuous Monitoring), CM-3 (Configuration Change Control), RA-3 (Risk Assessment), CA-2 (Control Assessments); NIST AI RMF (AI 100-1): GOVERN, MAP, MEASURE, MANAGE

Appendix B - Security Controls Cross Reference Table

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
SG-GCP-GECC-000010	Features of Gemini Enterprise for CX that are Non-GA or Pre-GA MUST NOT be used in production or with protected health information				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
	or other personal data.				
SG-GCP-GEEX-000020	Commerce agents MUST NOT be deployed.				
SG-GCP-GEEX-000030	The v1beta CX Agent Studio API and the v1alpha1 CX Insights API MUST NOT be called from production workloads.				
SG-GCP-GEEX-000040	The Google Maps tool in CX Agent Studio MUST NOT be enabled on any agent application.				
SG-GCP-GEEX-000050	CX Insights capabilities documented as Preview, including fine-grained access control, conversation datasets, and multiple scorecards, MUST NOT be used as the control of record or as a production dependency.				
SG-GCP-GEEX-000060	A capability certification review MUST be completed and approved before any Gemini Enterprise for CX component processes production member conversation data.				
SG-GCP-GEEX-000070	Newly released Gemini Enterprise for CX features MUST be reviewed and explicitly approved before enablement, on a review cadence no				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
	longer than monthly.				
SG-GCP-GECX-000080	The configuration baseline for every Gemini Enterprise for CX project - guardrails, tools, deployment channels, encryption, residency, retention, and audit settings - MUST be documented and drift-checked at least quarterly.				
SG-GCP-GECX-000090	Personnel who build, deploy, or administer Gemini Enterprise for CX agent applications SHOULD complete role-specific training covering the confused-deputy tool execution model and the irreversible configuration decisions documented in this guide.				
SG-GCP-GECX-000100	Administrative and builder access to CX Agent Studio, CX Insights, and Agent Assist MUST be federated through the organization's enterprise identity provider.				
SG-GCP-GECX-000110	Multi-factor authentication MUST be enforced for every human user account holding any CX Agent Studio (roles/ces.*) or CX Insights (roles/contact				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
	centerinsights.*) role.				
SG-GCP-GEEX-000120	The roles/ces.admin role MUST be granted only to named individual administrators.				
SG-GCP-GEEX-000130	Basic IAM roles - the legacy Owner, Editor, and Viewer roles and the Admin, Writer, and Reader basic roles - MUST NOT be granted on any project hosting a Gemini Enterprise for CX component.				
SG-GCP-GEEX-000140	The roles/ces.securitySettingsEditor role MUST be held by a different set of individuals than those holding roles/ces.agentEditor or roles/ces.toolsEditor.				
SG-GCP-GEEX-000150	The roles/ces.deploymentEditor role MUST be restricted to personnel explicitly authorized to promote changes to production.				
SG-GCP-GEEX-000160	Direct bindings of the roles/ces.client role MUST be limited to the service identities used by approved deployment channels and to the documented end-user principal set of an approved OAuth2				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
	deployment channel.				
SG-GCP-GECX-000170	The CX Agent Studio service agent service-PROJECT_NUMBER@gcp-sa-ces.iam.gserviceaccount.com MUST be granted only the minimum IAM roles required by the approved tools in that project.				
SG-GCP-GECX-000180	Service account keys MUST NOT be created for any identity holding a Gemini Enterprise for CX role.				
SG-GCP-GECX-000190	Entitlements to all ces.googleapis.com and contactcenterinsights.googleapis.com roles MUST be recertified at least quarterly by the accountable business owner.				
SG-GCP-GECX-000200	Contact centre representatives receiving Agent Assist suggestions MUST authenticate through the organization's identity provider.				
SG-GCP-GECX-000210	Standing administrative access to production Gemini Enterprise for CX projects SHOULD be replaced by time-bound, approved elevation.				
SG-GCP-GECX-000220	Access to Gemini Enterprise for CX administrative				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
	surfaces SHOULD be conditioned on managed-device posture.				
SG-GCP-GEEX-001410	The <code>roles/ces.appEditor</code> role SHOULD be held by a different set of individuals than those holding <code>roles/ces.agentEditor</code> or <code>roles/ces.toolsEditor</code> in projects serving production traffic.				
SG-GCP-GEEX-000230	Guardrails MUST be explicitly configured and documented on every agent application rather than left at the shipped default.				
SG-GCP-GEEX-000240	The Safety guardrail MUST be set to Strict on every member-facing agent application, and to Strict or Balanced on every other agent application that can reach member data.				
SG-GCP-GEEX-000250	The Prompt guard MUST be enabled on every agent application, with a defined outcome for a triggered guard.				
SG-GCP-GEEX-000260	A Blocklist guardrail SHOULD be configured on member-facing agent applications to suppress terms the organization has designated as prohibited in a generated response.				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
SG-GCP-GEEX-000270	Agent instructions, prompts, application variables, and tool configurations MUST NOT contain credentials, API keys, tokens, or connection strings.				
SG-GCP-GEEX-000280	Every agent application MUST be security reviewed and approved before it is deployed to a channel carrying production traffic.				
SG-GCP-GEEX-000290	Agent evaluations MUST be executed and reviewed against a documented test set before an agent application is promoted to production, and after any change to its instructions, tools, or guardrails.				
SG-GCP-GEEX-000300	Agent applications MUST NOT be the sole authority for a coverage, eligibility, clinical, or other adverse determination communicated to a member.				
SG-GCP-GEEX-000310	Members interacting with a Gemini Enterprise for CX agent MUST be informed that they are interacting with an automated agent and offered a path to reach a human.				
SG-GCP-GEEX-000320	Agent applications generated by the Start with AI capability MUST be reviewed in full,				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
	including their generated instructions and tools, before deployment.				
SG-GCP-GEEX-000330	Where one agent is invoked as a tool of another - within one agent application or, through the A2A Protocol, across agent applications and projects - the delegation chain MUST be documented and reviewed as a single authorization surface.				
SG-GCP-GEEX-000340	Agent versioning and changelog history SHOULD be retained for the life of the agent application.				
SG-GCP-GEEX-001260	Only models on the organization's approved model allowlist MUST be selected to power a Gemini Enterprise for CX agent application.				
SG-GCP-GEEX-001270	A model designated Preview in the CX Agent Studio model picker MUST NOT be selected for an agent application carrying production traffic.				
SG-GCP-GEEX-001280	A model override applied to an individual sub-agent MUST be documented and approved as a change to the agent application.				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
SG-GCP-GEEX-001290	The launch stage of a selected model MUST be verified in the CX Agent Studio interface rather than inferred from that model's status in other Google Cloud products.				
SG-GCP-GEEX-000350	Each Gemini Enterprise for CX project MUST contain only agent applications that share a single trust domain.				
SG-GCP-GEEX-000360	An inventory of every registered tool, its type, its target system, its authentication method, and its approving owner MUST be maintained and reviewed at least quarterly.				
SG-GCP-GEEX-000370	Static credentials used by OpenAPI and MCP tools - API keys and any other secret held in the tool configuration - MUST be stored in Secret Manager and referenced rather than embedded in tool configuration, agent instructions, or custom header values.				
SG-GCP-GEEX-000380	A tool MUST NOT be able to retrieve data beyond what the principal conversing with the agent is authorized to see, unless the backend authorizes every request against an				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
	identity bound to the session at authentication rather than supplied by the model.				
SG-GCP-GEEX-000390	Data store tools and File search tools MUST NOT be grounded on content whose authorized audience is narrower than the audience able to converse with the agent.				
SG-GCP-GEEX-000400	Content ingested into a data store or RAG knowledge base used by a member-facing agent MUST be reviewed and approved before each ingestion and ingested only from locations under the organization's control.				
SG-GCP-GEEX-000410	Tool responses, retrieved data store content, and knowledge base excerpts MUST be treated as untrusted input that cannot authorize a subsequent action the caller could not authorize directly.				
SG-GCP-GEEX-000420	Third-party and externally hosted MCP servers MUST pass a supply chain security review before being registered as a tool.				
SG-GCP-GEEX-000430	MCP servers used by production agent applications SHOULD be				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
	hosted within the organization's Google Cloud boundary, with invocation restricted to the CX Agent Studio service agent.				
SG-GCP-GEEX-000440	Tools that connect to Salesforce, ServiceNow, Jira, Confluence, or SharePoint - both the dedicated tool types for those systems and Integration Connector tools - MUST authenticate with the end user's own credentials or with a dedicated connection identity scoped to the minimum records the agent requires.				
SG-GCP-GEEX-000450	Python code tools MUST be reviewed as application source code before registration and before any subsequent modification.				
SG-GCP-GEEX-000460	Client function tools MUST NOT be passed data that the end user is not already authorized to see.				
SG-GCP-GEEX-000470	The Google Search tool SHOULD NOT be enabled on member-facing agent applications.				
SG-GCP-GEEX-000480	Where a tool's backend is reachable through Service Directory private network access, OpenAPI tools, MCP tools,				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
	and the dedicated Salesforce, ServiceNow, Jira, Confluence, and SharePoint tools MUST be configured to use the Service Directory path rather than a public endpoint.				
SG-GCP-GEEX-000490	The set of tools registered in a project MUST be restricted to those the approved agent use cases require, with unused registrations removed.				
SG-GCP-GEEX-001310	Tool invocations MUST carry a correlation identifier, comprising at minimum the agent application identifier and the conversation or session identifier, that the receiving backend system records in its own logs.				
SG-GCP-GEEX-001330	Results returned by a client function tool MUST NOT be relied upon to establish the end user's identity, entitlement, or authorization for any subsequent action.				
SG-GCP-GEEX-001340	Data store tools that reference a search engine MUST name the specific data stores to be searched rather than leaving the data store selection empty.				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
SG-GCP-GEEX-001360	The RAG knowledge base behind a File search tool MUST be located in a US region where RAG Engine is designated GA.				
SG-GCP-GEEX-001370	RAG knowledge bases used by File search tools MUST be protected by customer-managed encryption keys and placed inside the VPC Service Controls perimeter before any file is uploaded.				
SG-GCP-GEEX-001380	File search tools SHOULD NOT be used to ground agents on content containing protected health information.				
SG-GCP-GEEX-001390	Agent-to-agent (A2A) Protocol tools MUST NOT be configured on any agent application, for outbound delegation or for inbound invocation, while the capability is designated Preview.				
SG-GCP-GEEX-000500	An inventory of every deployment channel, its authentication mode, and its approving owner MUST be maintained for each agent application.				
SG-GCP-GEEX-000510	Public access through the Google-hosted token broker				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
	MUST NOT be enabled for any agent application whose tools can reach member data.				
SG-GCP-GEEX-000520	Where public access is approved for a bounded public-information agent, origin checks and reCAPTCHA MUST both be enabled on the widget configuration.				
SG-GCP-GEEX-000530	Agent applications serving authenticated members MUST authenticate each member individually through the organization's identity provider - using the OAuth2 client path or a custom authentication API that issues a short-lived token for the member's session - and grant member identities no role that includes the <code>ces.tools.execute</code> permission.				
SG-GCP-GEEX-000540	A self-hosted token broker SHOULD be used in preference to the Google-hosted broker for any agent application that serves unauthenticated callers or bounded public information.				
SG-GCP-GEEX-000550	The web widget MUST be embedded only on web origins the				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
	organization controls.				
SG-GCP-GEEX-000560	Non-production agent development and testing MUST be performed in a separate Google Cloud project from production, using deployment environments that carry no production traffic.				
SG-GCP-GEEX-000570	Traffic splitting MUST NOT direct production conversations to an agent version that has not completed security review and evaluation.				
SG-GCP-GEEX-000580	Third-party platforms that carry member conversations to or from a deployment channel - contact center providers such as AudioCodes, Five9, SecureCo, and Twilio, messaging platforms such as WhatsApp and Instagram, and any comparable intermediary - MUST have completed a third-party security assessment and, where they process ePHI, be covered by an executed business associate agreement.				
SG-GCP-GEEX-000590	Direct API access to deployed agent applications MUST be routed through				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
	the organization's API gateway rather than exposed to callers as a direct Google endpoint.				
SG-GCP-GEEX-000600	Voice channels MUST present a recording and automated-interaction disclosure to the member before conversation content is captured.				
SG-GCP-GEEX-001300	Quota caps and cost alerting MUST be configured for every agent application exposed on a public or high-volume deployment channel.				
SG-GCP-GEEX-001400	WhatsApp and Instagram deployments MUST NOT be created for any Gemini Enterprise for CX agent application.				
SG-GCP-GEEX-000610	Customer-managed encryption keys MUST be initialized for Agent Assist before it processes any production conversation.				
SG-GCP-GEEX-000620	Sensitive Data Protection redaction MUST be configured for Agent Assist conversation data using an inspect template and a deidentify template.				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
SG-GCP-GEEX-000630	Agent Assist conversation data retention MUST be configured to the shortest period that meets a documented business need.				
SG-GCP-GEEX-000640	Generated conversation summaries MUST be reviewed by the human representative before they are committed to a system of record.				
SG-GCP-GEEX-000650	Smart Reply, AI coach, and other generated response suggestions MUST NOT be transmitted to a member without an affirmative action by the human representative.				
SG-GCP-GEEX-000660	Knowledge bases used by Knowledge Assist and Generative Knowledge Assist MUST be scoped to content the entire representative population is authorized to see.				
SG-GCP-GEEX-000670	Live translation output MUST NOT be relied upon as the authoritative record of a member interaction.				
SG-GCP-GEEX-000680	Agent Assist deployments MUST be pinned to a region consistent with the organization's data residency position, with per-feature				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
	residency coverage verified before enablement.				
SG-GCP-GECX-000690	Where Agent Assist data about identified human representatives - for example, AI coach suggestion usage or conversations passed to CX Insights for Quality AI scoring - is used to evaluate representative performance, that evaluation MUST be governed by the organization's employee monitoring and workforce policy before enablement.				
SG-GCP-GECX-001320	The Agent Assist Build your own assist capability MUST NOT be enabled while it is designated Preview.				
SG-GCP-GECX-001350	Gemini Transcribe Live MUST NOT be enabled in any Agent Assist conversation profile while it is designated Preview.				
SG-GCP-GECX-000700	The CX Insights encryption specification MUST be initialized with a customer-managed key for every location before any conversation is ingested into that location.				
SG-GCP-GECX-000710	A project-level conversation_t				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
	tl MUST be configured in CX Insights before the first conversation is ingested.				
SG-GCP-GECX-000720	Sensitive Data Protection redaction MUST be applied on every CX Insights ingestion path before production conversations are imported - through RedactionConfig for upload and ingest paths, and in the upstream Agent Assist or CX Agent Studio configuration for runtime integrations.				
SG-GCP-GECX-000730	Project-level CX Insights access - roles/contactcenterinsights.viewer, roles/contactcenterinsights.editor, and roles/contactcenterinsights.admin granted directly, and the same access inherited through any CX Agent Studio role (roles/ces.*) - MUST be held only by a named, minimal, documented group.				
SG-GCP-GECX-000740	CX Insights authorized views MUST NOT be applied to conversation data containing PHI while the capability is Pre-GA, or configured with an empty filter				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
	expression in any project.				
SG-GCP-GEEX-000750	The CX Insights global endpoint MUST NOT be used for production conversation data.				
SG-GCP-GEEX-000760	Cloud Storage buckets holding conversation audio for CX Insights MUST be encrypted with customer-managed keys, located in the approved region, and placed inside the service perimeter.				
SG-GCP-GEEX-000770	Cloud Speech-to-Text MUST be configured with customer-managed encryption keys where it transcribes conversation audio for CX Insights or Agent Assist.				
SG-GCP-GEEX-000780	BigQuery datasets receiving the CX Insights conversation export MUST be encrypted with customer-managed keys, located in the approved region, and placed inside the service perimeter.				
SG-GCP-GEEX-000790	CX Insights Pub/Sub notifications for triggers whose message data is a Conversation resource - create-conversation and update-conversation,				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
	including when all events are selected - MUST NOT be routed to a topic whose subscribers are not approved to receive member conversation content.				
SG-GCP-GEEX-000800	The CX Insights Google Sheets integration MUST NOT be used in any project that holds member conversation data.				
SG-GCP-GEEX-000810	Topic models, scorecards, summarization generators, and other artifacts trained or derived from conversation content MUST be treated as carrying the sensitivity of the source conversations.				
SG-GCP-GEEX-000820	Where Quality AI assessments evaluate identified human representatives, their use MUST be approved under the organization's workforce monitoring policy before enablement.				
SG-GCP-GEEX-000830	Conversations ingested into CX Insights during pilot or proof-of-concept activity MUST be deleted before the production deployment is certified, unless they were ingested under the full production control set.				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
SG-GCP-GEEX-000840	CX Agent Studio MUST be CMEK-integrated at project creation, before any agent application or conversation data exists in the project.				
SG-GCP-GEEX-000850	Cloud KMS keys protecting Gemini Enterprise for CX data MUST be monitored for availability, with key destruction and disablement gated on multi-party authorization.				
SG-GCP-GEEX-000860	Cloud KMS key versions protecting Gemini Enterprise for CX data MUST NOT be disabled or destroyed while any data encrypted under them is still retained.				
SG-GCP-GEEX-000870	CX Agent Studio agent data MUST be located in the us multi-region.				
SG-GCP-GEEX-000880	Cloud Logging MUST be configured with a US region for log storage independently of the Gemini Enterprise for CX residency setting.				
SG-GCP-GEEX-000890	Conversation history retention in CX Agent Studio MUST be configured to a documented period no longer than the business need requires.				
SG-GCP-GEEX-000900	The state of the Log your customer				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
	conversations setting (labeled Interaction data in agent application settings) MUST be an explicit, documented decision for every agent application.				
SG-GCP-GEEX-000910	Written confirmation from Google that the Service Specific Terms training restriction covers every Gemini Enterprise for CX component and data path in use MUST be obtained and retained as certification evidence.				
SG-GCP-GEEX-000920	Sensitive Data Protection templates used by any Gemini Enterprise for CX component MUST be located inside the same VPC Service Controls perimeter as the component that references them.				
SG-GCP-GEEX-000930	Member identifiers and other sensitive values MUST NOT be written into application variables, agent instructions, or tool configuration as static values.				
SG-GCP-GEEX-000940	A documented procedure MUST exist to locate and delete all copies of an individual member's conversation data across every store in the deployment.				
SG-GCP-GEEX-000950	The short-lived caches the				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
	product maintains MUST be documented in the data flow record supporting certification.				
SG-GCP-GEEX-000960	Google personnel access to Gemini Enterprise for CX conversation data SHOULD be gated by Access Approval and recorded through Access Transparency.				
SG-GCP-GEEX-000970	A VPC Service Controls perimeter MUST be configured with <code>ces.googleapis.com</code> , <code>contactcenterinsights.googleapis.com</code> , and, where Agent Assist is used, <code>dialogflow.googleapis.com</code> in the restricted services list.				
SG-GCP-GEEX-000980	The service perimeter MUST be established and enforced before agent applications, data stores, deployment channels, and CX Insights locations are created.				
SG-GCP-GEEX-000990	The service perimeter MUST be validated in dry-run mode and its findings resolved before enforcement.				
SG-GCP-GEEX-001000	Tools and callbacks MUST NOT be able to call HTTP(S) endpoints outside the approved list, enforced through				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
	the CX Agent Studio allowed origins endpoint control policy with its enforcement scope set to ALWAYS.				
SG-GCP-GEEX-001010	Service Directory private network access MUST be configured for OpenAPI tool targets hosted inside the organization's VPC network.				
SG-GCP-GEEX-001020	Cloud Storage buckets, BigQuery datasets, Secret Manager secrets, Sensitive Data Protection templates, and data stores referenced by Gemini Enterprise for CX MUST reside inside the same service perimeter as the components that reference them.				
SG-GCP-GEEX-001030	Every ingress rule, egress rule, and allowed origin for the Gemini Enterprise for CX perimeter MUST name specific identities, sources, services, or URLs - never ANY_IDENTITY, an access level or service name of "*" - and carry a documented owner and a review at least annually.				
SG-GCP-GEEX-001040	Flow-based agents MUST NOT reference agent resources				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
	located outside the service perimeter.				
SG-GCP-GEEX-001050	Import and export operations for agent configuration MUST target Cloud Storage buckets inside the service perimeter.				
SG-GCP-GEEX-001060	Changes to the service perimeter protecting Gemini Enterprise for CX MUST be change controlled and alerted on.				
SG-GCP-GEEX-001070	Data Access audit logs for <code>ces.googleapis.com</code> MUST be explicitly enabled for all three sub-types: ADMIN_READ, DATA_READ, and DATA_WRITE.				
SG-GCP-GEEX-001080	Data Access audit logs for <code>contactcenterinsights.googleapis.com</code> MUST be explicitly enabled for all three sub-types: ADMIN_READ, DATA_READ, and DATA_WRITE.				
SG-GCP-GEEX-001090	Audit logs from every Gemini Enterprise for CX project MUST be exported to the organization's security information and event management platform.				
SG-GCP-GEEX-001100	Audit log retention MUST meet or exceed the organization's retention				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
	requirement for records of access to protected health information.				
SG-GCP-GEEX-001110	Exported audit logs MUST be protected against modification and deletion by the administrators of the Gemini Enterprise for CX projects.				
SG-GCP-GEEX-001120	Alerts MUST be configured for changes to CX Agent Studio security settings and to agent application logging, redaction, and export settings.				
SG-GCP-GEEX-001130	Alerts MUST be configured for conversation deletion and bulk deletion operations in CX Agent Studio and CX Insights.				
SG-GCP-GEEX-001140	Alerts MUST be configured for tool registration and modification in CX Agent Studio and for changes to the tools assigned to agents.				
SG-GCP-GEEX-001150	Alerts MUST be configured for anomalous read volume against CX Insights conversation data.				
SG-GCP-GEEX-001160	Operational monitoring MUST NOT depend solely on the product's built-in conversation dashboards where conversation logging is disabled				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
	or can be disabled.				
SG-GCP-GECX-001170	An incident response procedure covering Gemini Enterprise for CX MUST be documented, including containment steps for a compromised agent application or tool.				
SG-GCP-GECX-001180	A business associate agreement covering Google Cloud MUST be executed and its scope confirmed to include every Gemini Enterprise for CX component in use before production member conversation data is processed.				
SG-GCP-GECX-001190	Gemini Enterprise for CX components MUST NOT process protected health information unless Google's HIPAA covered products list names the component or Google confirms in writing that the component falls within a listed product.				
SG-GCP-GECX-001200	Every Google API in the path of member conversation data, including the Dialogflow API (dialogflow.googleapis.com) used by Agent Assist and				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
	Conversational Agents, MUST be confirmed by Google in writing as within a product on Google's HIPAA covered products list before it processes protected health information.				
SG-GCP-GEEX-001210	Compliance attestations relied upon for Gemini Enterprise for CX MUST be retrieved, reviewed, and their exclusions tracked at least annually.				
SG-GCP-GEEX-001220	The complete data flow for member conversation content across all Gemini Enterprise for CX components and supporting services MUST be documented and maintained as certification evidence.				
SG-GCP-GEEX-001230	The residual risks this product cannot mitigate MUST be documented and formally accepted before production certification.				
SG-GCP-GEEX-001240	Gemini Enterprise for CX agent applications MUST be registered in the organization's AI system inventory with a named accountable owner.				
SG-GCP-GEEX-001250	The security posture of this				

ID	Requirement	Detective Policies	Sentinel Modules	CSP Level Controls	Monitoring Controls
	deployment MUST be reassessed whenever a Gemini Enterprise for CX component transitions a capability from Preview to general availability.				